

**PENGEMBANGAN KONTROL AKSES
GRANULAR DAN DELEGASI AKSES ANTAR
TENAGA KESEHATAN PADA SISTEM REKAM
MEDIS ELEKTRONIK DECMED
MENGUNAKAN MACAROONS**

Laporan Tugas Akhir

Disusun sebagai syarat kelulusan tingkat sarjana

Oleh

Tazkia Nizami

NIM: 13522032



**PROGRAM STUDI TEKNIK INFORMATIKA
SEKOLAH TEKNIK ELEKTRO & INFORMATIKA
INSTITUT TEKNOLOGI BANDUNG**

Juli 2026

**PENGEMBANGAN KONTROL AKSES
GRANULAR DAN DELEGASI AKSES ANTAR
TENAGA KESEHATAN PADA SISTEM REKAM
MEDIS ELEKTRONIK DECMED
MENGUNAKAN MACAROONS**

Oleh

Tazkia Nizami

NIM: 13522032

Program Studi Teknik Informatika

Sekolah Teknik Elektro dan Informatika

Institut Teknologi Bandung

Telah disetujui dan disahkan sebagai Laporan Tugas Akhir
di Bandung, pada tanggal 2 Juli 2026

Pembimbing,

Dr. Phil. Eng. Hari Purnama, S.Si., M.Si.

NIP. 118110072

LEMBAR PERNYATAAN

Dengan ini saya menyatakan bahwa:

1. Pengerjaan dan penulisan Laporan Tugas Akhir ini dilakukan tanpa menggunakan bantuan yang tidak dibenarkan.
2. Segala bentuk kutipan dan acuan terhadap tulisan orang lain yang digunakan di dalam penyusunan laporan tugas akhir ini telah dituliskan dengan baik dan benar.
3. Laporan Tugas Akhir ini belum pernah diajukan pada program pendidikan di perguruan tinggi mana pun.

Jika terbukti melanggar hal-hal di atas, saya bersedia dikenakan sanksi sesuai dengan Peraturan Akademik dan Kemahasiswaan Institut Teknologi Bandung bagian Penegakan Norma Akademik dan Kemahasiswaan khususnya Pasal 2.1 dan Pasal 2.2.

Bandung, 2 Juli 2026



Tazkia Nizami

NIM: 13522032

SURAT PERNYATAAN PENGGUNAAN AI

Dengan ini, saya:

Nama/NIM : Tazkia Nizami / 13522032
Fakultas/Sekolah : Sekolah Teknik Elektro dan Informatika
Judul : Pengembangan Kontrol Akses Granular dan Delegasi
Akses Antar Tenaga Kesehatan pada Sistem Rekam Medis
Elektronik DecMed Menggunakan Macaroons

Menyatakan bahwa saya menggunakan AI dalam pengerjaan maupun penyusunan luaran tugas akhir yang tertulis di atas. Alat AI/kecerdasan buatan yang digunakan adalah:

Lingkup Pekerjaan	Digunakan?	Tingkat Penggunaan
Pemeriksaan Ejaan: ChatGPT	Ya	10%
Pembuatan Teks: ChatGPT	Ya	40%
Bantuan Diskusi dalam Penyusunan Konten: ChatGPT	Ya	70%
Pembuatan Gambar, Video, dan/atau Grafik: ChatGPT	Ya	40%
Pencarian Referensi: Perplexity dan ChatGPT	Ya	60%

Saya juga menyatakan bahwa setiap penggunaan AI/kecerdasan buatan yang dilakukan pada tugas akhir tersebut telah dinyatakan di dalam surat ini.

Bandung, 2 Juli 2026



Tazkia Nizami

13522032

ABSTRAK

PENGEMBANGAN KONTROL AKSES GRANULAR DAN DELEGASI AKSES ANTAR TENAGA KESEHATAN PADA SISTEM REKAM MEDIS ELEKTRONIK DEC MED MENGUNAKAN MACAROONS

Oleh:

Tazkia Nizami
NIM: 13522032

Transformasi Rekam Medis Elektronik (RME) menuntut mekanisme kontrol akses yang menjaga kendali pasien sekaligus mendukung alur pelayanan kesehatan kolaboratif. DecMed sebagai sistem RME terdesentralisasi telah memanfaatkan IOTA, IPFS, dan Proxy Re-Encryption (PRE), tetapi mekanisme sebelumnya masih bergantung pada pasien untuk menerbitkan akses baru, masih bersifat *coarse-grained* karena hanya berbasis *role* dan *purpose*, serta menyimpan data RME sebagai objek besar yang sulit ditegakkan sesuai kebutuhan layanan. Kontrol akses pada DecMed diperluas agar keputusan akses mencakup aktor, objek RME, hak akses, dan kondisi akses secara lebih luas, sekaligus mendukung segmentasi data, delegasi terbatas, revokasi, audit, dan verifikasi identitas aktor pada rantai delegasi. Pendekatan yang digunakan mencakup penerapan *Policy-Based Access Control* (PBAC) sebagai model kebijakan, Macaroon sebagai media pembawa kapabilitas dengan *caveats* untuk atenuasi, segmentasi data RME *off-chain* berdasarkan kategori dataset dan fungsi klinis, pencatatan metadata serta audit pada IOTA, dan PRE sebagai titik penegakan kebijakan sebelum data terenkripsi diambil atau diproses ulang untuk penerima akses. Implementasi mencakup komponen segmentasi RME, token Macaroon, penegakan otoritas pada *Server PRE*, *smart contract IOTA Move*, *Patient Client*, dan *Hospital Client* untuk alur pasien, petugas rekam medis, perawat, dokter, petugas laboratorium, dan apoteker. Pengujian dilakukan melalui skenario fungsional P-KF-01 sampai P-KF-12 pada alur rawat jalan dan rawat inap serta pengujian nonfungsional P-KNF-01 sampai P-KNF-13. Evaluasi menunjukkan seluruh kebutuhan fungsional dan nonfungsional yang dirumuskan dinyatakan terpenuhi. Hasil penelitian ini menunjukkan bahwa kontrol akses berbasis kebijakan, segmentasi RME, delegasi terbatas, revokasi, audit, dan verifikasi identitas aktor pada rantai delegasi dapat dioperasionalkan dalam DecMed pada batas implementasi prototipe yang diuji.

Kata kunci: *Rekam Medis Elektronik, Policy-Based Access Control, Macaroon, IOTA, Proxy Re-Encryption*

KATA PENGANTAR

Puji dan syukur penulis panjatkan kepada Tuhan Yang Maha Esa atas berkat dan rahmatnya, laporan tugas akhir yang berjudul "Pengembangan Kontrol Akses Granular dan Delegasi Akses Antar Tenaga Kesehatan pada Sistem Rekam Medis Elektronik DecMed Menggunakan Macaroons" dapat diselesaikan dalam rangka memenuhi syarat kelulusan tingkat sarjana. Perlu diakui pengerjaan tugas akhir ini didukung oleh banyak pihak. Khususnya, penulis ingin mengucapkan terima kasih kepada:

1. Ani Rochani Rochmawati dan Widodo selaku orang tua penulis atas dukungan materi dan emosi selama ini hingga penulis berhasil menyelesaikan pengerjaan tugas akhir.
2. Fathiya Alisa Zahrandika selaku kakak penulis atas dukungan emosi dan materi selama masa perkuliahan hingga bisa menjalani perkuliahan dengan baik.
3. Bapak Dr. Phil. Eng. Hari Purnama, S.Si., M.Si., selaku dosen pembimbing atas segala bentuk dukungan yang telah diberikan, kesabarannya dalam membimbing penulis, serta memberikan saran dalam pengerjaan tugas akhir.
4. Daffa Ramadhan Elengi selaku teman dekat penulis yang selalu menjadi teman berpetualang dan mencari pengalaman baru selama dari awal masa perkuliahan hingga saat ini.
5. Grup DecMed loh dek, yaitu Bagas dan Rafa, sebagai teman perjuangan selama pengerjaan tugas akhir.
6. Grup Mamang Boneng, yaitu Dhidit dan Naufal yang sebagai teman perkuliahan selama masa perkuliahan di jurusan Teknik Informatika.
7. Grup Orang Orangan Dapur, yaitu Dapur, Yusuf, Ihsan, Dabbir, Gonza,

Fairuz, dan Saad yang telah menjadi teman bermain Mobile Legends setiap malam hingga mencapai *rank* Immortal.

8. Teman-teman Teknik Informatika angkatan 2022, angkatan BYTE, yang telah menjalani perkuliahan bersama penulis selama ini.
9. Seluruh pihak lain yang tidak disebutkan disini yang telah membantu dan mendukung dalam proses pengerjaan tugas akhir.

Akhir kata, penulis mengucapkan terima kasih kepada semua pihak yang telah terlibat dalam pengerjaan tugas akhir ini. Penulis juga ingin menyampaikan mohon maaf apabila terdapat kesalahan maupun kekurangan dalam laporan tugas akhir ini. Penulis berharap semoga tugas akhir ini dapat bermanfaat bagi pembaca dan riset-riset kedepannya.

Bandung, 2 Juli 2026

A handwritten signature in black ink, appearing to be 'Tazkia Nizami', written in a cursive style.

Tazkia Nizami

DAFTAR ISI

ABSTRAK	v
KATA PENGANTAR	vi
DAFTAR ISI	viii
DAFTAR LAMPIRAN	xiv
DAFTAR GAMBAR	xv
DAFTAR TABEL	xvii
DAFTAR KODE PROGRAM	xix
BAB I PENDAHULUAN	1
I.1 Latar Belakang	1
I.2 Rumusan Masalah	3
I.3 Tujuan	3
I.4 Batasan Masalah	4
I.5 Metodologi	4
I.6 Sistematika Pembahasan	5
BAB II STUDI LITERATUR	7
II.1 Rekam Medis Elektronik	7
II.1.1 Definisi RME	7
II.1.2 Isi RME	7
II.1.3 RME dalam Alur Pelayanan Kesehatan Kolaboratif	8
II.1.4 Hak Akses RME	9
II.2 IOTA	10
II.2.1 Distributed Ledger Technology	10
II.2.2 IOTA	11
II.3 <i>InterPlanetary File System</i> (IPFS)	11
II.4 <i>Proxy Re-Encryption</i> (PRE)	12
II.4.1 Umbral PRE	12
II.5 Kontrol Akses	14
II.5.1 Definisi Kontrol Akses	14
II.5.2 Kontrol Akses Granular	14
II.5.3 Model CapBAC	15

II.5.4	Policy-Based Access Control	16
II.6	Token Otorisasi	18
II.6.1	JSON Web Token	18
II.6.2	PASETO	19
II.6.3	Macaroons	19
II.6.4	Biscuit Token	20
II.7	DecMed	22
II.7.1	Arsitektur DecMed	22
II.7.2	Alur Pengelolaan dan Akses RME pada DecMed	23
II.8	Pemodelan Ancaman STRIDE	24
II.9	Penelitian Terkait	25
II.9.1	Hybrid RBAC dan ABAC pada Sistem RME Berbasis Blockchain.....	25
II.9.2	Model Kontrol Akses Empat Lapis untuk RME Berbasis Blockchain.....	26
II.9.3	Kontrol Akses Granular Menggunakan <i>Composable NFT</i>	26
II.9.4	Implementasi Macaroons untuk Delegasi Akses pada Sistem Nyata	27
BAB III	ANALISIS DAN RANCANGAN SOLUSI	30
III.1	Analisis Masalah	30
III.1.1	Analisis Sistem DecMed.....	30
III.1.1.1	Keterbatasan Token Kapabilitas DecMed	31
III.1.1.2	Keterbatasan Segmentasi Data pada DecMed	32
III.1.1.3	Analisis Skenario Layanan Kesehatan Kolaboratif	34
III.1.1.4	Analisis STRIDE pada Sistem DecMed	36
III.1.1.5	Analisis Mekanisme Penggunaan dan Revokasi Token	37
III.1.2	Identifikasi Masalah.....	38
III.1.3	Kebutuhan Sistem	40
III.1.3.1	Kebutuhan Fungsional Tambahan.....	40
III.1.3.2	Kebutuhan Nonfungsional.....	41
III.1.3.3	Pemetaan Masalah terhadap Kebutuhan Sistem	42
III.2	Analisis Solusi	42
III.2.1	Analisis Delegasi Akses Antar Tenaga Kesehatan	43

III.2.2	Analisis Pemilihan Token Otorisasi	45
III.2.3	Analisis Segmentasi Data RME	47
III.2.4	Analisis Pendekatan Kontrol Akses Berbasis Kebijakan	50
III.2.5	Analisis Penegakan Otoritas pada <i>Server</i> PRE	53
III.2.5.1	Analisis Verifikasi Aktor dan Operasi Tulis	53
III.2.5.2	Analisis Verifikasi Bukti Identitas Aktor pada Rantai Delegasi	53
III.2.5.3	Analisis Revokasi dan Audit Delegasi	54
III.2.6	Pemetaan Masalah terhadap Solusi	55
III.3	Rancangan Solusi	55
III.3.1	Rancangan Arsitektur Solusi	56
III.3.2	Rancangan Segmentasi Data RME	57
III.3.3	Rancangan Model PBAC pada DecMed	59
III.3.3.1	Ruang Lingkup Adaptasi Policy Machine	59
III.3.3.2	Pengguna dan Atribut Pengguna	60
III.3.3.3	Objek dan Atribut Objek	61
III.3.3.4	Hak Akses dan Asosiasi	63
III.3.3.5	Kondisi Kebijakan Akses	65
III.3.3.6	Rancangan Kebijakan Delegasi	66
III.3.3.7	Fungsi Keputusan Akses	67
III.3.3.8	Pemetaan Model Kebijakan ke Komponen DecMed	69
III.3.4	Rancangan Representasi Kebijakan pada Token Macaroons..	70
III.3.4.1	Struktur Kapabilitas Efektif Token	71
III.3.4.2	Pemetaan Elemen Kebijakan ke Caveat	72
III.3.4.3	Pemisahan Kebijakan di Dalam dan di Luar Token	73
III.3.4.4	Rancangan Token Read dan Update	73
III.3.4.5	Rancangan Subjek Rantai Delegasi	75
III.3.4.6	Penerbitan Token Awal	76
III.3.4.7	Atenuasi Token sebagai Realisasi Delegasi	76
III.3.4.8	Pembatasan Kedalaman dan Hubungan Token	78
III.3.4.9	Penerapan Whitelisting dan Least Privilege	79
III.3.4.10	Hubungan dengan Proses Verifikasi	80
III.3.5	Rancangan Penegakan Otoritas	81
III.3.5.1	Penegakan Kebijakan	81

III.3.5.2	Verifikasi <i>Role</i> dan <i>Subrole</i> Tenaga Medis untuk Akses <i>Dataset</i>	83
III.3.5.3	Verifikasi <i>Wallet</i> Aktor pada Rantai Delegasi	84
III.3.5.4	Pencabutan Hak Akses Macaroon Delegasi	85
III.3.6	Rancangan Alur Akses dan Delegasi Macaroon	87
III.3.6.1	Penerbitan Token Awal oleh Pasien kepada Petugas Rekam Medis	88
III.3.6.2	Delegasi dari Petugas Rekam Medis kepada Perawat dan Dokter	90
III.3.6.3	Delegasi dari Dokter kepada Laboratorium dan Apoteker	91
III.3.6.4	Proses Pemberian dan Penggunaan Token Macaroon Delegasi	91
III.3.7	Pemetaan Rancangan terhadap Solusi	95
BAB IV	IMPLEMENTASI DAN PENGUJIAN	96
IV.1	Lingkungan Implementasi	96
IV.2	Implementasi Sistem	97
IV.2.1	Batasan Implementasi	98
IV.2.2	Implementasi Arsitektur Sistem	99
IV.2.3	Implementasi Segmentasi Data RME	100
IV.2.3.1	Implementasi Segmentasi Metadata RME pada Penyimpanan <i>On-Chain</i>	102
IV.2.3.2	Implementasi Segmentasi Data RME pada Penyimpanan <i>Off-Chain</i>	103
IV.2.4	Implementasi Token Otorisasi Berbasis Macaroons	104
IV.2.4.1	Komponen Implementasi Macaroons	104
IV.2.4.2	Struktur <i>Caveats</i> Macaroons	105
IV.2.4.3	Penerbitan Token Macaroon	105
IV.2.4.4	Atenuasi Token Macaroon	106
IV.2.4.5	Revokasi Token Macaroon	106
IV.2.5	Delegasi Akses dan Atenuasi <i>Offline</i>	107
IV.2.5.1	Delegasi Akses dari Pasien kepada Petugas Rekam Medis	107
IV.2.5.2	Delegasi Akses antar Tenaga Kesehatan	110

IV.2.6	Implementasi Penegakan Otoritas	113
IV.2.6.1	Autentikasi Token Macaroon.....	114
IV.2.6.2	Pemeriksaan Status Revokasi Token	116
IV.2.6.3	Verifikasi <i>Role</i> dan <i>Subrole</i> melalui <i>Move Smart Contract</i>	116
IV.2.6.4	Verifikasi Konteks Segmen.....	116
IV.2.6.5	Verifikasi Bukti Kepemilikan <i>Wallet</i>	117
IV.2.6.6	Eksekusi Operasi <i>Re-encryption</i> , IPFS, dan IOTA .	118
IV.2.7	Implementasi <i>Smart Contract</i> IOTA Move	120
IV.2.8	Implementasi <i>Patient Client</i>	120
IV.2.8.1	Halaman <i>Home</i> (<i>List RME</i>)	121
IV.2.8.2	Halaman Detail RME.....	121
IV.2.8.3	Halaman Audit Delegasi	121
IV.2.8.4	Halaman Detail <i>Scan QR</i>	122
IV.2.9	Implementasi <i>Hospital Client</i>	122
IV.2.9.1	Halaman <i>Dashboard</i> (<i>List RME</i>)	122
IV.2.9.2	Halaman Delegasi Akses	123
IV.2.9.3	Halaman Daftar RME Pasien	124
IV.2.9.4	Halaman Baca Detail RME	124
IV.2.9.5	Halaman Tulis Segmen RME	124
IV.3	Pengujian Sistem.....	125
IV.3.1	Strategi Pengujian.....	125
IV.3.2	Pengujian Kebutuhan Fungsional	125
IV.3.3	Pengujian Kebutuhan Nonfungsional	126
IV.3.3.1	Pengujian KNF-TA-01	126
IV.3.3.2	Pengujian KNF-TA-02	127
IV.3.3.3	Pengujian KNF-TA-03	129
IV.3.3.4	Pengujian KNF-TA-04	131
IV.3.3.5	Pengujian KNF-TA-05	132
IV.3.3.6	Pengujian KNF-TA-06	133
IV.4	Evaluasi.....	134
IV.4.1	Evaluasi terhadap Kebutuhan Sistem	134
BAB V	PENUTUP	136
V.1	Kesimpulan.....	136

V.2	Saran.....	136
DAFTAR REFERENSI		142

DAFTAR LAMPIRAN

Lampiran A.	Metadata Rekam Medis Elektronik	143
Lampiran B.	Alur Pemberian Akses Medis pada DecMed	146
Lampiran C.	Kebutuhan Fungsional DecMed	147
Lampiran D.	DFD DecMed	149
Lampiran E.	Analisis STRIDE pada Sistem DecMed	153
Lampiran F.	Legenda Diagram Arsitektur Solusi	155
Lampiran G.	Skema Penyimpanan Data RME	156
Lampiran H.	Contoh <i>Caveat</i> Token Macaroon untuk Setiap Tahapan	159
Lampiran I.	Pengujian dan Evaluasi Kebutuhan Sistem	163
I.1	Pengujian Kebutuhan Fungsional	163
I.2	Evaluasi Kebutuhan Sistem.....	164
Lampiran J.	Daftar Dependensi DecMed	166
Lampiran K.	Legenda Package Diagram	169
Lampiran L.	Modul dan Implementasi <i>Crate</i> decmed-rme-segment	170
Lampiran M.	Modul dan Implementasi <i>Crate</i> decmed-macaroon-auth	171
Lampiran N.	Alur Implementasi Penegakan Otoritas pada Server PRE	173
Lampiran O.	Implementasi REST API Server PRE	176
Lampiran P.	Implementasi Smart Contract Sistem DecMed	177
Lampiran Q.	Tangkapan Layar Implementasi <i>Patient Client</i>	181
Lampiran R.	Tangkapan Layar Implementasi <i>Hospital Client</i>	184

DAFTAR GAMBAR

Gambar II.1. Gambaran simulasi dari PRE (Nuñez, 2017).....	13
Gambar II.2. <i>Sequence diagram</i> dari model CapBAC. (Dokumentasi penulis).....	16
Gambar II.3. Contoh delegasi dan atenuasi kewenangan pada Macaroon. C memegang Macaroon yang diturunkan dari <i>service</i> FS untuk mengakses data pada <i>service</i> TS dengan batasan waktu, lokasi IP, dan target data yang spesifik. (Birgisson dkk., 2014).....	21
Gambar II.4. Arsitektur DecMed (Sadewa, 2025).....	22
Gambar II.5. Ilustrasi struktur data DMR menggunakan composable NFT. (Amaracitra & Alamsyah, 2025).....	27
Gambar III.1. Arsitektur Solusi (Dokumentasi Penulis).....	57
Gambar III.2. Alur penegakan otoritas pada <i>Server</i> PRE.....	82
Gambar III.3. <i>Sequence Diagram</i> Rancangan Validasi <i>subrole</i> Tenaga Medis terhadap <i>Dataset Category</i>	84
Gambar III.4. <i>Sequence Diagram</i> Rancangan Alur Pencabutan Hak Akses Macaroon Delegasi.....	86
Gambar III.5. <i>Flow Diagram</i> Alur Akses dan Delegasi pada Proses Pelayanan Pasien.....	88
Gambar III.6. <i>Sequence diagram</i> pembentukan dan pencatatan token Macaroon delegasi	92
Gambar III.7. <i>Sequence diagram</i> pengambilan dan penggunaan token Macaroon delegasi	94
Gambar IV.1. Package Diagram Implementasi	100
Gambar B.1. <i>Sequence Diagram</i> Alur Pemberian Akses Medis dari Pasien kepada Tenaga Medis (Sadewa, 2025)	146
Gambar D.1. Legenda <i>Data Flow Diagram</i> (Dokumentasi Penulis)	149
Gambar D.2. DFD DecMed Level 0 (Dokumentasi Penulis).....	149
Gambar D.3. DFD DecMed Level 1 (Dokumentasi Penulis).....	150

Gambar F.1. Legenda Diagram Arsitektur Solusi (Dokumentasi Penulis)	155
Gambar K.1. Legenda Package Diagram (Dokumentasi Penulis)	169
Gambar N.1. Legenda bentuk pada <i>Flow Diagram</i>	173
Gambar N.2. Alur implementasi penegakan otoritas pada <i>Server PRE</i> bagian autentikasi token, <i>effective capability</i> , <i>delegation chain</i> , dan revokasi...	174
Gambar N.3. Alur implementasi penegakan otoritas pada <i>Server PRE</i> bagian validasi <i>role</i> dan <i>subrole</i> , validasi segmen, <i>wallet proof</i> , serta eksekusi <i>PRE</i> , <i>IPFS</i> , dan <i>IOTA</i>	175
Gambar Q.1. Halaman <i>Home</i> daftar RME.	181
Gambar Q.2. Halaman detail RME.	182
Gambar Q.3. Halaman audit delegasi RME.....	182
Gambar Q.4. Halaman <i>scan QR</i>	183
Gambar Q.5. Halaman konfirmasi pemberian akses awal.	183
Gambar R.1. Halaman <i>dashboard MedicalPersonnel</i>	184
Gambar R.2. Halaman delegasi akses bagian 1.....	184
Gambar R.3. Halaman delegasi akses bagian 2.....	185
Gambar R.4. Halaman daftar RME pasien pada <i>Hospital Client</i>	185
Gambar R.5. Halaman detail RME pada <i>Hospital Client</i>	186
Gambar R.6. Halaman alur akses tulis pada <i>Hospital Client</i>	186

DAFTAR TABEL

Tabel II.1.	Komponen dan fungsi dalam arsitektur DecMed	23
Tabel II.2.	Aktor, <i>client</i> , dan peran dalam DecMed	23
Tabel II.3.	Kategori ancaman pada STRIDE.....	24
Tabel III.1.	Pemetaan Aktor dan Kebutuhan Akses pada Skenario Layanan Kesehatan Kolaboratif	35
Tabel III.2.	Identifikasi Masalah DecMed	39
Tabel III.3.	Kebutuhan Fungsional Tambahan DecMed	41
Tabel III.4.	Kebutuhan Nonfungsional Tambahan DecMed	42
Tabel III.5.	Pemetaan Masalah terhadap Kebutuhan Sistem.....	42
Tabel III.6.	Perbandingan Pendekatan Token Otorisasi.....	46
Tabel III.7.	Analisis Pendekatan Pemodelan Kebijakan Akses	51
Tabel III.8.	Daftar Solusi yang Diusulkan Berdasarkan Hasil Analisis.....	55
Tabel III.9.	Tabel Pemetaan <i>Dataset Category</i>	57
Tabel III.10.	Tabel Pemetaan <i>Function Category</i>	58
Tabel III.11.	Kondisi Kebijakan Akses DecMed	65
Tabel III.12.	Pemetaan Model Kebijakan terhadap Komponen DecMed.....	69
Tabel III.13.	Pemetaan Elemen Kebijakan ke <i>Caveat</i> Macaroon	72
Tabel III.14.	Elemen Kebijakan yang Diverifikasi di Luar Token.....	74
Tabel III.15.	Pemetaan Hak Akses Update Berdasarkan subrole Tenaga Medis.....	83
Tabel III.16.	Pemetaan Delegasi Token dari Petugas Rekam Medis.....	90
Tabel III.17.	Pemetaan Delegasi Lanjutan dari Dokter	91
Tabel III.18.	Pemetaan Rancangan terhadap Solusi.....	95
Tabel IV.1.	Daftar Implementasi Sistem	98
Tabel IV.2.	<i>Caveats</i> yang Diimplementasikan pada Token Macaroon.....	105
Tabel IV.3.	Status Implementasi Penegakan Otoritas pada <i>Server</i> PRE	114
Tabel A.1.	Metadata Variabel RME Rawat Jalan.....	143
Tabel A.2.	Metadata Variabel RME Rawat Inap.....	144

Tabel A.3.	Metadata Variabel RME Laboratorium	145
Tabel A.4.	Metadata Variabel RME Apotek	145
Tabel C.1.	Kebutuhan Fungsional DecMed (Sadewa, 2025)	147
Tabel D.1.	Daftar <i>External Entities</i> pada DFD DecMed.....	151
Tabel D.2.	Daftar <i>Process</i> DFD DecMed	151
Tabel D.3.	Daftar <i>Data Store</i> pada DFD DecMed.....	151
Tabel D.4.	Daftar Data Flow pada DFD DecMed (Level 0)	152
Tabel D.5.	Daftar Data Flow pada DFD DecMed (Level 1)	152
Tabel E.1.	Analisis STRIDE pada Sistem DecMed	153
Tabel G.1.	Skema Metadata Segmen RME <i>On-Chain</i>	156
Tabel G.2.	Skema Segmen Data RME <i>Off-Chain</i>	157
Tabel I.1.	Pengujian Kebutuhan Fungsional pada Alur Rawat Jalan dan Rawat Inap.....	163
Tabel I.2.	Evaluasi Kebutuhan Sistem terhadap Implementasi dan Pengujian .	164
Tabel J.1.	Dependensi Umum yang Digunakan pada Beberapa Komponen ...	166
Tabel J.2.	Dependensi PRE.....	167
Tabel J.3.	Dependensi <i>Client</i>	167
Tabel J.4.	Dependensi <i>decmed-rme-segment</i>	168
Tabel J.5.	Dependensi <i>decmed-macaroon-auth</i>	168
Tabel L.1.	Daftar Modul dan Implementasi <i>Crate</i> <i>decmed-rme-segment</i>	170
Tabel M.1.	Daftar Modul dan Implementasi <i>Crate</i> <i>decmed-macaroon-auth</i>	171
Tabel O.1.	Daftar Endpoint REST API pada Server PRE	176
Tabel P.1.	Daftar Module Smart Contract Sistem DecMed.....	177
Tabel P.2.	Daftar Method pada Module <i>decmed::admin</i>	177
Tabel P.3.	Daftar Method pada Module <i>decmed::hospital_personnel</i>	178
Tabel P.4.	Daftar Method pada Module <i>decmed::patient</i>	179
Tabel P.5.	Daftar Method pada Module <i>decmed::proxy</i>	180

DAFTAR KODE PROGRAM

III.1	Struktur klaim JWT pada DecMed.....	31
III.2	Struktur metadata medis pasien pada DecMed	32
III.3	Struktur serialisasi metadata medis DecMed	33
III.4	Potongan struktur data medis <i>off-chain</i> pada DecMed	33
IV.1	Implementasi DatasetCategory pada <i>crate</i> decmed-rme-segment	100
IV.2	Implementasi FunctionCategory pada <i>crate</i> decmed-rme-segment	101
IV.3	Implementasi struktur RmeSegmentMetadata pada <i>crate</i> decmed-rme-segment	102
IV.4	Implementasi struktur RmeSegmentData pada <i>crate</i> decmed-rme-segment	103
IV.5	Definisi DelegationProofContext	111
IV.6	Definisi EffectiveCapability	114
IV.7	Definisi DelegationStep dan DelegationChain.....	115
IV.8	Struktur WalletProofContext sebagai konteks verifikasi <i>wallet</i> <i>signature</i>	117
IV.9	Pengujian P-KNF-01 untuk KNF-TA-01	126
IV.10	Pengujian P-KNF-03 untuk KNF-TA-02	127
IV.11	Pengujian P-KNF-04 untuk KNF-TA-02	128
IV.12	Pengujian P-KNF-05 untuk KNF-TA-02	129
IV.13	Pengujian P-KNF-07 untuk KNF-TA-03	129
IV.14	Pengujian P-KNF-08 untuk KNF-TA-03	130
IV.15	Pengujian P-KNF-09 untuk KNF-TA-03 dan KNF-TA-06	131
IV.16	Pengujian P-KNF-11 untuk KNF-TA-05	132
IV.17	Pengujian P-KNF-13 untuk KNF-TA-06	133
H.1	Contoh <i>Caveat</i> Token Read Awal untuk Petugas Rekam Medis	159
H.2	Contoh <i>Caveat</i> Token Update Awal untuk Petugas Rekam Medis....	159
H.3	Contoh <i>Caveat</i> Delegasi Petugas Rekam Medis → Dokter.....	160
H.4	Contoh <i>Caveat</i> Delegasi Petugas Rekam Medis → Perawat	161
H.5	Contoh <i>Caveat</i> Delegasi Dokter → Petugas Laboratorium	161
H.6	Contoh <i>Caveat</i> Delegasi Dokter → Apoteker	162

BAB I

PENDAHULUAN

I.1 Latar Belakang

Transformasi sistem rekam medis di Indonesia semakin didorong oleh regulasi pemerintah. Peraturan Menteri Kesehatan Republik Indonesia (Permenkes) Nomor 24 Tahun 2022 mewajibkan fasilitas pelayanan kesehatan (fasyankes) untuk mengimplementasikan Rekam Medis Elektronik (RME) yang terintegrasi (Kementerian Kesehatan Republik Indonesia, 2022b). Integrasi RME diperlukan untuk mendukung interoperabilitas data antar fasyankes, sesuai amanat Undang-Undang Nomor 29 Tahun 2004 (Republik Indonesia, 2004). Namun, integrasi tersebut juga menimbulkan kebutuhan perlindungan data yang lebih kuat karena RME merupakan informasi pribadi spesifik yang sensitif (UU 27/2022 tentang PDP, 2022).

Salah satu tantangan penting dalam pengembangan sistem RME adalah aspek kepemilikan data (Liu & Chen, 2025). Kepemilikan data berkaitan dengan kendali pasien terhadap informasi kesehatan miliknya, termasuk siapa yang dapat mengakses data tersebut dan dalam kondisi apa akses dapat diberikan. Sejumlah penelitian menekankan pentingnya pergeseran paradigma kontrol akses menuju sistem yang bersifat *patient-centric*, yaitu sistem yang memberikan kendali lebih besar kepada pasien sebagai pemilik data kesehatan (Patil, 2024; Peng dkk., 2023).

Meskipun kontrol pasien merupakan aspek penting, perawatan pasien di rumah sakit bersifat kolaboratif dan melibatkan banyak tenaga kesehatan lintas unit, seperti dokter, perawat, petugas laboratorium, apoteker, dan tenaga kesehatan lain yang bekerja sesuai kewenangannya (Kementerian Kesehatan Republik Indonesia, 2022a; Srinivas dkk., 2023). Dalam konteks tersebut, informasi klinis yang relevan perlu tersedia bagi tenaga kesehatan yang terlibat agar proses pelayanan dapat berjalan efektif (Srinivas dkk., 2023). NHS England menyatakan bahwa informasi yang relevan dapat dibagikan antar tenaga kesehatan yang terlibat dalam perawatan pasien berdasarkan *implied consent*, dengan tetap memperhatikan prinsip

need-to-know (NHS England, 2023, Maret 28/2025). Prinsip serupa juga tercermin pada konsep *minimum necessary* dalam HIPAA, yaitu bahwa penggunaan dan pengungkapan informasi kesehatan perlu dibatasi pada informasi minimum yang diperlukan untuk tujuan tertentu (of Health & Services, 2009).

Kondisi tersebut menunjukkan adanya kebutuhan untuk menyeimbangkan kendali pasien dengan kebutuhan operasional klinis. Studi terkait juga menunjukkan bahwa pasien pada umumnya mendukung pembagian data klinis untuk tujuan perawatan langsung tanpa persetujuan eksplisit pada setiap akses, selama pasien memperoleh informasi yang jelas dan tetap memiliki pilihan untuk *opt-out* (L. A. Jones dkk., 2022).

Kebutuhan tersebut sejalan dengan ISO 22600 yang menempatkan pengelolaan *privilege* dan kontrol akses yang granular sebagai bagian penting dalam pertukaran informasi kesehatan, khususnya pada lingkungan yang melibatkan banyak aktor, banyak sistem, dan beberapa domain kebijakan (for Standardization, 2014). Standar tersebut menunjukkan bahwa akses pada sistem kesehatan perlu dikelola berbasis *policy*, sejalan dengan prinsip *privilege management* pada sistem informasi kesehatan (for Standardization, 2014).

Salah satu solusi sistem RME terdesentralisasi adalah DecMed (Sadewa, 2025). Sistem ini memanfaatkan DLT IOTA, *InterPlanetary File System* (IPFS), dan *Proxy Re-Encryption* (PRE) dengan menerapkan *capability-based access control*. Namun, mekanisme pemberian akses pada DecMed masih bertumpu pada pasien sebagai *resource owner* untuk menerbitkan token hak akses baru. Dalam konteks layanan klinis yang kolaboratif, asumsi tersebut dapat menjadi hambatan karena kebutuhan akses sering kali muncul secara dinamis sesuai peran tenaga kesehatan dalam episode perawatan. Selain itu, kontrol akses DecMed masih bersifat *coarse-grained* karena keputusan akses terutama ditentukan oleh *role* dan *purpose* pada token, sehingga belum mencakup hubungan kebijakan yang lebih luas antara aktor, objek RME, hak akses, dan kondisi akses. Data RME yang dilindungi juga masih disimpan sebagai satu *entry* besar dan perlu dipisahkan ke dalam unit yang lebih kecil agar data dapat diakses sesuai dengan kebutuhan layanan. Dengan demikian, terdapat dua keterbatasan utama yang perlu diperbaiki, yaitu mekanisme delegasi akses yang masih bergantung pada keterlibatan langsung pasien dan struktur data RME yang perlu mendukung pemisahan informasi medis sesuai prinsip

need-to-know.

Untuk menjawab keterbatasan tersebut, kontrol akses pada DecMed diperluas melalui penerapan *Policy-Based Access Control* (PBAC), segmentasi data medis, dan fitur *offline attenuation* pada token Macaroon. PBAC digunakan agar kebijakan akses tidak lagi terbatas pada *role* dan *purpose*, melainkan mencakup hubungan antara aktor, objek RME, hak akses, dan kondisi akses secara lebih luas. Segmentasi data medis digunakan untuk mendukung penegakan kebijakan tersebut pada unit data yang relevan dengan prinsip *need-to-know*. Fitur *offline attenuation* memungkinkan pasien menerbitkan token awal pada proses administrasi, lalu pemegang token menurunkan hak akses kepada tenaga kesehatan yang terlibat tanpa intervensi ulang dengan pasien. Macaroon berperan sebagai media pembawa kapabilitas hasil kebijakan, bukan sebagai pengganti model kebijakan itu sendiri.

I.2 Rumusan Masalah

Berdasarkan latar belakang yang telah diuraikan pada subbab I.1, rumusan masalah yang dibahas dalam tugas akhir ini adalah sebagai berikut:

1. Bagaimana rancangan dan implementasi mekanisme kontrol akses granular pada kerangka kerja DecMed dengan memanfaatkan Macaroons?
2. Bagaimana rancangan dan implementasi segmentasi data RME yang mendukung penegakan kontrol akses granular pada DecMed?
3. Bagaimana rancangan dan implementasi fitur *offline attenuation* pada token otorisasi untuk memfasilitasi pendelegasian hak akses antar tenaga kesehatan yang terlibat dalam layanan klinis tanpa memerlukan intervensi langsung dari pasien?

I.3 Tujuan

Tujuan dari Tugas Akhir ini adalah:

1. Kontrol akses berbasis kebijakan (PBAC) dirancang dan diterapkan pada kerangka kerja DecMed agar keputusan akses mencakup aktor, objek, hak akses, dan kondisi secara lebih luas.

2. Segmentasi data yang mendukung penegakan kontrol akses pada DecMed dirancang dan diterapkan.
3. Fitur atenuasi *offline* dirancang dan diterapkan untuk memfasilitasi pendelegasian hak akses antar tenaga medis tanpa memerlukan intervensi langsung dari pasien.

I.4 Batasan Masalah

Terdapat beberapa batasan masalah dari Tugas Akhir ini. Batasan masalah tersebut antara lain:

1. Kajian dan pengembangan hanya mencakup implementasi kerangka kerja DecMed.
2. Masalah terkait *performance* dan *availability* tidak termasuk ke dalam kajian dan skenario uji.
3. Kasus skenario delegasi layanan klinis terbatas hanya pada aktor dokter, perawat, petugas laboratorium, dan apoteker pada alur Rawat Jalan dan Rawat Inap.
4. Data RME pada dataset Instalasi Gawat Darurat (IGD) tidak termasuk dalam kajian rancangan dan implementasi.
5. Segmentasi data RME hanya dilakukan untuk dokumentasi klinis. Dokumentasi administratif tidak termasuk ke dalam fokus Tugas Akhir ini dan hanya diimplementasikan sesuai dengan implementasi DecMed sebelumnya.

I.5 Metodologi

Terdapat beberapa tahapan untuk melaksanakan tugas akhir secara sistematis, berikut merupakan tahapan-tahapan yang dilakukan:

1. Studi Literatur

Pada tahap awal, fondasi teoretis dan kontekstual dikumpulkan melalui studi literatur.

2. Analisis Kebutuhan

Pada tahap ini, kekurangan pada kerangka kerja DecMed dianalisis. Kekurangan tersebut diinterpretasikan sebagai masalah dan didefinisikan menjadi kebutuhan. Tahap ini diakhiri dengan perumusan kebutuhan fungsional dan nonfungsional sistem.

3. Analisis dan Rancangan Solusi

Pada tahap ini, alternatif solusi dianalisis untuk mengatasi masalah pada kerangka kerja DecMed. Solusi yang terpilih kemudian dirancang menjadi rancangan solusi.

4. Implementasi Prototipe

Pada tahap ini, rancangan direalisasikan melalui pengembangan prototipe DecMed yang sudah ada.

5. Pengujian

Pada tahap ini, prototipe diuji untuk memastikan pemenuhan kebutuhan sistem sesuai dengan skenario pengujian yang ditentukan.

6. Evaluasi

Pada tahap ini, prototipe dievaluasi berdasarkan hasil pengujian sebagai dasar kesimpulan dan saran untuk penelitian selanjutnya.

I.6 Sistematika Pembahasan

Berikut merupakan sistematika pembahasan dari Tugas Akhir ini:

Bab I - Pendahuluan Gagasan utama dari tugas akhir diuraikan pada bab ini, meliputi latar belakang, rumusan masalah, tujuan, batasan, metodologi, hingga sistematika pembahasan mengenai proses pengembangan solusi.

Bab II - Studi Literatur Studi literatur terkait sistem yang dikembangkan dipaparkan pada bab ini. Pembahasan difokuskan pada uraian teoritis berbagai komponen yang digunakan, termasuk regulasi dan teknologi yang digunakan dalam sistem.

Bab III - Analisis dan Rancangan Solusi Pada bab ini, analisis terhadap masalah yang ditemukan serta berbagai alternatif solusi yang dapat digunakan untuk mengatasinya diuraikan. Selain itu, rancangan solusi yang dikembangkan juga dibahas, meliputi pendefinisian kebutuhan fungsional dan nonfungsional, serta rancangan setiap komponen sistem.

Bab IV - Implementasi dan Pengujian Sistem Hasil implementasi dari rancangan solusi yang telah dipaparkan pada Bab III dijelaskan pada bab ini. Selain itu, strategi pengujian serta hasil pengujian yang dilakukan terhadap solusi juga dibahas pada bab ini.

Bab V - Penutup Kesimpulan dari hasil penelitian serta saran untuk pengembangan lebih lanjut disajikan pada bab ini.

BAB II

STUDI LITERATUR

II.1 Rekam Medis Elektronik

II.1.1 Definisi RME

Di Indonesia, definisi dari Rekam Medis dan Rekam Medis Elektronik didefinisikan pada Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 (Permenkes 24/2022). "Rekam Medis adalah dokumen yang berisikan identitas pasien, pemeriksaan, pengobatan, tindakan, dan pelayanan lain yang telah diberikan pada pasien" sedangkan "Rekam Medis Elektronik adalah Rekam Medis yang dibuat dengan menggunakan sistem elektronik yang diperuntukkan bagi penyelenggaraan Rekam Medis." (Kementerian Kesehatan Republik Indonesia, 2022b).

Berdasarkan definisi tersebut, rekam medis adalah salah satu komponen vital dalam sistem kesehatan di Indonesia. Rekam medis bukanlah sebuah catatan biasa yang dibuat lalu disimpan, melainkan sebuah catatan yang terus diperbarui. Keberadaan Rekam Medis bertujuan untuk meningkatkan mutu pelayanan kesehatan dan memberikan kepastian hukum dalam peristiwa medis.

II.1.2 Isi RME

Berdasarkan Permenkes 24/2022 Pasal 27 Ayat 1 (Kementerian Kesehatan Republik Indonesia, 2022b), isi dari Rekam Medis Elektronik terbagi menjadi dua bagian, yaitu:

1. Dokumentasi Administratif
2. Dokumentasi Klinis

Panduan lebih rinci terkait isi dari Rekam Medis Elektronik diatur pada Keputusan Menteri Kesehatan (KMK) No. HK.01.07/MENKES/1423/2022 tentang Pedoman Variabel dan metadata pada Penyelenggaraan Rekam Medis Elektronik (Menteri

Kesehatan Republik Indonesia, 2022). Pada setiap data RME, terdapat dokumentasi administratif dan dokumentasi klinis. Dokumentasi Klinis kemudian dibagi berdasarkan kategori fungsi klinis. KMK ini mengatur variabel dan metadata yang terdapat pada RME dengan dataset yang terdiri dari:

1. IGD (Instalasi Gawat Darurat).
2. Rawat Jalan.
3. Rawat Inap.
4. Laboratorium.
5. Apotek.

Detail metadata dataset RME untuk dataset Rawat Jalan, Rawat Inap, Laboratorium, dan Apotek dapat dilihat pada Lampiran A.

II.1.3 RME dalam Alur Pelayanan Kesehatan Kolaboratif

Penyelenggaraan layanan kesehatan pada praktiknya tidak selalu dilakukan oleh satu aktor tunggal, melainkan melibatkan beberapa tenaga kesehatan dan tenaga lain yang bekerja sesuai kewenangan masing-masing (World Health Organization, 2010). Dalam konteks layanan kolaboratif, pasien dapat berinteraksi dengan petugas rekam medis pada tahap pendaftaran, perawat pada tahap pemeriksaan awal, dokter pada tahap pemeriksaan dan pengambilan keputusan klinis, petugas laboratorium pada tahap pemeriksaan penunjang, serta apoteker atau tenaga kefarmasian pada tahap pelayanan resep dan obat. Pola ini sejalan dengan konsep praktik kolaboratif antarprofesi, yaitu ketika tenaga kesehatan dari latar belakang profesi berbeda bekerja bersama pasien untuk memberikan pelayanan yang bermutu (Srinivas dkk., 2023).

Struktur RME di Indonesia juga menunjukkan bahwa data kesehatan pasien tidak bersifat tunggal, melainkan terdiri dari dokumentasi administratif dan dokumentasi klinis (Kementerian Kesehatan Republik Indonesia, 2022b). Pembagian ini menunjukkan bahwa kebutuhan akses terhadap RME dapat berbeda antara aktor administratif dan aktor klinis.

Standar Akreditasi Rumah Sakit memberikan dasar bahwa pelayanan pasien dilakukan melalui kerja kolaboratif antarprofesi. Dalam standar tersebut, DPJP

(Dokter Penanggung Jawab Pasien) ditempatkan sebagai *clinical leader*, sedangkan PPA (Profesional Pemberi Asuhan) bekerja sebagai tim interdisiplin dalam proses asuhan pasien (Kementerian Kesehatan Republik Indonesia, 2022a). Standar yang sama juga menunjukkan keterlibatan perawat dalam pengkajian dan asuhan keperawatan, laboratorium sebagai layanan penunjang untuk memenuhi kebutuhan pasien dan PPA, serta apoteker dalam proses penggunaan obat yang terkoordinasi.

Alur operasional layanan tersebut diperjelas oleh panduan interoperabilitas SATUSEHAT untuk layanan Rawat Jalan dan Rawat Inap. Panduan tersebut memuat tahapan layanan seperti pendaftaran pasien, pendaftaran kunjungan, anamnesis, pemeriksaan, rencana rawat, instruksi medik dan keperawatan, pemeriksaan penunjang, diagnosis, tindakan, peresepan, pengkajian resep, pemberian obat, tindak lanjut, dan resume medis (SATUSEHAT Platform, nodate, 2023). Sementara itu, Pedoman Variabel dan Metadata RME dari Kementerian Kesehatan memetakan dokumentasi RME ke dalam dataset seperti Rawat Jalan, Rawat Inap, Laboratorium, dan Apotek (Menteri Kesehatan Republik Indonesia, 2022). Kombinasi antara alur pelayanan, keterlibatan aktor, dan struktur dataset tersebut menunjukkan bahwa kebutuhan akses terhadap RME berbeda menurut tahap layanan, peran aktor, dan jenis data yang digunakan.

II.1.4 Hak Akses RME

Karena RME memuat data administratif dan klinis yang termasuk data pribadi spesifik, akses terhadap RME harus dibatasi berdasarkan kewenangan, tindakan, dan kebutuhan pelayanan. Tenaga kesehatan dapat melakukan beberapa aksi terhadap data RME pasien, yaitu (Kementerian Kesehatan Republik Indonesia, 2022b):

1. Menambahkan data baru.
2. Melakukan perbaikan data.
3. Melihat atau membaca data.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP) menjadi landasan yuridis utama yang menetapkan standar keamanan bagi sistem data rekam medis. Pasal 4 ayat 2 huruf a UU PDP mengklasifikasikan data dan informasi kesehatan sebagai data pribadi spesifik (UU 27/2022 tentang

PDP, 2022). Pengendali data pribadi diwajibkan untuk melindungi dan memastikan keamanan data yang diprosesnya (Pasal 35), mewajibkan pengendali data pribadi untuk menyediakan *audit trail* pemrosesan data pribadi (Pasal 32), wajib melindungi data dari pemrosesan yang tidak sah (Pasal 38) dan mencegah akses yang tidak sah melalui sistem keamanan yang andal (Pasal 39) (UU 27/2022 tentang PDP, 2022).

Berdasarkan Permenkes No. 73 Tahun 2016 tentang Standar Pelayanan Kefarmasian di Apotek, pelayanan farmasi klinik mencakup pengkajian resep dan *dispensing* (Indonesia, 2016). Hal ini menunjukkan bahwa apoteker memerlukan akses terhadap informasi yang relevan dengan resep, terapi, dan penggunaan obat pasien untuk memastikan kesesuaian, keamanan, dan ketepatan pelayanan obat.

Kebutuhan akses pada petugas laboratorium dapat diturunkan dari struktur metadata RME pada KMK 1423/2022 (Menteri Kesehatan Republik Indonesia, 2022). Pada pedoman tersebut, permintaan pemeriksaan laboratorium yang diminta oleh dokter untuk pasien dicantumkan sebagai bagian dari data pemeriksaan penunjang. Hal ini menunjukkan bahwa dalam alur pelayanan, petugas laboratorium tidak perlu memperoleh akses terhadap seluruh data klinis pasien, tetapi cukup terhadap informasi yang relevan untuk memproses pemeriksaan penunjang terkait laboratorium.

II.2 IOTA

II.2.1 Distributed Ledger Technology

Distributed Ledger Technology (DLT) merupakan teknologi pencatatan data terdistribusi yang memungkinkan data direkam, disimpan, dan diverifikasi oleh banyak *node* tanpa bergantung pada satu otoritas terpusat. DLT mencakup berbagai bentuk implementasi, termasuk *blockchain* dan struktur alternatif seperti *Directed Acyclic Graph* (DAG), yang masing-masing memiliki pendekatan berbeda dalam mencapai konsensus, keamanan, dan skalabilitas pada jaringan terdesentralisasi (Savadatti dkk., 2025).

Karakteristik utama DLT meliputi replikasi data pada banyak *node*, ketahanan terhadap perubahan data melalui mekanisme kriptografi, serta kemampuan

verifikasi oleh partisipan jaringan. Karakteristik tersebut membuat DLT banyak digunakan sebagai infrastruktur untuk pencatatan transaksi, penyimpanan referensi data, dan eksekusi aturan terprogram melalui *smart contract* (Savadatti dkk., 2025). Dalam konteks sistem rekam medis elektronik terdesentralisasi, DLT dapat digunakan untuk mendukung pencatatan data yang dapat diverifikasi tanpa menempatkan seluruh kendali pada satu pihak terpusat.

II.2.2 IOTA

IOTA merupakan salah satu implementasi DLT yang dirancang untuk mendukung transaksi pada lingkungan terdesentralisasi, khususnya pada skenario yang membutuhkan skalabilitas tinggi dan biaya transaksi rendah. Berbeda dari *blockchain* konvensional, IOTA menggunakan struktur DAG yang dikenal sebagai *Tangle* sebagai dasar buku besar terdistribusinya (Sedi Nzakuna dkk., 2025). Pada perkembangannya, IOTA mengalami perubahan arsitektur melalui IOTA Rebased. Perubahan ini bertujuan meningkatkan skalabilitas, desentralisasi, dan kemampuan ekosistem IOTA untuk mendukung aplikasi terdesentralisasi, termasuk penggunaan *smart contract* (Sedi Nzakuna dkk., 2025). IOTA menggunakan *Move smart contract* untuk berinteraksi dengan data dan melakukan transaksi.

II.3 InterPlanetary File System (IPFS)

IPFS adalah sebuah protokol *peer-to-peer* dan sistem *file* terdistribusi yang dirancang untuk menyimpan dan membagikan data secara desentralisasi (Benet, 2014). Berbeda dengan sistem penyimpanan tradisional yang bergantung pada *server* pusat, IPFS membangun jaringan global dengan setiap pengguna (*node*) dapat berperan sebagai penyimpan dan penyedia konten. Teknologi ini menggunakan *content addressing* daripada *location addressing*, sehingga setiap *file* diidentifikasi dengan unik berdasarkan hash kriptografi dari konten tersebut. Dengan pendekatan desentralisasi ini, IPFS menawarkan solusi yang lebih tahan terhadap sensor, lebih andal, dan tidak bergantung pada satu titik kegagalan pusat.

IPFS beroperasi melalui mekanisme yang mengintegrasikan beberapa komponen kunci. Pertama, menggunakan *Distributed Hash Table* (DHT) yang memungkinkan setiap *file* diberi identitas unik berdasarkan hash konten (*Content Identifier/CID*),

memungkinkan *file* diakses dari *node* terdekat yang menyimpannya daripada harus mengakses *server* pusat yang jauh. Kedua, IPFS menerapkan penyimpanan terdistribusi dengan membagi *file* ke dalam blok-blok kecil yang tersebar di berbagai *node* dalam jaringan, sehingga meningkatkan kecepatan akses dan ketahanan terhadap kegagalan. Ketiga, teknologi ini menggunakan sistem *caching* lokal pada setiap *node* yang menyimpan salinan konten yang sering diakses, memungkinkan akses lebih cepat tanpa perlu mengunduh ulang dari internet. Keempat, IPFS menggunakan protokol komunikasi *peer-to-peer* yang memungkinkan setiap *node* bertindak sebagai klien, *server*, atau *node* perantara, sehingga memfasilitasi komunikasi langsung antar *node* tanpa perantara *server* pusat (Benet, 2014).

II.4 *Proxy Re-Encryption (PRE)*

Proxy Re-Encryption adalah skema kriptografi yang memungkinkan pihak ketiga (disebut proxy) mengubah suatu *ciphertext* yang awalnya dienkripsi untuk satu pengguna menjadi *ciphertext* baru yang bisa didekripsi oleh pengguna lain, tanpa pernah membuka *plaintext* dan tanpa memegang kunci privat kedua pihak. Teknik ini dipakai untuk mendelegasikan hak dekripsi secara aman, misalnya pada skenario berbagi data terenkripsi di *cloud*. PRE pertama kali diperkenalkan oleh Blaze et al. (Blaze dkk., 1998) sebagai solusi untuk mendelegasikan hak dekripsi secara aman.

Gambaran simulasi dari PRE dapat dilihat pada Gambar II.1. Dalam PRE, pemilik data (misalnya Alice) mengenkripsi datanya dengan kunci publik miliknya dan menyimpannya di server atau cloud. Ketika Alice ingin memberi akses ke Bob, ia membuat *re-encryption key* dari kunci miliknya dan kunci Bob, lalu memberikannya ke proxy agar proxy bisa mengubah *ciphertext* milik Alice menjadi *ciphertext* yang dapat didekripsi Bob, tanpa pernah melihat isi datanya.

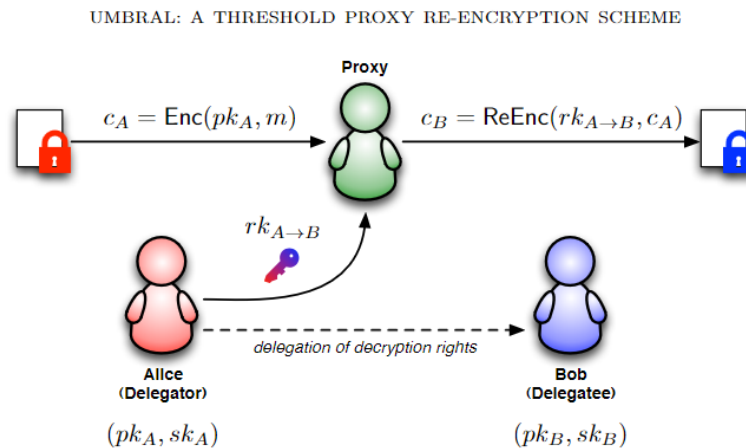
II.4.1 **Umbral PRE**

Umbral adalah skema *threshold proxy re-encryption* yang memungkinkan pemilik data mendelegasikan hak dekripsi kepada penerima akses melalui satu atau beberapa proxy *semi-trusted* (Nuñez, 2017). Dalam Umbral, pihak yang memberikan akses disebut *delegator*, pihak yang menerima akses disebut *delegatee*,

sedangkan proxy bertugas melakukan re-enkripsi tanpa mengetahui isi data. Berbeda dengan PRE sederhana yang dapat menggunakan satu *re-encryption key*, Umbral membagi kemampuan re-enkripsi ke dalam beberapa *key fragments* atau kfrag. Dengan pendekatan ini, proses re-enkripsi dapat dibuat berbasis ambang batas, misalnya minimal t dari total n fragmen harus digunakan agar akses dekripsi dapat berhasil.

Pada tahap awal, data dienkripsi menggunakan kunci publik milik *delegator*. Hasil enkripsi pada Umbral terdiri atas *ciphertext* dan *capsule*. *Ciphertext* berisi data terenkripsi, sedangkan *capsule* memuat informasi kriptografis yang diperlukan untuk membuka kunci enkripsi data. Ketika *delegator* ingin memberi akses kepada *delegatee*, *delegator* membuat sejumlah kfrag berdasarkan kunci privat miliknya, kunci publik milik *delegatee*, dan parameter ambang batas yang ditentukan. Fragmen tersebut kemudian diberikan kepada proxy agar proxy dapat melakukan re-enkripsi terhadap *capsule*.

Ketika *delegatee* ingin mengakses data, *delegatee* mengambil *ciphertext* dan *capsule*, lalu meminta proxy menghasilkan *capsule fragment* atau cfrag dari kfrag yang dimiliki proxy. Proxy hanya melakukan transformasi kriptografis terhadap *capsule*; proxy tidak mendekripsi *ciphertext*, tidak mengetahui *plaintext*, dan tidak membutuhkan kunci privat *delegator* maupun *delegatee*. Setelah *delegatee* memperoleh jumlah cfrag valid yang memenuhi ambang batas t , *delegatee* dapat membuka *capsule* menggunakan kunci privatnya, memperoleh kunci simetris, lalu mendekripsi *ciphertext*. Dengan demikian, Umbral memungkinkan delegasi hak



Gambar II.1: Gambaran simulasi dari PRE (Nuñez, 2017)

dekripsi tanpa membagikan kunci privat dan tanpa memberikan akses langsung terhadap isi data kepada proxy.

II.5 Kontrol Akses

II.5.1 Definisi Kontrol Akses

Kontrol Akses adalah proses pengaturan akses ke sumber daya (data, sistem informasi, perangkat, atau area tertentu) (Li dkk., 2022; Sandhu & Samarati, 1994). Proses ini memutuskan apakah seorang subjek harus diberikan atau ditolak aksesnya berdasarkan aturan tertentu. Akses dapat berarti memakai, memasuki, atau menggunakan. Kontrol Akses bertujuan untuk mencegah aktivitas yang dapat menimbulkan pelanggaran keamanan seperti kebocoran data atau modifikasi tidak sah.

II.5.2 Kontrol Akses Granular

Kontrol akses granular atau *fine-grained access control* adalah pendekatan kontrol akses yang memungkinkan keputusan otorisasi dilakukan pada tingkat cakupan yang lebih spesifik dibandingkan pemberian izin secara umum atau menyeluruh. Jika kontrol akses kasar (*coarse-grained access control*) hanya membedakan akses berdasarkan kategori besar, seperti *role* pengguna atau jenis akses, maka kontrol akses granular mempertimbangkan detail yang lebih banyak, seperti akses berdasarkan pengguna, per baris/kolom data, konteks ketika melakukan akses, waktu berlaku, dan batasan tambahan lain yang relevan dengan kebijakan sistem (Hu dkk., 2014; Odugu & Rajesh, 2021).

Sebuah mekanisme kontrol akses dapat disebut granular apabila sistem mampu membedakan hak akses berdasarkan beberapa dimensi otorisasi secara lebih spesifik. Dimensi tersebut meliputi: (1) subjek yang meminta akses, misalnya identitas pengguna, peran, atau atribut; (2) objek atau sumber daya yang diakses, misalnya pengguna tertentu, sumber data tertentu, *dataset* tertentu, atau bagian tertentu dari data; (3) operasi yang dilakukan, misalnya membaca, menulis, memperbarui, mendelegasikan, dan menghapus; dan (4) kondisi atau konteks akses, misalnya waktu berlaku, tujuan akses, lokasi, atau kondisi layanan tertentu (Hu

dkk., 2014).

Granularitas dalam kontrol akses juga berkaitan erat dengan prinsip *least privilege*, yaitu pemberian hak akses sebatas yang diperlukan untuk menjalankan tugas tertentu (Joint Task Force Transformation Initiative, 2020). Dengan pendekatan ini, pengguna tidak langsung memperoleh akses penuh terhadap seluruh sumber daya hanya karena memiliki peran tertentu. Sebagai contoh, tenaga medis tidak cukup hanya diberi akses berdasarkan peran umum sebagai “dokter”, melainkan aksesnya dapat dibatasi hanya pada pasien tertentu, episode layanan tertentu, data tertentu, dan operasi tertentu yang sesuai dengan kebutuhan tugasnya. Dengan demikian, kontrol akses granular dapat mengurangi risiko akses berlebihan dan membatasi dampak apabila kredensial atau token akses disalahgunakan.

Pada Tugas Akhir ini, perluasan kontrol akses dimaknai sebagai penerapan model kebijakan yang memperluas batasan akses dari *role* dan *purpose* menjadi kombinasi antara subjek, objek data, jenis operasi, waktu berlaku, kondisi akses, dan batasan delegasi.

II.5.3 Model CapBAC

Capability-Based Access Control (CapBAC) adalah model kontrol akses yang hak aksesnya direpresentasikan sebagai “*capability token*” yang tidak dapat dipalsukan (Anagnostopoulou dkk., 2025; Li dkk., 2022). Token tersebut menyatakan otoritas untuk melakukan operasi tertentu terhadap objek atau sumber daya tertentu. Dalam implementasi tertentu, *capability token* juga dapat dibatasi dengan identitas subjek, waktu berlaku, cakupan operasi, atau kondisi tambahan lain untuk mempersempit hak akses yang diberikan.

Secara garis besar, model CapBAC bekerja dalam 2 tahapan, (1) Pengguna meminta *capability token* dari sebuah *Authorization Server*, kemudian (2) Pengguna menggunakan *capability token* yang diperoleh dari tahap pertama untuk melakukan akses ke *Resource Server* (Li dkk., 2022). *Sequence diagram* dari model CapBAC dapat dilihat pada Gambar II.2. CapBAC memungkinkan otorisasi terdesentralisasi karena mengandalkan token kapabilitas yang tidak dapat dipalsukan sebagai bukti.

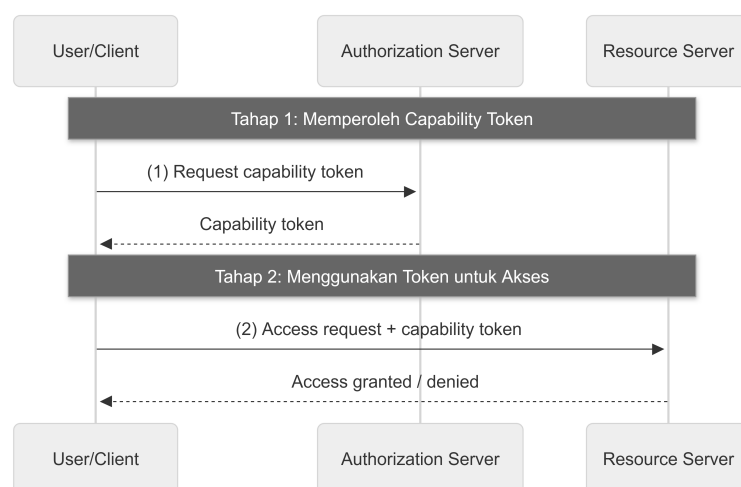
II.5.4 Policy-Based Access Control

Policy-Based Access Control (PBAC) merupakan pendekatan kontrol akses yang menentukan keputusan otorisasi berdasarkan sekumpulan kebijakan eksplisit (Ferraiolo dkk., 2015). PBAC tidak selalu diposisikan sebagai model yang sepenuhnya terpisah dari *Role-Based Access Control* (RBAC) atau *Attribute-Based Access Control* (ABAC). Peran dan atribut dapat digunakan sebagai bagian dari pertimbangan kebijakan dalam PBAC. Perbedaannya terletak pada cara keputusan akses dirumuskan. Pada RBAC, hak akses terutama diperoleh berdasarkan peran pengguna, sedangkan pada PBAC keputusan akses ditentukan melalui evaluasi aturan kebijakan yang dapat menggabungkan peran, atribut, konteks, tujuan, dan batasan lainnya. Oleh karena itu, PBAC dapat digunakan untuk membentuk kontrol akses yang lebih kontekstual dan granular dibandingkan penggunaan peran secara tunggal.

Secara umum, suatu kebijakan akses dalam PBAC melibatkan elemen-elemen berikut (Ferraiolo dkk., 2015).

1. **Subjek** Subjek merupakan entitas yang mengajukan permintaan akses, seperti pengguna, aplikasi, atau layanan.
2. **Sumber daya**

Sumber daya merupakan objek yang akan diakses. Sumber daya dapat dikelompokkan berdasarkan kategori, pemilik, tingkat sensitivitas, atau



Gambar II.2: *Sequence diagram* dari model CapBAC. (Dokumentasi penulis)

fungsi data.

3. Tindakan

Tindakan menyatakan operasi yang akan dilakukan terhadap sumber daya, seperti *read* atau *write*.

4. Konteks

Konteks merupakan kondisi tambahan ketika permintaan akses dilakukan.

5. Tujuan penggunaan

Tujuan penggunaan menjelaskan alasan suatu data diakses. Dua *request* dari subjek yang sama terhadap sumber daya yang sama dapat menghasilkan keputusan berbeda apabila memiliki tujuan penggunaan yang berbeda.

6. Keputusan dan kewajiban

Hasil evaluasi kebijakan umumnya berupa keputusan *permit* atau *deny*. Kebijakan juga dapat menetapkan kewajiban yang harus dijalankan ketika akses diberikan.

Berdasarkan elemen-elemen tersebut, suatu permintaan akses dapat direpresentasikan sebagai:

$$q = \langle s, r, a, c, p \rangle, \quad (\text{II.1})$$

dengan s sebagai subjek, r sebagai sumber daya, a sebagai tindakan, c sebagai konteks, dan p sebagai tujuan penggunaan. Keputusan akses diberikan dengan mengevaluasi permintaan tersebut terhadap seluruh kebijakan yang berlaku. Secara sederhana, keputusan akses dapat dinyatakan sebagai:

$$\text{Decision}(q) = \begin{cases} \text{Permit,} & \text{jika seluruh kondisi kebijakan yang berlaku terpenuhi,} \\ \text{Deny,} & \text{jika terdapat kondisi wajib yang tidak terpenuhi.} \end{cases} \quad (\text{II.2})$$

Penerapan PBAC terdiri atas beberapa proses utama. Pertama, kebijakan didefinisikan dengan menentukan subjek, sumber daya, tindakan, dan kondisi

yang diizinkan. Kedua, sistem membentuk konteks permintaan akses berdasarkan identitas pengguna dan sumber daya yang diminta. Ketiga, permintaan tersebut dievaluasi terhadap kebijakan yang berlaku untuk menghasilkan keputusan akses. Terakhir, keputusan tersebut ditegakkan pada sumber daya yang dilindungi serta dapat dicatat sebagai bagian dari proses audit.

Policy Machine merupakan salah satu kerangka formal yang dapat digunakan untuk merepresentasikan kebijakan melalui elemen kebijakan, hubungan penugasan, dan asosiasi antar elemen. Kerangka tersebut dapat mendukung berbagai pola kebijakan, termasuk kebijakan berbasis peran, atribut, atau tujuan penggunaan (Ferraiolo dkk., 2015). Namun, *Policy Machine* bukan satu-satunya bentuk PBAC. PBAC dapat diimplementasikan menggunakan berbagai cara, selama keputusan akses tetap didasarkan pada evaluasi kebijakan yang telah ditetapkan.

II.6 Token Otorisasi

II.6.1 JSON Web Token

JSON Web Token (JWT) adalah format token yang ringkas dan *URL-safe* untuk merepresentasikan klaim yang dipertukarkan antara dua pihak (M. B. Jones dkk., 2015). Klaim pada JWT direpresentasikan dalam bentuk objek JSON dan dapat diamankan menggunakan JSON Web Signature (JWS) atau JSON Web Encryption (JWE). Dengan demikian, JWT dapat digunakan untuk membawa informasi seperti identitas pengguna, peran, cakupan akses, waktu penerbitan, dan waktu kedaluwarsa token.

Secara umum, JWT terdiri dari tiga bagian utama, yaitu *header*, *payload*, dan *signature*. Ketiga bagian tersebut dikodekan menggunakan Base64URL dan dipisahkan dengan tanda titik. Bentuk umum JWT dapat dituliskan sebagai berikut:

$$JWT = header.payload.signature$$

Bagian *header* berisi informasi mengenai tipe token dan algoritma kriptografi yang digunakan. Bagian *payload* berisi klaim yang menyatakan informasi mengenai subjek atau hak akses. Bagian *signature* digunakan untuk memastikan integritas

token sehingga perubahan pada *header* atau *payload* dapat terdeteksi oleh pihak yang memverifikasi token.

II.6.2 PASETO

PASETO atau *Platform-Agnostic Security Tokens* adalah format token yang dirancang sebagai alternatif terhadap JWT dengan pendekatan kriptografi yang lebih terarah (Arciszewski & Haussmann, 2022). Seperti JWT, PASETO digunakan untuk merepresentasikan klaim dalam bentuk token yang ringkas dan dapat dipertukarkan antar pihak. Namun, PASETO membatasi pilihan algoritma kriptografi berdasarkan versi dan tujuan penggunaan token, sehingga mengurangi risiko kesalahan konfigurasi algoritma yang dapat terjadi pada token berbasis JWT.

Secara umum, token PASETO P dapat direpresentasikan sebagai:

$$P = \text{version.purpose.message}[\text{.footer}]$$

version menunjukkan versi PASETO, *purpose* menunjukkan tujuan penggunaan token, *message* adalah *payload* yang telah diproses secara kriptografis, dan *footer* adalah *footer* opsional. Nilai *purpose* dapat berupa *local* atau *public*. Nilai *local* digunakan ketika isi token perlu dienkripsi menggunakan kunci simetris, sedangkan nilai *public* digunakan ketika token perlu ditandatangani menggunakan kriptografi kunci publik.

Keunggulan PASETO terletak pada desainnya yang lebih *opinionated* dibandingkan JWT, terutama dalam pemilihan algoritma kriptografi. Dengan membatasi pilihan algoritma, PASETO berupaya mengurangi fleksibilitas yang berpotensi menimbulkan kesalahan implementasi. Namun, dari sisi model otorisasi, PASETO tetap berperan sebagai token pembawa klaim. Artinya, pembatasan akses seperti peran, cakupan, dan waktu berlaku tetap perlu didefinisikan pada saat token diterbitkan.

II.6.3 Macaroons

Macaroon adalah *credential* otorisasi berbasis *bearer* yang mendukung delegasi terdesentralisasi dalam sistem terdistribusi (Birgisson dkk., 2014). Keunggulan

utama Macaroon terletak pada penggunaan *chained-HMAC*, yang memungkinkan proses delegasi bersifat terdesentralisasi secara efisien serta mendukung penambahan syarat *caveat* yang sesuai dengan konteks penggunaan.

Sebuah Macaroon M didefinisikan dengan struktur:

$$M = (id, location, \vec{c}, sig)$$

id adalah pengidentifikasi unik, $location$ adalah alamat layanan target, $\vec{c} = (c_1, c_2, \dots, c_n)$ adalah daftar *caveat*, dan sig adalah tanda tangan (Birgisson dkk., 2014). Tanda tangan (sig) dihitung secara rekursif untuk menjamin integritas setiap penambahan batasan (*caveat*):

$$sig_0 = \text{HMAC}(\text{RootKey}, id)$$

$$sig_n = \text{HMAC}(sig_{n-1}, c_n)$$

RootKey adalah kunci rahasia yang digunakan untuk membangkitkan token Macaroon awal. Struktur ini memungkinkan pemegang Macaroon menambahkan *caveat* baru c_{new} (misalnya: $\text{time} < 24\text{h}$) dan menghasilkan sig_{new} untuk diberikan ke pihak lain, tanpa mengetahui *RootKey* yang asli. Kemampuan untuk menambahkan batasan baru pada token secara lokal tanpa melibatkan penerbit awal ini disebut dengan *offline attenuation*. Mekanisme ini memungkinkan delegasi terdesentralisasi yang aman dan fleksibel. Gambaran mengenai delegasi dan atenuasi kewenangan melalui *caveats* dapat dilihat pada Gambar II.3.

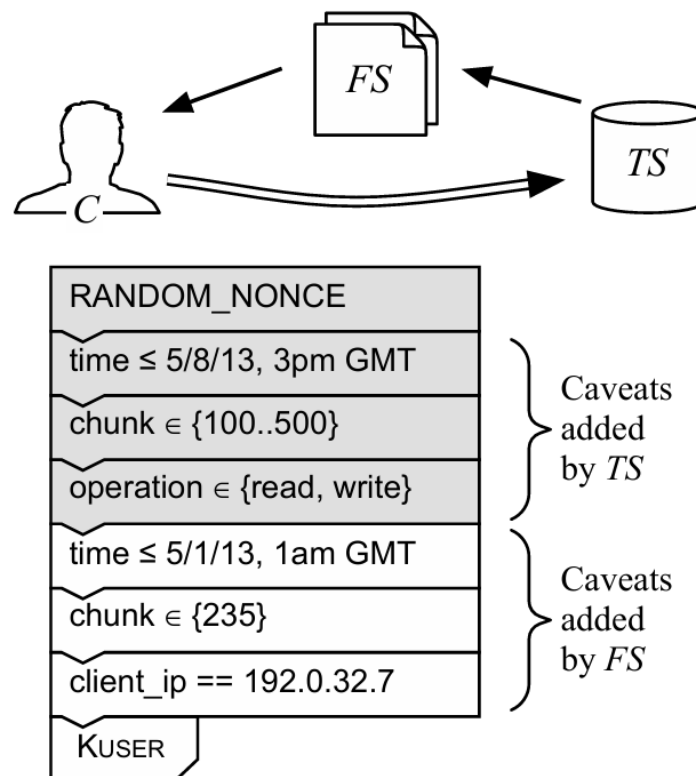
II.6.4 Biscuit Token

Biscuit adalah token otorisasi yang dirancang untuk mendukung verifikasi terdesentralisasi, atenuasi *offline*, dan penegakan kebijakan akses berbasis *logic language* (Eclipse Biscuit Project, nodate). Berbeda dari JWT dan PASETO yang berperan sebagai pembawa klaim, Biscuit dirancang sebagai token otorisasi berbasis *capability*. Token ini memungkinkan suatu layanan memverifikasi hak akses menggunakan informasi publik, sehingga cocok untuk lingkungan

terdistribusi.

Biscuit menggunakan kriptografi kunci publik untuk memungkinkan verifikasi token oleh pihak yang memiliki kunci publik dari penerbit token. Biscuit mendukung atenuasi hak akses melalui penambahan blok baru pada token. Pemegang token dapat menambahkan batasan baru untuk mempersempit hak akses sebelum token diberikan ke pihak lain.

Karakteristik utama Biscuit adalah penggunaan *logic language* untuk mengekspresikan *rule*. Informasi otorisasi dapat direpresentasikan dalam bentuk *fact*, *rule*, dan *check*. Pada saat token digunakan, pihak *verifier* dapat mengevaluasi token bersama dengan kebijakan lokal untuk menentukan apakah suatu permintaan akses diperbolehkan. Pendekatan ini membuat Biscuit lebih ekspresif dalam memodelkan kebijakan akses yang kompleks, misalnya kebijakan berbasis relasi antar aktor, sumber daya, aksi, dan konteks permintaan.



Gambar II.3: Contoh delegasi dan atenuasi kewenangan pada Macaroon. C memegang Macaroon yang diturunkan dari *service* FS untuk mengakses data pada *service* TS dengan batasan waktu, lokasi IP, dan target data yang spesifik. (Birgisson dkk., 2014)

Tabel II.1: Komponen dan fungsi dalam arsitektur DecMed

Komponen	Fungsi
IOTA DLT	Menyimpan metadata, referensi data, dan status akses
IPFS	Menyimpan <i>encrypted blob</i> data RME
PRE	Melakukan verifikasi token akses dan <i>re-encryption</i> agar penerima akses dapat membuka data tanpa kunci privat pasien
Redis	Mengelola <i>cache ephemeral</i> , yang terdiri dari data Nonce, Re-Encryption Key, dan Revoked Key
<i>Patient Client</i>	Mengambil, mendekripsi, dan memberi akses
<i>Hospital Client</i>	Mengambil, menenkripsi, dan mendekripsi data RME sesuai hak akses
<i>Ministry Client</i>	Mengelola fasyankes dan adminnya
<i>IOTA Gas Station</i>	Mensponsori transaksi <i>on-chain</i> agar pengguna tidak perlu membayar <i>gas</i> secara langsung

Tabel II.2: Aktor, *client*, dan peran dalam DecMed

Aktor	<i>Client</i>	Peran dalam DecMed
Pasien	<i>Patient Client</i>	Mengelola identitas, menyimpan atau memperbarui data, dan memberikan akses kepada tenaga medis
Tenaga kesehatan / fasyankes	<i>Hospital Client</i>	Mengakses atau memperbarui RME sesuai akses yang diberikan pasien
Pemerintah	<i>Ministry Client</i>	Mengelola registrasi atau verifikasi fasyankes dalam sistem

Akhir ini, komponen *Gas Station IOTA* akan diasumsikan sebagai bagian dari IOTA.

II.7.2 Alur Pengelolaan dan Akses RME pada DecMed

Alur pengelolaan RME pada DecMed dimulai ketika data medis dibuat melalui aplikasi *hospital client*. Data tersebut dienkripsi terlebih dahulu di sisi *client* sebelum disimpan pada IPFS. Setelah data terenkripsi berhasil diunggah, IPFS menghasilkan CID sebagai referensi lokasi data. CID, *capsule key*, dan metadata pendukung kemudian dicatat pada DLT IOTA. Dengan demikian, IOTA tidak menyimpan isi rekam medis secara langsung, melainkan menyimpan metadata yang diperlukan untuk menemukan, memverifikasi, dan membuka data terenkripsi melalui mekanisme PRE.

Ketika pasien memberikan akses kepada tenaga medis, PRE menerbitkan token kapabilitas yang digunakan sebagai bukti otorisasi. Tenaga medis membawa

Tabel II.3: Kategori ancaman pada STRIDE

Kategori	Fokus Keamanan	Deskripsi Singkat
<i>Spoofing</i>	Otentikasi	Pemalsuan identitas entitas untuk memperoleh akses tidak sah.
<i>Tampering</i>	Integritas	Modifikasi data, pesan, atau kode secara tidak sah.
<i>Repudiation</i>	<i>Non-repudiation</i>	Penyangkalan terhadap tindakan atau transaksi karena kurangnya bukti audit.
<i>Information Disclosure</i>	Kerahasiaan	Kebocoran informasi sensitif kepada pihak yang tidak berhak.
<i>Denial of Service</i>	Ketersediaan	Gangguan terhadap ketersediaan layanan atau sumber daya sistem.
<i>Elevation of Privilege</i>	Otorisasi	Perolehan hak akses yang lebih tinggi dari yang seharusnya.

token tersebut ketika meminta akses data melalui *Hospital Client*. *Server PRE* kemudian memverifikasi token, melakukan *re-encryption* terhadap *capsule key*, dan mengembalikan material kriptografis yang diperlukan agar *Hospital Client* dapat membuka data terenkripsi sesuai hak akses yang diberikan. *Sequence Diagram* yang menjelaskan alur pemberian akses dapat dilihat pada Lampiran B

II.8 Pemodelan Ancaman STRIDE

STRIDE merupakan metode *threat modeling* yang dikembangkan oleh Microsoft untuk membantu mengidentifikasi ancaman keamanan pada sistem perangkat lunak sejak tahap perancangan. Metode ini mengelompokkan ancaman ke dalam enam kategori utama, yaitu *Spoofing*, *Tampering*, *Repudiation*, *Information Disclosure*, *Denial of Service*, dan *Elevation of Privilege* (Microsoft, 2006; Shostack, 2014).

Dalam praktiknya, STRIDE biasanya digunakan bersama *Data Flow Diagram* (DFD) untuk memetakan kemungkinan ancaman terhadap komponen sistem, aliran data, penyimpanan data, dan batas kepercayaan (*trust boundary*) (Shostack, 2014). Pendekatan ini membantu perancang sistem mengidentifikasi kebutuhan kontrol keamanan seperti otentikasi, otorisasi, enkripsi, integritas data, dan *audit logging* sejak tahap desain (Shostack, 2014).

Tabel II.3 merangkum enam kategori ancaman pada STRIDE beserta fokus keamanan yang terkait.

Melalui STRIDE, pengembang dapat mengidentifikasi ancaman keamanan secara sistematis serta menentukan kontrol mitigasi yang sesuai pada tahap perancangan sistem (Shostack, 2014).

II.9 Penelitian Terkait

Bagian ini meninjau beberapa penelitian yang relevan dengan perancangan kontrol akses berbasis kebijakan pada sistem RME berbasis DLT serta representasi kapabilitas menggunakan Macaroons.

II.9.1 Hybrid RBAC dan ABAC pada Sistem RME Berbasis Blockchain

Singh dkk. mengusulkan model kontrol akses hibrida untuk sistem RME berbasis Blockchain dengan menggabungkan RBAC dan ABAC (Singh dkk., 2025). Penelitian ini berangkat dari keterbatasan dua model tersebut ketika digunakan secara terpisah. RBAC dinilai terlalu kaku karena keputusan akses hanya bergantung pada peran pengguna. Pendekatan ini menyulitkan penerapan kontrol akses yang *fine-grained* dan berpotensi menimbulkan *role explosion* ketika kebutuhan akses semakin beragam. Di sisi lain, ABAC menawarkan fleksibilitas yang lebih tinggi karena keputusan akses mempertimbangkan atribut pengguna, objek, dan konteks, namun kompleksitas perancangan dan pengelolaan kebijakannya juga meningkat.

Penelitian tersebut menunjukkan bahwa semakin banyak atribut yang digunakan dalam ABAC, semakin besar pula kemungkinan konflik kebijakan dan beban evaluasi aturan (Singh dkk., 2025). Oleh karena itu, penulis mengusulkan pendekatan *hybrid*, yaitu RBAC digunakan sebagai lapisan awal untuk menyaring akses berdasarkan peran utama, sedangkan ABAC digunakan untuk menambahkan batasan kontekstual yang lebih rinci. Hasil evaluasi pada *smart contract* menunjukkan bahwa pendekatan *hybrid* ini cukup efisien dari sisi konsumsi *gas* dan tetap relatif sederhana untuk diimplementasikan dibandingkan penggunaan ABAC murni.

II.9.2 Model Kontrol Akses Empat Lapis untuk RME Berbasis Blockchain

Liu dan Chen meneliti model kontrol akses untuk RME berbasis Blockchain dengan menempatkan RME sebagai kasus *big data* (Liu & Chen, 2025). Peran DLT dalam mengatasi masalah tersebut relevan untuk menjelaskan mengapa pendekatan DLT layak dipertimbangkan sebagai alternatif terhadap sistem RME terpusat, karena DLT menawarkan integritas data yang lebih kuat, jejak audit yang transparan, dan distribusi kendali yang lebih baik.

Untuk menjawab permasalahan tersebut, penelitian ini mengusulkan model otorisasi empat lapis yang terdiri dari:

1. *Role Check* menggunakan RBAC,
2. *Identity Verification* menggunakan *Identity-Based Encryption* (IBE),
3. *Policy Execution* menggunakan *smart contract*, dan
4. *Data Volume Check* menggunakan pendekatan *entropy*.

II.9.3 Kontrol Akses Granular Menggunakan *Composable NFT*

Amaracitra mengusulkan model *Decentralized Medical Record* (DMR) yang menggunakan *composable NFT* untuk mencapai keamanan data, interoperabilitas, dan privasi melalui akses data yang granular (Amaracitra & Alamsyah, 2025). Nilai utama dari penelitian ini terletak pada cara data RME dipecah menjadi unit-unit yang lebih kecil, sehingga tidak seluruh data pasien harus selalu dibuka dalam satu paket akses.

Dalam model tersebut, struktur data DMR disusun secara hierarkis ke dalam beberapa token, yaitu:

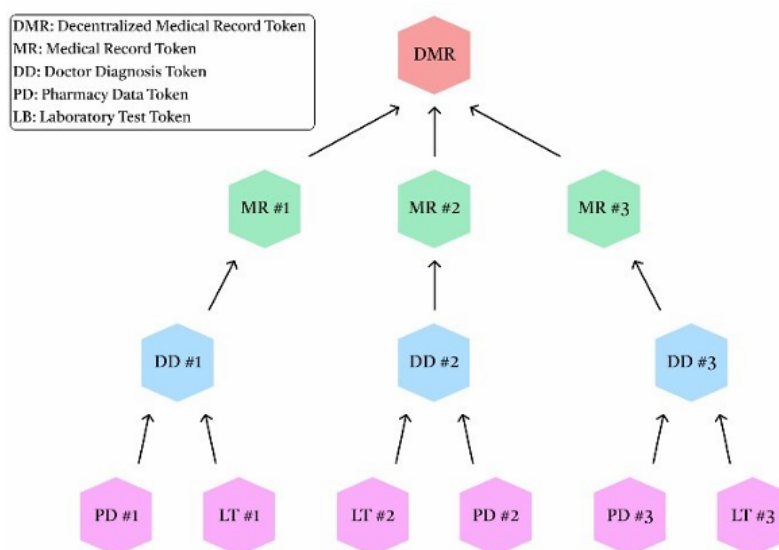
1. *DMR Token* sebagai token induk (*root/parent*),
2. *Medical Record Token*,
3. *Doctor Diagnoses Token*,
4. *Laboratory Test Token*, dan
5. *Pharmacy Data Token*.

Ilustrasi struktur data dari implementasi DMR menggunakan composable NFT ini dapat dilihat pada Gambar II.5.

Pemisahan ini penting karena menunjukkan bahwa granularitas akses tidak hanya bergantung pada mekanisme otorisasi, tetapi juga pada cara data medis dimodelkan sejak awal (Amaracitra & Alamsyah, 2025). Dengan struktur seperti ini, akses dapat diberikan hanya pada bagian data yang relevan dengan kebutuhan tenaga kesehatan tertentu. Misalnya, tenaga laboratorium dapat berinteraksi dengan data pemeriksaan laboratorium tanpa harus memperoleh akses ke keseluruhan rekam medis pasien.

II.9.4 Implementasi Macaroons untuk Delegasi Akses pada Sistem Nyata

Selain diperkenalkan secara teoretis sebagai mekanisme otorisasi berbasis *caveats*, Macaroons juga telah digunakan pada beberapa sistem penyimpanan terdistribusi. Salah satu contohnya adalah Storj, yaitu platform penyimpanan objek terdesentralisasi yang menggunakan Macaroons sebagai dasar pengelolaan akses pada jaringan Tardigrade (Leffew, 2019). Dalam implementasi tersebut, Macaroons diposisikan sebagai *API key* yang berisi aturan akses yang melekat pada token tersebut. Aturan tersebut dapat membatasi operasi yang diperbolehkan, seperti *read*, *write*, *delete*, dan *list*, serta membatasi ruang lingkup akses berdasarkan *bucket*, *path*, *path prefix*, dan jendela waktu akses. Dengan demikian, pengguna dapat



Gambar II.5: Ilustrasi struktur data DMR menggunakan composable NFT. (Amaracitra & Alamsyah, 2025)

membagikan akses terhadap objek data tertentu tanpa memberikan akses penuh terhadap seluruh akun atau seluruh ruang penyimpanan.

Penerapan Macaroons pada Storj menunjukkan bahwa token otorisasi tersebut dapat digunakan pada lingkungan penyimpanan terdesentralisasi. Otoritas akses dibawa oleh token yang secara eksplisit memuat cakupan hak aksesnya. Token tersebut kemudian dapat diturunkan menjadi token dengan cakupan yang lebih sempit melalui penambahan *caveats*.

Contoh implementasi lain dapat ditemukan pada dCache, yaitu sistem penyimpanan data ilmiah berskala besar yang mendukung Macaroons sebagai *bearer token* (dCache, nodate). Dalam dCache, Macaroons dirancang untuk mempermudah proses berbagi akses terhadap file atau direktori tertentu. Pengguna yang memiliki akses terhadap suatu *resource* dapat meminta Macaroon, kemudian token tersebut dapat digunakan oleh pihak lain untuk mengakses sumber daya yang sama sesuai batasan yang tertanam di dalam token. dCache mendefinisikan beberapa *caveats* yang merepresentasikan batasan akses, seperti *activity* untuk menentukan aktivitas yang diizinkan, *before* untuk membatasi masa berlaku token, *ip* untuk membatasi alamat jaringan pengguna, serta *path* dan *root* untuk membatasi ruang lingkup akses pada struktur direktori.

Implementasi dCache juga menunjukkan bahwa beberapa *caveats* dapat dikombinasikan untuk menghasilkan hak akses yang lebih terbatas. Sebagai contoh, beberapa *activity* caveat digabungkan dengan mengambil irisan dari aktivitas yang diizinkan, sehingga penambahan *caveat* baru tidak memperluas hak akses token, melainkan mempersempitnya. Selain itu, pengguna yang telah memiliki Macaroon dapat membuat Macaroon baru dengan tambahan *caveats*, baik secara mandiri menggunakan pustaka Macaroons maupun melalui permintaan ke dCache. Mekanisme ini memperlihatkan pola delegasi akses yang sesuai dengan prinsip atenuasi, yaitu token turunan tidak dapat memiliki hak akses yang lebih besar daripada token asal.

Dari kedua implementasi tersebut, dapat disimpulkan bahwa Macaroons telah digunakan untuk membatasi dan mendelegasikan akses pada sistem penyimpanan data terdistribusi. Storj menekankan penggunaan Macaroons untuk pengelolaan akses objek data pada jaringan penyimpanan terdesentralisasi, sedangkan dCache

menunjukkan bagaimana *caveats* dapat digunakan untuk membatasi aktivitas, lokasi sumber daya, alamat jaringan, dan masa berlaku akses.

BAB III

ANALISIS DAN RANCANGAN SOLUSI

III.1 Analisis Masalah

Dalam mengembangkan mekanisme kontrol akses berbasis kebijakan dan delegasi pada kerangka kerja DecMed, diperlukan analisis terhadap implementasi dan arsitektur sistem yang sudah ada. Hasil analisis tersebut digunakan sebagai dasar identifikasi permasalahan serta perumusan kebutuhan sistem yang diusulkan pada Tugas Akhir ini.

Analisis masalah pada Tugas Akhir ini diawali dengan analisis terhadap implementasi dan arsitektur DecMed pada Subbab III.1.1, termasuk analisis STRIDE dan skenario layanan kesehatan kolaboratif. Hasil analisis tersebut kemudian digunakan sebagai dasar identifikasi permasalahan pada Subbab III.1.2 dan perumusan kebutuhan sistem pada Subbab III.1.3.

III.1.1 Analisis Sistem DecMed

Sebagaimana dijelaskan pada Bab II.7, DecMed adalah kerangka kerja manajemen RME terdesentralisasi dengan menggunakan DLT IOTA sebagai penyimpanan *on-chain*, IPFS sebagai penyimpanan *off-chain*, serta PRE untuk mendukung distribusi akses data yang aman. Arsitektur ini sudah memberikan fondasi untuk menjaga integritas data dan mengurangi ketergantungan pada penyimpanan terpusat. Terdapat tiga aktor utama pada DecMed, yaitu:

1. Pasien
2. Staf fasyankes, terdiri dari tenaga kesehatan, petugas rekam medis, dan admin fasyankes
3. Pemerintah, yaitu Kementerian Kesehatan

Pada DecMed, masing-masing aktor memiliki kepentingan dan aplikasi *client* yang berbeda. *Patient Client* digunakan oleh pasien, *Hospital Client* digunakan

oleh tenaga kesehatan di sebuah fasyankes, dan *Ministry Client* digunakan oleh pemerintah. Detail kebutuhan fungsional DecMed untuk memenuhi kebutuhan masing-masing aktor dapat dilihat pada Lampiran C.

III.1.1.1 Keterbatasan Token Kapabilitas DecMed

Model kontrol akses yang digunakan pada sistem DecMed adalah model CapBAC. Token otorisasi berupa JWT digunakan sebagai media yang merepresentasikan kapabilitas akses. Pada kerangka kerja DecMed, ketika pasien memberikan akses terhadap RME mereka kepada seorang tenaga medis, maka PRE akan menerbitkan token JWT sesuai dengan *request* dari pasien. Token yang diterbitkan oleh pasien membawa klaim seperti pada Kode III.1. Dalam implementasi DecMed sebelumnya, token JWT masih bersifat *coarse-grained*. Penentuan hak akses pengguna dilakukan hanya berdasarkan *role* dan *purpose* yang ada pada token yang disertakan saat melakukan *request* ke PRE. Token tersebut belum dirancang untuk membawa batasan kontekstual, misalnya jenis data yang boleh diakses. Padahal, pada praktik pelayanan kesehatan, setiap tenaga medis tidak selalu membutuhkan keseluruhan isi RME pasien sesuai dengan prinsip *need-to-know*. Kondisi ini menunjukkan bahwa DecMed belum memiliki model kebijakan akses yang cukup luas untuk menghubungkan aktor, objek RME, hak akses, dan kondisi akses secara terstruktur.

```
1  #[derive(Debug, Deserialize, Serialize)]
2  pub struct JwtClaims {
3      pub address: String, // address IOTA pemegang token
4      pub role: AuthRole, // AdministrativePersonnel
5                          // atau MedicalPersonnel
6      pub purpose: ReencryptionPurposeType, // Read atau Update
7  }
```

Kode III.1: Struktur klaim JWT pada DecMed

Dengan struktur klaim tersebut, DecMed hanya mampu membedakan kategori umum pengguna dan jenis operasi, tanpa mendefinisikan kebijakan akses yang menghubungkan aktor, objek RME, hak akses, dan kondisi secara lebih luas.

III.1.1.2 Keterbatasan Segmentasi Data pada DecMed

Pada kerangka kerja DecMed, data RME pasien disimpan dalam dua sistem penyimpanan yang berbeda, yaitu penyimpanan *on-chain* (IOTA) dan *off-chain* (IPFS). Penyimpanan *on-chain* digunakan untuk menyimpan metadata dan CID dari data yang disimpan di *off-chain*. Penyimpanan *off-chain* digunakan untuk menyimpan data administratif dan klinis yang terenkripsi. Pemisahan ini sesuai dengan kebutuhan yang dibahas pada II.1.2 terkait dokumentasi administratif dan klinis.

Pada penyimpanan *on-chain*, data RME pasien direpresentasikan sebagai metadata dalam sebuah *struct* `MedicalMetadata` untuk data klinis. Metadata tersebut menyimpan CID serta informasi kunci terenkripsi yang digunakan dalam proses dekripsi data medis terkait. Struktur penyimpanannya terikat dengan *struct* `PatientAccount` dan `PatientMedicalMetadata` pada Kode III.2.

```
1 public struct PatientAccount has store {
2     ...
3     medical_metadata: TableVec<PatientMedicalMetadata>,
4 }
5 public struct PatientMedicalMetadata has copy, drop, store {
6     index: u64,
7     metadata: String,
8 }
```

Kode III.2: Struktur metadata medis pasien pada DecMed

Karena *field* `medical_metadata` pada *struct* `PatientAccount` menyimpan daftar metadata klinis pasien, akses terhadap struktur ini memungkinkan sistem memperoleh referensi menuju objek data klinis terenkripsi, seperti CID dan *capsule* untuk PRE. CID dan *capsule* tidak secara langsung membuka isi RME karena data klinis tetap disimpan dalam bentuk terenkripsi. Namun, struktur metadata tersebut menunjukkan bahwa unit akses pada DecMed masih mengarah pada satu objek data klinis yang relatif besar, bukan pada segmen data yang spesifik.

Kondisi tersebut menyulitkan penegakan kebijakan akses yang lebih rinci. Ketika proses *re-encryption* diberikan terhadap objek data klinis tersebut, penerima akses berpotensi memperoleh cakupan *plaintext* yang lebih luas daripada kebutuhan

aktualnya. Hal ini terjadi karena struktur metadata belum menyediakan atribut segmentasi yang cukup untuk membedakan cakupan akses sesuai kebutuhan pelayanan. Variabel metadata pada *struct* PatientMedicalMetadata merupakan serialisasi dari *struct* yang ditunjukkan pada Kode III.3.

```
1  #[derive(Debug, Deserialize, Serialize)]
2  pub struct MedicalMetadata {
3      pub capsule: String, // capsule untuk PRE re-encryption
4      pub cid: String, // pointer ke data di IPFS
5      pub created_at: String, // timestamp
6      pub enc_key_and_nonce: String, // kunci dan nonce yang
7      // terenkripsi
8  }
```

Kode III.3: Struktur serialisasi metadata medis DecMed

cid pada *struct* MedicalMetadata merupakan *pointer* ke data klinis yang sudah terenkripsi disimpan di penyimpanan *off-chain* sebagai sebuah *Encrypted Blob*. Potongan field relevan pada *struct* MedicalData dapat dilihat pada Kode III.4.

```
1  pub struct MedicalData {
2      pub anamnesis: String,
3      pub physical_check: String,
4      pub psychological_check: String,
5      pub diagnose: String,
6      pub therapy: String,
7  }
```

Kode III.4: Potongan struktur data medis *off-chain* pada DecMed

Penyimpanan data klinis pada DecMed hanya berfokus pada dataset rawat jalan. Pada *struct* MedicalData, data klinis masih disimpan dengan format yang sederhana, tanpa kategorisasi yang jelas. DecMed memang sudah memisahkan penyimpanan metadata di *on-chain* dan data klinis di *off-chain*, tetapi pendekatan tersebut belum secara eksplisit menunjukkan segmentasi data klinis yang cukup rinci untuk menegakkan kebijakan akses yang lebih luas. Jika data klinis masih dikelola sebagai objek terenkripsi yang terlalu besar, pemberian akses kepada tenaga medis berisiko membuka data di luar kebutuhan klinisnya. Sebagai contoh,

seorang perawat tidak membutuhkan akses tulis ke data therapy pada *struct* MedicalData karena yang berhak menentukan terapi adalah dokter.

III.1.1.3 Analisis Skenario Layanan Kesehatan Kolaboratif

Kebutuhan akan perluasan kebijakan akses dan delegasi berantai menjadi lebih jelas ketika arsitektur DecMed ditempatkan pada skenario layanan kesehatan yang nyata. Dalam alur pelayanan rumah sakit, pasien tidak hanya berinteraksi dengan satu pihak, tetapi dengan beberapa aktor yang memiliki kebutuhan akses berbeda pada tahap yang berbeda pula sebagaimana dibahas pada Subbab II.1.3. Oleh karena itu, satu skenario layanan kesehatan kolaboratif dimodelkan untuk menunjukkan secara konkret mengapa mekanisme akses pada DecMed saat ini belum memadai.

Skenario yang dianalisis adalah pelayanan pasien rawat jalan dan rawat inap yang melibatkan petugas rekam medis, perawat, dokter penanggung jawab pasien, petugas laboratorium, dan apoteker. Alur tersebut dipilih karena mewakili pola kolaborasi yang umum terjadi di sebuah fasyankes.

1. **Tahap pendaftaran pasien.** Saat pasien datang ke rumah sakit, petugas rekam medis hanya membutuhkan akses terhadap data administratif pasien.
2. **Tahap pemeriksaan awal oleh perawat.** Setelah proses pendaftaran selesai, perawat memerlukan hak untuk menulis data klinis untuk anamnesis awal, pemeriksaan fisik, dan pemeriksaan psikologis.
3. **Tahap pemeriksaan oleh dokter.** Pada tahap ini, dokter penanggung jawab pasien memerlukan hak baca terhadap keseluruhan data RME pasien dan hak tulis untuk pelayanan saat ini.
4. **Tahap rujukan internal ke laboratorium.** Apabila dokter membutuhkan pemeriksaan laboratorium, maka pasien perlu diarahkan ke petugas laboratorium. Dalam tahap ini, petugas laboratorium hanya membutuhkan akses terhadap data administratif pasien dan permintaan pemeriksaan laboratorium.
5. **Tahap tindak lanjut hasil pemeriksaan.** Setelah hasil laboratorium tersedia, dokter kembali menggunakan data tersebut sebagai bahan pengambilan keputusan klinis.

Tabel III.1: Pemetaan Aktor dan Kebutuhan Akses pada Skenario Layanan Kesehatan Kolaboratif

Aktor	Jenis Akses	Cakupan Data yang Dibutuhkan
Petugas Rekam Medis	Baca data administratif	Data administratif pasien.
Perawat	Baca dan tulis data klinis (hanya pemeriksaan awal)	Baca data administratif pasien. Tulis data anamnesis awal, pemeriksaan fisik, dan pemeriksaan psikologis.
Dokter	Baca dan tulis data klinis	Baca keseluruhan RME pasien. Tulis data sesuai konteks pelayanan saat ini.
Petugas Laboratorium	Baca dan tulis terbatas (hanya data laboratorium)	Baca data administratif pasien dan permintaan pemeriksaan penunjang. Tulis data laboratorium.
Apoteker	Baca dan tulis terbatas (hanya data apotek)	Baca data administratif pasien dan data terapi. Tulis data peresepan dan <i>dispensing</i> .

6. **Tahap pemberian resep oleh apotek.** Setelah dokter memberikan resep, apotek memerlukan hak untuk membaca data resep dan mengunggah data obat yang diresepkan.

Berdasarkan skenario tersebut, kebutuhan akses setiap aktor dapat diringkas pada Tabel III.1.

Tabel III.1 juga menunjukkan bahwa kategori tenaga medis tidak dapat diperlakukan sebagai satu kelompok akses tenaga medis. Dokter, perawat, petugas laboratorium, dan apoteker sama-sama terlibat dalam pelayanan klinis, tetapi memiliki kewenangan baca dan tulis yang berbeda. Oleh karena itu, penggunaan role umum seperti `MedicalPersonnel` yang digunakan pada DecMed saat ini belum cukup untuk menentukan hak akses tulis secara aman, karena sistem tetap perlu membedakan fungsi klinis masing-masing aktor.

Alur pemberian akses terhadap data RME pasien oleh pasien kepada tenaga medis pada DecMed sebelumnya dapat dilihat pada Lampiran B. Pada alur tersebut, pasien harus memilih satu tenaga medis lalu menerbitkan akses untuk tenaga medis tersebut. Implementasi DecMed sebelumnya tidak memiliki mekanisme delegasi antar tenaga kesehatan. Sehingga ketika akses perlu diberikan kepada lebih dari satu tenaga medis, proses yang sama perlu diulang dari awal untuk masing-masing penerima akses.

Dalam skenario tersebut, keterbatasan DecMed tampak secara operasional. Model token kapabilitas yang statis menyulitkan proses pembatasan akses secara bertahap

sesuai perpindahan peran di lapangan. Selain itu, pemberian akses hanya dapat dilakukan secara individual dari pasien kepada satu tenaga medis pada satu waktu, sehingga proses otorisasi menjadi tidak efektif ketika layanan melibatkan beberapa tenaga medis sekaligus. Pasien perlu memberikan akses kepada dokter utama dan petugas laboratorium secara terpisah, padahal proses tersebut dapat dibuat lebih efisien apabila dokter utama dapat mendelegasikan sebagian hak aksesnya kepada petugas laboratorium tanpa perlu intervensi langsung dari pasien. Dokter perlu dapat mendelegasikan sebagian hak akses saja, misalnya akses terhadap permintaan pemeriksaan dan hak tulis hasil laboratorium tanpa ikut membuka seluruh riwayat klinis pasien.

Dengan demikian, skenario layanan kesehatan kolaboratif ini memperlihatkan bahwa tiga persoalan penelitian saling berkaitan: sistem memerlukan model kebijakan akses yang lebih luas agar setiap aktor hanya memperoleh data yang relevan, segmentasi data *off-chain* agar kebijakan tersebut dapat ditegakkan secara teknis, dan delegasi antar tenaga kesehatan agar perpindahan hak akses dapat berlangsung efisien tanpa intervensi ulang dari pasien dan tanpa penerbitan token baru.

III.1.1.4 Analisis STRIDE pada Sistem DecMed

Analisis STRIDE digunakan untuk mengevaluasi implikasi keamanan dari arsitektur DecMed saat ini ketika ditempatkan pada skenario layanan kesehatan kolaboratif yang menjadi fokus analisis. Berdasarkan pembahasan pada Subbab II.8, tahapan awal pemodelan ancaman menggunakan STRIDE adalah mengidentifikasi komponen dan alur kerja sistem yang menjadi target ancaman. Identifikasi tersebut dilakukan melalui penggambaran DFD yang menunjukkan aliran data dan komunikasi antar komponen sistem. Pada analisis ini, DFD Level 0 dan Level 1 dimodelkan. Pemodelan ke level lebih lanjut tidak dilakukan karena pemodelan hingga level 1 sudah cukup untuk mengidentifikasi komponen dari DecMed dan alur data antar komponen. Hasil pemodelan DFD dapat dilihat pada Lampiran D.

Berdasarkan arsitektur DecMed pada Gambar II.4 dan DFD pada Lampiran D, *attack surface* utama sistem mencakup *Patient Client*, *Hospital Client*, *Ministry Client*, data pada lapisan *on-chain*, data terenkripsi pada lapisan *off-chain*, Redis

PRE, jaringan IOTA, IOTA *Gas Station*, serta token kapabilitas yang mengatur otorisasi akses. Hasil identifikasi ancaman berdasarkan metode STRIDE terhadap komponen utama pada DecMed dapat dilihat pada Lampiran E.

Berdasarkan hasil analisis STRIDE pada Tabel E.1, ancaman yang paling relevan terhadap fokus analisis adalah *spoofing* (T01), *tampering* (T02 dan T03), *information disclosure* (T05 dan T06), dan *elevation of privilege* (T08). Ancaman-ancaman tersebut secara langsung berkaitan dengan kebutuhan akan model kebijakan akses yang lebih luas, segmentasi data *off-chain*, dan mekanisme delegasi yang mampu membatasi hak akses secara bertahap. Ancaman *repudiation* (T04) tetap relevan terhadap kebutuhan audit delegasi, tetapi diposisikan sebagai implikasi pendukung karena fokus utama berada pada perluasan kebijakan akses dan delegasi. Ancaman *denial of service* (T07) tidak dijadikan masalah yang diselesaikan ataupun diuji, karena tidak termasuk dalam fokus terkait model kebijakan akses, segmentasi data, dan mekanisme delegasi antar tenaga kesehatan.

Dengan demikian, hasil analisis STRIDE memperkuat bahwa keterbatasan pada model kontrol akses dan delegasi DecMed tidak hanya merupakan persoalan fungsional, tetapi juga memiliki implikasi keamanan yang nyata. Oleh karena itu, diperlukan mekanisme otorisasi yang mampu mendukung pembatasan akses yang lebih rinci dan aman pada sistem rekam medis elektronik terdesentralisasi

III.1.1.5 Analisis Mekanisme Penggunaan dan Revokasi Token

Pada implementasi DecMed sebelumnya, kapabilitas akses ditentukan oleh kepemilikan token dan klaim yang dibawa oleh token tersebut. Setiap operasi pembacaan maupun penulisan data RME dilakukan melalui *request* yang menyertakan token akses. Komponen PRE kemudian memvalidasi token dengan mengacu pada hak akses yang tercatat pada penyimpanan *on-chain* IOTA. Validasi ini digunakan untuk memastikan bahwa *address* IOTA yang tercantum pada klaim token memiliki hak akses yang sesuai pada penyimpanan *on-chain* dan hak akses tersebut masih berlaku. Struktur klaim token ditunjukkan pada Kode III.1.

Mekanisme tersebut masih memiliki keterbatasan karena validasi berfokus pada klaim yang dibawa token, bukan pada pembuktian bahwa pengirim *request* benar-benar merupakan pemilik *address* yang tercantum pada klaim. Jika token

akses diperoleh oleh pihak lain, misalnya melalui kebocoran atau pencurian token, pihak tersebut dapat mengirimkan *request* dengan klaim *address* yang masih valid. Kondisi ini membuat token dapat digunakan oleh aktor yang tidak berwenang selama klaim di dalam token masih diterima oleh sistem. Oleh karena itu, diperlukan mekanisme tambahan agar penggunaan token diikat dengan bukti identitas dari aktor yang melakukan akses.

Selain verifikasi terhadap pengguna token, mekanisme pencabutan hak akses juga perlu diperhatikan. Pada DecMed, pasien dapat mencabut hak akses sebelum masa berlaku akses berakhir. Proses pencabutan dilakukan melalui *patient client* dengan mengirimkan *request* revokasi ke PRE. Setelah diterima, status revokasi dicatat pada Redis dan penyimpanan *on-chain* IOTA agar akses yang telah dicabut tidak lagi diterima oleh sistem.

Apabila mekanisme delegasi akses ditambahkan, sebagaimana dibutuhkan pada skenario layanan kesehatan kolaboratif di fasilitas pelayanan kesehatan pada Subbab III.1.1.3, mekanisme revokasi tidak cukup hanya menangani token awal. Token hasil delegasi juga perlu diperhitungkan, termasuk hubungan antara token induk dan token turunannya. Dengan demikian, pencabutan akses dapat diterapkan tidak hanya terhadap akses yang diberikan langsung oleh pasien, tetapi juga terhadap akses yang muncul melalui proses delegasi.

III.1.2 Identifikasi Masalah

Berdasarkan analisis terhadap arsitektur DecMed pada Subbab III.1.1, sejumlah masalah diidentifikasi agar DecMed dapat mendukung kontrol akses berbasis kebijakan yang lebih luas dan delegasi antar tenaga kesehatan. Permasalahan utama terdiri atas tiga aspek. Pertama, kontrol akses DecMed masih bersifat *coarse-grained* karena keputusan akses terutama ditentukan oleh *role* dan *purpose*, sehingga belum mencakup hubungan kebijakan yang lebih luas antara aktor, objek RME, hak akses, dan kondisi akses. Kedua, data RME pada penyimpanan *off-chain* belum direpresentasikan sebagai objek akses yang tersegmentasi sehingga pembatasan akses sulit ditegakkan pada unit data spesifik. Ketiga, alur pemberian akses DecMed masih bergantung pada keterlibatan langsung pasien sehingga belum mendukung delegasi antaraktor dalam proses layanan kesehatan yang kolaboratif.

Tabel III.2: Identifikasi Masalah DecMed

ID	Masalah	Dasar Analisis
M-TA-01	Kontrol akses DecMed masih bersifat <i>coarse-grained</i> karena belum mendefinisikan kebijakan yang menghubungkan aktor, objek RME, hak akses, dan kondisi secara lebih luas.	III.1.1.1, T02, T05
M-TA-02	Data RME belum direpresentasikan sebagai objek akses yang tersegmentasi.	III.1.1.2, T05
M-TA-03	Alur pemberian akses belum mendukung delegasi antaraktor dalam layanan kolaboratif.	III.1.1.3
M-TA-04	Delegasi antaraktor memerlukan mekanisme atenuasi.	III.1.1.3, T05, T08
M-TA-05	<i>Role</i> MedicalPersonnel terlalu umum untuk membedakan kewenangan antar aktor.	III.1.1.3, T02, T05
M-TA-06	Mekanisme revokasi dan audit akses perlu diperluas agar mencakup akses turunan pada rantai delegasi.	III.1.1.5, T04, T08
M-TA-07	Token akses belum secara eksplisit membuktikan kepemilikan identitas aktor pada rantai delegasi.	III.1.1.5, T01

Selain tiga masalah utama tersebut, terdapat beberapa masalah turunan yang perlu diperhatikan agar rancangan solusi dapat ditegakkan secara aman. Delegasi antaraktor harus dibatasi agar hak akses turunan tidak melebihi hak akses induknya. Perbedaan data klinis yang dapat diakses oleh masing-masing aktor juga perlu diperhitungkan karena *role* umum seperti MedicalPersonnel belum cukup untuk membedakan kewenangan dokter, perawat, petugas laboratorium, dan apoteker. Selain itu, karena delegasi dapat membentuk rantai akses, mekanisme pencabutan dan audit pada DecMed perlu diperluas agar dapat mencakup akses turunan. Penggunaan token akses juga perlu dikaitkan dengan pembuktian identitas aktor pada rantai delegasi agar token tidak hanya diperlakukan sebagai *bearer token* yang dapat digunakan oleh pihak yang tidak semestinya.

Agar keterhubungan antara analisis masalah, ancaman keamanan, kebutuhan sistem, rancangan, implementasi, dan pengujian dapat ditelusuri, permasalahan tersebut dirinci menggunakan ID M-TA pada Tabel III.2.

Berdasarkan Tabel III.2, keterbatasan DecMed tidak hanya dipandang sebagai persoalan format token, tetapi sebagai rangkaian masalah yang saling bergantung. M-TA-01, M-TA-02, dan M-TA-03 merupakan masalah inti yang masing-masing berkaitan dengan kebutuhan kontrol akses berbasis kebijakan yang lebih luas, segmentasi objek data RME, dan delegasi antaraktor. Sementara itu, M-TA-04,

M-TA-05, M-TA-06, dan M-TA-07 merupakan masalah turunan atau implikasi yang perlu diselesaikan agar ketiga masalah inti tersebut dapat ditangani secara aman. M-TA-04 menekankan perlunya pembatasan hak akses turunan, M-TA-05 menekankan perlunya pembedaan kewenangan berdasarkan aktor, M-TA-06 menekankan perlunya perluasan pencabutan dan audit terhadap rantai delegasi, sedangkan M-TA-07 menekankan perlunya pembuktian identitas aktor pada rantai delegasi. ID masalah tersebut kemudian digunakan sebagai dasar pemetaan kebutuhan, rancangan, implementasi, dan pengujian pada bagian selanjutnya.

III.1.3 Kebutuhan Sistem

Berdasarkan masalah yang telah dipetakan pada Tabel III.2, kebutuhan sistem pada Tugas Akhir ini dirumuskan sebagai perluasan terhadap kebutuhan DecMed sebelumnya. Kebutuhan ini tidak dimaksudkan untuk menggantikan fungsi dasar DecMed, melainkan untuk memastikan bahwa sistem dapat mendukung kontrol akses berbasis kebijakan yang lebih luas, segmentasi data RME, delegasi berantai, revokasi akses turunan, audit delegasi, dan pembuktian identitas aktor pada rantai delegasi.

Kebutuhan sistem dibagi menjadi kebutuhan fungsional dan kebutuhan nonfungsional. Kebutuhan fungsional menjelaskan kemampuan yang harus disediakan oleh sistem dari sudut pandang aktor dan proses bisnis layanan kesehatan. Sementara itu, kebutuhan nonfungsional menjelaskan batasan kualitas dan keamanan yang harus dipenuhi dalam penerapan mekanisme kontrol akses dan delegasi.

III.1.3.1 Kebutuhan Fungsional Tambahan

Kebutuhan fungsional tambahan dirumuskan dari sudut pandang aktor, sama seperti pola pada kebutuhan fungsional DecMed pada Lampiran C. Perumusan berbasis aktor digunakan untuk memperjelas pihak yang dapat menerima akses, jenis data yang dapat diakses, operasi yang dapat dilakukan, serta batasan akses yang harus ditegakkan. Batasan tersebut mencakup pasien, episode RME, dataset, fungsi klinis, aksi akses, waktu berlaku, penerima delegasi, dan kedalaman delegasi. Rangkuman kebutuhan fungsional tambahan DecMed ditunjukkan pada Tabel III.3.

Tabel III.3: Kebutuhan Fungsional Tambahan DecMed

ID	Deskripsi
KF-TA-01	Pasien dapat memberikan akses awal kepada petugas rekam medis sesuai konteks layanan kesehatan.
KF-TA-02	Pasien dapat mencabut akses awal dan akses turunannya yang telah diberikan.
KF-TA-03	Pasien dapat melihat riwayat akses dan delegasi terhadap RME miliknya.
KF-TA-04	Petugas rekam medis dapat mendelegasikan akses terbatas kepada perawat dan dokter sesuai cakupan akses.
KF-TA-05	Dokter dapat membaca dan menulis segmen klinis sesuai cakupan akses dan konteks pelayanan.
KF-TA-06	Dokter dapat mendelegasikan akses terbatas kepada tenaga laboratorium dan apoteker sesuai cakupan akses.
KF-TA-07	Perawat dapat membaca data yang relevan dan menulis segmen klinis pemeriksaan awal sesuai cakupan akses.
KF-TA-08	Petugas laboratorium dapat membaca data yang relevan dan menulis segmen klinis terkait pemeriksaan laboratorium sesuai cakupan akses.
KF-TA-09	Apoteker dapat membaca data yang relevan dan menulis segmen klinis terkait pelayanan obat sesuai cakupan akses.

Kebutuhan fungsional dengan ID KF-TA-01 merupakan penyesuaian dari F06 dan F07 pada Lampiran C. Penyesuaian ini diperlukan karena dalam skenario layanan kesehatan kolaboratif, akses awal terhadap RME hanya diberikan langsung oleh pasien kepada petugas rekam medis. Kemudian hak akses tersebut dapat didelegasikan secara terbatas kepada aktor tenaga medis yang terlibat dalam proses pelayanan, seperti dokter, perawat, petugas laboratorium, dan apoteker.

KF-TA-02 juga merupakan penyesuaian dari F09 pada Lampiran C. Penyesuaian ini terkait dengan mekanisme revokasi akses pada skenario layanan kesehatan kolaboratif. Dalam skenario tersebut, pasien memerlukan kemampuan untuk mencabut akses awal dan akses turunannya yang telah didelegasikan.

III.1.3.2 Kebutuhan Nonfungsional

Selain kebutuhan fungsional, sistem juga memiliki kebutuhan nonfungsional untuk memastikan bahwa mekanisme kontrol akses berbasis kebijakan dan delegasi berantai dapat diterapkan secara aman. Kebutuhan nonfungsional pada Tugas Akhir ini difokuskan pada aspek keamanan, keterlacakan, dan kompatibilitas dengan arsitektur DecMed.

Tabel III.4: Kebutuhan Nonfungsional Tambahan DecMed

ID	Deskripsi
KNF-TA-01	Sistem harus menjaga kerahasiaan data RME dengan memastikan bahwa penerima akses hanya dapat memperoleh <i>plaintext</i> dari segmen yang sesuai dengan cakupan otorisasinya.
KNF-TA-02	Sistem menjamin integritas token otorisasi dan batasan akses tidak mungkin diperluas ketika delegasi.
KNF-TA-03	Sistem menjamin penolakan permintaan akses jika token, rantai delegasi, atau bukti kepemilikan identitas aktor pemohon tidak valid.
KNF-TA-04	Sistem menyediakan keterlacakan delegasi dengan mencatat informasi delegasi.
KNF-TA-05	Sistem menjamin penolakan akses untuk hak akses yang dicabut.
KNF-TA-06	Sistem harus memverifikasi keterikatan bukti kepemilikan identitas terhadap aktor pada rantai delegasi, token akses, dan konteks permintaan akses.

Tabel III.5: Pemetaan Masalah terhadap Kebutuhan Sistem

ID Masalah	Kebutuhan Fungsional	Kebutuhan Nonfungsional
M-TA-01	KF-TA-01, KF-TA-04–KF-TA-09	KNF-TA-01, KNF-TA-02, KNF-TA-03
M-TA-02	KF-TA-05, KF-TA-07, KF-TA-08, KF-TA-09	KNF-TA-01
M-TA-03	KF-TA-01, KF-TA-04, KF-TA-06	KNF-TA-04
M-TA-04	KF-TA-04, KF-TA-06	KNF-TA-02, KNF-TA-03
M-TA-05	KF-TA-05, KF-TA-07, KF-TA-08, KF-TA-09	KNF-TA-01, KNF-TA-03
M-TA-06	KF-TA-02, KF-TA-03	KNF-TA-04, KNF-TA-05
M-TA-07	<i>Tidak ada</i>	KNF-TA-03, KNF-TA-06

III.1.3.3 Pemetaan Masalah terhadap Kebutuhan Sistem

Setelah kebutuhan fungsional dan nonfungsional dirumuskan, masalah yang telah diidentifikasi dipetakan terhadap kebutuhan sistem yang diusulkan. Pemetaan ini digunakan untuk memastikan bahwa setiap masalah memiliki kebutuhan yang menanganinya. Hasil pemetaan masalah terhadap kebutuhan sistem ditunjukkan pada Tabel III.5.

Kebutuhan fungsional dan nonfungsional tambahan tersebut menjadi dasar bagi perancangan solusi pada tahap berikutnya.

III.2 Analisis Solusi

DecMed sudah memiliki fondasi yang sesuai untuk sistem RME terdesentralisasi melalui IOTA, IPFS, dan PRE. Oleh karena itu, solusi yang dianalisis pada

bagian ini diarahkan untuk memperluas kontrol akses melalui kebijakan yang lebih komprehensif dan memfasilitasi kemampuan delegasi antar tenaga kesehatan.

Berdasarkan kebutuhan sistem pada Subbab III.1.3, solusi yang dianalisis dikelompokkan ke dalam aspek utama berikut: model kebijakan akses, token otorisasi sebagai media kapabilitas, segmentasi objek data, delegasi akses antar tenaga kesehatan, serta penegakan otoritas. Pengelompokan ini diperlukan karena kontrol akses yang lebih luas tidak dapat ditegakkan hanya melalui penggantian format token. Model kebijakan diperlukan untuk mendefinisikan hubungan antara aktor, objek, hak akses, dan kondisi; token diperlukan untuk membawa kapabilitas; segmentasi data diperlukan agar kebijakan memiliki objek penegakan yang jelas; sedangkan *Server PRE* diperlukan sebagai titik penegakan sebelum data terenkripsi diambil dan diproses *re-encryption*. Dengan demikian, analisis solusi pada bagian ini berfungsi sebagai dasar pemilihan pendekatan sebelum rancangan teknis dijelaskan pada Subbab III.3.

III.2.1 Analisis Delegasi Akses Antar Tenaga Kesehatan

Delegasi akses antar tenaga kesehatan diperlukan berdasarkan hasil analisis pada Subbab III.1.1.3. Dalam skenario DecMed sebelumnya, pasien memberikan akses kepada aktor tertentu secara langsung. Pola tersebut kurang sesuai untuk layanan klinis kolaboratif karena kebutuhan akses dapat berpindah antar aktor selama episode berlayanan berlangsung. Jika setiap perpindahan akses harus selalu diterbitkan langsung oleh pasien, maka proses pelayanan menjadi bergantung pada ketersediaan pasien.

Inti dari fitur delegasi antar tenaga kesehatan yang dianalisis adalah bahwa proses delegasi tidak melibatkan pasien dan tidak menerbitkan token baru. Setelah pasien memberikan akses awal, aktor yang sah dapat menurunkan hak akses yang sudah diterima kepada tenaga kesehatan lain dengan menambahkan batasan yang mempersempit cakupan akses.

Alternatif solusi pertama yang dipertimbangkan adalah delegasi akses melalui *client* dengan pencatatan hasil delegasi pada penyimpanan *on-chain*. Pada pendekatan ini, aktor yang memiliki token induk membentuk token turunan secara lokal dengan menambahkan batasan baru terhadap hak akses yang dimiliki. Token turunan

tersebut kemudian dibagikan kepada penerima delegasi melalui penyimpanan *on-chain*. Pendekatan ini dapat mengurangi keterlibatan pasien karena pemegang token dapat menurunkan hak akses yang sudah diterima sebelumnya.

Namun, pendekatan tersebut menjadikan *client* sebagai komponen yang menentukan hasil delegasi. Kondisi ini kurang ideal karena *client* dapat dimanipulasi untuk melakukan delegasi sesuka hati. Akibatnya, sistem berpotensi mencatat delegasi yang tidak konsisten dengan hak akses induk, meskipun token turunan tersebut kemudian dapat ditolak ketika digunakan untuk mengakses *Server PRE*.

Alternatif berikutnya adalah melibatkan *Server PRE* sebagai komponen yang memverifikasi permintaan delegasi sebelum token turunan dibentuk. Pada pendekatan ini, aktor delegator tetap menginisiasi delegasi melalui *client*. *Client* mengirimkan token induk yang dimiliki *delegator*, lalu token dan hak akses *delegator* diverifikasi oleh *Server PRE*.

Jika permintaan delegasi dinyatakan sah, *Server PRE* membentuk hak akses turunan dengan menambahkan batasan baru yang mempersempit hak akses. *PRE* kemudian mengembalikan hak akses tersebut kepada *client*. Setelah menerima hasil atenuasi dari *PRE*, *client* kemudian dapat melakukan proses pencatatan lebih lanjut pada penyimpanan *on-chain*. Dengan demikian, *PRE* hanya menjadi verifikator dan pembentuk hak akses turunan, sedangkan pencatatan delegasi tetap dilakukan oleh *client*.

Berdasarkan pertimbangan tersebut, mekanisme delegasi akses antar tenaga kesehatan yang dimediasi oleh *Server PRE* dipilih. Mekanisme ini memanfaatkan konsep atenuasi sehingga hak akses turunan hanya dapat memiliki cakupan yang sama atau lebih sempit daripada hak akses induk. Setelah pasien memberikan akses awal, aktor yang sah dapat mengajukan delegasi terbatas melalui *client* tanpa melibatkan pasien kembali dan tanpa menerbitkan token baru, sedangkan *PRE* memverifikasi dan membentuk hak akses turunan berdasarkan hak akses induk yang masih berlaku.

Pemilihan mekanisme ini memberikan batas tanggung jawab yang lebih jelas. *client* berperan sebagai inisiator delegasi dan pencatat delegasi pada penyimpanan *on-chain*. *Server PRE* berperan sebagai pembentuk hak akses turunan.

Penyimpanan *on-chain* mencatat riwayat delegasi dan bukti akses. Dengan pembagian tersebut, proses pelayanan tidak perlu selalu melibatkan pasien, tetapi pembentukan hak akses turunan tetap melewati validasi PRE sebelum dicatat dan digunakan.

III.2.2 Analisis Pemilihan Token Otorisasi

Berdasarkan masalah yang telah diidentifikasi pada Subbab III.1.2, mekanisme otorisasi pada DecMed perlu mendukung representasi kapabilitas yang sesuai dengan kebijakan akses serta memiliki mekanisme atenuasi. Selain itu, pada Subbab III.2.1 dibahas bahwa mekanisme delegasi antaraktor perlu mendukung atenuasi *offline*. Oleh karena itu, perbandingan terhadap beberapa pendekatan token otorisasi dianalisis untuk menentukan teknologi token yang paling sesuai sebagai media pembawa kapabilitas.

Alternatif token otorisasi yang dibandingkan pada analisis ini adalah JWT, PASETO, Macaroons, dan Biscuit. JWT dipilih sebagai pembanding karena merupakan bentuk token yang digunakan pada rancangan DecMed awal dan umum digunakan untuk merepresentasikan klaim otorisasi. PASETO dipilih karena memiliki tujuan penggunaan yang serupa dengan JWT, tetapi dengan kriptografi yang *opinionated*. Macaroons dianalisis sebagai kandidat utama karena menyediakan mekanisme *caveat* yang memungkinkan atenuasi *offline*. Biscuit dianalisis sebagai pembanding karena mendukung verifikasi terdesentralisasi dan atenuasi *offline*, tetapi menggunakan pendekatan yang lebih ekspresif melalui aturan berbasis *logic language*.

Kriteria evaluasi antar token diturunkan dari kebutuhan sebagai berikut:

1. Representasi kapabilitas dan batasan akses

Menilai apakah token dapat membawa kapabilitas dan batasan yang telah ditetapkan oleh kebijakan akses.

2. Atenuasi *offline*

Menilai apakah pemegang token dapat menambahkan batasan baru tanpa harus melibatkan pasien dan menerbitkan token baru. Sesuai dengan solusi dari Subbab III.2.1.

Tabel III.6: Perbandingan Pendekatan Token Otorisasi

Kriteria	JWT	PASETO	Macaroons	Biscuit
Representasi kapabilitas dan batasan akses	Melalui klaim	Melalui klaim	Melalui <i>caveats</i>	Melalui <i>fact, rule</i> , dan <i>check</i>
Atenuasi <i>offline</i>	Tidak didukung secara <i>native</i>	Tidak didukung secara <i>native</i>	Didukung melalui penambahan <i>caveat</i>	Didukung melalui penambahan <i>block logic</i>
Jaminan token turunan tidak memperluas hak akses	Bergantung pada implementasi	Bergantung pada implementasi	Ditegakkan melalui verifikasi <i>caveat</i>	Ditegakkan melalui <i>logic language</i>
Model verifikasi dan pengelolaan kunci	Kunci simetris atau asimetris	Mode lokal atau publik	Berbasis kunci simetris	Berbasis kunci asimetris
Kesesuaian ekspresivitas dengan kebutuhan DecMed	Sesuai	Sesuai	Sesuai	Lebih ekspresif
Kompleksitas integrasi	Rendah	Rendah	Sedang	Tinggi

3. Jaminan token turunan tidak memperluas hak akses

Menganalisis jenis kunci kriptografi yang digunakan dan seberapa kuat sistem delegasi token mencegah token turunan digunakan untuk mengakses lebih banyak atau lebih luas daripada token induknya.

4. Model verifikasi dan pengelolaan kunci

Mengkaji bagaimana masing-masing token diverifikasi dan bagaimana pengelolaan kuncinya.

5. Kesesuaian ekspresivitas dengan aturan akses DecMed

DecMed membutuhkan token yang dapat mengekspresikan batasan akses secara langsung sebagai atribut pada token itu sendiri.

6. Kompleksitas integrasi ke PRE

membahas tingkat kesulitan integrasi ke dalam sistem PRE sebagai penegak otoritas akses.

Tabel III.6 menunjukkan perbandingan antar token otorisasi berdasarkan kriteria evaluasi.

JWT dan PASETO dapat digunakan untuk membawa informasi otorisasi dalam bentuk klaim, seperti identitas subjek, cakupan akses, dan waktu kedaluwarsa. Namun, keduanya tidak menyediakan mekanisme bawaan untuk menambahkan batasan baru pada token yang sudah diterbitkan. Akibatnya, delegasi hak akses yang lebih sempit tetap membutuhkan penerbitan token baru oleh pihak penerbit atau mekanisme tambahan di sisi *server*. Karakteristik tersebut kurang sesuai dengan kebutuhan delegasi antar tenaga kesehatan yang dianalisis.

Macaroons dan Biscuit lebih dekat dengan kebutuhan karena keduanya mendukung atenuasi *offline*. Perbedaan utama keduanya terletak pada model pembatasan dan model verifikasi. Macaroons menggunakan *caveats* untuk menambahkan batasan pada token, sedangkan Biscuit menggunakan blok berisi *fact*, *rule*, dan *check*. Model Biscuit memberikan ekspresivitas yang lebih tinggi, tetapi kebutuhan pembatasan akses pada DecMed masih dapat direpresentasikan melalui klaim pada token, seperti identitas pasien, identitas aktor, cakupan data, aksi, dan masa berlaku. Pembatasan tersebut hanya memanfaatkan *fact* saja, karena pemeriksaan otoritas dari klaim pada token sudah cukup ditangani oleh *server* PRE. Oleh karena itu, penggunaan Biscuit dinilai menambah kompleksitas integrasi yang tidak diperlukan untuk ruang lingkup yang dianalisis.

Dari sisi model verifikasi, Macaroons lebih sesuai dengan rancangan DecMed karena proses verifikasi token tetap dipusatkan pada *Server* PRE sebagai titik penegakan otorisasi. Dengan model tersebut, kunci verifikasi tidak perlu disebar ke banyak layanan. Biscuit lebih sesuai untuk arsitektur yang membutuhkan verifikasi token oleh banyak komponen berbeda menggunakan kunci publik. Pada rancangan DecMed, kebutuhan tersebut tidak menjadi fokus karena seluruh akses data RME tetap melewati PRE.

Berdasarkan perbandingan tersebut, Macaroons dipilih sebagai media pembawa kapabilitas pada DecMed karena memberikan keseimbangan antara kemampuan merepresentasikan batasan yang diturunkan dari kebijakan akses, dukungan delegasi terbatas melalui atenuasi *offline*, dan kompleksitas integrasi yang sesuai dengan ruang lingkup yang dianalisis. Melalui mekanisme *caveats*, token dapat membawa batasan kapabilitas dan pemegang token dapat menambahkan batasan baru secara lokal untuk mempersempit hak akses sebelum token didelegasikan kepada aktor lain. Perluasan kontrol akses itu sendiri tetap didasarkan pada model PBAC, bukan pada format token semata.

III.2.3 Analisis Segmentasi Data RME

Masalah granularitas tidak hanya berada pada token, tetapi juga pada struktur data yang dilindungi. Sesuai analisis pada Subbab III.1.1.2, jika data RME disimpan sebagai satu *encrypted blob*, maka pemberian akses terhadap blob tersebut akan membuka seluruh isi data meskipun aktor hanya membutuhkan sebagian informasi.

Oleh karena itu, pemrosesan data pada DecMed perlu disesuaikan untuk memenuhi kebutuhan akses granular.

Alternatif pertama yang dipertimbangkan adalah pemfilteran setelah data klinis diambil dari penyimpanan *off-chain*. Pada pendekatan ini, data tetap disimpan sebagai satu *encrypted blob*, kemudian sistem memilih bagian data yang boleh ditampilkan berdasarkan hak akses pengguna. Pendekatan ini kurang sesuai dengan karakteristik DecMed. IPFS tidak menyediakan mekanisme pencarian atau pemfilteran isi data secara langsung. Selain itu, DecMed menyimpan data dalam bentuk terenkripsi, sehingga isi data baru dapat diproses setelah didekripsi. Jika pemfilteran dilakukan di *client*, maka keseluruhan *plaintext* data klinis sudah terbuka terlebih dahulu sebelum batas akses diterapkan.

Alternatif yang dipilih adalah segmentasi data klinis sebelum data disimpan pada penyimpanan *off-chain*. Pada pendekatan ini, data klinis dipisahkan menjadi beberapa segmen. Setiap segmen memiliki metadata yang disimpan pada penyimpanan *on-chain*. Metadata tersebut digunakan oleh sistem untuk memilih segmen yang sesuai dengan cakupan akses sebelum data diambil dari IPFS. Dengan cara ini, proses pengambilan data menjadi lebih terarah karena sistem hanya mengambil segmen yang relevan dengan hak akses pengguna.

Penentuan kategori segmentasi tidak dilakukan secara arbitrer. Opsi pertama adalah mengikuti pembagian data pada penelitian terkait yang dibahas pada Subbab II.9.3. Namun, pembagian tersebut kurang sesuai dijadikan dasar segmentasi karena ditujukan untuk pembuktian konseptual, bukan untuk merepresentasikan struktur data pelayanan medis. Oleh karena itu, rancangan segmentasi mengacu pada KMK 1423/2022 tentang Pedoman Variabel dan Metadata pada Penyelenggaraan Rekam Medis Elektronik yang telah dibahas pada Subbab II.1.2.

Berdasarkan pedoman tersebut, data RME dapat dibedakan berdasarkan *dataset* pelayanan. Dalam cakupan yang dianalisis, *dataset category* yang digunakan meliputi:

- Rawat Jalan
- Rawat Inap
- Laboratorium

- Apotek

Pembagian berdasarkan *dataset* pelayanan dipilih karena setiap layanan memiliki jenis data dan kebutuhan akses yang berbeda. Sebagai contoh, petugas laboratorium membutuhkan akses tulis terhadap *dataset* laboratorium, sedangkan apoteker membutuhkan akses tulis terhadap *dataset* apotek. Dengan pemisahan ini, sistem dapat membedakan konteks layanan sebelum menentukan segmen data yang dapat dibaca atau ditulis oleh aktor.

Selain berdasarkan *dataset*, data klinis juga disegmentasi berdasarkan kategori fungsi klinis. *Function category* digunakan untuk membedakan fungsi data di dalam suatu *dataset*, seperti anamnesis, pemeriksaan fisik, pemeriksaan penunjang, diagnosis, persetujuan tindakan, atau terapi. Metadata fungsi klinis digunakan untuk menentukan apakah suatu segmen data relevan dengan peran dan kebutuhan akses tenaga medis.

Kombinasi *dataset category* dan *function category* dipilih agar segmentasi tidak terlalu kasar seperti pemisahan per dokumen penuh, tetapi juga tidak terlalu rinci hingga tingkat *field*. Segmentasi hingga tingkat *field* akan membuat kontrol akses bergantung pada setiap elemen data yang tersimpan. Pendekatan tersebut tidak dipilih karena kebutuhan akses pada rancangan ini dinilai berdasarkan konteks layanan dan fungsi klinis, bukan berdasarkan setiap *field* secara terpisah.

Sebagai contoh, Formulir Umum / Asesmen Awal Rawat Jalan dapat dipetakan ke fungsi klinis seperti anamnesis, pemeriksaan fisik, dan pemeriksaan psikologi. Sementara itu, Pemeriksaan Spesialistik dapat dipetakan ke fungsi klinis seperti riwayat penggunaan obat, rencana rawat, instruksi medik dan keperawatan, pemeriksaan penunjang, diagnosis, persetujuan tindakan, dan terapi. Pemetaan lengkap kategori fungsi klinis dapat dilihat pada Lampiran A.

Melalui pendekatan ini, data *off-chain* tidak lagi diperlakukan sebagai satu objek besar, tetapi sebagai kumpulan segmen klinis dengan metadata yang terdefinisi. Segmentasi tersebut menyediakan objek penegakan yang lebih jelas bagi token otorisasi karena batasan akses pada token dapat dicocokkan langsung dengan *dataset category* dan *function category* pada metadata *on-chain*.

III.2.4 Analisis Pendekatan Kontrol Akses Berbasis Kebijakan

Hasil analisis masalah menunjukkan bahwa kontrol akses pada DecMed tidak cukup ditentukan hanya berdasarkan *role* dan *purpose* yang terdapat pada token JWT. Klaim tersebut dapat membedakan kategori umum pengguna dan operasi yang dilakukan, tetapi belum merepresentasikan pasien yang datanya diakses, episode RME, kategori dataset, kategori fungsi klinis, masa berlaku akses, maupun batasan delegasi. Selain itu, *role* MedicalPersonnel pada DecMed masih terlalu umum untuk membedakan kewenangan dokter, perawat, petugas laboratorium, dan apoteker.

Keterbatasan tersebut berkaitan terutama dengan masalah M-TA-01, M-TA-02, M-TA-04, dan M-TA-05. Kontrol akses yang lebih luas membutuhkan model kebijakan untuk menghubungkan aktor dengan operasi yang diizinkan terhadap bagian RME tertentu. Segmentasi data yang telah dianalisis pada Subbab III.2.3 menyediakan objek yang dapat dilindungi, tetapi segmentasi tersebut belum menentukan siapa yang dapat mengakses setiap segmen dan dalam kondisi apa akses dapat diberikan. Oleh karena itu, dibutuhkan model kebijakan yang dapat merepresentasikan hubungan antara pengguna, objek RME, hak akses, dan kondisi akses secara terstruktur. Model inilah yang menjawab keterbatasan kontrol *coarse-grained* pada DecMed, sementara token otorisasi berperan sebagai media pembawa kapabilitas hasil dari kebijakan tersebut.

Terdapat tiga pendekatan yang dipertimbangkan untuk mendefinisikan kebijakan akses pada pengembangan DecMed. Perbandingan pendekatan tersebut ditunjukkan pada Tabel III.7.

Pendekatan berbasis *role* saja tidak dipilih karena keputusan akses pada DecMed tidak hanya bergantung pada profesi atau kedudukan pengguna. Sebagai contoh, dua pengguna dengan *subrole* dokter tidak selalu memiliki akses terhadap pasien dan episode RME yang sama. Demikian pula, petugas laboratorium yang terlibat dalam satu episode pelayanan tidak memerlukan akses terhadap seluruh data klinis pasien. Peran pengguna tetap diperlukan untuk merepresentasikan kewenangan kelembagaan, tetapi belum cukup untuk menjadi satu-satunya dasar keputusan akses.

Perancangan *caveat* secara langsung sebenarnya dapat digunakan untuk

Tabel III.7: Analisis Pendekatan Pemodelan Kebijakan Akses

Pendekatan	Keunggulan	Keterbatasan
Kontrol akses berbasis <i>role</i>	Sederhana dan sesuai dengan struktur <i>role</i> pengguna yang telah terdapat pada DecMed.	Belum dapat membatasi akses berdasarkan pasien, episode RME, kategori dataset, kategori fungsi klinis, waktu berlaku, dan rantai delegasi.
Perancangan <i>caveat</i> secara langsung	Batasan akses dapat langsung direpresentasikan dalam token Macaroon tanpa membentuk model kebijakan tersendiri.	Hubungan antara aktor, objek, hak akses, dan kondisi akses tidak dimodelkan secara eksplisit sehingga ketertelusuran kebijakan terhadap kebutuhan sistem menjadi lebih sulit.
PBAC dengan adaptasi elemen <i>Policy Machine</i>	Dapat memisahkan pengguna, atribut pengguna, objek, atribut objek, hak akses, relasi penugasan, dan asosiasi hak akses secara terstruktur.	Membutuhkan pemetaan tambahan dari model konseptual ke token Macaroon, metadata segmen, dan fungsi verifikasi pada <i>Server PRE</i> .

mengimplementasikan pembatasan akses. Namun, pendekatan tersebut hanya menjelaskan bentuk token dan belum memberikan model konseptual yang menghubungkan kebutuhan aktor, objek RME, serta hak akses. Tanpa model kebijakan, setiap *caveat* berisiko dipandang sebagai batasan yang berdiri sendiri dan hubungan antara token, segmentasi data, serta validasi *role* menjadi kurang jelas.

Berdasarkan pertimbangan tersebut, pendekatan *Policy-Based Access Control* digunakan dengan mengadaptasi elemen inti *Policy Machine*. *Policy Machine* menyediakan struktur untuk merepresentasikan pengguna, atribut pengguna, objek, atribut objek, kelas kebijakan, hak akses, relasi penugasan, dan asosiasi hak akses sesuai dengan penjelasan pada II.5.4. Struktur tersebut sesuai dengan kebutuhan DecMed karena pengguna dapat dikelompokkan berdasarkan *role* atau *subrole*, sedangkan segmen RME dapat dikelompokkan secara hierarkis berdasarkan rumah sakit, pasien, episode RME, kategori dataset, dan kategori fungsi klinis.

Adaptasi *Policy Machine* juga memungkinkan pemisahan antara kebijakan akses dan mekanisme implementasinya. Pada tingkat kebijakan, model menentukan aktor, objek, dan operasi yang diizinkan. Pada tingkat implementasi, cakupan kebijakan direpresentasikan melalui *caveat* Macaroon, metadata segmen pada IOTA, dan informasi *role* serta *subrole* aktor. Permintaan akses kemudian dievaluasi dan

ditegakkan oleh *Server PRE* sebelum data terenkripsi diambil atau diproses melalui mekanisme *re-encryption*.

Model kebijakan yang dibutuhkan DecMed mencakup beberapa dimensi berikut.

1. **Aktor akses**, yaitu alamat dompet aktor pemohon beserta *role* atau *subrole* yang tercatat pada sistem.
2. **Pemilik dan konteks data**, yaitu pasien, rumah sakit, dan episode RME yang menjadi cakupan akses.
3. **Objek akses**, yaitu segmen RME yang diklasifikasikan menggunakan *dataset_category* dan *function_category*.
4. **Operasi akses**, yaitu operasi Read atau Update terhadap segmen RME.
5. **Kondisi akses**, yaitu masa berlaku token, validitas identitas aktor pada rantai delegasi, status revokasi, dan kesesuaian rantai delegasi.
6. **Batasan delegasi**, yaitu ketentuan bahwa token turunan tidak boleh memiliki cakupan data, operasi, masa berlaku, atau kemampuan delegasi yang melebihi token induknya.

Dalam ruang lingkup ini, *Policy Machine* tidak diimplementasikan sebagai mesin kebijakan lengkap. Seluruh fungsi administratif, *prohibition*, *obligation engine*, maupun penyimpanan graf kebijakan sebagaimana didefinisikan pada spesifikasi *Policy Machine* tidak diimplementasikan. Elemen, relasi penugasan, dan asosiasi hak aksesnya digunakan sebagai kerangka konseptual untuk menyusun kebijakan akses DecMed. Keputusan akses aktual tetap dihasilkan melalui verifikasi Macaroon, metadata segmen, informasi aktor, dan bukti kepemilikan *wallet* pada *Server PRE*.

Dengan pembagian tersebut, model PBAC menjawab keterbatasan kontrol *coarse-grained* melalui perluasan kebijakan akses dari batasan *role* dan *purpose* menjadi hubungan antara aktor, objek, hak akses, dan kondisi. *Policy Machine* menjelaskan struktur kebijakan tersebut, Macaroon membawa kapabilitas hasil kebijakan, IOTA menyediakan metadata dan atribut yang menjadi dasar evaluasi, sedangkan *Server PRE* menjadi titik evaluasi dan penegakan kebijakan.

III.2.5 Analisis Penegakan Otoritas pada *Server* PRE

Pada DecMed, PRE digunakan untuk mengubah data terenkripsi dari pasien ke penerima akses tanpa sekalipun membuka *plaintext*. Pada implementasi DecMed sebelumnya, PRE berfokus melakukan verifikasi token dan menjalankan proses *re-encryption*. *Server* PRE dipilih sebagai titik penegakan otoritas karena komponen ini berada pada jalur kritis sebelum data terenkripsi diproses. Pengguna tidak memperoleh *plaintext* langsung dari penyimpanan *off-chain*, melainkan membutuhkan proses *re-encryption* yang dikendalikan oleh PRE. Oleh karena itu, PRE dapat berperan sebagai titik penegakan kebijakan akses yang memverifikasi token dan menolak permintaan sebelum data diambil dari IPFS apabila otorisasi tidak valid.

III.2.5.1 Analisis Verifikasi Aktor dan Operasi Tulis

Pada DecMed sebelumnya, *role* `MedicalPersonnel` digunakan untuk merepresentasikan tenaga medis secara umum, dan memberikan hak untuk mengakses data klinis pasien. Namun, *role* tersebut belum cukup untuk membedakan dokter, perawat, petugas laboratorium, dan apoteker. Padahal, keempat aktor tersebut memiliki kewenangan tulis yang berbeda. Sebagai contoh, dokter dapat menulis diagnosis dan terapi sedangkan petugas laboratorium hanya dapat menulis hasil laboratorium.

Oleh karena itu, diperlukan verifikasi tambahan terhadap *subrole* tenaga medis, terutama untuk operasi tulis. *Server* PRE tetap perlu memastikan bahwa aktor pemohon memiliki *subrole* yang sesuai dengan *dataset category* dan *function category* yang akan ditulis. Verifikasi ini mencegah kondisi ketika aktor membawa token dengan izin tulis, tetapi secara kewenangan profesional tidak berhak memperbarui segmen data tertentu.

III.2.5.2 Analisis Verifikasi Bukti Identitas Aktor pada Rantai Delegasi

Pada DecMed sebelumnya, proses otorisasi berfokus pada pemeriksaan klaim yang terdapat pada token. Namun, mekanisme tersebut belum memastikan bahwa pengirim *request* merupakan aktor yang identitasnya tercantum pada token. Kondisi ini menimbulkan kebutuhan verifikasi tambahan, yaitu verifikasi bukti kepemilikan identitas aktor sebagaimana dirumuskan pada KNF-TA-06.

Identitas pengguna pada DecMed direpresentasikan melalui *wallet* yang dibuat saat pendaftaran akun. *Wallet address* menjadi identifikator unik yang dapat membedakan setiap pengguna pada sistem. Oleh karena itu, *wallet* digunakan sebagai dasar verifikasi identitas aktor yang menggunakan token.

Pada token hasil delegasi, himpunan aktor yang berwenang dibentuk dari *root_subject* dan seluruh *delegated_to* pada rantai delegasi. Verifikasi dilakukan dengan meminta pemohon membuktikan kepemilikan *wallet* yang cocok dengan salah satu aktor pada himpunan tersebut. Dengan mekanisme ini, *request* tidak hanya membawa token otorisasi, tetapi juga membawa bukti bahwa pengirim *request* menguasai *wallet* dari aktor yang tercatat pada rantai. Tanda tangan dari aktor di luar rantai ditolak. Hasil verifikasi ini kemudian digunakan oleh *Server PRE* untuk menentukan apakah pemohon berwenang melanjutkan operasi akses terhadap data RME.

III.2.5.3 Analisis Revokasi dan Audit Delegasi

Delegasi akses menyebabkan token tidak lagi berdiri sendiri, tetapi membentuk relasi antara token induk dan token turunan. Oleh karena itu, mekanisme revokasi pada DecMed perlu diperluas agar pencabutan token induk dapat berdampak pada token turunan yang berasal dari token tersebut. Tanpa pencabutan berantai, aktor yang memperoleh token turunan masih dapat menggunakan akses meskipun akses asalnya telah dicabut oleh pasien.

Revokasi berantai diperlukan untuk mempertahankan kendali pasien sebagai pemilik data. Ketika pasien mencabut akses awal, sistem harus dapat mengenali bahwa token-token turunan yang berada dalam rantai delegasi yang sama tidak lagi memiliki dasar kewenangan yang sah. Dengan demikian, pemeriksaan revokasi tidak cukup hanya dilakukan terhadap token yang dikirim pada saat permintaan akses, tetapi juga perlu mempertimbangkan hubungan token tersebut dengan token asalnya.

Selain revokasi, delegasi juga membutuhkan audit yang mencatat hubungan antaraktor. Audit tidak cukup hanya mencatat bahwa suatu segmen diakses, tetapi juga perlu mencatat sumber kewenangan akses tersebut, termasuk aktor pemberi delegasi, aktor penerima delegasi, waktu delegasi, cakupan akses, dan token yang

Tabel III.8: Daftar Solusi yang Diusulkan Berdasarkan Hasil Analisis

ID	Nama Solusi	Masalah Terkait
S-TA-01	Model kebijakan PBAC dengan adaptasi elemen <i>Policy Machine</i>	M-TA-01
S-TA-02	Segmentasi data RME berdasarkan <i>dataset_category</i> dan <i>function_category</i>	M-TA-02
S-TA-03	Token Macaroons dengan <i>caveats</i> dan atenuasi <i>offline</i> untuk delegasi akses	M-TA-03, M-TA-04
S-TA-04	Penegakan akses pada <i>Server PRE</i> berbasis kebijakan PBAC, kapabilitas efektif, <i>wallet proof</i> , dan metadata	M-TA-01, M-TA-02, M-TA-04, M-TA-05, M-TA-07
S-TA-05	Validasi subrole tenaga medis terhadap dataset untuk operasi tulis	M-TA-05
S-TA-06	Pencabutan akses berantai dan audit log akses dan delegasi	M-TA-06

digunakan. Informasi ini diperlukan agar pasien dan sistem dapat menelusuri bagaimana akses terhadap data RME terbentuk selama proses pelayanan.

III.2.6 Pemetaan Masalah terhadap Solusi

Setelah pendekatan solusi dianalisis, setiap solusi pada bagian ini diberi ID S-TA untuk menjaga ketertelusuran terhadap masalah yang telah diidentifikasi pada Tabel III.2. Daftar solusi utama ditunjukkan pada Tabel III.8.

III.3 Rancangan Solusi

Berdasarkan hasil analisis solusi pada Subbab III.2, rancangan solusi difokuskan pada perluasan kontrol akses DecMed melalui model PBAC, representasi kapabilitas pada token Macaroons, segmentasi data, dan delegasi terbatas. Fondasi utama DecMed tetap dipertahankan pada rancangan ini, yaitu IOTA sebagai penyimpanan *on-chain*, IPFS sebagai penyimpanan *off-chain*, dan PRE sebagai mekanisme distribusi akses terhadap data terenkripsi. Arsitektur sistem, model kebijakan PBAC, token otorisasi berbasis Macaroons, segmentasi data *off-chain*, penegakan otoritas pada *Server PRE*, validasi subrole tenaga medis, pencabutan akses, audit, alur akses data, dan delegasi antar tenaga kesehatan tercakup dalam perancangan ini.

III.3.1 Rancangan Arsitektur Solusi

Keseluruhan arsitektur kerangka kerja DecMed dipertahankan pada arsitektur solusi. Tiga *client* utama DecMed, yaitu *Patient Client*, *Hospital Client*, dan *Ministry Client* tetap ada namun disesuaikan dengan kebutuhan pada Tugas Akhir ini. *Patient Client* digunakan pasien untuk menerbitkan token akses awal. *Hospital Client* digunakan oleh petugas rekam medis, dokter, perawat, apoteker dan petugas laboratorium untuk mengakses atau memperbarui data sesuai kewenangannya. *Ministry Client* tetap berada pada ruang lingkup manajemen fasyankes sebagaimana rancangan DecMed awal.

Perubahan utama berada pada model kebijakan akses PBAC, *server PRE* sebagai titik penegakan kebijakan, token otorisasi berbasis Macaroons sebagai media kapabilitas, dan implementasi *Move smart contract*. Pada rancangan ini, kebijakan akses diperluas agar mencakup aktor, objek RME, hak akses, dan kondisi akses. Sebagian batasan kebijakan direpresentasikan sebagai *caveats* pada Macaroon. Setiap *request* akses data harus menyertakan Macaroon. *Server PRE* kemudian mengevaluasi permintaan terhadap kebijakan akses. Implementasi *Move smart contract* disesuaikan untuk menyimpan metadata yang diperlukan oleh mekanisme segmentasi dan penegakan kebijakan.

Pada rancangan ini, *server PRE* juga berperan sebagai komponen penerbit token turunan Macaroon pada proses delegasi. *Client delegator* mengirimkan permintaan atenuasi kepada *server PRE*. *Server PRE* memverifikasi *request* delegasi. Apabila valid, *server PRE* mengembalikan token turunan untuk diproses lebih lanjut oleh *client delegator* untuk dicatat pada penyimpanan *on-chain*.

Skema penyimpanan *on-chain* dan *off-chain* disesuaikan agar penegakan kebijakan akses dapat didukung sesuai hasil analisis solusi pada Subbab III.2.3. Penyimpanan data pada sistem yang diusulkan dibagi menjadi dua lapisan. Penyimpanan pada lapisan *on-chain* disesuaikan melalui perubahan implementasi *Move smart contract*. Sedangkan penyimpanan pada lapisan *off-chain* disesuaikan melalui perubahan mekanisme penyimpanan data yang diproses pada *hospital client*.

Gambaran arsitektur sistem secara keseluruhan dapat dilihat pada gambar III.1. Warna merah digunakan untuk merepresentasikan komponen yang diubah dari rancangan DecMed awal. Legenda dari diagram arsitektur ini dapat dilihat pada

Tabel III.9: Tabel Pemetaan *Dataset Category*

<i>Dataset Category</i>	<i>Enum Value</i>
Rawat Jalan	RAWAT_JALAN
Rawat Inap	RAWAT_INAP
Laboratorium	LABORATORIUM
Apotek	APOTEK

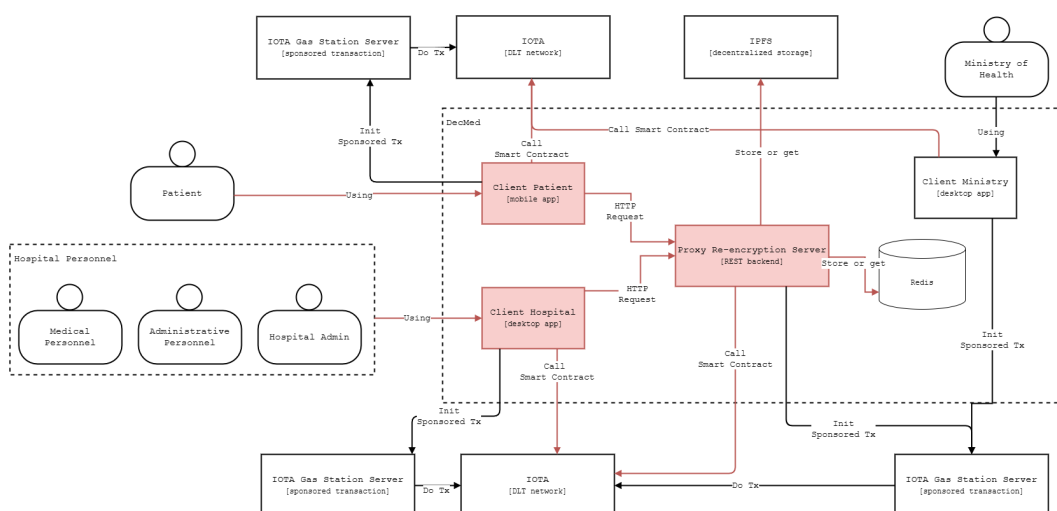
lampiran F.

III.3.2 Rancangan Segmentasi Data RME

Sesuai dengan analisis solusi pada Subbab III.2.6, data klinis dipecah menjadi beberapa segmen terenkripsi pada rancangan segmentasi data RME. Setiap segmen dibentuk berdasarkan kombinasi *dataset category* dan *function category*. *Dataset category* merepresentasikan konteks layanan, seperti Rawat Jalan, Rawat Inap, Laboratorium, dan Apotek. *Function category* merepresentasikan fungsi data di dalam *dataset*, seperti anamnesis, diagnosis, terapi, pemeriksaan penunjang, atau *dispensing*. Kombinasi kedua kategori tersebut menjadi unit data terkecil yang digunakan dalam proses kontrol akses.

Tabel III.9 menunjukkan *dataset category* yang digunakan pada rancangan ini.

Setiap *dataset category* kemudian dibagi lagi berdasarkan *function category*. Kategori fungsi klinis mengacu pada hasil klasifikasi metadata RME yang disajikan pada Lampiran A. Selain fungsi klinis, kategori untuk dokumentasi administratif tetap disediakan pada rancangan ini. Dokumentasi administratif tidak



Gambar III.1: Arsitektur Solusi (Dokumentasi Penulis)

Tabel III.10: Tabel Pemetaan *Function Category*

<i>Function Category</i>	<i>Enum Value</i>
Dokumentasi Administratif	ADMINISTRATIVE_GENERAL
Anamnesis	ANAMNESIS
Pemeriksaan Fisik	PEMERIKSAAN_FISIK
Pemeriksaan Psikologis, Sosial Ekonomi, Spiritual	PEMERIKSAAN_PSIKOLOGIS
Riwayat Penggunaan Obat	RIWAYAT_PENGUNAAN_OBAT
Rencana Rawat	RENCANA_RAWAT
Perencanaan Pemulangan Pasien	PERENCANAAN_PEMULANGAN
Instruksi Medik dan Keperawatan	INSTRUKSI_MEDIK_DAN_KEPERAWATAN
Pemeriksaan Penunjang	PEMERIKSAAN_PENUNJANG
Diagnosis	DIAGNOSIS
<i>Informed Consent</i>	INFORMED_CONSENT
Terapi	TERAPI
Laboratorium	LABORATORIUM
Peresepan	PERESEPAN
<i>Dispensing</i>	DISPENSING

difokuskan pada Tugas Akhir ini, sehingga dokumen administratif dikelompokkan ke dalam satu kategori umum, yaitu ADMINISTRATIVE_GENERAL. Kategori ini tetap disediakan karena beberapa kebutuhan fungsional DecMed masih bergantung pada keberadaan data administratif, khususnya F01, F06, F07, F14, dan F21 pada Tabel di Lampiran C.1.

Tabel III.10 menunjukkan *function category* yang digunakan pada implementasi.

Pada rancangan ini, *function category* tidak selalu dibentuk dari setiap subkelompok metadata secara langsung. Beberapa subkelompok metadata dapat digabung ke dalam satu *function category* selama masih memiliki fungsi pelayanan dan kebutuhan akses yang sama. Sebagai contoh, subkelompok pada *dataset* Laboratorium, seperti permintaan pemeriksaan, spesimen klinis, hasil pemeriksaan, serta interpretasi dan validasi hasil, dikelompokkan ke dalam *function category* LABORATORIUM karena seluruhnya merepresentasikan satu rangkaian fungsi pemeriksaan laboratorium. Sementara itu, *dataset* Apotek dibedakan menjadi PERESEPAN dan DISPENSING karena keduanya merepresentasikan dua fungsi yang berbeda, yaitu pencatatan resep dan proses penyiapan serta penyerahan obat.

Secara penyimpanan, satu entri metadata *on-chain* menunjuk pada satu segmen data terenkripsi di penyimpanan *off-chain*. Rincian skema metadata *on-chain* disajikan pada Tabel G.1, sedangkan skema objek data segmen *off-chain* disajikan pada Tabel G.2.

Dengan rancangan ini, akses pada tingkat segmen dapat ditegakkan oleh *Server PRE*. Ketika aktor meminta akses terhadap data RME, *Server PRE* mencocokkan *caveats* pada token Macaroon dengan metadata segmen yang diminta. Sebagai contoh, token yang hanya mengizinkan akses tulis terhadap *dataset* Laboratorium tidak dapat digunakan untuk menulis segmen pada *dataset* Rawat Jalan.

III.3.3 Rancangan Model PBAC pada DecMed

Berdasarkan hasil analisis pada Subbab III.2.4, elemen dan relasi pada *Policy Machine* diadaptasi pada rancangan kebijakan akses DecMed. Adaptasi ini digunakan untuk memodelkan hubungan antara pengguna, atribut pengguna, segmen RME, atribut segmen, dan hak akses. Informasi yang direpresentasikan melalui *caveat* Macaroon dan kondisi yang diverifikasi oleh *Server PRE* ditentukan berdasarkan model tersebut.

III.3.3.1 Ruang Lingkup Adaptasi Policy Machine

Elemen kebijakan DecMed didefinisikan sebagai:

$$PE_{DecMed} = U \cup UA \cup O \cup OA \cup PC, \quad (III.1)$$

dengan:

U himpunan pengguna;

UA himpunan atribut pengguna;

O himpunan objek yang dilindungi;

OA himpunan atribut objek; dan

PC himpunan kelas kebijakan.

Berdasarkan elemen tersebut, model kebijakan DecMed dirumuskan sebagai:

$$PM_{DecMed} = \langle PE_{DecMed}, AR, ASSIGN, ASSOCIATION, \mathcal{C} \rangle, \quad (III.2)$$

dengan AR sebagai himpunan hak akses, $ASSIGN$ sebagai relasi penugasan, $ASSOCIATION$ sebagai relasi asosiasi hak akses, dan $\mathcal{C}$ sebagai himpunan kondisi

akses DecMed.

Elemen $\mathcal{C}$ merupakan perluasan pada rancangan ini untuk merepresentasikan kondisi dinamis yang ditegakkan melalui Macaroon dan *Server PRE*, seperti masa berlaku, rantai delegasi, revokasi, dan bukti kepemilikan identitas aktor pada rantai delegasi. Elemen tersebut tidak dinyatakan sebagai penambahan terhadap spesifikasi asli *Policy Machine*, tetapi sebagai pemetaan kondisi implementasi yang diperlukan oleh DecMed.

Hanya elemen kebijakan, relasi penugasan, dan asosiasi yang relevan terhadap kontrol akses RME yang diadaptasi. *Prohibition*, *obligation*, fungsi administratif, atau implementasi graf kebijakan *Policy Machine* secara lengkap tidak dicakup pada rancangan ini.

III.3.3.2 Pengguna dan Atribut Pengguna

Himpunan pengguna U berisi pengguna DecMed yang diidentifikasi berdasarkan alamat dompet IOTA:

$$U = u_{\text{pasien}}, u_{\text{petugas-rm}}, u_{\text{perawat}}, u_{\text{dokter}}, u_{\text{laboratorium}}, u_{\text{apoteker}}. \quad (\text{III.3})$$

Elemen pada himpunan tersebut merepresentasikan alamat dompet aktual, bukan hanya nama peran. Sebagai contoh, $u_{\text{dokter-A}}$ dan $u_{\text{dokter-B}}$ merupakan dua pengguna yang berbeda meskipun keduanya memiliki atribut *subrole* dokter.

Atribut pengguna dibagi menjadi atribut kelembagaan dan atribut kapabilitas:

$$UA = UA_{\text{role}} \cup UA_{\text{capability}}. \quad (\text{III.4})$$

Atribut kelembagaan menyatakan *role* atau *subrole* pengguna yang tercatat pada penyimpanan *on-chain*:

$$UA_{\text{role}} = ua_{\text{patient}}, ua_{\text{administrative-personnel}}, ua_{\text{nurse}}, ua_{\text{doctor}}, ua_{\text{laboratory}}, ua_{\text{pharmacist}}. \quad (\text{III.5})$$

Relasi penugasan pengguna terhadap atribut perannya dinyatakan sebagai:

$$u; ASSIGN; ua_{role(u)}. \quad (III.6)$$

Atribut kapabilitas merupakan abstraksi terhadap kapabilitas efektif yang diperoleh dari suatu token Macaroon. Untuk token τ , atribut kapabilitasnya dinyatakan sebagai:

$$ua_{cap(\tau)} \in UA_{capability}. \quad (III.7)$$

Atribut tersebut tidak disimpan sebagai simpul graf kebijakan pada IOTA. Atribut kapabilitas dibentuk secara konseptual ketika *Server* PRE mengevaluasi token dan membentuk himpunan subjek dari *root_subject* serta seluruh *delegated_to* pada rantai delegasi. Pengguna hanya dianggap memiliki atribut kapabilitas apabila pengguna tersebut termasuk dalam himpunan subjek token dan dapat membuktikan kepemilikan alamat dompetnya:

$$u; ASSIGN; ua_{cap(\tau)} \iff \text{ContainsSubject}(\tau, u) \wedge \text{WalletProofValid}(u). \quad (III.8)$$

Pemisahan atribut peran dan atribut kapabilitas diperlukan karena keduanya memiliki fungsi yang berbeda. Atribut kapabilitas menentukan cakupan data yang diberikan melalui token, sedangkan atribut peran menentukan apakah pengguna masih memiliki kewenangan kelembagaan yang sesuai. Dengan demikian, kepemilikan *subrole* dokter tidak secara otomatis memberikan akses terhadap seluruh RME pasien.

III.3.3.3 Objek dan Atribut Objek

Himpunan objek O terdiri atas segmen RME terenkripsi yang disimpan pada IPFS:

$$O = o_1, o_2, \dots, o_n. \quad (III.9)$$

Setiap objek merepresentasikan satu segmen klinis. Informasi mengenai objek, seperti pasien, episode RME, kategori dataset, kategori fungsi, dan CID data

terenkripsi, direpresentasikan melalui metadata pada IOTA.

Atribut objek OA digunakan untuk mengelompokkan segmen berdasarkan beberapa tingkat berikut:

1. rumah sakit;
2. pasien;
3. episode RME;
4. kategori dataset; dan
5. kategori fungsi klinis.

Hubungan objek dan atribut objek membentuk hierarki:

$$o_s; ASSIGN; oa_{f(s)}; ASSIGN; oa_{d(s)}; ASSIGN; oa_{r(s)}; ASSIGN; oa_{p(s)}; ASSIGN; oa_{h(s)}; ASSIGN; pc_{DecN} \quad (III.10)$$

dengan:

$f(s)$ kategori fungsi dari segmen s ;

$d(s)$ kategori dataset dari segmen s ;

$r(s)$ identitas episode RME;

$p(s)$ alamat pasien pemilik RME; dan

$h(s)$ rumah sakit tempat episode pelayanan berlangsung.

Atribut kategori fungsi dan dataset harus dibentuk dalam konteks pasien atau episode RME tertentu. Sebagai contoh, atribut diagnosis pada RME milik pasien A berbeda dengan atribut diagnosis pada RME milik pasien B. Pemisahan tersebut diperlukan agar asosiasi terhadap fungsi diagnosis pada satu RME tidak memberikan akses terhadap fungsi diagnosis pada seluruh pasien.

Contoh relasi penugasan untuk satu segmen diagnosis adalah:

$$\begin{aligned}
& o_{\text{diagnosis-17}}; \text{ASSIGN}; oa_{\text{diagnosis-RME-17}} \\
& \quad ; \text{ASSIGN}; oa_{\text{rawat-jalan-RME-17}} \\
& \quad ; \text{ASSIGN}; oa_{\text{RME-17}} \\
& \quad ; \text{ASSIGN}; oa_{\text{pasien-P}} \\
& \quad ; \text{ASSIGN}; oa_{\text{rumah-sakit-H}} \\
& \quad ; \text{ASSIGN}; pc_{\text{DecMed}}.
\end{aligned} \tag{III.11}$$

Himpunan kategori dataset yang digunakan pada rancangan ini adalah:

$$D = \text{RAWAT_JALAN}, \text{RAWAT_INAP}, \text{LABORATORIUM}, \text{APOTEK}. \tag{III.12}$$

Sementara itu, kategori fungsi mengikuti segmentasi data yang telah dijelaskan pada Subbab III.3.2, seperti anamnesis, pemeriksaan fisik, pemeriksaan psikologis, diagnosis, pemeriksaan penunjang, terapi, laboratorium, persepan, dan *dispensing*.

III.3.3.4 Hak Akses dan Asosiasi

Himpunan hak akses yang digunakan adalah:

$$AR = \text{Read}, \text{Update}. \tag{III.13}$$

Hak Read menyatakan kemampuan membaca segmen RME, sedangkan hak Update menyatakan kemampuan menulis atau memperbarui segmen. Pada implementasi token, hak tersebut direpresentasikan melalui *caveat* purpose. Cakupan objeknya direpresentasikan melalui `read_dataset_in`, `write_dataset_in`, `read_function_in`, dan `write_function_in`.

Pada *Policy Machine*, asosiasi dinyatakan sebagai hubungan antara atribut pengguna, himpunan hak akses, dan atribut target:

$$(ua, ars, oa) \in \text{ASSOCIATION}. \tag{III.14}$$

Dalam rancangan DecMed, asosiasi dibentuk secara konseptual dari kapabilitas efektif token:

$$(ua_{\text{cap}}(\tau), AR_{\text{eff}}(\tau), OA_{\text{scope}}(\tau)) \in ASSOCIATION. \quad (\text{III.15})$$

$AR_{\text{eff}}(\tau)$ merupakan hak akses efektif token, sedangkan $OA_{\text{scope}}(\tau)$ merupakan himpunan atribut objek yang termasuk dalam cakupan token.

Cakupan objek token didefinisikan sebagai:

$$\begin{aligned} \text{Scope}(\tau) = \{o_s \in O \mid & p(s) = \text{Patient}(\tau) \\ & \wedge h(s) = \text{Hospital}(\tau) \\ & \wedge d(s) \in D_{\text{eff}}(\tau) \\ & \wedge f(s) \in F_{\text{eff}}(\tau) \\ & \wedge (\text{Purpose}(\tau) = \text{Update} \Rightarrow r(s) = \text{RME}(\tau))\}. \end{aligned} \quad (\text{III.16})$$

$D_{\text{eff}}(\tau)$ merupakan irisan seluruh batasan kategori dataset pada token, sedangkan $F_{\text{eff}}(\tau)$ merupakan irisan seluruh batasan kategori fungsi:

$$D_{\text{eff}}(\tau) = \bigcap_{i=1}^n D_i, \quad (\text{III.17})$$

$$F_{\text{eff}}(\tau) = \bigcap_{i=1}^m F_i. \quad (\text{III.18})$$

Penggunaan operasi irisan memastikan bahwa penambahan *caveat* pada token turunan hanya dapat mempertahankan atau mempersempit cakupan akses. Penambahan batasan baru tidak dapat mengembalikan kategori dataset atau fungsi yang telah dikecualikan oleh token induk.

Untuk operasi Read, token dapat digunakan terhadap seluruh episode RME pasien yang termasuk dalam kategori dataset dan fungsi yang diizinkan. Untuk operasi Update, cakupan juga harus sesuai dengan `related_rme_id` sehingga perubahan hanya dapat dilakukan terhadap episode pelayanan yang sedang menjadi konteks token.

Tabel III.11: Kondisi Kebijakan Akses DecMed

Kondisi	Representasi	Fungsi
Identitas pasien	<code>patient_address</code>	Membatasi token pada data milik pasien tertentu.
Rumah sakit	<code>hospital_cid</code>	Membatasi penggunaan token pada konteks rumah sakit tertentu.
Episode RME	<code>related_rme_id</code>	Membatasi operasi Update pada episode RME tertentu.
Subjek rantai delegasi	<code>root_subject</code> dan seluruh <code>delegated_to</code>	Menentukan himpunan alamat dompet yang berwenang menggunakan token.
Identitas aktor pemohon	<i>Wallet proof</i>	Membuktikan bahwa permintaan ditandatangani oleh salah satu subjek rantai.
Masa berlaku	<code>expires_before</code>	Membatasi waktu penggunaan token.
Kedalaman delegasi	<code>max_delegation_depth</code> dan rantai delegasi	Membatasi jumlah penurunan token.
Hubungan token	<code>parent_token_hash</code>	Menghubungkan token turunan dengan token induk untuk revokasi.
Otoritas kelembagaan	<i>Role</i> dan <i>subrole</i> pada IOTA	Membatasi operasi tulis sesuai kewenangan tenaga medis.
Status revokasi	Catatan revokasi	Menolak token awal atau token turunan yang telah dicabut.

III.3.3.5 Kondisi Kebijakan Akses

Selain asosiasi antara kapabilitas dan objek, keputusan akses juga dipengaruhi oleh himpunan kondisi $\mathcal{C}$. Kondisi yang digunakan pada DecMed ditunjukkan pada Tabel III.11.

Masa berlaku efektif token merupakan nilai paling awal dari seluruh *caveat* `expires_before`:

$$Expiry_{\text{eff}}(\tau) = \min Expiry_1, Expiry_2, \dots, Expiry_n. \quad (\text{III.19})$$

Himpunan subjek yang berwenang menggunakan token ditentukan berdasarkan rantai delegasi:

$$\text{Subjects}(\tau) = \{\text{root_subject}(\tau)\} \cup \{\text{delegated_to}_i(\tau) \mid 1 \leq i \leq n\}, \quad (\text{III.20})$$

dan permintaan dari aktor u hanya diterima apabila:

$$\text{ContainsSubject}(\tau, u) \iff u \in \text{Subjects}(\tau). \quad (\text{III.21})$$

Kedalaman delegasi dihitung berdasarkan jumlah perpindahan aktor pada rantai delegasi dan harus memenuhi:

$$\text{Depth}(\tau) \leq \text{MaxDepth}(\tau). \quad (\text{III.22})$$

III.3.3.6 Rancangan Kebijakan Delegasi

Delegasi dimodelkan sebagai pembentukan kapabilitas turunan τ_c dari kapabilitas induk τ_p . Token turunan hanya valid apabila tidak memperluas hak akses token induk.

Hubungan cakupan token harus memenuhi:

$$\text{Scope}(\tau_c) \subseteq \text{Scope}(\tau_p). \quad (\text{III.23})$$

Hak akses token turunan juga harus memenuhi:

$$\text{AR}_{\text{eff}}(\tau_c) \subseteq \text{AR}_{\text{eff}}(\tau_p). \quad (\text{III.24})$$

Batas waktu token turunan tidak boleh melebihi batas waktu token induk:

$$\text{Expiry}_{\text{eff}}(\tau_c) \leq \text{Expiry}_{\text{eff}}(\tau_p). \quad (\text{III.25})$$

Selain itu, token turunan harus tetap berada dalam konteks pasien dan rumah sakit yang sama:

$$Patient(\tau_c) = Patient(\tau_p), \quad (III.26)$$

$$Hospital(\tau_c) = Hospital(\tau_p). \quad (III.27)$$

Untuk token dengan operasi Update, episode RME token turunan juga tidak boleh berbeda dari token induk:

$$RME(\tau_c) = RME(\tau_p). \quad (III.28)$$

Hubungan antara token turunan dan token induk disimpan melalui `parent_token_hash`. Sementara itu, perubahan aktor direpresentasikan dengan menambahkan `delegated_by` dan `delegated_to`. Karena seluruh *caveat* token induk tetap dipertahankan, proses delegasi hanya dapat menambahkan batasan baru dan tidak dapat menghapus batasan sebelumnya.

III.3.3.7 Fungsi Keputusan Akses

Suatu permintaan akses terhadap segmen RME direpresentasikan sebagai:

$$q = \langle u, h, p, r, d, f, a, t, \tau, \pi \rangle, \quad (III.29)$$

dengan:

u alamat dompet pengguna yang melakukan permintaan;

h identitas rumah sakit;

p alamat pasien;

r identitas episode RME;

d kategori dataset;

f kategori fungsi;

a operasi yang diminta;

t waktu permintaan;

τ token Macaroon; dan

π bukti kepemilikan *wallet*.

Permintaan diberikan apabila seluruh kondisi kebijakan terpenuhi:

$$\begin{aligned}
\text{Permit}(q) \iff & \text{TokenValid}(\tau) \\
& \wedge \text{PurposeMatch}(a, \tau) \\
& \wedge \text{ContainsSubject}(\tau, u) \\
& \wedge \text{WalletProofValid}(\pi, q, u) \\
& \wedge \text{PatientMatch}(p, \tau) \\
& \wedge \text{HospitalMatch}(h, \tau) \\
& \wedge \text{DatasetAllowed}(d, \tau) \\
& \wedge \text{FunctionAllowed}(f, \tau) \\
& \wedge \text{TimeValid}(t, \tau) \\
& \wedge \text{DelegationChainValid}(\tau) \\
& \wedge \neg \text{Revoked}(\tau) \\
& \wedge (a \neq \text{Update} \vee \text{RoleScopeValid}(u, d, f)) \\
& \wedge (a \neq \text{Update} \vee \text{RmeMatch}(r, \tau)).
\end{aligned} \tag{III.30}$$

Apabila salah satu kondisi tidak terpenuhi, keputusan akses adalah:

$$\text{Decision}(q) = \text{Deny}. \tag{III.31}$$

Prinsip *deny by default* diterapkan melalui fungsi tersebut. Kepemilikan token saja tidak cukup untuk memperoleh akses. Token harus valid, permintaan harus berasal dari salah satu aktor pada rantai delegasi, objek harus berada dalam cakupan token, token tidak boleh kedaluwarsa atau direvokasi, dan operasi tulis harus sesuai dengan *subrole* tenaga medis.

Tabel III.12: Pemetaan Model Kebijakan terhadap Komponen DecMed

Elemen	Representasi DecMed	Sumber atau Mekanisme Implementasi
U	Pengguna berdasarkan <i>wallet address</i>	<i>wallet address</i> dan tanda tangan <i>wallet</i> .
UA_{role}	<i>Role</i> dan <i>subrole</i> pengguna	<i>Registry Personnel</i> pada IOTA.
$UA_{capability}$	Kapabilitas efektif pengguna	Token Macaroon dan rantai delegasi.
O	Segmen RME terenkripsi	Objek data pada IPFS.
OA	Rumah sakit, pasien, RME, dataset, dan fungsi	Metadata segmen pada IOTA.
PC	Kelas kebijakan DecMed	Aturan kontrol akses yang diberlakukan pada sistem DecMed.
AR	Operasi Read dan Update	purpose dan batasan baca atau tulis pada Macaroon.
$ASSIGN$	Penugasan pengguna ke peran dan segmen ke kategori	Registri personel serta struktur metadata segmen.
$ASSOCIATION$	Hubungan kapabilitas dengan hak dan cakupan objek	<i>Effective capability</i> hasil evaluasi <i>caveat</i> .
$\mathcal{C}$	Masa berlaku, delegasi, revokasi, dan bukti identitas	Macaroon, <i>wallet proof</i> , Redis, IOTA, dan fungsi verifikasi PRE.

III.3.3.8 Pemetaan Model Kebijakan ke Komponen DecMed

Pemetaan elemen model kebijakan terhadap komponen implementasi ditunjukkan pada Tabel III.12.

Berdasarkan rancangan tersebut, model CapBAC yang telah digunakan oleh DecMed tidak digantikan oleh model PBAC. Macaroon tetap berfungsi sebagai token kapabilitas yang dibawa oleh pengguna, sedangkan elemen dan kondisi yang harus diperiksa untuk menafsirkan kapabilitas tersebut ditentukan oleh model PBAC. Dengan demikian, cara otoritas dibawa oleh token dijelaskan melalui CapBAC, sedangkan kebijakan yang menentukan validitas penggunaan otoritas tersebut dijelaskan melalui PBAC.

Rincian representasi kebijakan dalam bentuk *caveat* dijelaskan pada Subbab III.3.4. Mekanisme evaluasi dan penegakannya pada *Server PRE* dijelaskan pada Subbab III.3.5.

III.3.4 Rancangan Representasi Kebijakan pada Token Macaroons

Berdasarkan model PBAC pada Subbab III.3.3, keputusan akses pada DecMed ditentukan berdasarkan hubungan antara pengguna, atribut pengguna, objek, atribut objek, hak akses, dan kondisi akses. Model tersebut masih berada pada tingkat konseptual sehingga membutuhkan representasi yang dapat dibawa oleh pengguna dan diverifikasi pada saat permintaan akses dilakukan.

Pada rancangan ini, Macaroon digunakan untuk merepresentasikan kapabilitas dan sebagian kondisi kebijakan akses. Token memuat identitas aktor yang berwenang menggunakan kapabilitas, cakupan objek yang dapat diakses, hak akses yang diberikan, masa berlaku, dan batasan delegasi. Namun, token tidak memuat seluruh keadaan kebijakan DecMed. Atribut kelembagaan pengguna, metadata objek, status revokasi, dan bukti kepemilikan alamat dompet diperoleh atau diverifikasi dari komponen sistem lain.

Dengan demikian, pembagian representasi kebijakan pada DecMed adalah sebagai berikut:

1. Macaroon merepresentasikan atribut kapabilitas pengguna, hak akses, cakupan objek, masa berlaku, dan rantai delegasi.
2. Penyimpanan *on-chain* IOTA menyediakan atribut kelembagaan pengguna serta metadata pasien, rumah sakit, episode RME, kategori dataset, dan kategori fungsi dari objek.
3. Redis menyediakan informasi yang diperlukan untuk memeriksa status revokasi token.
4. Tanda tangan permintaan atau bukti kepemilikan *wallet* mengikat penggunaan token dengan alamat dompet salah satu aktor pada rantai delegasi.
5. *Server* PRE menggabungkan seluruh informasi tersebut untuk menghasilkan keputusan *permit* atau *deny*.

Macaroon tetap mengikuti model *Capability-Based Access Control* karena token berfungsi sebagai bukti kapabilitas yang dibawa oleh pengguna. Sementara

itu, aturan yang digunakan untuk menafsirkan dan memvalidasi kapabilitas tersebut ditentukan oleh model PBAC. Oleh karena itu, PBAC dan CapBAC tidak diposisikan sebagai dua pendekatan yang saling menggantikan. Kebijakan akses didefinisikan melalui PBAC, sedangkan Macaroon menjadi media pembawa kapabilitas yang dibatasi oleh kebijakan tersebut.

III.3.4.1 Struktur Kapabilitas Efektif Token

Sebuah token Macaroon τ secara konseptual terdiri atas identitas token, himpunan *caveat*, dan tanda tangan autentikasi:

$$\tau = \langle id_\tau, C_\tau, \sigma_\tau \rangle, \quad (III.32)$$

dengan id_τ sebagai identitas token, C_τ sebagai himpunan *caveat*, dan σ_τ sebagai tanda tangan Macaroon.

Himpunan *caveat* pada token dievaluasi untuk membentuk kapabilitas efektif:

$$Cap_{\text{eff}}(\tau) = \langle U_{\text{subj}}(\tau), h, p, r, D_{\text{eff}}, F_{\text{eff}}, AR_{\text{eff}}, t_{\text{exp}}, depth \rangle, \quad (III.33)$$

dengan:

$U_{\text{subj}}(\tau)$ himpunan aktor yang berwenang menggunakan token berdasarkan rantai delegasi;

h rumah sakit yang menjadi konteks token;

p pasien pemilik data;

r episode RME yang dibatasi oleh token apabila berlaku;

D_{eff} himpunan kategori dataset efektif;

F_{eff} himpunan kategori fungsi efektif;

AR_{eff} hak akses efektif;

t_{exp} batas waktu efektif token; dan

$depth$ kedalaman rantai delegasi.

Kapabilitas efektif tersebut merupakan representasi dari atribut kapabilitas $ua_{cap}(\tau)$ dan asosiasi hak akses yang telah didefinisikan pada Subbab III.3.3. Token tidak secara langsung menyimpan objek RME, tetapi menyimpan batasan yang akan dicocokkan dengan atribut objek pada metadata segmen.

III.3.4.2 Pemetaan Elemen Kebijakan ke Caveat

Pemetaan elemen kebijakan PBAC terhadap *caveat* Macaroon ditunjukkan pada Tabel III.13.

Tabel III.13: Pemetaan Elemen Kebijakan ke *Caveat* Macaroon

Elemen Kebijakan	<i>Caveat</i>	Fungsi	Token
Hak akses	purpose	Menyatakan operasi yang diizinkan, yaitu Read atau Update.	Keduanya
Atribut objek: pasien	patient_address	Membatasi kapabilitas terhadap RME milik pasien tertentu.	Keduanya
Atribut objek: rumah sakit	hospital_cid	Membatasi penggunaan kapabilitas pada konteks rumah sakit tertentu.	Keduanya
Atribut objek: episode RME	related_rme_id	Membatasi operasi perubahan data pada satu episode RME.	Update
Atribut kapabilitas: penerima awal	root_subject	Menyatakan alamat dompet penerima token awal dari pasien.	Keduanya
Rantai delegasi	delegated_by	Menyatakan alamat dompet aktor yang menurunkan token.	Turunan
Rantai delegasi	delegated_to	Menyatakan alamat dompet penerima token turunan.	Turunan
Cakupan objek baca	read_dataset_in	Membatasi kategori dataset yang dapat dibaca.	Read
Cakupan objek tulis	write_dataset_in	Membatasi kategori dataset yang dapat ditulis atau diperbarui.	Update

Elemen Kebijakan	<i>Caveat</i>	Fungsi	Token
Cakupan objek baca	read_function_in	Membatasi kategori fungsi klinis yang dapat dibaca.	Read
Cakupan objek tulis	write_function_in	Membatasi kategori fungsi klinis yang dapat ditulis atau diperbarui.	Update
Kondisi waktu	expires_before	Menentukan batas waktu maksimum penggunaan kapabilitas.	Keduanya
Kondisi delegasi	max_delegation_depth	Membatasi jumlah penurunan kapabilitas yang masih diizinkan.	Keduanya
Hubungan token	parent_token_hash	Menghubungkan token turunan dengan token induknya untuk pemeriksaan rantai dan revokasi.	Turunan

Nama *caveat* purpose dipertahankan untuk menjaga kompatibilitas dengan implementasi DecMed sebelumnya. Namun, karena nilai yang digunakan adalah Read dan Update, secara semantik *caveat* tersebut merepresentasikan hak akses AR.

III.3.4.3 Pemisahan Kebijakan di Dalam dan di Luar Token

Tidak seluruh elemen kebijakan disimpan sebagai *caveat* agar token tidak menjadi satu-satunya sumber kebenaran mengenai kondisi pengguna dan objek. Pemetaan elemen kebijakan yang diperiksa dari luar token ditunjukkan pada Tabel III.14.

III.3.4.4 Rancangan Token Read dan Update

Implementasi DecMed sebelumnya menggunakan dua token terpisah untuk operasi baca dan perubahan data. Pola tersebut dipertahankan untuk menjaga kompatibilitas dengan *smart contract*, *client*, penyimpanan metadata akses, dan *Server PRE*.

Token baca memiliki:

Tabel III.14: Elemen Kebijakan yang Diverifikasi di Luar Token

Elemen	Sumber	Fungsi
<i>Role</i> dan <i>subrole</i>	Registri personel pada IOTA	Memastikan aktor masih mempunyai kewenangan kelembagaan yang sesuai dengan operasi dan kategori data.
Atribut objek	Metadata segmen pada IOTA	Menyediakan pasien, rumah sakit, episode RME, kategori dataset, dan kategori fungsi aktual dari segmen.
Kepemilikan alamat dompet	Tanda tangan permintaan atau <i>wallet proof</i>	Memastikan pemohon merupakan salah satu aktor yang tercatat pada rantai delegasi token.
Status revokasi	Redis dan hubungan <i>parent_token_hash</i>	Memastikan token dan token induknya belum dicabut.
Data terenkripsi	IPFS dan material kunci PRE	Memastikan data hanya dapat dipulihkan setelah kebijakan akses terpenuhi.

$$AR_{\text{eff}}(\tau_{\text{read}}) = \text{Read}, \quad (\text{III.34})$$

sedangkan token perubahan data memiliki:

$$AR_{\text{eff}}(\tau_{\text{update}}) = \text{Update}. \quad (\text{III.35})$$

Token baca menggunakan `read_dataset.in` dan `read_function.in`. Token perubahan data menggunakan `write_dataset.in` dan `write_function.in`. Pemisahan tersebut mencegah token baca digunakan sebagai dasar operasi tulis meskipun kategori dataset atau kategori fungsi yang diminta sama.

Pada token Read, `related_rme_id` tidak diwajibkan. Token baca dapat digunakan untuk membaca episode RME pasien yang berada pada rumah sakit, kategori dataset, dan kategori fungsi yang diizinkan. Dengan rancangan ini, kebutuhan tenaga medis, terutama dokter, untuk meninjau riwayat RME pasien ketika menentukan tindakan klinis didukung.

Pada token Update, `related_rme_id` wajib disertakan. Token tersebut hanya dapat digunakan untuk menulis atau memperbarui segmen pada episode pelayanan yang dinyatakan oleh *caveat*. Pembatasan ini mencegah tenaga medis memperbarui episode RME lain hanya karena masih memiliki akses terhadap pasien yang sama.

Nilai `related_rme_id` menggunakan format `RME- $\{sequence\_6\_digit\}$` , misalnya `RME-000001`. Format tersebut mengikuti implementasi DecMed sebelumnya dan digunakan sebagai identitas episode RME pada prototipe.

III.3.4.5 Rancangan Subjek Rantai Delegasi

Caveat `holder_address` tidak digunakan pada rancangan token untuk menyatakan pemegang token tunggal. Hal ini disebabkan oleh sifat *append-only* pada Macaroon. Apabila token awal memuat:

```
holder_address = 0xPETUGAS_REKAM_MEDIS
```

kemudian token turunan menambahkan:

```
holder_address = 0xDOKTER
```

maka token akan memiliki dua batasan identitas yang tidak dapat dipenuhi secara bersamaan. *Caveat* lama tidak dapat dihapus atau diganti ketika token diturunkan.

Sebagai gantinya, aktor yang berwenang menggunakan token ditentukan dari rantai delegasi. `root_subject` menyatakan aktor penerima token awal, sedangkan setiap proses delegasi menambahkan pasangan `delegated_by` dan `delegated_to`. Himpunan subjek token didefinisikan sebagai:

$$\text{Subjects}(\tau) = \{\text{root_subject}(\tau)\} \cup \{\text{delegated_to}_i(\tau) \mid 1 \leq i \leq n\}, \quad (\text{III.36})$$

dengan n sebagai jumlah langkah delegasi pada token. Dengan demikian, seluruh aktor yang tercatat pada rantai delegasi berwenang menggunakan token tersebut, sepanjang mampu membuktikan kepemilikan *wallet* masing-masing. Tanda tangan dari aktor di luar $\text{Subjects}(\tau)$ ditolak.

Untuk setiap pasangan delegasi ke- i , rantai harus memenuhi:

$$\text{delegated_by}_i = \begin{cases} \text{root_subject}, & i = 1, \\ \text{delegated_to}_{i-1}, & i > 1. \end{cases} \quad (\text{III.37})$$

Pemeriksaan keanggotaan subjek dinyatakan sebagai:

$$\text{ContainsSubject}(\tau, u) \iff u \in \text{Subjects}(\tau). \quad (\text{III.38})$$

III.3.4.6 Penerbitan Token Awal

Pada rancangan ini, *Server PRE* bertindak sebagai penerbit token awal dan menyimpan *RootKey* yang digunakan untuk membentuk tanda tangan Macaroon. *RootKey* disimpan pada *environment variable* *Server PRE* dan tidak pernah diberikan kepada *client*.

Token awal diterbitkan setelah alur pemberian akses oleh pasien telah terpenuhi. Pasien menentukan penerima awal, rumah sakit, cakupan kategori dataset, cakupan kategori fungsi, hak akses, masa berlaku, dan batas delegasi. Informasi tersebut menjadi dasar pembentukan *caveat* pada token awal.

Alur penerbitan token awal adalah sebagai berikut:

1. Pasien memilih aktor penerima dan cakupan akses.
2. *Client* pasien membentuk permintaan pemberian akses.
3. *Server PRE* memvalidasi identitas pasien dan parameter akses.
4. *Server PRE* membentuk token Macaroon menggunakan *RootKey*.
5. Token dan metadata akses dicatat sesuai mekanisme pemberian akses DecMed.
6. Token dapat digunakan oleh aktor yang ditentukan sebagai *root.subject*.

Pemisahan antara pasien dan penerbit token tidak menghilangkan sifat *patient-centric*. Pasien tetap menjadi pihak yang menentukan pemberian akses awal, sedangkan *Server PRE* menjalankan fungsi kriptografis untuk membentuk token yang dapat diverifikasi secara konsisten.

III.3.4.7 Atenuasi Token sebagai Realisasi Delegasi

Delegasi diwujudkan melalui pembentukan token turunan dengan penambahan *caveat*. Pada rancangan ini, *client* delegator tidak membentuk token turunan secara mandiri. *Client* mengirimkan token induk, alamat penerima, cakupan yang diminta, masa berlaku, dan bukti identitas delegator kepada *Server PRE*.

Server PRE kemudian:

1. memverifikasi tanda tangan dan seluruh *caveat* token induk;
2. membentuk himpunan subjek rantai delegasi token induk;
3. memverifikasi bahwa permintaan berasal dari salah satu subjek pada rantai tersebut;
4. memeriksa status revokasi token induk;
5. memeriksa batas kedalaman delegasi;
6. memastikan cakupan token turunan tidak melebihi token induk;
7. menambahkan *delegated_by*, *delegated_to*, dan *parent_token_hash*;
8. menambahkan batasan dataset, fungsi, masa berlaku, atau kedalaman delegasi yang lebih sempit; dan
9. menghasilkan token turunan.

Token turunan τ_c dari token induk τ_p harus memenuhi:

$$D_{\text{eff}}(\tau_c) \subseteq D_{\text{eff}}(\tau_p), \quad (\text{III.39})$$

$$F_{\text{eff}}(\tau_c) \subseteq F_{\text{eff}}(\tau_p), \quad (\text{III.40})$$

$$AR_{\text{eff}}(\tau_c) \subseteq AR_{\text{eff}}(\tau_p), \quad (\text{III.41})$$

dan:

$$\text{Expiry}_{\text{eff}}(\tau_c) \leq \text{Expiry}_{\text{eff}}(\tau_p). \quad (\text{III.42})$$

Pasien dan rumah sakit pada token turunan tidak dapat diubah:

$$\text{Patient}(\tau_c) = \text{Patient}(\tau_p), \quad (\text{III.43})$$

$$Hospital(\tau_c) = Hospital(\tau_p). \quad (III.44)$$

Untuk token Update, identitas episode RME juga harus tetap sama:

$$RME(\tau_c) = RME(\tau_p). \quad (III.45)$$

Sifat *append-only* pada Macaroon memastikan seluruh *caveat* token induk tetap terdapat pada token turunan. Nilai efektif dari batasan kategori dataset dan fungsi diperoleh melalui irisan seluruh batasan:

$$D_{\text{eff}}(\tau) = \bigcap_{i=1}^n D_i, \quad (III.46)$$

$$F_{\text{eff}}(\tau) = \bigcap_{i=1}^m F_i. \quad (III.47)$$

Batas waktu efektif diperoleh dari nilai paling awal:

$$Expiry_{\text{eff}}(\tau) = \min Expiry_1, Expiry_2, \dots, Expiry_n. \quad (III.48)$$

Dengan demikian, penambahan *caveat* hanya dapat mempertahankan atau mempersempit kapabilitas. Token turunan tidak dapat menghapus batasan token induk untuk memperoleh cakupan akses yang lebih luas.

III.3.4.8 Pembatasan Kedalaman dan Hubungan Token

Caveat `max_delegation_depth` menyatakan batas maksimum delegasi pada token. Kedalaman aktual dihitung dari jumlah pasangan `delegated_by` dan `delegated_to` pada rantai delegasi.

Token hanya dapat diturunkan apabila:

$$Depth(\tau) < MaxDepth_{\text{eff}}(\tau). \quad (III.49)$$

Token turunan dapat menambahkan nilai `max_delegation_depth` yang lebih kecil

untuk mengurangi kemampuan delegasi lebih lanjut. Nilai efektifnya diperoleh dari nilai minimum seluruh batasan kedalaman yang terdapat pada token.

Caveat `parent_token_hash` hanya ditambahkan pada token turunan. Nilainya merupakan *hash* token induk dan digunakan untuk membentuk hubungan antar-token. Hubungan tersebut mendukung pemeriksaan rantai delegasi dan mekanisme revokasi hierarkis.

III.3.4.9 Penerapan Whitelisting dan Least Privilege

Pendekatan *whitelisting* digunakan untuk pembatasan kategori data. Token harus secara eksplisit mencantumkan kategori dataset dan kategori fungsi yang diizinkan. Kategori yang tidak dicantumkan dianggap tidak termasuk dalam cakupan token.

Pada token baca, sebuah segmen o_s termasuk dalam cakupan apabila:

$$\begin{aligned} o_s \in \text{Scope}(\tau_{\text{read}}) &\iff p(s) = \text{Patient}(\tau) \\ &\wedge h(s) = \text{Hospital}(\tau) \\ &\wedge d(s) \in D_{\text{eff}}(\tau) \\ &\wedge f(s) \in F_{\text{eff}}(\tau). \end{aligned} \tag{III.50}$$

Pada token perubahan data, syarat tersebut ditambah dengan kesesuaian episode RME:

$$\begin{aligned} o_s \in \text{Scope}(\tau_{\text{update}}) &\iff p(s) = \text{Patient}(\tau) \\ &\wedge h(s) = \text{Hospital}(\tau) \\ &\wedge r(s) = \text{RME}(\tau) \\ &\wedge d(s) \in D_{\text{eff}}(\tau) \\ &\wedge f(s) \in F_{\text{eff}}(\tau). \end{aligned} \tag{III.51}$$

Prinsip *least privilege* didukung oleh pendekatan ini. Dokter dapat memperoleh kapabilitas yang relatif luas sesuai kebutuhan pelayanan klinis, tetapi token turunan untuk petugas laboratorium atau apoteker dapat dibatasi hanya pada objek yang

relevan.

Sebagai contoh, petugas laboratorium dapat memperoleh hak membaca fungsi PEMERIKSAAN_PENUNJANG pada dataset RAWAT_JALAN dan hak memperbarui fungsi LABORATORIUM pada dataset LABORATORIUM. Petugas tersebut tidak memperoleh akses terhadap anamnesis, diagnosis, terapi, resep, atau fungsi klinis lain yang tidak dicantumkan dalam token.

III.3.4.10 Hubungan dengan Proses Verifikasi

Token Macaroon bukan satu-satunya masukan keputusan akses. Pada saat token digunakan, *Server* PRE membentuk kapabilitas efektif dengan memproses seluruh *caveat*, kemudian mencocokkannya dengan permintaan, metadata objek, atribut pengguna, status revokasi, dan bukti kepemilikan *wallet* dari aktor yang tercatat pada rantai delegasi.

Secara konseptual, penggunaan token hanya valid apabila:

$$\begin{aligned} \text{TokenUsable}(\tau, q) \iff & \text{SignatureValid}(\tau) \\ & \wedge \text{ContainsSubject}(\tau, u) \\ & \wedge \text{ObjectScopeMatch}(\tau, q) \\ & \wedge \text{AccessRightMatch}(\tau, q) \\ & \wedge \text{TimeValid}(\tau) \\ & \wedge \text{DelegationValid}(\tau) \\ & \wedge \neg \text{Revoked}(\tau) \\ & \wedge \text{ExternalAttributesValid}(q). \end{aligned} \tag{III.52}$$

$\text{ExternalAttributesValid}(q)$ mencakup pemeriksaan *role* atau *subrole*, metadata segmen, dan bukti kepemilikan dompet. Rincian mekanisme penegakan tersebut dijelaskan pada Subbab III.3.5.

Contoh token awal untuk petugas rekam medis tetap disajikan pada Kode H.1 dan Kode H.2. Kedua contoh tersebut menunjukkan bagaimana kebijakan akses yang telah didefinisikan pada model PBAC direpresentasikan sebagai kumpulan *caveat* yang dapat diverifikasi dan diatenuasi.

III.3.5 Rancangan Penegakan Otoritas

Fungsi keputusan akses yang telah didefinisikan pada model PBAC direalisasikan melalui penegakan otoritas pada rancangan ini. Kebijakan akses ditetapkan pada Subbab III.3.3 melalui fungsi $\text{Permit}(q)$ pada Persamaan III.30, sedangkan representasi kapabilitas dan sebagian kondisi kebijakan melalui token Macaroon dijelaskan pada Subbab III.3.4. Pada subbab ini, evaluasi permintaan akses q pada Persamaan III.29 terhadap kebijakan tersebut oleh *Server PRE* diuraikan sehingga hanya permintaan yang memenuhi seluruh kondisi yang dilayani. Penerapan penegakan tersebut pada penerbitan token awal, delegasi antaraktor, dan penggunaan token dalam skenario pelayanan dijelaskan pada Subbab III.3.6.

Tiga aspek utama penegakan otoritas pada *Server PRE* diuraikan pada bagian ini. Pertama, evaluasi keseluruhan $\text{Permit}(q)$ pada *Server PRE* dijelaskan pada Subbab III.3.5.1. Kedua, realisasi $\text{RoleScopeValid}(u, d, f)$ untuk operasi Update diuraikan pada Subbab III.3.5.2. Ketiga, mekanisme revokasi yang mendukung pemeriksaan $\neg \text{Revoked}(\tau)$ dijelaskan pada Subbab III.3.5.4.

Sebagai gambaran, Gambar III.2 menunjukkan alur penegakan otoritas pada *Server PRE*. Secara garis besar, alur akses dimulai dengan aktor melalui *client* untuk mengirimkan permintaan akses ke *Server PRE*. *Server PRE* kemudian mengevaluasi kondisi pada Persamaan III.30, termasuk validitas token, keanggotaan aktor pada rantai delegasi, status revokasi, dan atribut eksternal. Jika seluruh kondisi terpenuhi, *Server PRE* melanjutkan proses ke tiga kemungkinan skenario, yaitu mengambil daftar RME yang dapat diakses, melakukan pembacaan data RME yang melibatkan proses *re-encryption*, dan melakukan penulisan data RME. Apabila salah satu kondisi gagal, keputusan mengikuti Persamaan III.31. Alur tersebut menjadi titik penegakan yang sama pada setiap tahap penerbitan, delegasi, dan penggunaan token yang dirancang pada Subbab III.3.6.

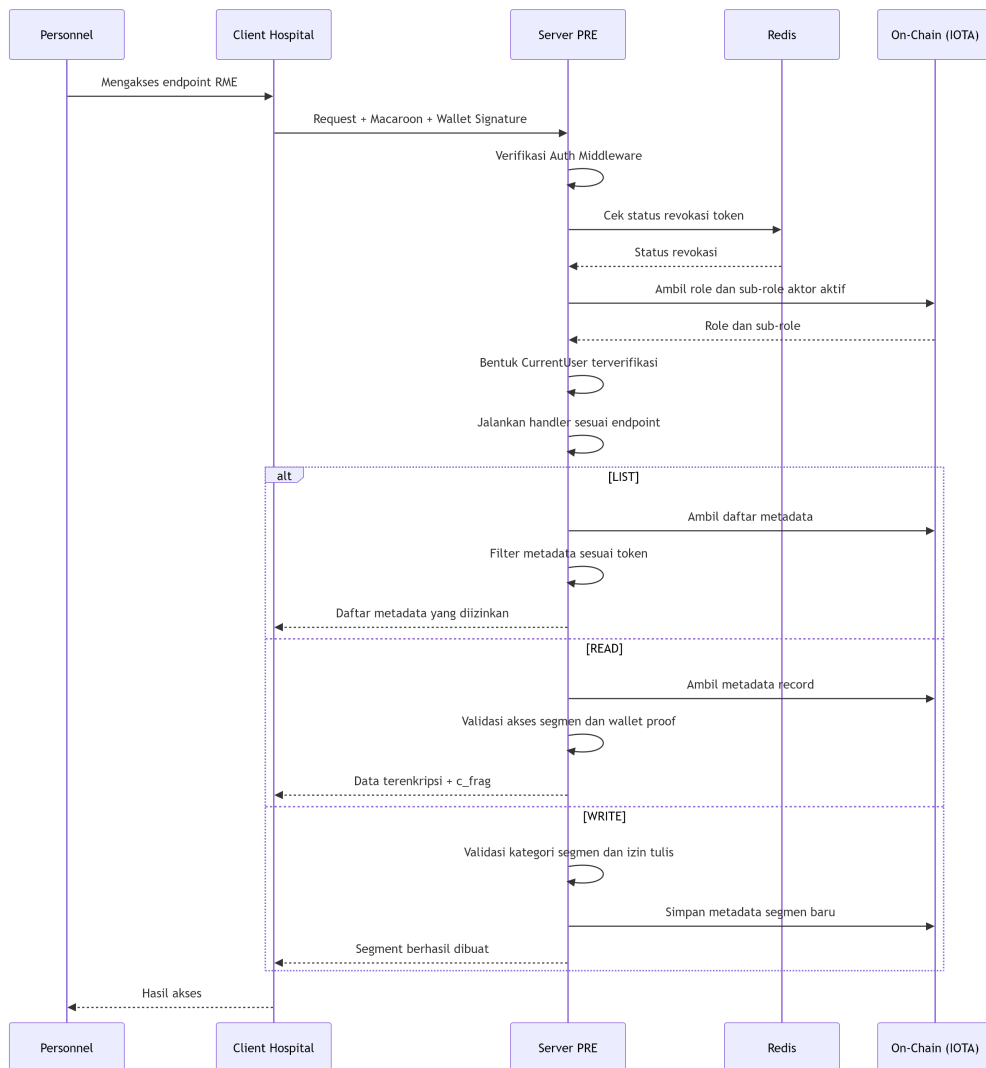
III.3.5.1 Penegakan Kebijakan

Server PRE bertindak sebagai titik penegakan kebijakan akses yang mengevaluasi $\text{Permit}(q)$ pada Persamaan III.30. Token Macaroon bukan satu-satunya masukan keputusan tersebut. Pada saat token digunakan, *Server PRE* membentuk kapabilitas efektif dari seluruh *caveat*, kemudian mencocokkannya dengan permintaan,

metadata objek, atribut pengguna, status revokasi, dan bukti kepemilikan *wallet* dari aktor yang tercatat pada rantai delegasi, sebagaimana dinyatakan pada Persamaan III.52.

Kondisi kebijakan pada model PBAC direalisasikan melalui kesesuaian tersebut. Pemeriksaan token, keanggotaan subjek rantai delegasi, cakupan objek, hak akses, masa berlaku, dan konsistensi rantai bersumber dari representasi kapabilitas pada Subbab III.3.4. Sementara itu, $\text{WalletProofValid}(\pi, q, u)$, $\text{RoleScopeValid}(u, d, f)$, dan $\neg \text{Revoked}(\tau)$ ditegakkan melalui atribut dan status di luar token. Bukti kepemilikan dompet dijelaskan pada Subbab III.3.5.3, kesesuaian *role* atau *subrole* pada Subbab III.3.5.2, dan status revokasi pada Subbab III.3.5.4.

Jika seluruh predikat pada Persamaan III.30 terpenuhi, permintaan akses dilanjutkan. Jika salah satu pemeriksaan gagal, keputusan akses adalah Deny sesuai



Gambar III.2: Alur penegakan otoritas pada *Server PRE*

Tabel III.15: Pemetaan Hak Akses Update Berdasarkan subrole Tenaga Medis

<i>subrole</i>	<i>Dataset Category</i>	<i>Function Category</i>
Perawat	Rawat Jalan/Rawat Inap	Anamnesis, Pemeriksaan Fisik, Pemeriksaan Psikologis
Dokter	Rawat Jalan/Rawat Inap	Seluruh <i>function category</i>
Lab	Laboratorium	Laboratorium
Apoteker	Apotek	Peresepan dan Dispensing

Persamaan III.31. Evaluasi tersebut diterapkan setiap kali token digunakan dalam alur penerbitan, delegasi, dan akses data RME yang dijelaskan pada Subbab III.3.6.

III.3.5.2 Verifikasi *Role* dan *Subrole* Tenaga Medis untuk Akses *Dataset*

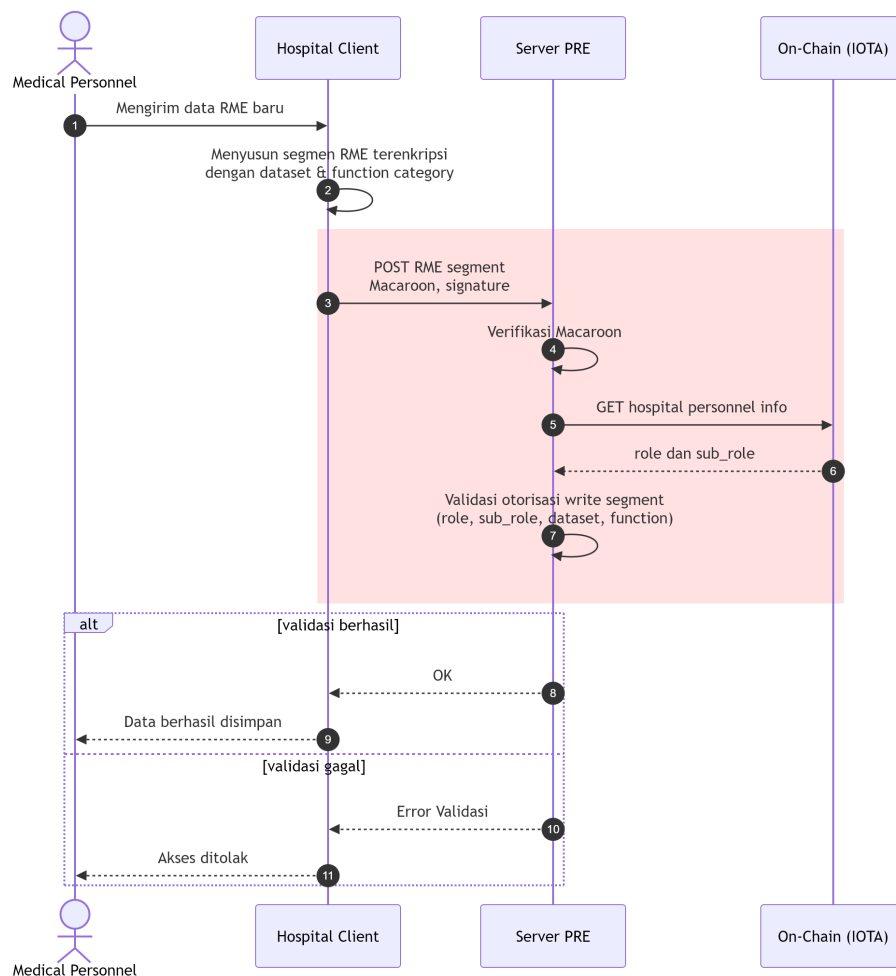
Kebutuhan verifikasi tambahan terhadap *subrole* *MedicalPersonnel* direalisasikan melalui kondisi $\text{RoleScopeValid}(u, d, f)$ pada Persamaan III.30 agar akses tulis hanya dapat dilakukan pada *dataset category* yang sesuai dengan kewenangannya, sebagaimana dianalisis pada Subbab III.2.5.1. Pada implementasi Tugas Akhir ini, terdapat 4 *subrole* turunan dari *role* *MedicalPersonnel*, yaitu dokter, perawat, petugas laboratorium, dan apoteker. Sebagaimana dijelaskan pada Subbab III.2.3, setiap *subrole* tersebut memiliki kebutuhan akses data yang berbeda-beda untuk melakukan akses jenis *update*. Pemetaan kebutuhan akses data untuk setiap *subrole* dapat dilihat pada Tabel III.15.

Berdasarkan pemetaan tersebut, verifikasi tambahan untuk *role* *MedicalPersonnel* diterapkan dengan memvalidasi apakah *subrole* pengguna yang saat ini mencoba melakukan aksi *write* memang sesuai dengan jenis *dataset* yang diakses. Alur tambahan tersebut ditunjukkan pada Gambar III.3. Pada alur ini, *Server PRE* terlebih dahulu mendapatkan informasi *subrole* tenaga medis melalui *smart contract*. Informasi tersebut kemudian digunakan untuk memvalidasi pasangan *role* dan *subrole* terhadap kategori *dataset* yang coba ditulis. Apabila *subrole* aktor tidak memiliki kewenangan untuk menulis pada kategori *dataset* tersebut, maka *request* ditolak. Bagian berlatar merah pada Gambar III.3 menunjukkan alur yang berubah atau ditambahkan pada rancangan Tugas Akhir ini dibandingkan Implementasi DecMed sebelumnya. Perubahan tersebut mencakup pengambilan informasi *subrole* dari *smart contract* serta validasi kesesuaian *role*, *subrole*, dan kategori *dataset* sebelum akses tulis diberikan.

Validasi didasarkan pada data *role* dan *subrole* yang terdapat pada penyimpanan *non-chain* karena pada Macaroon tidak terdapat informasi *role* dari aktor pemohon, sesuai dengan rancangan *caveats* pada Subbab III.3.4. Sementara itu, *registry personnel* pada penyimpanan *on-chain* merepresentasikan status kelembagaan aktor, misalnya apakah aktor masih terdaftar sebagai *personnel* rumah sakit dengan *role* atau *subrole* tertentu. Dengan demikian, *request* hanya dilanjutkan apabila aktor memiliki token yang valid sekaligus masih memiliki otoritas kelembagaan yang sesuai.

III.3.5.3 Verifikasi *Wallet* Aktor pada Rantai Delegasi

Kondisi $\text{ContainsSubject}(\tau, u)$ dan $\text{WalletProofValid}(\pi, q, u)$ pada Persamaan III.30 menegaskan bahwa bukti kepemilikan *wallet* wajib diverifikasi terhadap salah satu aktor yang tercatat pada rantai delegasi, sesuai analisis pada Subbab III.2.5.2.



Gambar III.3: *Sequence Diagram* Rancangan Validasi *subrole* Tenaga Medis terhadap *Dataset Category*

Proses verifikasi dirancang dengan mekanisme *presigned request*. Ketika *client* mengirimkan *request* ke *Server PRE*, *client* juga menambahkan header yang berisi konteks *request* yang telah di-sign menggunakan kunci privat *wallet* pengguna. Konteks *request* memuat informasi seperti *token_id*, *patient_address*, *related_rme_id*, *operation*, *segment_id*, *dataset_category*, *function_category*, dan *timestamp*. *Server PRE* mencoba mencocokkan tanda tangan tersebut terhadap seluruh subjek pada $\text{Subjects}(\tau)$. Apabila tanda tangan cocok dengan salah satu subjek, permintaan dilanjutkan dengan aktor pemohon tersebut sebagai identitas yang digunakan untuk pemeriksaan *role* atau *subrole*. Apabila tanda tangan tidak cocok dengan subjek mana pun, atau berasal dari aktor di luar rantai, permintaan ditolak. Keberadaan *timestamp* pada konteks yang ditandatangani juga membuat *signature* hanya berlaku untuk rentang waktu tertentu.

III.3.5.4 Pencabutan Hak Akses Macaroon Delegasi

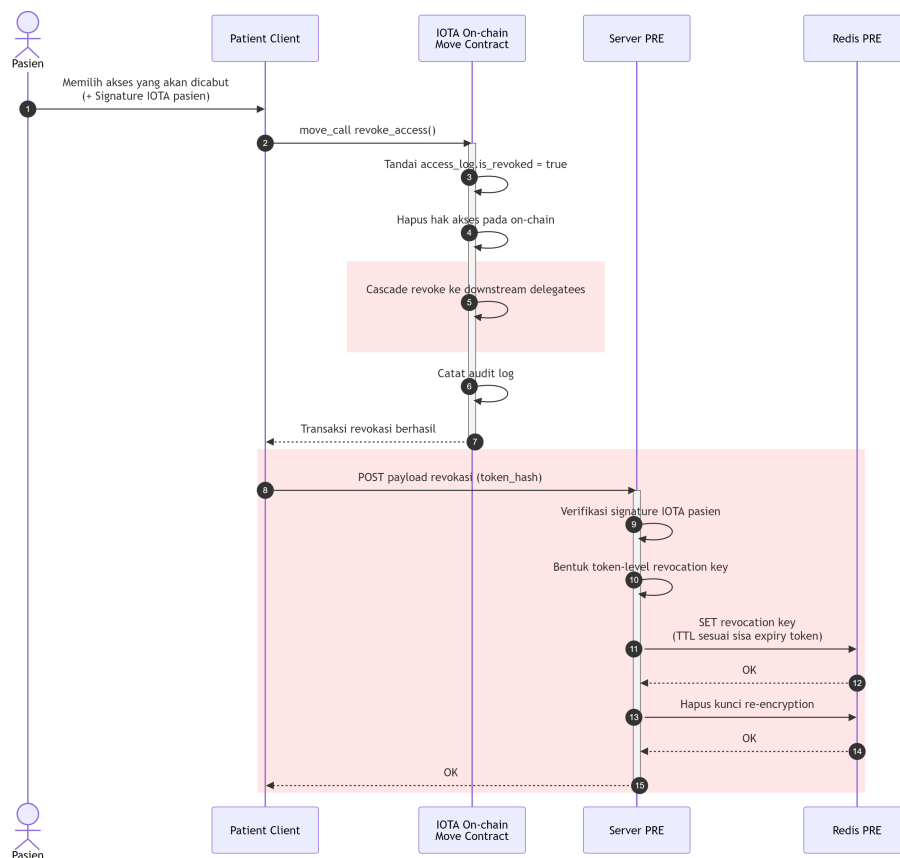
Pemeriksaan $\neg \text{Revoked}(\tau)$ pada Persamaan III.30 membutuhkan mekanisme revokasi dan audit delegasi agar pencabutan akses berdampak pada seluruh token turunan, sesuai analisis pada Subbab III.2.5.3. Pada implementasi Tugas Akhir ini, pasien tetap dijadikan *resource owner* yang berwenang untuk mencabut akses terhadap RME.

Revokasi akses pada implementasi ini diwujudkan melalui kombinasi pencatatan status di IOTA *on-chain* dan Redis PRE, dengan *server PRE* bertindak sebagai titik penegakan kebijakan akses. Lapisan *on-chain* digunakan untuk mencatat perubahan status akses dan audit trail revokasi, sedangkan Redis PRE digunakan untuk menyimpan *hash* dari token yang telah dicabut. Alur pencabutan akses oleh pasien ditunjukkan pada Gambar III.4. Pada alur tersebut, pasien memilih akses yang akan dicabut melalui *Patient Client*. *Patient Client* kemudian mengeksekusi fungsi `revoke_access()` pada *smart contract Move* untuk menandai akses sebagai dicabut, menghapus hak akses pada penyimpanan *on-chain*, melakukan pencabutan berantai terhadap penerima delegasi turunan, serta mencatat kejadian revokasi ke dalam *audit log*. Setelah transaksi *on-chain* berhasil, *Patient Client* mengirimkan *payload* revokasi ke *Server PRE* agar menyimpan *hash* dari token yang telah dicabut pada Redis PRE dan menghapus *re-encryption key* terkait dengan token Macaroon

yang direvokasi.

Bagian berlatar merah pada Gambar III.4 menunjukkan alur baru yang ditambahkan pada Tugas Akhir ini. Alur baru tersebut mencakup pencabutan berantai terhadap seluruh *downstream delegates*, pengiriman *payload* revokasi ke *Server PRE*, pembentukan *revocation key*, penyimpanan status revokasi pada Redis dengan TTL sesuai masa berlaku token, serta penghapusan kunci *re-encryption*. Dengan penambahan alur ini, revokasi tidak hanya tercatat pada IOTA, tetapi juga langsung ditegakkan oleh *Server PRE* ketika token Macaroon digunakan kembali.

Pada saat verifikasi, *Server PRE* memeriksa *hash* token yang sedang digunakan dan setiap *caveat parent_token_hash* ke *revocation key* pada Redis. Dengan demikian, apabila pasien mencabut akses pada delegator awal, maka token Macaroon turunan yang dibuat dari akses tersebut juga akan dianggap tidak valid. Selain itu, pemeriksaan status hak akses juga dilakukan pada penyimpanan *on-chain* yang mencatat status hak akses.



Gambar III.4: *Sequence Diagram* Rancangan Alur Pencabutan Hak Akses Macaroon Delegasi

III.3.6 Rancangan Alur Akses dan Delegasi Macaroon

Sesuai dengan analisis pada Subbab III.2.1 dan skenario pada Subbab III.1.1.3, kebutuhan delegasi akses antar aktor layanan kesehatan tanpa mengharuskan pasien menerbitkan ulang token setiap kali terjadi perpindahan tugas dalam proses pelayanan dijawab melalui rancangan alur akses dan delegasi pada Tugas Akhir ini. Model kebijakan pada Subbab III.3.3, representasi kapabilitas pada Subbab III.3.4, serta penegakan otoritas pada Subbab III.3.5 digunakan pada alur tersebut sebagai dasar evaluasi setiap permintaan penerbitan, delegasi, dan penggunaan token.

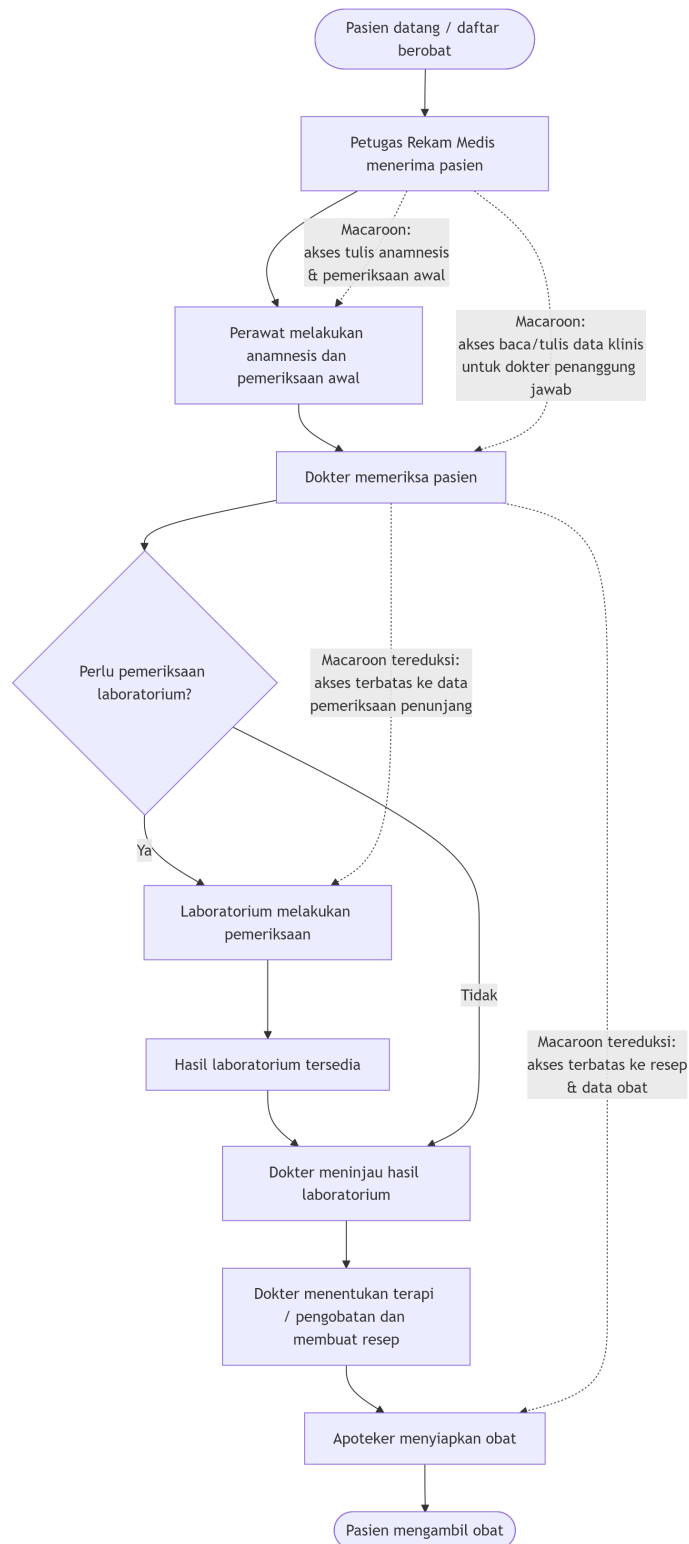
Alur akses dan delegasi pada rancangan ini mengikuti alur pelayanan kesehatan yang umum terjadi pada proses rawat jalan dan rawat inap. Alur ini diuraikan pada Subbab III.1.1.3. Pasien terlebih dahulu diterima oleh petugas rekam medis. Setelah itu, petugas rekam medis memberikan akses kepada perawat untuk melakukan pemeriksaan awal. Petugas rekam medis juga memberikan akses kepada dokter terkait agar dokter dapat memeriksa pasien dan menentukan tindakan medis berikutnya. Apabila dokter membutuhkan pemeriksaan penunjang, dokter dapat mendelegasikan akses kepada petugas laboratorium. Setelah hasil pemeriksaan tersedia dan dokter menentukan terapi atau pengobatan, dokter dapat mendelegasikan akses kepada apoteker untuk memproses resep dan penyerahan obat. Rancangan alur tersebut ditunjukkan pada Gambar III.5.

Delegasi akses pada rancangan ini terdiri atas tiga tahap utama. Tahap pertama adalah penerbitan token awal kepada petugas rekam medis sebagai aktor yang menerima pasien dan mengoordinasikan akses awal dalam proses pelayanan. Tahap kedua adalah delegasi dari petugas rekam medis kepada perawat dan dokter. Tahap ketiga adalah delegasi lanjutan dari dokter kepada petugas laboratorium dan apoteker, sesuai kebutuhan tindakan medis.

Pola teknis proses pemberian token Macaroon atau proses delegasi oleh *delegator* hingga akhirnya digunakan oleh *delegatee* untuk mengakses data RME diuraikan pada bagian berikutnya. Pola teknis ini dibagi menjadi dua bagian, yaitu proses pemberian token Macaroon delegasi hingga tercatat pada *on-chain* dan proses pengambilan dan penggunaan token Macaroon delegasi.

III.3.6.1 Penerbitan Token Awal oleh Pasien kepada Petugas Rekam Medis

Penerbitan token awal merupakan proses pemberian otorisasi pertama pada saat pasien memulai layanan kesehatan. Pada tahap ini, pasien tetap menjadi pihak



Gambar III.5: *Flow Diagram* Alur Akses dan Delegasi pada Proses Pelayanan Pasien

yang mengendalikan pemberian akses awal terhadap data RME miliknya. Pasien memberikan persetujuan akses melalui *Patient Client*, kemudian *Server PRE* menerbitkan token awal berdasarkan persetujuan tersebut. Pasien mengetahui identitas dari petugas rekam medis melalui QR yang dipindai, kemudian membuktikan kepemilikan *wallet* kepada PRE dengan *nonce* sebelum token awal diterbitkan.

Pada rancangan ini, petugas rekam medis berperan sebagai aktor awal yang menerima pasien dan menginisiasi proses pelayanan. Token ini tidak dimaksudkan agar petugas rekam medis dapat mengakses seluruh data klinis pasien secara bebas, melainkan sebagai token induk yang dapat digunakan untuk menurunkan akses kepada aktor layanan kesehatan yang relevan. Terdapat 2 token Macaroon yang diterbitkan pada tahapan ini, yaitu token Read dan token Update. Penggunaan langsung token tersebut tetap dibatasi oleh pemeriksaan otoritas yang dibahas pada Subbab III.3.5, sehingga cakupan token induk tidak otomatis berarti seluruh data dapat dibaca bebas oleh petugas rekam medis. Contoh *caveat* yang ditambahkan pada token awal untuk petugas rekam medis dapat dilihat pada Lampiran H.1 dan H.2.

Untuk memastikan RME tetap dapat diproses dengan mekanisme Umbral PRE, dibutuhkan sebuah *data PRE seed*. *Data PRE seed* ini digunakan untuk membangkitkan pasangan kunci PRE data yang dibutuhkan dalam proses enkripsi, dekripsi, dan *re-encryption*. *Data PRE seed* tersebut dibuat pada *patient client* ketika akses awal diberikan, lalu disimpan dalam metadata akses di *on-chain* dalam kondisi terenkripsi menggunakan kunci publik PRE penerima akses. Pada proses delegasi, *data PRE seed* yang sudah ada didekripsi oleh pemberi delegasi, kemudian dienkripsi ulang menggunakan kunci publik PRE penerima delegasi dan disimpan kembali bersama metadata delegasi di *on-chain*.

Alur penerbitan token awal kepada petugas rekam medis diawali dengan pasien bertemu dengan petugas rekam medis yang menerima permintaan pelayanan serta memperlihatkan QR untuk discan oleh pasien. Pasien memberikan persetujuan akses awal melalui *Patient Client* setelah memilih konteks pelayanan (rawat jalan atau rawat inap), batasan waktu akses, dan jenis akses yang diberikan. *Patient Client* mengirimkan permintaan penerbitan token kepada *Server PRE*. *Server PRE* memverifikasi identitas pasien, identitas petugas rekam medis, dan

Tabel III.16: Pemetaan Delegasi Token dari Petugas Rekam Medis

Penerima Delegasi	Tujuan Delegasi	Cakupan Akses
Perawat	Melakukan anamnesis dan pemeriksaan awal pasien.	Menulis segmen anamnesis, pemeriksaan fisik, dan pemeriksaan psikologis pada <i>dataset</i> rawat jalan.
Dokter	Memeriksa pasien, membaca hasil pemeriksaan awal, menentukan tindakan medis, diagnosis, terapi, dan kebutuhan pemeriksaan penunjang.	Membaca dan menulis segmen klinis yang relevan pada <i>dataset</i> rawat jalan atau rawat inap, serta memiliki kemampuan delegasi lanjutan untuk apoteker dan petugas laboratorium.

batasan yang diberikan. Jika lolos proses verifikasi, *Server* PRE menerbitkan token Macaroon awal dengan *caveats* yang mengikat token pada pasien, ID RME terkait, petugas rekam medis sebagai penerima awal, cakupan akses, masa berlaku, dan batas delegasi. *Server* PRE mencatat penerbitan token awal ke dalam penyimpanan *on-chain*. Token awal didistribusikan kepada petugas rekam medis melalui mekanisme yang dijelaskan pada Subbab III.3.6.4 dengan memanfaatkan penyimpanan *on-chain*.

III.3.6.2 Delegasi dari Petugas Rekam Medis kepada Perawat dan Dokter

Setelah menerima token awal, petugas rekam medis dapat mendelegasikan akses kepada perawat dan dokter terkait sesuai kebutuhan pelayanan. Pada delegasi ini, permintaan atenuasi dikirimkan kepada *server* PRE. *Server* PRE memverifikasi *request* delegasi. Apabila valid, *server* PRE mengembalikan token turunan untuk diproses lebih lanjut oleh *client delegator* untuk dicatat pada penyimpanan *on-chain*.

Delegasi kepada perawat diberikan agar perawat dapat membaca RME pasien untuk melakukan penanganan, dan menulis hasil pemeriksaan awal. Sementara itu, delegasi kepada dokter diberikan agar dokter dapat membaca data seluruh rekam medis pasien, menuliskan RME untuk episode layanan saat ini, serta melakukan delegasi lanjutan apabila diperlukan. Pemetaan delegasi dari petugas rekam medis ditunjukkan pada Tabel III.16. Contoh *caveats* yang ditambahkan pada token turunan untuk perawat dan dokter dapat dilihat pada Lampiran H.3 dan H.4.

Tabel III.17: Pemetaan Delegasi Lanjutan dari Dokter

Penerima Delegasi	Tujuan Delegasi	Cakupan Akses
Petugas Laboratorium	Melakukan pemeriksaan penunjang berdasarkan permintaan dokter dan mengunggah hasil pemeriksaan.	Membaca segmen pemeriksaan penunjang dan menulis pada <i>dataset</i> laboratorium.
Apoteker	Memproses resep, menyiapkan obat, dan mencatat penyerahan obat kepada pasien.	Membaca segmen terapi dan menulis pada <i>dataset</i> apotek.

III.3.6.3 Delegasi dari Dokter kepada Laboratorium dan Apoteker

Setelah dokter menerima token turunan dari petugas rekam medis, dokter dapat melakukan delegasi lanjutan apabila dibutuhkan dalam proses pelayanan. Delegasi lanjutan dilakukan kepada petugas laboratorium apabila dokter membutuhkan pemeriksaan penunjang. Setelah dokter menentukan terapi, dokter juga dapat mendelegasikan akses kepada apoteker untuk memproses resep dan penyerahan obat. Contoh *caveats* yang ditambahkan pada token turunan untuk laboratorium dan apoteker dapat dilihat pada Lampiran H.5 dan H.6. Pemetaan delegasi lanjutan dari dokter ditunjukkan pada Tabel III.17.

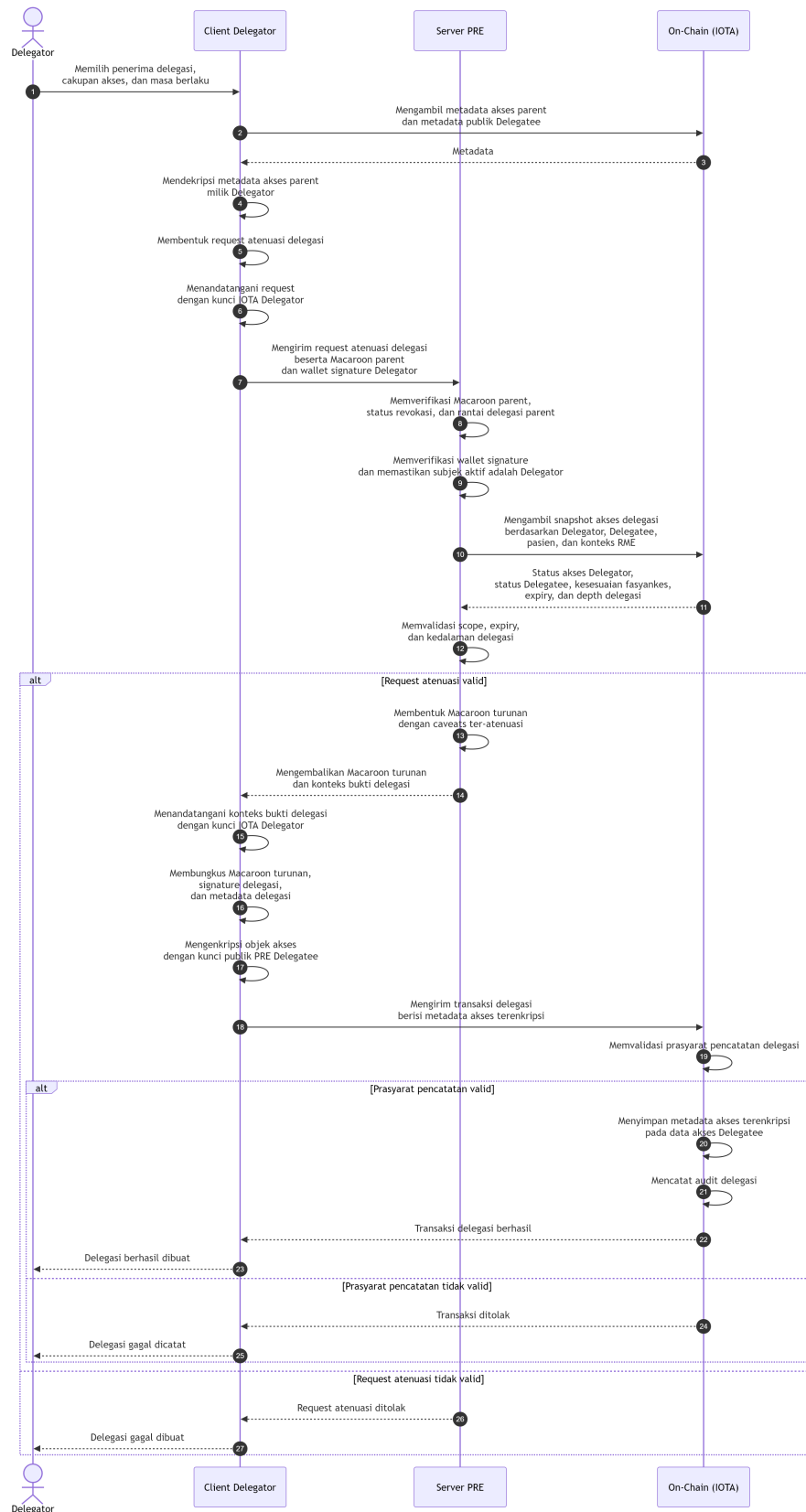
III.3.6.4 Proses Pemberian dan Penggunaan Token Macaroon Delegasi

Secara umum, proses pemberian dan penggunaan token Macaroon delegasi dibagi menjadi dua bagian. Bagian pertama adalah proses pembentukan dan pencatatan delegasi, *client* yang meminta atenuasi token ke *server* PRE. Bagian ini mencakup pembentukan token Macaroon turunan, enkripsi metadata delegasi, serta pencatatan metadata akses terenkripsi pada penyimpanan *on-chain*. Alur proses tersebut ditunjukkan pada Gambar III.6.

Berdasarkan Gambar III.6, proses delegasi diawali ketika *delegator* memilih cakupan akses yang akan diberikan kepada *delegatee*. Setelah cakupan akses ditentukan, *client delegator* mengambil token Macaroon yang dimiliki oleh *delegator* dan melakukan *request* atenuasi token ke *server* PRE.

Server PRE memverifikasi *request* delegasi. Validasi mencakup pemeriksaan apakah cakupan akses turunan lebih luas, verifikasi *signature* dari *delegator*, status akses *delegator* pada *on-chain*, serta batasan cakupan yang diminta. Apabila valid,

server PRE mengembalikan token turunan untuk diproses lebih lanjut oleh *client delegator* untuk dicatat pada penyimpanan *on-chain*.



Gambar III.6: Sequence diagram pembentukan dan pencatatan token Macaroon delegasi

Setelah token Macaroon turunan terbentuk, token tersebut tidak disimpan secara langsung dalam bentuk *plaintext* pada penyimpanan *on-chain*. Aplikasi *client* milik *delegator* terlebih dahulu mengambil kunci publik milik *delegatee* dari IOTA, termasuk kunci publik PRE milik *delegatee*. Kunci publik PRE kemudian digunakan untuk mengenkripsi objek akses yang berisi token Macaroon turunan dan metadata delegasi. Dengan pendekatan ini, metadata akses yang dicatat pada *on-chain* hanya tersedia dalam bentuk terenkripsi yang hanya bisa dibuka oleh *delegatee*.

Metadata akses terenkripsi kemudian disimpan pada IOTA menggunakan *smart contract*. Pada tahap ini, *smart contract* mencatat metadata terenkripsi pada data akses milik *delegatee* dan juga memvalidasi prasyarat delegasi yang dapat diperiksa dari penyimpanan *on-chain*. Prasyarat tersebut meliputi status aktif akun, kesesuaian fasyankes antara *delegator* dan *delegatee*, serta keberadaan dan masa berlaku akses *delegator* terhadap pasien terkait. Apabila prasyarat tersebut valid, metadata akses terenkripsi disimpan pada daftar akses milik *delegatee*. Apabila prasyarat tidak terpenuhi, transaksi delegasi ditolak.

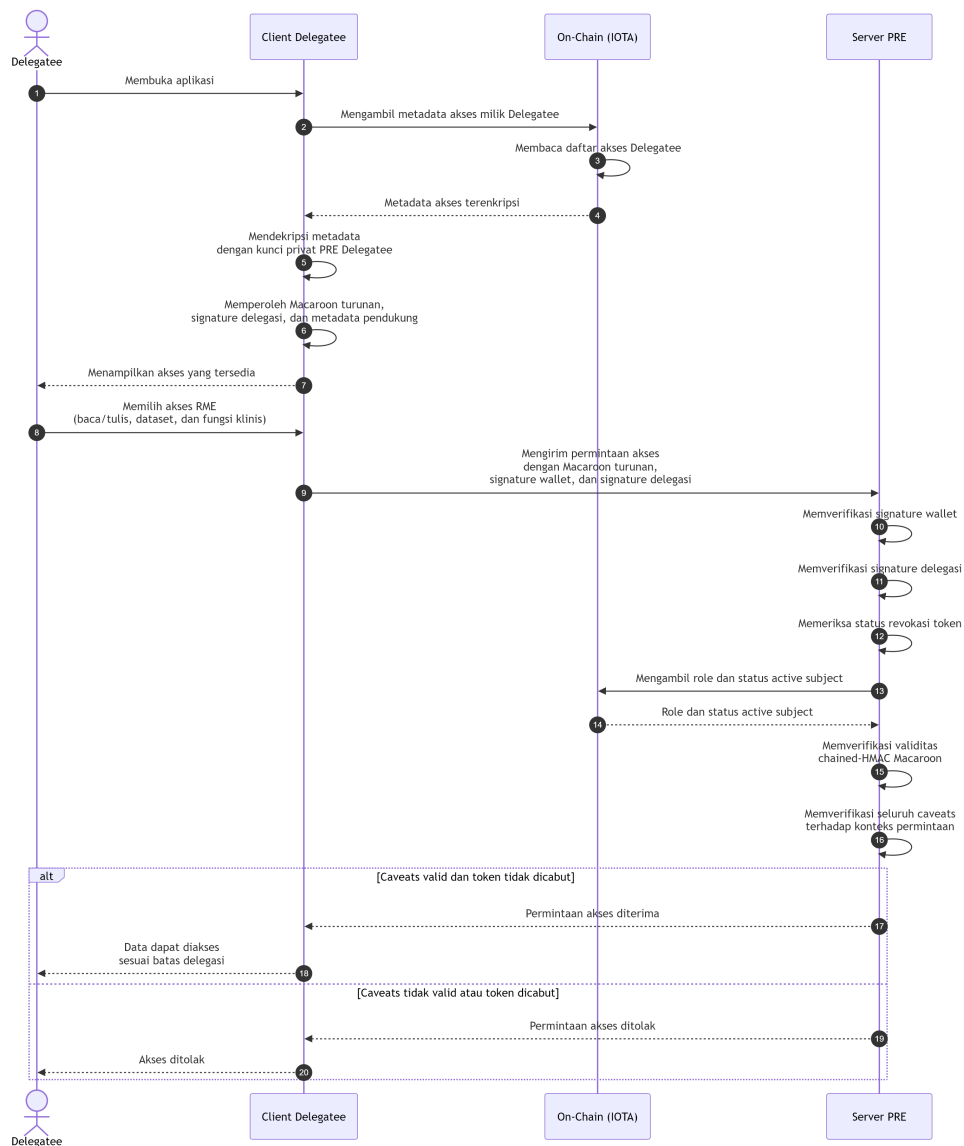
Bagian kedua dari proses ini adalah pengambilan dan penggunaan token Macaroon delegasi oleh *delegatee*. Bagian ini terjadi setelah metadata akses terenkripsi berhasil dicatat pada blockchain. Alur pengambilan dan penggunaan token Macaroon delegasi ditunjukkan pada Gambar III.7.

Berdasarkan Gambar III.7, ketika *delegatee* membuka aplikasi, *client* mengambil metadata akses terenkripsi yang tersimpan pada blockchain. Metadata tersebut kemudian didekripsi secara lokal menggunakan kunci privat PRE milik *delegatee*. Apabila proses dekripsi berhasil, aplikasi memperoleh token Macaroon turunan beserta metadata pendukungnya. Token Macaroon turunan tersebut kemudian dapat digunakan sebagai token otorisasi ketika *delegatee* mengirim permintaan akses baca atau tulis ke *Server* PRE. Selain membentuk token turunan, aplikasi *client* juga membentuk bukti delegasi yang di-*sign* menggunakan *wallet* milik *delegator*. Bukti ini digunakan agar *Server* PRE dapat memastikan bahwa token turunan memang dibuat oleh pihak yang berwenang dalam rantai delegasi.

Pada tahap penggunaan token, *Server* PRE melakukan penegakan otoritas terhadap token Macaroon yang dikirimkan oleh *delegatee* sesuai Subbab III.3.5. Evaluasi

tersebut menerapkan $\text{Permit}(q)$ pada Persamaan III.30, mencakup pemeriksaan validitas token, status revokasi, bukti kepemilikan *wallet*, rantai delegasi, serta seluruh *caveat* terhadap konteks permintaan akses. Apabila seluruh kondisi terpenuhi, permintaan akses diterima sesuai batas delegasi yang diberikan. Sebaliknya, apabila terdapat kondisi yang tidak terpenuhi, keputusan akses adalah Deny sesuai Persamaan III.31.

Dengan mekanisme ini, IOTA digunakan sebagai media pencatatan dan distribusi metadata akses yang dapat diaudit, sedangkan kerahasiaan token tetap dilindungi melalui enkripsi. Token Macaroon tidak tersedia dalam bentuk terbuka pada *state on-chain*, sehingga pihak selain *delegatee* tidak dapat langsung memanfaatkan metadata akses yang tercatat pada blockchain. Selain itu, karena batasan kapabilitas



Gambar III.7: Sequence diagram pengambilan dan penggunaan token Macaroon delegasi

Tabel III.18: Pemetaan Rancangan terhadap Solusi

ID	Nama Rancangan	Merealisasikan Solusi
R-TA-01	Rancangan arsitektur solusi DecMed dengan PBAC, Macaroons, segmentasi, dan PRE sebagai <i>policy enforcement point</i> .	S-TA-01, S-TA-02, S-TA-03, S-TA-04
R-TA-02	Rancangan segmentasi data RME berdasarkan <i>dataset</i> dan <i>function category</i> .	S-TA-02
R-TA-03	Rancangan model PBAC pada DecMed.	S-TA-01
R-TA-04	Rancangan representasi kapabilitas pada <i>caveats</i> Macaroons dan rantai delegasi.	S-TA-03
R-TA-05	Rancangan penegakan kebijakan akses berdasarkan kapabilitas efektif token Macaroon dan bukti kepemilikan <i>wallet</i> pada <i>Server</i> PRE.	S-TA-01, S-TA-04
R-TA-06	Rancangan validasi <i>subrole</i> tenaga medis terhadap <i>dataset category</i> .	S-TA-05
R-TA-07	Rancangan revokasi delegasi token Macaroons.	S-TA-06
R-TA-08	Rancangan alur akses dan delegasi pada skenario layanan kesehatan kolaboratif.	S-TA-03, S-TA-04, S-TA-05

yang diturunkan dari kebijakan akses dibawa melalui *caveats* pada Macaroon, *server* PRE tetap dapat menegakkan batas delegasi pada saat token digunakan.

Untuk mengurangi risiko *delegator* melakukan delegasi akses berlebihan, jumlah delegasi yang dapat dilakukan oleh seorang pemegang hak akses dapat dibatasi dengan mencatat jumlah delegasi yang telah dilakukan oleh *delegator* pada penyimpanan *on-chain*. Jumlah delegasi ini dapat diperiksa oleh *server* PRE saat memverifikasi *request* delegasi. Apabila jumlah delegasi melebihi batas yang ditentukan, *server* PRE menolak *request* delegasi. Jumlah delegasi ini dapat dibatasi dengan aturan bahwa seorang *delegator* hanya dapat melakukan delegasi sebanyak 1 kali untuk setiap *role*.

III.3.7 Pemetaan Rancangan terhadap Solusi

Setelah rancangan solusi diuraikan, setiap rancangan dipetakan kembali terhadap solusi yang telah dianalisis pada Subbab III.2.6. Melalui pemetaan ini, keterkaitan langsung setiap rancangan R-TA dengan solusi S-TA yang diusulkan ditunjukkan. Hasil pemetaan rancangan terhadap solusi ditunjukkan pada Tabel III.18.

BAB IV

IMPLEMENTASI DAN PENGUJIAN

IV.1 Lingkungan Implementasi

Implementasi sistem dilakukan pada lingkungan prototipe yang merepresentasikan komponen utama DecMed, yaitu *patient client*, *hospital client*, *ministry client*, *Server PRE*, penyimpanan *off-chain* IPFS, Redis, IOTA *Gas Station*, dan *smart contract* IOTA Move pada jaringan IOTA Localnet. Lingkungan ini dipilih agar rancangan pada Bab III dapat diuji tanpa bergantung pada integrasi langsung dengan sistem informasi rumah sakit yang sesungguhnya.

Pada implementasi DecMed sebelumnya, semua komponen dijalankan pada lingkungan lokal. Semua *client*, *Server PRE*, Redis PRE, kluster IPFS, IOTA *Gas Station*, dan jaringan IOTA jenis Localnet dijalankan langsung di komputer lokal. Perangkat lokal yang digunakan tidak cukup kuat untuk menjalankan semua komponen secara bersamaan. Oleh karena itu, dilakukan pembagian komponen implementasi tersebut ke dalam lingkungan lokal dan dua buah *Virtual Private Server* (VPS).

Komponen *client* dan *Server PRE* dijalankan pada lingkungan lokal. Lingkungan lokal digunakan untuk memudahkan pengembangan fitur, pengujian alur akses, dan pengamatan sistem. Komponen pendukung yang membutuhkan ketersediaan jaringan, yaitu kluster IPFS dan IOTA *Gas Station*, dijalankan pada VPS. *Smart contract* IOTA Move di-deploy pada jaringan IOTA Localnet yang juga berjalan di VPS. IOTA Localnet digunakan karena sudah memadai untuk menyimulasikan interaksi dengan jaringan IOTA. VPS digunakan untuk menjalankan komponen pendukung karena komponen tersebut tidak banyak berubah selama implementasi, tetapi tetap dibutuhkan selama pengembangan. Beban perangkat lokal juga dikurangi melalui pemanfaatan VPS karena perangkat lokal tidak perlu menjalankan seluruh komponen pendukung.

Berikut adalah spesifikasi dari perangkat lokal yang digunakan untuk implementasi:

- Sistem Operasi: Ubuntu 24.04.4, berjalan di lingkungan WSL2
- CPU: Intel Core i5-11400H (3 core fisik dan 6 *logical thread* dialokasikan untuk WSL2)
- Memori RAM: 16 GB (8 GB teralokasi untuk WSL2)
- *Tools*:
 - Rust (rustc 1.93.0, cargo 1.93.0)
 - Node.js v24.13.0
 - Docker 29.5.3

Sementara itu, spesifikasi kedua VPS yang digunakan adalah sebagai berikut:

- Sistem Operasi: Ubuntu 24.04.4 LTS
- Jumlah vCPU: 8 vCPU
- Memori RAM: 8 GB
- *Tools*:
 - Docker: Docker 29.4.2

IV.2 Implementasi Sistem

Pada bagian ini dijelaskan implementasi dari rancangan solusi yang telah dijabarkan pada Bab III. Implementasi difokuskan pada penerapan kebijakan akses PBAC melalui representasi kapabilitas pada Macaroons, segmentasi data RME, mekanisme atenuasi dan delegasi akses, penegakan otoritas pada *Server* PRE, perubahan *smart contract* IOTA Move, dan penyesuaian antarmuka *client*.

Daftar komponen implementasi dan keterkaitannya dengan rancangan solusi ditunjukkan pada Tabel IV.1. ID I-TA digunakan sebagai rujukan pada implementasi terkait. Rancangan ID R-TA-01 merupakan rancangan arsitektur sistem yang implementasinya merupakan keseluruhan implementasi sistem DecMed, sehingga tidak muncul pada tabel.

Tabel IV.1: Daftar Implementasi Sistem

ID	Komponen	Merealisasikan Rancangan
I-TA-01	<i>Crate decmed-rme-segment.</i>	R-TA-02
I-TA-02	<i>Crate decmed-macaroon-auth</i> dan <i>Crate macaroon.</i>	R-TA-04, R-TA-05
I-TA-03	Implementasi penegakan otoritas pada <i>Server PRE.</i>	R-TA-05, R-TA-06, R-TA-07
I-TA-04	Implementasi <i>smart contract</i> IOTA Move untuk metadata segmen, akses, dan audit.	R-TA-02, R-TA-04, R-TA-07
I-TA-05	Implementasi <i>Patient Client</i> untuk pemberian akses awal, pencabutan, dan audit.	R-TA-07, R-TA-08
I-TA-06	Implementasi <i>Hospital Client</i> untuk akses baca dan tulis segmen RME dan delegasi antar tenaga kesehatan.	R-TA-02, R-TA-04, R-TA-08

IV.2.1 Batasan Implementasi

Implementasi pada Tugas Akhir ini memiliki beberapa batasan sebagai berikut:

1. Implementasi dilakukan dalam lingkungan komputer lokal dan VPS.
 - Semua *client* dan *Server PRE* dijalankan langsung di komputer lokal.
 - VPS menjalankan kluster IPFS dan IOTA *Gas Station*.
 - *Smart contract* yang digunakan di-deploy pada IOTA Localnet yang berjalan di VPS.
2. Implementasi mempertahankan arsitektur kerangka kerja DecMed sebagaimana yang dijelaskan pada Subbab III.3.1.
3. Komponen perangkat lunak yang digunakan mengikuti dependensi dari implementasi DecMed sebelumnya. Daftar dependensi langsung setiap komponen disajikan pada Lampiran J.
4. Kluster IPFS yang digunakan dalam implementasi hanya menggunakan konfigurasi *default* sesuai implementasi DecMed sebelumnya. Konfigurasi tersebut terdiri atas tiga buah *peers*.
5. Segmentasi data sesuai dengan yang dibahas pada III.3.2 hanya dilakukan hingga tingkat kombinasi *dataset category* dan *function category*, kemudian disimpan sebagai *text*.
6. Nilai `max_delegation_depth` pada token Macaroon hanya diatur sampai

tingkat 2. Hal ini untuk memastikan bahwa token turunan hanya dapat diturunkan sebanyak 2 kali sesuai dengan skenario pada Subbab III.1.1.3 dan rancangan pada Subbab III.3.6.

IV.2.2 Implementasi Arsitektur Sistem

Implementasi arsitektur sistem mengikuti rancangan pada Subbab III.3.1. Komponen dasar DecMed dipertahankan, yaitu IOTA untuk metadata *on-chain*, IPFS untuk penyimpanan *off-chain* segmen data yang terenkripsi, dan *Server PRE* sebagai penegak otoritas dan proses *re-encryption* data. Arsitektur DecMed secara keseluruhan dapat dilihat pada gambar III.1.

Selain perubahan sesuai rancangan yang sudah dijelaskan pada subbab III.3, pola pengorganisasian kode juga diperbaiki. Pada DecMed awal, beberapa bagian yang memiliki fungsi serupa ditulis berulang pada beberapa komponen. Pola tersebut membuat perubahan kode menjadi lebih sulit di-*maintain* karena perubahan pada satu bagian perlu direplikasi pada komponen lain. Pada implementasi ini, bagian yang digunakan bersama dipisahkan menjadi *crate* Rust agar dapat digunakan ulang oleh beberapa komponen.

Crate yang diimplementasikan dan digunakan adalah *decmed-rme-segment* dan *decmed-macaroon-auth*. *decmed-rme-segment* berisi definisi struktur segmentasi RME, definisi *dataset category* dan *function category*, serta fungsi pendukungnya. Sementara itu, *decmed-macaroon-auth* berisi implementasi token otorisasi berbasis Macaroons di DecMed, termasuk pembuatan token, atenuasi token, dan proses verifikasi. *crate* *decmed-macaroon-auth* memiliki dependensi utama yaitu *crate* *macaroon* yang merupakan *crate open source* implementasi Macaroons dengan pembaruan *dependency*. *decmed-rme-segment* digunakan oleh *Patient Client*, *Hospital Client*, dan *Server PRE*, sedangkan *decmed-macaroon-auth* digunakan oleh *Hospital Client* dan *Server PRE*. *Ministry Client* tidak memiliki dependensi langsung terhadap kedua *crate* tersebut karena perannya tetap terbatas pada kebutuhan registrasi dan aktivasi rumah sakit. Hubungan antar komponen implementasi dan dependensi *crate* bersama ditunjukkan pada *package diagram* pada Gambar IV.1 dengan legenda dari *package diagram* tersebut dapat dilihat pada Lampiran K.

Dengan pemisahan tersebut, implementasi segmentasi data dan otorisasi tidak tersebar sebagai kode duplikatif pada setiap komponen.

IV.2.3 Implementasi Segmentasi Data RME

Segmentasi data RME diimplementasikan dengan memecah satu data RME menjadi beberapa objek data terenkripsi berdasarkan kombinasi *dataset category* dan *function category*. Kombinasi kategori tersebut mengikuti rancangan pada Subbab III.3.2. Setiap segmen data RME disimpan sebagai satu entri metadata pada penyimpanan *on-chain* dan satu objek data pada penyimpanan *off-chain*.

Segmentasi data RME diimplementasikan pada *crate* `decmed-rme-segment`. *Crate* ini mendefinisikan `DatasetCategory` dan `FunctionCategory` yang digunakan sebagai atribut objek dalam penegakan kebijakan akses terhadap data RME. Rincian modul dan implementasi pada *crate* `decmed-rme-segment` disajikan pada Lampiran L. Implementasi `DatasetCategory` ditunjukkan pada Kode IV.1, implementasi `FunctionCategory` ditunjukkan pada Kode IV.2.

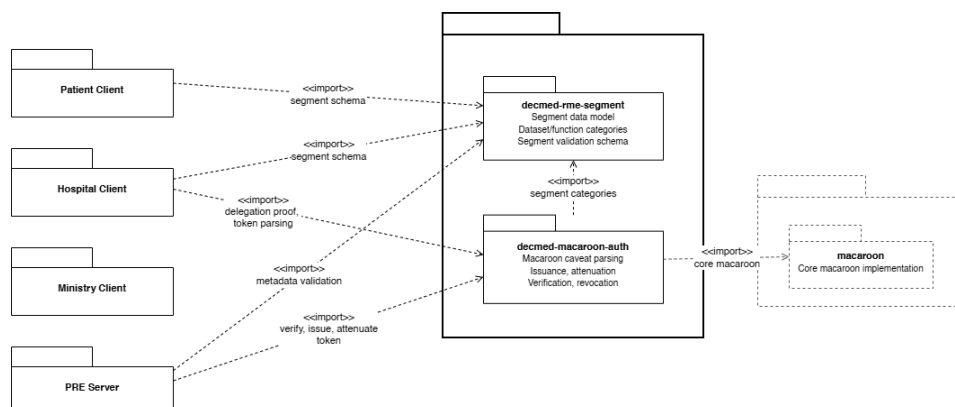
```

1  pub enum DatasetCategory {
2      RAWAT_JALAN,
3      RAWAT_INAP,
4      LABORATORIUM,
5      APOTEK,
6  }

```

Kode IV.1: Implementasi `DatasetCategory` pada *crate* `decmed-rme-segment`

Perbedaan antara *dataset category* rawat jalan dan rawat inap terdapat pada *function*



Gambar IV.1: Package Diagram Implementasi

category PERENCANAAN_PEMULANGAN. Segmen data ini hanya ada pada *dataset category* RAWAT_INAP, sedangkan pada *dataset category* RAWAT_JALAN tidak ada. Selain itu, *function category* ADMINISTRATIVE_GENERAL ada pada setiap *dataset category*.

```
1      pub enum FunctionCategory {
2          // ADMINISTRATIVE
3          ADMINISTRATIVE_GENERAL,
4
5          // RAWAT_JALAN & RAWAT_INAP
6          ANAMNESIS,
7          PEMERIKSAAN_FISIK,
8          PEMERIKSAAN_PSIKOLOGIS,
9          RIWAYAT_PENGUNAAN_OBAT,
10         RENCANA_RAWAT,
11         INSTRUKSI_MEDIK_DAN_KEPERAWATAN,
12         PEMERIKSAAN_PENUNJANG,
13         DIAGNOSIS,
14         INFORMED_CONSENT,
15         TERAPI,
16
17         // RAWAT_INAP
18         PERENCANAAN_PEMULANGAN,
19
20         // LABORATORIUM
21         LABORATORIUM,
22
23         // APOTEK
24         PERESEPAN,
25         DISPENSING,
26     }
```

Kode IV.2: Implementasi FunctionCategory pada *crate* decmed-rme-segment

IV.2.3.1 Implementasi Segmentasi Metadata RME pada Penyimpanan On-Chain

Definisi struktur metadata segmentasi ditulis pada *crate* *decmed-rme-segment*. *Crate* ini mendefinisikan *RmeSegmentMetadata* yang merupakan representasi metadata segmen sebelum diserialisasi menjadi JSON base64 dan disimpan pada *field* metadata milik *PatientMedicalMetadata* yang sudah ditunjukkan pada Kode III.2. Implementasi struktur *RmeSegmentMetadata* terdapat pada Kode IV.3. Struktur tersebut sesuai dengan rancangan skema metadata segmen RME pada Lampiran Tabel G.1.

```
1 pub struct RmeSegmentMetadata {
2     pub segment_id: String,
3     pub related_rme_id: String,
4     pub patient_address: String,
5     pub author_address: String,
6     pub hospital_cid: String,
7     pub dataset_category: DatasetCategory,
8     pub function_category: FunctionCategory,
9     pub ipfs_cid: String,
10    pub integrity_hash: String,
11    pub capsule: String,
12    pub enc_key_and_nonce: String,
13    pub created_at: String,
14 }
```

Kode IV.3: Implementasi struktur *RmeSegmentMetadata* pada *crate* *decmed-rme-segment*

Sebelum metadata segmen disimpan pada IOTA, struktur metadata divalidasi terlebih dahulu. Validasi tersebut mencakup pemeriksaan setiap *field* wajib terisi, validitas kombinasi *dataset_category* dan *function_category*, serta kesesuaian *integrity_hash* terhadap data terenkripsi. *dataset_category* dan *function_category* memiliki nilai sesuai dengan Kode IV.1 dan IV.2. *patient_address* dan *author_address* memuat *address wallet* dari pasien dan aktor yang menulis isi segmen. *hospital_cid* merupakan *identifier* fasyankes, menunjukkan bahwa segmen data tersebut dihasilkan oleh tenaga medis dari

fasyankes tersebut. *ipfs_cid* merupakan *pointer* ke data segmen terenkripsi yang disimpan pada penyimpanan *off-chain*. *integrity_hash* merupakan hash SHA-256 dari data segmen terenkripsi yang digunakan untuk memverifikasi integritas data. *capsule* merupakan kapsul PRE yang diperlukan untuk proses *re-encryption*. *enc_key_and_nonce* merupakan kunci simetris dan *nonce* yang sudah terenkripsi untuk membuka segmen data. *created_at* memuat informasi tanggal dan waktu ketika segmen tercatat dengan format YYYY-MM-DD HH:MM:SS serta informasi *timezone*.

IV.2.3.2 Implementasi Segmentasi Data RME pada Penyimpanan Off-Chain

Definisi struktur segmentasi data penyimpanan *off-chain* didefinisikan pada *crate* *decmed-rme-segment*. *Crate* ini mendefinisikan *RmeSegmentData*, struktur data segmen RME yang disimpan pada penyimpanan *off-chain*. Implementasi struktur *RmeSegmentData* terdapat pada Kode IV.4. Struktur tersebut sesuai dengan rancangan skema data segmen RME pada Lampiran Tabel G.2.

```
1 pub struct RmeSegmentData {  
2     pub segment_id: String,  
3     pub related_rme_id: String,  
4     pub dataset_category: DatasetCategory,  
5     pub function_category: FunctionCategory,  
6     pub patient_address: String,  
7     pub service_date: String,  
8     pub author_address: String,  
9     pub payload: Value,  
10    pub payload_hash: String,  
11 }
```

Kode IV.4: Implementasi struktur *RmeSegmentData* pada *crate* *decmed-rme-segment*

segment_id merupakan ID unik untuk satu segmen data RME. *dataset_category* dan *function_category* digunakan sebagai atribut objek untuk penegakan kebijakan akses terhadap data RME. Atribut tersebut memiliki nilai sesuai dengan Kode IV.1 dan IV.2. *patient_address* dan *author_address* memuat *address wallet* dari pasien dan aktor yang menulis isi segmen. *service_date* merupakan

tanggal dan waktu ketika segmen tercatat dengan format YYYY-MM-DD HH:MM:SS beserta informasi *timezone*. *payload* berisi konten utama segmen dengan tipe data *Value*. Pada implementasi ini, *payload* berisi data dalam bentuk *text*. *payload_hash* merupakan hash integritas dari konten *payload*.

Pada saat data RME disimpan, *Hospital Client* membentuk objek untuk setiap segmen. Setiap segmen berisi data klinis atau administratif sesuai kategorinya, kemudian dienkrpsi sebelum diunggah ke IPFS. Hasil unggahan IPFS berupa CID disimpan bersama metadata segmen pada IOTA sebagai *ipfs_cid*. Metadata tersebut disimpan dalam bentuk serialisasi JSON dan dikodekan dalam base64 pada *field* metadata milik *PatientMedicalMetadata*. Keputusan ini menjaga kompatibilitas dengan struktur penyimpanan DecMed yang masih berbentuk daftar metadata *flat*, tetapi tetap memungkinkan *Server PRE* membaca kategori segmentasi dari isi metadata.

IV.2.4 Implementasi Token Otorisasi Berbasis Macaroons

IV.2.4.1 Komponen Implementasi Macaroons

Seperti yang sudah dijelaskan pada subbab IV.2.2, terdapat dua *crate* yang berkaitan dengan implementasi Macaroons pada implementasi Tugas Akhir ini, yaitu *macaroon* dan *decmed-macaroon-auth*.

Crate macaroon merupakan hasil penyesuaian dari implementasi Macaroons berbasis Rust yang tersedia secara *open source* pada URL <https://github.com/macaroon-rs/macaroon>. Penyesuaian dilakukan karena *crate* asli memerlukan beberapa penyesuaian agar lebih sesuai dengan kebutuhan implementasi sistem DecMed, terutama dari sisi kompatibilitas *toolchain* dan pengelolaan *dependency*. Perubahan utama pada *crate macaroon* adalah penggantian *dependency* kriptografi berbasis *sodiumoxide* dengan *crate* pure Rust, yaitu *hmac*, *sha2*, *chacha20poly1305*, dan *rand*.

Setelah perubahan tersebut diterapkan, *unit testing* pada *crate* dijalankan untuk memastikan bahwa fungsi utama Macaroons tetap berjalan dengan benar. Pengujian tersebut mencakup pembuatan Macaroon, penambahan *caveat*, serialisasi, deserialisasi, dan verifikasi token. Dengan demikian, *crate macaroon* digunakan sebagai fondasi implementasi Macaroons pada sistem DecMed.

Tabel IV.2: *Caveats* yang Diimplementasikan pada Token Macaroon

<i>Caveat</i>	Tipe Data
<code>patient_address</code>	String (alamat IOTA format heksadesimal)
<code>related_rme_id</code>	String (ID episode RME)
<code>root_subject</code>	String (alamat IOTA format heksadesimal)
<code>delegated_by</code>	String (alamat IOTA format heksadesimal)
<code>delegated_to</code>	String (alamat IOTA format heksadesimal)
<code>read_dataset_in</code>	HashSet<DatasetCategory>
<code>write_dataset_in</code>	HashSet<DatasetCategory>
<code>read_function_in</code>	HashSet<FunctionCategory>
<code>write_function_in</code>	HashSet<FunctionCategory>
<code>expires_before</code>	DateTime<Utc> (YYYY-MM-DD HH:MM:SS)
<code>max_delegation_depth</code>	u32
<code>hospital_cid</code>	String (CID IPFS)
<code>parent_token_hash</code>	String (hash SHA-256 dari token induk)
<code>purpose</code>	String (nilai: Read atau Update)

`decmed-macaroon-auth` merupakan *wrapper* yang dibangun untuk mempermudah penggunaan *crate* macaroon pada implementasi sistem DecMed. *Wrapper* ini menyediakan fungsi-fungsi utilitas untuk kebutuhan otorisasi DecMed, seperti proses penerbitan token Macaroon, atenuasi dengan penambahan *caveat* baru, definisi struktur *caveats* Macaroon, verifikasi Macaroon, dan fungsi pendukung lainnya. Rincian modul dan implementasi yang diimplementasikan pada *crate* `decmed-macaroon-auth` ditunjukkan pada Lampiran M.

IV.2.4.2 Struktur *Caveats* Macaroons

Struktur *caveats* pada token Macaroon pada implementasi ini ditunjukkan pada Tabel IV.2. *caveats* terdefinisi pada *crate* `decmed-macaroon-auth`, sehingga *hospital client* membentuk token dengan menambahkan *caveats* sesuai dengan daftar *caveats* yang terdefinisi pada *crate*, dan PRE akan menolak *request* jika terdapat *caveats* yang tidak termasuk ke dalam daftar *caveats*.

IV.2.4.3 Penerbitan Token Macaroon

Token otorisasi diimplementasikan menggunakan Macaroons sesuai rancangan pada Subbab III.3.4. Pada implementasi ini, penerbitan token dilakukan oleh *Server* PRE setelah permintaan akses dari pasien dinyatakan valid.

Pada proses penerbitan akses awal, *Server* PRE menerbitkan dua jenis token untuk penerima akses, yaitu token Read dan token Update. Token Read memuat

caveat utama berupa *patient_address*, *root_subject*, *read_dataset_in*, *read_function_in*, *expires_before*, *max_delegation_depth*, *hospital_cid*, dan *purpose* = Read. Token Update memuat *caveat* berupa *patient_address*, *related_rme_id*, *root_subject*, *write_dataset_in*, *write_function_in*, *expires_before*, *max_delegation_depth*, *hospital_cid*, dan *purpose* = Update.

Pada penerbitan untuk petugas rekam medis, fungsi yang dipanggil adalah *issue_admin_personnel_token* yang termasuk implementasi pada *crate* *decmed-macaroon-auth*. Alur lengkap pemberian akses awal dari pasien kepada petugas rekam medis, termasuk pemindaian QR code, verifikasi identitas, pembentukan material PRE, penyimpanan ke Redis, dan pencatatan grant akses ke *smart contract*, dijelaskan pada subbab IV.2.5.

IV.2.4.4 Atenuasi Token Macaroon

Pada implementasi ini, pemegang token utama adalah para tenaga kesehatan, dengan role *AdministrativePersonnel* atau *MedicalPersonnel*. Pemegang token melakukan atenuasi token melalui *hospital client* dengan mengirim *request* atenuasi token ke *server* PRE. Implementasi dari fungsi atenuasi ini terdapat pada *crate* *decmed-macaroon-auth* dengan nama fungsi *attenuate_macaroon*. Fungsi ini bekerja dengan tahapan sebagai berikut: token Macaroon dideserialisasi, lalu *caveat* baru ditambahkan sesuai dengan *caveats* yang ingin ditambahkan, kemudian token Macaroon yang telah diatenuasi diserialisasi kembali sebelum dikembalikan sebagai *response*. Perhitungan *signature* baru dari Macaroon pada proses *chained-HMAC* dilakukan setiap kali *caveat* baru ditambahkan.

IV.2.4.5 Revokasi Token Macaroon

Revokasi token pada implementasi ini sesuai dengan rancangan pada Subbab III.3.5. Implementasi revokasi akses melibatkan pencatatan di IOTA *on-chain*, Redis PRE, dan *server* PRE.

Setiap token turunan menyimpan keterkaitan terhadap token induknya melalui *caveat* *parent_token_hash*. Informasi ini digunakan untuk mendukung pencabutan berantai, sehingga pencabutan terhadap token pada tingkat tertentu dapat berdampak pada token-token turunan yang bergantung kepadanya.

Pemeriksaan pencabutan dilakukan oleh *Server PRE* sebelum akses terhadap data terenkripsi diberikan. Saat *request* diterima oleh PRE, maka PRE akan memeriksa *hash* dari token Macaroon yang digunakan, dan mengecek apakah ada di daftar *revoked keys* yang tersimpan pada Redis PRE dengan pola *revoked:token:<hash>*. Pemeriksaan yang sama juga diterapkan terhadap semua *hash* token yang ada pada *caveat parent_token_hash*. Jika ada salah satu *hash* yang ditemukan, maka *request* akan ditolak. Selain itu, hak akses yang tercatat pada *on-chain* juga ditandai sebagai *revoked*.

IV.2.5 Delegasi Akses dan Atenuasi Offline

Mekanisme ini merupakan realisasi dari rancangan pada Subbab III.3.6. Implementasi dibagi menjadi dua bagian. Bagian pertama adalah proses pemberian akses awal dari pasien kepada petugas rekam medis sebagai penerima akses awal. Bagian kedua adalah proses delegasi akses antar tenaga kesehatan.

IV.2.5.1 Delegasi Akses dari Pasien kepada Petugas Rekam Medis

Implementasi delegasi akses dari pasien kepada petugas rekam medis merupakan realisasi dari rancangan pada Subbab III.3.6.2 dan III.3.6.3.

Proses diawali ketika pasien melakukan *scan* QR code milik AdministrativePersonnel. QR code tersebut memuat sebuah *string* dengan format *{hospitalCid}@{personnelIota}@{personnelPrePK}*. Informasi tersebut terdiri dari *hospital_cid* sebagai *identifier* fasyankes, *personnel_iota_address* sebagai alamat IOTA milik AdministrativePersonnel, dan *personnel_pre_public_key* sebagai PRE *public key* milik AdministrativePersonnel dalam format base64. PRE *public key* tersebut digunakan untuk mengenkripsi *data_pre_secret_key_seed* yang nantinya hanya dapat dibuka oleh petugas penerima akses.

Setelah QR code berhasil di-*scan*, *Patient Client* mengambil informasi publik AdministrativePersonnel melalui *smart contract* *get_hospital_personnel_info*. Langkah ini dilakukan untuk memastikan identitas petugas yang akan menerima akses. Pasien kemudian memilih jenis layanan, yaitu RAWAT_JALAN atau RAWAT_INAP, serta memilih mode akses

yang akan diberikan. Tiga mode akses didukung, yaitu read, update, dan read_update. Pada mode read, hanya token baca yang diterbitkan; pada mode update, hanya token pembaruan yang diterbitkan; sedangkan pada mode read_update, kedua token tersebut diterbitkan. Pada implementasi, batas waktu akses bawaan untuk RAWAT_JALAN adalah 1 hari, sedangkan batas waktu akses bawaan untuk RAWAT_INAP adalah 3 hari. Namun, nilai *expires_before* khusus juga didukung sehingga batas waktu akses dapat disesuaikan dengan kebutuhan.

Selanjutnya, *Patient Client* meminta *nonce* kepada *Server PRE* melalui *endpoint /nonce*. Sebelum *nonce* diterbitkan, *Server PRE* memeriksa terlebih dahulu apakah alamat pasien telah terdaftar pada *smart contract is_patient_registered*. *Nonce* yang diterima kemudian di-sign menggunakan kunci IOTA pasien. Tanda tangan ini digunakan sebagai bukti bahwa permintaan penerbitan akses benar-benar berasal dari pasien yang sah.

Bersamaan dengan proses tersebut, *Patient Client* membuat *data_pre_secret_key_seed* baru dan menurunkan *data_pre_public_key* dari *seed* tersebut. *Seed* kemudian dienkripsi menggunakan *personnel_pre_public_key*. Selain itu, *Patient Client* juga membuat *key fragment k_frag* dari *PRE secret key* pasien menuju *data_pre_public_key*. Material PRE ini disimpan pada Redis PRE agar *Server PRE* dapat melakukan *re-encryption* ketika petugas mengakses data pasien. TTL untuk material PRE dihitung berdasarkan waktu kedaluwarsa aktual dari token yang diterbitkan.

Permintaan penerbitan akses kemudian dikirim ke *endpoint /keys*. *Payload* yang dikirim mencakup alamat IOTA pasien, alamat IOTA petugas, *hospital.cid*, *encounter_dataset*, mode akses, *signature* pasien, *k_frag*, *data_pre_public_key*, *enc_data_pre_secret_key_seed*, *data_pre_secret_key_seed_capsule*, *patient_pre_public_key*, dan *signer_pre_public_key*. *Server PRE* kemudian memverifikasi *signature* pasien terhadap *nonce* dan memeriksa apakah *role* petugas penerima akses adalah *AdministrativePersonnel*.

Jika verifikasi berhasil, *Server PRE* membentuk *MacaroonKey* dari *RootKey* dan menerbitkan token Macaroon sesuai mode akses yang diminta. Jika mode yang dipilih adalah read, *Server PRE* hanya menerbitkan token Read. Jika mode yang

dipilih adalah update, *Server PRE* hanya menerbitkan token Update. Jika mode yang dipilih adalah read_update, *Server PRE* menerbitkan token Read dan token Update.

Token Read memiliki *caveat* patient_address, root_subject, read_dataset_in, read_function_in, expires_before, max_delegation_depth, hospital_cid, dan purpose = Read. Nilai read_dataset_in dan read_function_in pada token ini mencakup seluruh *dataset category* dan seluruh *function category*. Dengan demikian, token Read memberikan kemampuan baca terhadap data RME pasien.

Token Update memiliki *caveat* patient_address, related_rme_id, root_subject, write_dataset_in, write_function_in, expires_before, max_delegation_depth, hospital_cid, dan purpose = Update. Berbeda dengan token Read, cakupan write_dataset_in pada token Update tidak mencakup seluruh *dataset category*. Nilainya dibatasi pada encounter_dataset yang dipilih pasien, ditambah LABORATORIUM dan APOTEK. Nilai write_function_in diturunkan dari *function category* yang termasuk ke dalam cakupan *dataset category* tersebut.

related_rme_id hanya dibuat apabila akses yang diterbitkan mencakup kemampuan Update. Pada kondisi tersebut, *Server PRE* membuat related_rme_id baru sebagai identitas episode rekam medis yang sedang dibuat atau diperbarui. ID tersebut menggunakan format RME-{sequence_6_digit}, misalnya RME-000001. Perhitungan *sequence* dilakukan pada *Server PRE* dengan memanfaatkan Redis untuk menyimpan nilai *sequence*. Apabila pasien hanya memberikan akses read, related_rme_id tidak dibuat oleh *Server PRE*.

Setelah token diterbitkan, *Server PRE* menyimpan material akses PRE ke Redis PRE. Entri PRE menggunakan *key* {personnel_iota_address}@{patient_iota_address}. *Server PRE* kemudian menghitung *hash* dari token yang diterbitkan. PRE lalu mengembalikan access_token_read, access_token_update, *hash* masing-masing token, serta related_rme_id kepada *Patient Client*.

Pada tahap akhir, *Patient Client* mengenkripsi token dan metadata akses menggunakan personnel_pre_public_key. Metadata akses kemudian dicatat ke

IOTA melalui *smart contract* `create_access`. Dengan demikian, token Macaroon awal telah dirilis kepada `AdministrativePersonnel` secara terenkripsi, *hash* token telah tersedia untuk keperluan audit dan revokasi, dan material PRE telah tersimpan di Redis PRE untuk proses akses data berikutnya.

IV.2.5.2 Delegasi Akses antar Tenaga Kesehatan

Implementasi delegasi akses antar tenaga kesehatan merupakan realisasi dari rancangan pada Subbab III.3.6.2 dan III.3.6.3. Tenaga medis memiliki *role* `MedicalPersonnel` dengan *subrole* masing-masing sesuai dengan tabel III.15.

Proses diawali ketika *delegator* memilih *delegatee* yang akan menerima akses. Informasi kandidat *delegatee* diperoleh melalui *smart contract* `get_delegatee_candidates`. Data yang digunakan dalam proses delegasi mencakup alamat IOTA *delegatee* dan PRE *public key* milik *delegatee*. PRE *public key* tersebut digunakan untuk mengenkripsi metadata delegasi dan material akses agar hanya dapat dibuka oleh *delegatee*.

Sebelum membentuk token turunan, *Hospital Client* memuat material kriptografis milik *delegator*, yaitu PRE *secret key*, alamat IOTA, dan pasangan kunci IOTA. *Delegator* kemudian mendekripsi `data_pre_secret_key_seed` yang terenkripsi, lalu mengenkripsi ulang *seed* tersebut menggunakan PRE *public key* milik *delegatee*. Proses ini memungkinkan *delegatee* memperoleh material yang diperlukan untuk membuka data yang didelegasikan.

Hospital client kemudian mengirim *request* atenuasi token ke *server* PRE. *request* memuat token induk, *requested scope*, *expiry*, alamat *delegator/delegatee/patient*, *parent delegation signature* bila token induk merupakan token hasil delegasi, serta *delegation_request_signature*. *Signature* terakhir merupakan tanda tangan IOTA *delegator* atas `DelegationRequestProofContext` dan digunakan PRE untuk memastikan bahwa permintaan atenuasi benar-benar disetujui oleh *delegator*.

Pertama PRE memverifikasi autentikasi token induk melalui mekanisme *chained-HMAC*, mengecek apakah token ada di daftar yang sudah direvokasi, dan dilanjutkan dengan pemeriksaan `EffectiveCapability` `EffectiveCapability` dari token induk divalidasi terhadap *requested scope*. Validasi ini memastikan bahwa waktu kedaluwarsa token turunan tidak melebihi token induk,

cakupan *dataset* dan *function* merupakan subset dari token induk, serta nilai `max_delegation_depth` tidak bertambah. Definisi `EffectiveCapability` dapat dilihat pada IV.6.

Pemeriksaan kemudian dilanjutkan dengan pemeriksaan metadata akses pada IOTA melalui `get_delegation_access_snapshot`. Pada pemeriksaan ini diverifikasi `expiry` dari hak akses yang dimiliki oleh *delegator*, kesamaan fasyankes, *delegation depth* saat ini, dan ada atau tidaknya delegasi aktif terhadap sebuah *subrole* yang telah didelegasikan oleh *delegator*. Jika sudah ada, maka *request* ditolak.

Apabila verifikasi berhasil, *server* PRE melakukan atenuasi pada token induk dengan menambahkan *caveat* melalui fungsi `attenuate_macaroon` dari *crate* `decmed-macaroon-auth`. Fungsi ini menerima token Macaroon induk dan parameter atenuasi berupa alamat *delegator*, alamat *delegatee*, cakupan *dataset category*, cakupan *function category*, waktu kedaluwarsa, dan batas kedalaman delegasi. *Server* PRE kemudian mengembalikan token turunan untuk diproses lebih lanjut oleh *client delegator* untuk dicatat pada penyimpanan *on-chain*. *Response* ke *client delegator* memuat token turunan, *hash* token turunan, dan konteks bukti delegasi yang akan menjadi bukti delegasi.

Caveat yang mungkin ditambahkan pada token turunan adalah `parent_token_hash`, `delegated_by`, `delegated_to`, `read_dataset_in`, `write_dataset_in`, `read_function_in`, `write_function_in`, `expires_before`, dan `max_delegation_depth`. Jika mengikuti *preset* pada *hospital client*, maka *caveats* yang ditambahkan dapat dilihat pada Lampiran H sesuai dengan alur delegasinya.

Setelah token turunan diterima oleh *client delegator*, *client* membuat bukti delegasi menggunakan `DelegationProofContext`. Struktur `DelegationProofContext` ditunjukkan pada Kode IV.5. Nilai `scope_fingerprint` merupakan *hash* dengan struktur `r:{ds_read}|w:{ds_write}|rf:{fn_read}|wf:{fn_write}`, dengan `ds_read`, `ds_write`, `fn_read`, dan `fn_write` merupakan *dataset category* dan *function category* yang didelegasikan. `DelegationProofContext` kemudian diserialisasi dan ditandatangani menggunakan kunci IOTA milik *delegator*.

```
1 pub struct DelegationProofContext {
```

```

2     pub token_hash: String,
3     pub delegated_by: String,
4     pub delegated_to: String,
5     pub related_rme_id: String,
6     pub expires_before: String,
7     pub scope_fingerprint: String,
8 }

```

Kode IV.5: Definisi DelegationProofContext

Token turunan, *hash* token, tanda tangan delegasi, metadata akses, dan *data_pre_secret_key_seed* yang telah dienkripsi ulang kemudian dikemas menjadi metadata delegasi. Metadata tersebut dienkripsi menggunakan PRE *public key* milik *delegatee*. Dengan demikian, token dan material akses hanya dapat dibuka oleh *delegatee*.

Tahap berikutnya adalah pencatatan delegasi ke IOTA melalui *smart contract* fungsi *create_delegated_access*. Fungsi ini menerima metadata delegasi, data audit delegasi, alamat pasien, dan alamat *delegatee*. Pada sisi *smart contract*, dilakukan validasi bahwa *delegatee* terdaftar dan aktif, keduanya berada pada fasyankes yang sama, serta *delegator* masih memiliki akses yang valid terhadap pasien terkait. Jika validasi berhasil, akses baru untuk *delegatee* dimasukkan ke tabel akses Read dan Update.

Selain menyimpan akses untuk *delegatee*, fungsi *create_delegated_access* juga mencatat audit delegasi pada data pasien. Entri audit tersebut memuat alamat *delegator*, *root subject* dari rantai delegasi, alamat *delegatee*, jenis akses, *related_rme_id*, kedalaman delegasi, *hash* token turunan, *hash* token induk, waktu kedaluwarsa. Dengan demikian, perpindahan akses antar tenaga kesehatan tetap dapat ditelusuri tanpa membuka isi token Macaroon dan metadata akses yang terenkripsi.

Khusus untuk delegasi dari *AdministrativePersonnel* kepada *MedicalPersonnel*, pada delegasi pertama dari *AdministrativePersonnel* ditambahkan *function category* ADMINISTRATIVE_GENERAL pada setiap *dataset category*. Hal ini mengasumsikan bahwa *AdministrativePersonnel* sudah memeriksa data ADMINISTRATIVE_GENERAL pasien, sehingga siap dicatat pada

setiap *dataset category*. Penambahan tersebut disesuaikan dengan Lampiran A yang memuat dokumentasi administratif pasien pada masing-masing *dataset category*.

Ketika *delegatee* menggunakan akses yang telah didelegasikan, *request* melewati *middleware* otorisasi pada *Server PRE*. *Server PRE* memverifikasi sesuai dengan implementasi yang dijelaskan pada subbab IV.2.6. Untuk memperoleh material *PRE*, *Server PRE* mencari entri Redis berdasarkan aktor pemohon, aktor pada rantai delegasi, hingga *root_subject*. Mekanisme ini memungkinkan token turunan menggunakan material *PRE* dari akses awal, sementara pembatasan akses tetap ditegakkan dengan memeriksa *Macaroon*.

Dengan mekanisme tersebut, delegasi antar tenaga kesehatan dapat dilakukan oleh *delegator* melalui atenuasi *Macaroon* di *server PRE*. Hak akses *delegatee* tetap tidak dapat melebihi hak akses *delegator*, proses delegasi tercatat pada *smart contract*, dan penggunaan akses berikutnya tetap diverifikasi oleh *Server PRE*.

IV.2.6 Implementasi Penegakan Otoritas

Penegakan otoritas pada *Server PRE* diimplementasikan sebagai tahap validasi berlapis sebelum operasi terhadap data RME dijalankan. Secara umum, mekanisme ini memastikan bahwa setiap *request* yang membutuhkan otorisasi membawa *Macaroon* yang valid, belum kedaluwarsa, belum dicabut, sesuai dengan cakupan akses yang diminta, dan digunakan oleh salah satu aktor yang tercatat pada rantai delegasi.

Alur implementasi penegakan otoritas pada *Server PRE* disajikan sebagai referensi pada Lampiran N. Bagian awal alur pada Gambar N.2 mencakup autentikasi token, perhitungan *effective capability*, pembentukan *delegation chain*, dan pemeriksaan revokasi. Kelanjutan alur pada Gambar N.3 mencakup validasi *role* dan *subrole*, validasi konteks segmen, verifikasi bukti kepemilikan *wallet*, serta eksekusi operasi *PRE*, *IPFS*, dan *IOTA*. Daftar endpoint REST API yang digunakan pada *Server PRE* disajikan pada Lampiran O. Status implementasi penegakan otoritas pada *Server PRE* disajikan pada Tabel IV.3.

Tabel IV.3: Status Implementasi Penegakan Otoritas pada *Server* PRE

Bagian	Status
Validasi <i>Bearer Macaroon</i>	Terimplementasi.
Validasi <i>chained-HMAC</i> pada token Macaroon	Terimplementasi.
<i>Parsing caveats</i> pada token Macaroon	Terimplementasi.
Perhitungan <i>EffectiveCapability</i>	Terimplementasi.
Pembentukan himpunan subjek rantai melalui <i>DelegationChain</i>	Terimplementasi.
Pemeriksaan revokasi token melalui Redis	Terimplementasi.
Pemeriksaan <i>role</i> dan <i>subrole</i> aktor melalui <i>Move Smart Contract</i>	Terimplementasi.
Validasi aksi baca dan tulis terhadap cakupan <i>dataset</i> dan <i>function</i>	Terimplementasi.
Verifikasi <i>wallet signature</i> terhadap subjek rantai dan konteks akses segmen	Terimplementasi.

IV.2.6.1 Autentikasi Token Macaroon

Tahap awal validasi dilakukan pada *middleware* PRE. *Middleware* membaca token Macaroon dari *header* Authorization dengan skema Bearer, mendeserialisasi token, mem-parsing *caveats* DecMed, serta memverifikasi keaslian token menggunakan mekanisme *chained-HMAC* dengan *RootKey* PRE. Apabila token tidak dapat dideserialisasi, bukan merupakan token DecMed, atau nilai HMAC tidak valid, *request* langsung ditolak.

Setelah token dinyatakan autentik, *Server* PRE membentuk *EffectiveCapability* dari seluruh *caveats* yang terdapat pada token. Struktur ini merepresentasikan cakupan akses efektif yang berlaku setelah proses pembatasan dan penggabungan *caveats*. Untuk *caveat* berbentuk *set*, seperti *read_dataset_in*, *write_dataset_in*, *read_function_in*, dan *write_function_in*, cakupan efektif diperoleh melalui irisan antar-*caveats*. Untuk *expires_before*, waktu kedaluwarsa efektif diambil dari nilai paling awal. Struktur *EffectiveCapability* ditunjukkan pada Kode IV.6.

```

1 pub struct EffectiveCapability {
2     pub read_datasets: HashSet<DatasetCategory>,
3     pub write_datasets: HashSet<DatasetCategory>,
4     pub read_functions: HashSet<FunctionCategory>,
5     pub write_functions: HashSet<FunctionCategory>,
6     pub expires_before: Option<DateTime<Utc>>,
7     pub root_max_delegation_depth: Option<u32>,

```

```

8     pub remaining_max_delegation_depth: Option<u32>,
9     pub patient_address: Option<String>,
10    pub related_rme_id: Option<String>,
11    pub hospital_cid: Option<String>,
12 }

```

Kode IV.6: Definisi EffectiveCapability

Selain menghitung EffectiveCapability, *Server* PRE membentuk DelegationChain untuk menentukan himpunan subjek yang berwenang menggunakan token. Himpunan tersebut diperoleh melalui subjects(), yaitu root_subject bersama seluruh nilai delegated_to pada langkah delegasi. Pemeriksaan keanggotaan dilakukan melalui contains_subject(). Rantai delegasi juga divalidasi agar setiap langkah delegasi tersambung secara konsisten, yaitu penerima delegasi pada satu langkah harus menjadi pemberi delegasi pada langkah berikutnya. Struktur DelegationChain ditunjukkan pada Kode IV.7.

```

1  pub struct DelegationStep {
2      pub delegated_by: String,
3      pub delegated_to: String,
4  }
5
6  pub struct DelegationChain {
7      pub root_subject: String,
8      pub steps: Vec<DelegationStep>,
9  }
10
11 impl DelegationChain {
12     pub fn subjects(&self) -> Vec<&str> { /* root_subject + seluruh delegated_to */
13     pub fn contains_subject(&self, address: &str) -> bool { /* cek keanggotaan s
14 }

```

Kode IV.7: Definisi DelegationStep dan DelegationChain

Setelah EffectiveCapability dan DelegationChain terbentuk, *Server* PRE memeriksa waktu kedaluwarsa token. Token ditolak apabila nilai expires_before pada EffectiveCapability telah melewati waktu saat

request diproses. *Server PRE* juga memeriksa batas kedalaman delegasi sudah melewati *max_delegation_depth* dengan menghitung jumlah *steps* pada *DelegationChain* untuk memastikan jumlah delegasi yang digunakan tidak melebihi batas yang ditentukan. Apabila ada yang tidak terpenuhi, *request* langsung ditolak.

IV.2.6.2 Pemeriksaan Status Revokasi Token

Pemeriksaan revokasi token dilakukan melalui Redis. *Server PRE* menghitung *hash* dari token yang sedang digunakan, kemudian membentuk kunci revokasi dengan format *revoked:token:<token_hash>*. Selain token yang sedang digunakan, *Server PRE* juga memeriksa *hash* token induk yang tersimpan dalam *caveat parent_token_hash*. Dengan demikian, pencabutan token induk juga dapat menyebabkan token hasil delegasi atau atenuasi ditolak.

IV.2.6.3 Verifikasi Role dan Subrole melalui Move Smart Contract

Setelah token dinyatakan valid dan tidak dicabut, *Server PRE* memeriksa identitas kelembagaan aktor pemohon melalui *smart contract* *get_hospital_personnel_auth_info* menggunakan alamat IOTA yang terbukti melalui *wallet proof*. Fungsi ini mengembalikan *role* dan *subrole* personel yang tersimpan pada penyimpanan *on-chain*. Eksistensi aktor pemohon dalam sistem juga tervalidasi melalui pemeriksaan ini.

IV.2.6.4 Verifikasi Konteks Segmen

Validasi konteks segmen dilakukan pada *handler* operasi baca dan tulis. Pada operasi baca, *handler* mengambil metadata segmen dari IOTA, kemudian mendekode metadata JSON yang tersimpan dalam format base64. Pada operasi tulis, *handler* membentuk metadata *preview* dari *payload* segmen sebelum data disimpan. Metadata ini digunakan untuk membangun *SegmentAccessContext* yang berisi *segment_id*, *patient_address*, *related_rme_id*, *dataset_category*, dan *function_category*.

Pemeriksaan akses segmen dilakukan dengan membandingkan konteks segmen terhadap *EffectiveCapability*. Pada operasi baca, *Server PRE* memastikan bahwa *patient_address* sesuai dengan token, serta *dataset_category*

dan `function_category` berada dalam cakupan `read_dataset_in` dan `read_function_in`. Pada operasi tulis, *Server PRE* memastikan bahwa `patient_address` sesuai, `related_rme_id` sesuai, serta `dataset_category` dan `function_category` berada dalam cakupan `write_dataset_in` dan `write_function_in`.

Untuk operasi tulis segmen, *Server PRE* juga melakukan pemeriksaan tambahan berdasarkan *role* dan *subrole* aktor pemohon. Aktor dengan *role* `MedicalPersonnel` hanya dapat menulis kategori dataset yang sesuai dengan *subrole*-nya. Dokter dan perawat dapat menulis dataset `RAWAT_JALAN` dan `RAWAT_INAP`, petugas laboratorium dapat menulis dataset `LABORATORIUM`, sedangkan apoteker dapat menulis dataset `APOTEK`. Aktor dengan *role* `AdministrativePersonnel` hanya dapat membuat segmen dengan *function category* `ADMINISTRATIVE_GENERAL`. Selain itu, pada operasi tulis, *Server PRE* memeriksa kesesuaian `hospital_cid` pada token dengan `hospital_cid` pada segmen yang akan disimpan.

IV.2.6.5 Verifikasi Bukti Kepemilikan *Wallet*

Setelah konteks akses dinyatakan sesuai, *Server PRE* memverifikasi bukti kepemilikan *wallet* dari aktor pemohon. Bukti ini dikirimkan melalui *header* `x-decmed-wallet-signature`, sedangkan waktu pembuktian dikirimkan melalui *header* `x-decmed-wallet-timestamp`. Tanda tangan dibuat terhadap representasi `WalletProofContext`. Struktur `WalletProofContext` ditunjukkan pada Kode IV.8. *Server PRE* kemudian mencoba mencocokkan *wallet signature* terhadap seluruh subjek pada `DelegationChain::subjects()`. Apabila tanda tangan cocok dengan salah satu subjek, aktor tersebut digunakan sebagai identitas pemohon untuk pemeriksaan lanjutan. Apabila tanda tangan tidak cocok dengan subjek mana pun, permintaan ditolak. Timestamp pada konteks pembuktian juga divalidasi agar berada dalam rentang waktu yang dapat diterima. Pada implementasi ini, waktu yang diterima adalah rentang waktu 5 menit.

```
1 pub struct WalletProofContext {
2     pub token_id: String,           // ID Macaroon
3     pub patient_address: String,    // Alamat pasien
4     pub related_rme_id: String,     // ID episode RME
```



```

5     pub operation: AccessMode,    // Read / Update
6     pub segment_id: String,      // ID segmen yang diakses
7     pub dataset_category: DatasetCategory,
8     pub function_category: FunctionCategory,
9     pub timestamp: String,       // YYYY-MM-DD HH:MM:SS
10  }

```

Kode IV.8: Struktur WalletProofContext sebagai konteks verifikasi *wallet signature*

Pada jalur operasi baca, apabila *wallet signature* belum disertakan, *Server PRE* mengembalikan respons 401 UNAUTHORIZED yang berisi *proof_context*. *Client* kemudian dapat menandatangani konteks tersebut menggunakan kunci privat *wallet* aktor pemohon dan mengirimkan ulang *request* dengan menyertakan *x-decmed-wallet-signature* serta *x-decmed-wallet-timestamp*.

IV.2.6.6 Eksekusi Operasi *Re-encryption*, IPFS, dan IOTA

Setelah seluruh pemeriksaan otorisasi selesai, *Server PRE* melanjutkan permintaan ke operasi utama sesuai jenis aksi yang diminta. Pada tahap ini, *Server PRE* berperan sebagai penghubung antara data terenkripsi yang tersimpan di IPFS, metadata segmen yang tersimpan di IOTA, dan mekanisme *proxy re-encryption*.

Pada operasi baca, *Server PRE* terlebih dahulu mengambil metadata RME dari IOTA berdasarkan pasien dan indeks data yang diminta. Metadata tersebut digunakan untuk memperoleh informasi penyimpanan data, seperti *ipfs_cid*, *capsule* dan *enc_key_and_nonce*. Setelah metadata diperoleh, *Server PRE* mengambil data medis terenkripsi dari IPFS menggunakan *ipfs_cid* pada metadata. Selanjutnya, *Server PRE* memuat material PRE yang diperlukan, yaitu *kfrag*, kunci publik pasien, kunci publik penanda tangan, dan kunci publik data RME.

Proses *re-encryption* dilakukan dengan Umbral PRE terhadap *capsule* yang terkait dengan data medis. Hasil proses ini adalah *cfrag*, yaitu fragmen kapsul yang memungkinkan *client* penerima membuka data terenkripsi.

Response yang dikembalikan ke *client* untuk operasi baca berisi data medis terenkripsi, *cfrag* hasil *re-encryption*, informasi kunci publik yang diperlukan oleh

client, *capsule*, *encrypted key and nonce*, dan waktu pembuatan data.

Pada operasi tulis, *client* mengirimkan segmen RME yang sudah terenkripsi. *Server PRE* menyimpan *payload* terenkripsi ke IPFS. Setelah penyimpanan berhasil, IPFS mengembalikan CID sebagai penunjuk terhadap data terenkripsi tersebut. CID dari IPFS kemudian dimasukkan ke dalam metadata segmen final. Metadata ini memuat informasi sesuai dengan skema pada Lampiran G. Setelah metadata final terbentuk, *Server PRE* menyimpannya ke IOTA melalui *smart contract create_medical_record_segment*.

Response yang dikembalikan ke *client* untuk operasi tulis berisi ringkasan metadata segmen yang baru dibuat, yaitu *segment_id*, *related_rme_id*, *dataset_category*, *function_category*, *ipfs_cid*, *integrity_hash*, dan *created_at*. *Response* ini menjadi konfirmasi bahwa data terenkripsi telah tersimpan di IPFS dan metadata referensinya telah dicatat di IOTA.

Pada operasi *list*, *Server PRE* mengambil kumpulan metadata dari IOTA secara bertahap menggunakan mekanisme *pagination*. Setiap metadata yang berhasil di-*decode* kemudian diubah menjadi *list item* yang berisi informasi ringkas, yaitu *index*, *segment_id*, *related_rme_id*, alamat pasien, *dataset category*, *function category*, *ipfs_cid*, *created_at* dan *author_address*. Daftar metadata tersebut kemudian diproses agar hanya menampilkan metadata aktif sesuai dengan *EffectiveCapability*. Setelah itu, hasilnya diurutkan dan dipotong sesuai parameter *cursor* dan *limit* dari *request*. *Response* yang dikembalikan berisi daftar item metadata aktif dan *next_cursor* apabila masih terdapat data lanjutan yang dapat diambil oleh *client*.

Dengan alur ini, IPFS digunakan untuk menyimpan isi data RME terenkripsi, sedangkan IOTA digunakan untuk menyimpan metadata referensial yang diperlukan untuk pencarian, validasi konteks, dan navigasi data. *Server PRE* menghubungkan keduanya dengan mekanisme Umbral PRE pada operasi baca, pencatatan metadata pada operasi tulis, dan penyusunan daftar metadata aktif pada operasi *list*.

IV.2.7 Implementasi *Smart Contract* IOTA Move

Smart contract IOTA Move diimplementasikan untuk menyimpan metadata yang diperlukan oleh mekanisme segmentasi dan kontrol akses. Data RME tetap disimpan secara *off-chain* pada IPFS, sedangkan IOTA menyimpan informasi yang dibutuhkan untuk menemukan, memverifikasi, dan menghubungkan segmen data yang diakses dengan pemiliknya.

Pada implementasi Tugas Akhir ini, struktur penyimpanan metadata klinis di Move masih bersifat flat melalui `medical.metadata: TableVec<PatientMedicalMetadata>`. Struktur `PatientMedicalMetadata` menyimpan index dan metadata. Informasi segmentasi seperti `dataset_category`, `function_category`, `related_rme_id`, CID IPFS, `integrity_hash`, dan `capsule` disimpan di dalam metadata sebagai JSON base64. Dengan cara ini, *Server* PRE dapat mengambil metadata segmen dari IOTA sebelum memutuskan apakah token Macaroon berhak mengakses segmen tersebut.

Fungsi pada *smart contract* disesuaikan untuk mendukung pembuatan metadata RME, penambahan segmen baru, pembaruan referensi segmen, pembacaan metadata, penyimpanan metadata akses personel, dan pencatatan audit delegasi. Operasi yang mengubah metadata hanya dapat dijalankan oleh aktor yang memiliki akses tulis yang sah pada lapisan aplikasi dan *smart contract*. Rincian *module* dan *method* pada implementasi *smart contract* IOTA Move disajikan pada Lampiran P.

IV.2.8 Implementasi *Patient Client*

Patient Client disesuaikan untuk mendukung skenario penerbitan token awal oleh pasien, pembacaan RME, peninjauan audit akses, dan pencabutan akses. *Patient Client* tidak hanya berfungsi sebagai tampilan pengguna, tetapi juga sebagai titik pembentukan konteks permintaan pasien yang dikirimkan ke *Server* PRE. Tangkapan layar implementasi disajikan pada Lampiran Q.

Beberapa bagian dari *Patient Client* yang sudah ada dari implementasi DecMed sebelumnya, seperti halaman register, halaman login, halaman *Home*, halaman Profil, halaman log akses, halaman *scan* QR, dan halaman detail RME, diadaptasi dan disesuaikan untuk mendukung implementasi Tugas Akhir ini. Penyesuaian

dan tambahan halaman baru pada *Patient Client* diterapkan untuk halaman-halaman berikut.

IV.2.8.1 Halaman *Home* (List RME)

Halaman *home* merupakan halaman utama yang pertama kali dilihat pasien setelah berhasil masuk ke dalam aplikasi. Halaman ini menampilkan seluruh RME pasien dalam bentuk daftar *card* yang tersusun secara vertikal. Setiap *card* merepresentasikan satu RME unik dan menampilkan tanggal pembuatan RME dan ID RME. Daftar RME diurutkan berdasarkan tanggal terbaru, sehingga RME yang paling baru selalu muncul di bagian atas. Setiap *card* dapat diklik, di mana klik tersebut akan mengarahkan pasien menuju halaman detail RME yang bersangkutan.

Tampilan dari halaman *home* dapat dilihat pada Gambar Q.1.

IV.2.8.2 Halaman Detail RME

Halaman detail RME ditampilkan setelah pasien memilih salah satu *card* dari daftar RME pada halaman *home*. Halaman ini menampilkan detail lengkap dari sebuah RME per dataset. Bagian atas halaman menampilkan ID dari RME. Di bawahnya, terdapat *tab* daftar *dataset category* RME tersebut. *Tab* yang terpilih menentukan entri data RME yang ditampilkan dalam bentuk *card* yang memuat nama *function category*. Pasien juga dapat kembali ke halaman *home* melalui tautan navigasi balik yang tersedia di bagian atas halaman.

Tampilan dari halaman detail RME dapat dilihat pada Gambar Q.2.

IV.2.8.3 Halaman Audit Delegasi

Halaman audit delegasi menampilkan informasi mengenai seluruh rantai delegasi akses yang terbentuk dari token Macaroon yang telah diterbitkan oleh pasien. Setiap entri pada halaman ini merepresentasikan satu rantai delegasi dan menampilkan identitas personel rumah sakit yang menjadi penerima akses awal, jenis akses yang diberikan, ID RME yang terkait, dan tanggal kedaluwarsa dari akses awal tersebut. Status keseluruhan rantai delegasi juga ditampilkan dalam bentuk label berwarna, yakni *Active* berwarna hijau, *Expired* berwarna kuning, atau *Revoked* berwarna merah. Di dalam setiap entri rantai delegasi, terdapat subdaftar yang merinci setiap

delegasi, yaitu pasangan delegasi dari satu personel ke personel lainnya, beserta informasi kedalaman delegasi, tanggal kedaluwarsa, dan status aktif atau dicabutnya delegasi tersebut.

Tampilan dari halaman detail audit delegasi RME dapat dilihat pada Gambar Q.3.

IV.2.8.4 Halaman Detail *Scan QR*

Halaman *scan QR* merupakan halaman yang digunakan pasien untuk memulai proses pemberian akses kepada personel rumah sakit. Halaman ini menyediakan antarmuka unggah berkas gambar QR yang diperoleh dari rumah sakit, di mana pasien dapat memilih berkas gambar dalam format PNG atau JPEG. Setelah berkas QR diunggah dan diproses, isi QR divalidasi dan identitas personel rumah sakit yang terkandung di dalamnya diidentifikasi. Apabila QR valid, sebuah dialog konfirmasi ditampilkan yang memuat nama personel dan nama rumah sakit tujuan pemberian akses. Pada dialog konfirmasi ini, pasien dapat mengonfigurasi cakupan akses yang akan diberikan, meliputi jenis layanan medis berupa rawat jalan atau rawat inap, mode akses berupa *Read*, *Update*, atau keduanya, serta tanggal dan waktu kedaluwarsa akses. Setelah mengonfirmasi pilihan tersebut, pasien diarahkan ke dialog masukan PIN enam digit sebagai verifikasi identitas sebelum token Macaroon awal diterbitkan dan akses resmi diberikan kepada personel rumah sakit yang dituju.

Tampilan dari halaman *scan QR* dan halaman konfirmasi akses awal dapat dilihat pada Gambar Q.4 dan Gambar Q.5.

IV.2.9 Implementasi *Hospital Client*

Hospital Client disesuaikan untuk mendukung skenario penggunaan token oleh tenaga medis, pembuatan token turunan, dan akses terhadap segmen data RME. Tangkapan layar implementasi disajikan pada Lampiran R.

IV.2.9.1 Halaman *Dashboard (List RME)*

Halaman *dashboard* merupakan halaman utama yang ditampilkan setelah aktor rumah sakit berhasil masuk ke sistem. Konten halaman ini bersifat *role-based*, sehingga tampilan yang disajikan berbeda-beda bergantung pada peran aktor yang

sedang aktif. Untuk peran `MedicalPersonnel`, halaman ini menampilkan dua tab yang dapat dipilih secara bergantian, yaitu tab *Read* dan tab *Write*.

Tab *Read* menampilkan daftar pasien yang token aksesnya memiliki kapabilitas baca, sedangkan tab *Write* menampilkan daftar pasien yang token aksesnya memiliki kapabilitas tulis. Setiap entri dalam kedua tab tersebut menampilkan nama pasien dan dapat diklik untuk menavigasi ke halaman berikutnya. Untuk entri pada tab *Read*, klik akan membawa aktor menuju halaman daftar RME pasien yang terkait dengan token baca. Untuk entri pada tab *Write*, klik akan membawa aktor langsung menuju halaman formulir penulisan segmen RME, dengan konteks token tulis yang sesuai.

Tampilan dari halaman *dashboard* untuk peran `MedicalPersonnel` dapat dilihat pada Gambar R.1.

IV.2.9.2 Halaman Delegasi Akses

Halaman delegasi akses digunakan oleh aktor yang memiliki hak untuk mendelegasikan token aksesnya kepada personel lain di fasyankes. Pada atas halaman ini terdapat ringkasan hak akses yang saat ini dimiliki oleh aktor, berupa daftar pasien. Di bawahnya adalah *form* delegasi yang aktif apabila terdapat setidaknya satu akses pasien yang tersedia. Pada formulir ini, aktor dapat memilih pasien sebagai hak akses yang akan didelegasikan, menentukan mode delegasi berupa *Read*, *Write*, atau keduanya, memilih *preset role* penerima delegasi seperti dokter atau perawat, serta menetapkan tanggal dan waktu kedaluwarsa delegasi. Waktu kedaluwarsa maksimum dibatasi secara otomatis sesuai token induk yang sedang digunakan. Formulir juga menyediakan pratinjau cakupan baca dan tulis berupa daftar *dataset category* dan *function category* yang dapat dipilih atau dihilangkan secara individual sesuai kapabilitas token induk. Terakhir, aktor memilih penerima delegasi dari daftar kandidat personel yang tersedia di fasyankes, kemudian menekan tombol *Delegate* untuk memulai proses delegasi.

Tampilan halaman delegasi akses dapat dilihat pada Gambar R.2 dan Gambar R.3.

IV.2.9.3 Halaman Daftar RME Pasien

Halaman daftar RME pasien menampilkan seluruh RME yang dimiliki oleh pasien tertentu dan dapat diakses oleh aktor sesuai token yang dibawa. Bagian atas halaman menampilkan nama pasien sebagai judul halaman. Di bawahnya, terdapat daftar RME dalam bentuk *card* yang masing-masing memuat ID RME, tanggal pembuatannya, serta kumpulan label *badge* yang merepresentasikan kategori dataset yang terdapat dalam RME tersebut. Setiap *card* RME dapat diklik dan akan mengarahkan aktor menuju halaman detail RME dari RME yang dipilih, dengan konteks token akses yang diteruskan melalui *query string*. Apabila tidak terdapat RME yang dapat diakses, halaman menampilkan pesan kosong.

Tampilan halaman daftar RME pasien dapat dilihat pada Gambar R.4.

IV.2.9.4 Halaman Baca Detail RME

Halaman detail RME menampilkan isi lengkap dari sebuah RME yang dipilih oleh aktor. Bagian atas halaman memuat ID RME sebagai identifikasi, diikuti oleh tab navigasi yang merepresentasikan masing-masing *dataset category* yang terdapat dalam RME tersebut. Aktor dapat berpindah antarklasifikasi dataset dengan mengklik tab yang sesuai. Pada setiap tab dataset, ditampilkan daftar kartu segmen yang memuat nama *function category* dari segmen tersebut. Setiap kartu segmen dilengkapi dengan tombol ikon informasi yang dapat diklik untuk menampilkan atau menyembunyikan metadata. Konten payload segmen dimuat secara *on-demand* dan ditampilkan dalam bentuk *textarea* hanya-baca, atau dalam format tabel data khusus apabila segmen termasuk *function category* ADMINISTRATIVE_GENERAL.

Tampilan halaman detail RME dapat dilihat pada Gambar R.5.

IV.2.9.5 Halaman Tulis Segmen RME

Halaman penulisan segmen RME digunakan ketika aktor memiliki kapabilitas tulis terhadap RME pasien tertentu. Halaman ini dapat diakses dari daftar pasien pada tab *Write* di halaman *dashboard*.

Bagian atas halaman menampilkan nama pasien sebagai konteks identifikasi. Di bawahnya, terdapat menu pilihan *dataset category* yang hanya memuat kategori yang diizinkan oleh token tulis yang aktif. Daftar formulir *textarea* yang

bersesuaian dengan *function category* yang diizinkan dalam dataset tersebut ditampilkan secara otomatis, di mana setiap *textarea* merepresentasikan satu jenis data klinis yang dapat diisi. Aktor hanya perlu mengisi *textarea* untuk *function category* yang ingin dituliskan, karena hanya entri yang terisi yang akan dikirimkan. Setelah mengisi data yang diperlukan, aktor menekan tombol *Write* untuk menyimpan segmen-segmen baru ke dalam RME pasien.

Tampilan halaman penulisan segmen RME dapat dilihat pada Gambar R.6.

IV.3 Pengujian Sistem

Pengujian sistem dilakukan untuk memastikan implementasi memenuhi kebutuhan yang sudah didefinisikan pada Subbab III.1.3.

IV.3.1 Strategi Pengujian

Strategi pengujian disusun berdasarkan kebutuhan sistem pada Tabel III.3 dan III.4. Pengujian dibagi menjadi pengujian kebutuhan fungsional dan pengujian kebutuhan nonfungsional.

Pengujian kebutuhan fungsional diberi ID PS-TA dan dijalankan melalui skenario manual untuk memeriksa perilaku sistem dari sudut pandang aktor layanan kesehatan. Pengujian kebutuhan nonfungsional diberi ID PU-TA dan dijalankan melalui pengujian unit atau integrasi terhadap komponen token, segmentasi data, validasi akses, dan *Server PRE*. Pengujian otomatis dijalankan dengan *cargo test* pada komponen yang relevan.

Kriteria keberhasilan pengujian ditentukan berdasarkan kesesuaian hasil skenario manual terhadap kebutuhan fungsional dan kelulusan pengujian otomatis terhadap kebutuhan nonfungsional.

IV.3.2 Pengujian Kebutuhan Fungsional

Pengujian kebutuhan fungsional dijalankan secara manual untuk memastikan perilaku sistem sesuai dengan rancangan alur akses dan delegasi pada Subbab III.3.6.

Rincian pengujian kebutuhan fungsional disajikan pada Lampiran I, Tabel I.1. Terdapat 12 skenario pengujian dengan ID P-KF-01 sampai P-KF-12 yang dijalankan untuk alur Rawat Jalan dan Rawat Inap. Perbedaan kedua alur tersebut terdapat pada keberadaan segmen data PERENCANAAN_PEMULANGAN yang hanya muncul pada alur Rawat Inap. Delegasi akses dijalankan mengikuti *preset* yang sudah terdefinisi, sehingga dihasilkan token turunan dengan *caveats* sesuai dengan Lampiran H.

IV.3.3 Pengujian Kebutuhan Nonfungsional

Pengujian kebutuhan nonfungsional dijalankan untuk mengevaluasi pemenuhan aspek keamanan dan keterlacakan pada sistem, khususnya pada komponen yang menangani token Macaroon, segmentasi data RME, validasi akses, *wallet proof*, revokasi, pencatatan delegasi, dan *Server PRE*. Setiap pengujian dikaitkan dengan kebutuhan nonfungsional yang telah didefinisikan pada Tabel III.4. Untuk memudahkan ketertelusuran evaluasi, pengujian yang terkait kebutuhan nonfungsional diberi ID P-KNF.

IV.3.3.1 Pengujian KNF-TA-01

Pengujian KNF-TA-01 memastikan bahwa penerima akses hanya dapat memperoleh data RME dalam bentuk *plaintext* apabila segmen yang diminta berada dalam cakupan otorisasi token. Dengan demikian, permintaan terhadap segmen di luar cakupan harus ditolak sebelum proses *re-encryption* menghasilkan data yang dapat didekripsi oleh penerima akses.

Pengujian pertama, yaitu P-KNF-01, dijalankan melalui *unit testing* pada komponen PRE. Kondisi ketika aktor memiliki token baca, tetapi token tersebut tidak mencakup akses baca terhadap segmen data laboratorium, disimulasikan pada tes ini. Kemudian fungsi yang diuji, yaitu `verify_segment_access`, dipanggil dengan parameter Macaroon tanpa akses ke laboratorium dan segmen data laboratorium. Pada tes ini, akses diharapkan ditolak. Kode pengujian dapat dilihat pada Kode IV.9.

```
1  #[test]
2  fn pre_rejects_segment_outside_caveats() {
3      let (_token, mac, verified) = verified_read_token();
```

```

4     let outside_scope = segment(
5         DatasetCategory::LABORATORIUM,
6         FunctionCategory::LABORATORIUM,
7     );
8
9     let err = verify_segment_for_token(
10         ...,
11         &outside_scope,
12         &mac,
13     )
14     .unwrap_err();
15     // assert error DatasetCategoryNotAllowed
16 }

```

Kode IV.9: Pengujian P-KNF-01 untuk KNF-TA-01

Pengujian kedua, yaitu P-KNF-02, dijalankan melalui *client hospital* untuk memastikan aktor apoteker tidak dapat membuka atau memperoleh segmen data laboratorium. Pada skenario ini, akun apoteker tidak memiliki caveat akses terhadap kategori laboratorium, sehingga segmen laboratorium tidak ditampilkan sebagai data yang dapat diakses.

IV.3.3.2 Pengujian KNF-TA-02

Pengujian KNF-TA-02 memastikan integritas token otorisasi dan batasan akses tetap terjaga selama proses delegasi. Secara khusus, pengujian diarahkan untuk memastikan bahwa token turunan tidak dapat memperluas cakupan akses, menaikkan kedalaman delegasi, atau memperpanjang masa berlaku melebihi token induk.

Pengujian pertama, yaitu P-KNF-03, dijalankan melalui *unit testing* pada Kode IV.10. Pada tes ini dipastikan bahwa token delegasi tidak dapat menambahkan hak akses `write_function` yang tidak dimiliki oleh *parent token*. Ketika *child token* mencoba meminta `write_functions` di luar scope *parent token*, proses `attenuate_macaroon()` ditolak dengan error `DelegationExpandsAccess`.

```

1  #[test]
2  fn cannot_delegate_write_function_from_parent_read_only_scope() {

```

```

3     let write_functions: Vec<_> = ... // tidak mencakup PERESEPAN
4     let parent = scoped_token(
5         ...
6         &write_functions,
7         Some("Read"),
8     );
9     let params = DelegationAttenuationParams {
10         write_functions: vec![FunctionCategory::PERESEPAN],
11         ...
12     };
13     let err = attenuate_macaroon(&parent, &params).unwrap_err();
14     // assert error DelegationExpandsAccess
15 }

```

Kode IV.10: Pengujian P-KNF-03 untuk KNF-TA-02

Pengujian kedua, yaitu P-KNF-04, dijalankan melalui *unit testing* pada Kode IV.11. Pada tes ini dipastikan bahwa batas kedalaman delegasi tidak dapat dinaikkan oleh token turunan. Jika *child token* mencoba menetapkan `max_delegation_depth` lebih besar dari batas *parent token*, delegasi ditolak dengan error `DelegationDepthNotMonotonic`.

```

1  #[test]
2  fn cannot_increase_max_delegation_depth_on_delegate() {
3      let mut params = DelegationAttenuationParams {
4          ...,
5          max_delegation_depth: 99
6      };
7      let err = attenuate_macaroon(
8          &doctor_token(), // max depth 1
9          &params
10     )
11     // assert error DelegationDepthNotMonotonic
12 }

```

Kode IV.11: Pengujian P-KNF-04 untuk KNF-TA-02

Pengujian ketiga, yaitu P-KNF-05, dijalankan melalui *unit testing* pada Kode

IV.12. Pada tes ini dipastikan bahwa delegasi dari token admin write tetap tidak dapat memperluas cakupan dataset. Ketika *child token* mencoba meminta *write_datasets* di luar cakupan *parent token*, sistem menolak dengan error *DelegationExpandsAccess*.

```
1  #[test]
2  fn admin_write_true_expansion_still_fails() {
3      let params = DelegationAttenuationParams {
4          ...,
5          write_datasets: vec![DatasetCategory::RAWAT_INAP],
6      };
7      let err = attenuate_macaroon(
8          &admin_write_token(), // write token RAWAT_JALAN
9          &params
10     )
11     // assert error DelegationExpandsAccess
12 }
```

Kode IV.12: Pengujian P-KNF-05 untuk KNF-TA-02

Pengujian terakhir, yaitu P-KNF-06, dijalankan melalui *client hospital* untuk memastikan sistem menolak atenuasi hak akses dengan batas waktu yang melebihi masa berlaku token induk. Pada skenario ini, notifikasi *error* ditampilkan pada halaman delegasi ketika pengguna mencoba membuat token turunan dengan waktu kedaluwarsa yang lebih panjang daripada token induk.

IV.3.3.3 Pengujian KNF-TA-03

Pengujian KNF-TA-03 memastikan permintaan akses ditolak apabila token, rantai delegasi, atau bukti kepemilikan identitas aktor pemohon tidak valid.

Pengujian pertama, yaitu P-KNF-07, dijalankan melalui *unit testing* pada Kode IV.13. Pada tes ini dipastikan bahwa token yang sudah melewati batas waktu berlaku tidak dapat digunakan untuk mengakses segmen RME. Pada skenario ini, waktu verifikasi dibuat berada setelah waktu kedaluwarsa token. Sistem menolak permintaan akses dengan error *ExpiredToken*.

```
1  #[test]
2  fn expired_token_rejected() {
```

```

3     let mac = ... // token dokter, expired 2026-07-02
4     let future = ... // 2031-01-01T00:00:00+00:00
5     let err = verify_decmed_token(
6         ...
7         &mac,
8         &ctx({
9             ...,
10            now: future,
11        }),
12    )
13    // assert error ExpiredToken
14 }

```

Kode IV.13: Pengujian P-KNF-07 untuk KNF-TA-03

Pengujian kedua, yaitu P-KNF-08, dijalankan melalui *unit testing* pada Kode IV.14. Pada tes ini dipastikan bahwa rantai delegasi yang tidak valid akan ditolak. Pada pengujian ini, token dimodifikasi dengan caveat `delegated_by` yang tidak sesuai dengan rantai delegasi semestinya. Ketika token diverifikasi, sistem menolak permintaan dengan error `InvalidDelegationChain`.

```

1  #[test]
2  fn broken_delegation_chain_rejected() {
3      let mut mac = ... // token dokter
4      add_caveat_to_macaroon(&mut mac, "delegated_by", "0xAPOTEK");
5      add_caveat_to_macaroon(&mut mac, "delegated_to", LAB);
6      let err = verify_ctx(
7          &mac,
8          ...
9      )
10     // assert error InvalidDelegationChain
11 }

```

Kode IV.14: Pengujian P-KNF-08 untuk KNF-TA-03

Pengujian ketiga, yaitu P-KNF-09, dijalankan melalui *unit testing* pada Kode IV.15. Pada tes ini dipastikan bahwa bukti kepemilikan *wallet* harus cocok dengan salah satu subjek pada rantai delegasi. Pada skenario ini, token memuat

rantai yang mencakup aktor LAB, tetapi permintaan pertama menggunakan tanda tangan dari aktor di luar rantai. Sistem menolak permintaan dengan error `InvalidWalletSignature`.

```
1  #[test]
2  fn wallet_proof_must_match_chain_subject() {
3      let mac = ... // token dengan subjects memuat LAB
4      let verifier = ChainSubjectVerifier {
5          subjects: vec![LAB],
6          valid_sig: "lab-sig",
7      };
8      let ctx = TokenVerificationContext {
9          ...,
10         wallet_signature: Some("outsider-sig"),
11     };
12     let err = verify_decmed_token(
13         &mac,
14         &ctx,
15         Some(&verifier),
16     )
17     // assert error InvalidWalletSignature
18 }
```

Kode IV.15: Pengujian P-KNF-09 untuk KNF-TA-03 dan KNF-TA-06

IV.3.3.4 Pengujian KNF-TA-04

Pengujian KNF-TA-04 memastikan sistem menyediakan keterlacakan akses dan delegasi melalui pencatatan metadata yang dapat ditinjau kembali oleh pasien.

Pengujian P-KNF-10 dijalankan melalui *client* pasien. Skenario dimulai dari pemberian akses awal oleh pasien kepada petugas rekam medis, kemudian dilanjutkan dengan delegasi dari petugas rekam medis kepada dokter. Setelah proses tersebut dijalankan, pasien membuka halaman riwayat delegasi untuk memastikan informasi delegator, delegatee, status, waktu, dan relasi delegasi dapat ditelusuri. Tangkapan layar halaman ini dapat dilihat pada Gambar Q.3.

IV.3.3.5 Pengujian KNF-TA-05

Pengujian KNF-TA-05 memastikan sistem menolak akses untuk hak akses yang sudah dicabut.

Pengujian pertama, yaitu P-KNF-11, dijalankan melalui tes pada Kode IV.16. Pada tes ini dipastikan bahwa token yang sudah masuk daftar revokasi tidak dapat digunakan kembali. Pada skenario ini, token yang belum dicabut diverifikasi terlebih dahulu dan hasilnya berhasil. Setelah itu, revocation key token dibuat bernilai cocok dengan token yang sedang diverifikasi. Sistem kemudian menolak akses dengan status UNAUTHORIZED.

```
1  #[test]
2  fn revocation_key_rejects_revoked_token() {
3      let token = verified_read_token(); // token valid
4      let revoked_key = ... // hash token valid
5
6      ensure_token_not_revoked(
7          ...,
8          &token,
9          |_| Ok(false), // simulasi Redis kosong
10     ) // success
11
12     let err = ensure_token_not_revoked(
13         ...,
14         &token,
15         |key| Ok(key == revoked_key), // simulasi revoked key
16         // terdapat pada Redis
17     ) // error UNAUTHORIZED
18
19     // assert status UNAUTHORIZED
20 }
```

Kode IV.16: Pengujian P-KNF-11 untuk KNF-TA-05

Pengujian kedua, yaitu P-KNF-12, dijalankan melalui *client* pasien dan *client hospital*. Pengujian dimulai dengan pasien mencabut hak akses yang sebelumnya diberikan kepada petugas rekam medis. Setelah revokasi dijalankan, akses dicoba

kembali dari akun petugas rekam medis dan dokter yang memperoleh delegasi. Sistem dinyatakan memenuhi kebutuhan apabila hak akses yang telah dicabut tidak lagi dapat digunakan dan tidak lagi muncul sebagai akses aktif pada halaman *Home* maupun halaman delegasi.

IV.3.3.6 Pengujian KNF-TA-06

Pengujian KNF-TA-06 memastikan bukti kepemilikan identitas terikat terhadap aktor pada rantai delegasi, token akses, dan konteks permintaan akses.

Pengujian pertama, yaitu P-KNF-13, dijalankan melalui *unit testing* pada Kode IV.17. Pada tes ini dipastikan bahwa setiap permintaan akses menggunakan token DecMed harus menyertakan bukti kepemilikan identitas berupa tanda tangan wallet. Jika `wallet_signature` tidak diberikan, sistem menolak permintaan dengan error `WalletSignatureRequired`. Hal ini menunjukkan bahwa token akses saja tidak cukup untuk memperoleh akses tanpa bukti identitas dari aktor yang tercatat pada rantai.

```
1  #[test]
2  fn wallet_signature_required_for_every_decmed_token() {
3      let mac = ... // token dokter
4      let err = verify_decmed_token(
5          &mac,
6          ...,
7          &TokenVerificationContext {
8              ...,
9              wallet_signature: None, // tidak ada
10         },
11     )
12     // assert error WalletSignatureRequired
13 }
```

Kode IV.17: Pengujian P-KNF-13 untuk KNF-TA-06

Pengujian kedua dijalankan melalui P-KNF-09 pada Kode IV.15, sama dengan yang digunakan sebelumnya untuk menguji KNF-TA-03. Pada tes ini dipastikan bahwa bukti identitas harus cocok dengan salah satu subjek pada rantai delegasi. Token pada skenario ini memuat subjek LAB. Ketika permintaan menggunakan

tanda tangan dari aktor di luar rantai, sistem menolak permintaan dengan error `InvalidWalletSignature`. Setelah tanda tangan diganti menjadi `lab-sig`, verifikasi token berhasil.

Pada implementasinya, fungsi `verify_decmed_token()` membentuk `WalletProofContext` dari token dan konteks akses yang sedang diminta. Konteks tersebut memuat `token_id`, alamat pasien, `related_rme_id`, mode operasi, `segment_id`, kategori dataset, kategori fungsi, dan `timestamp`. Konteks ini kemudian diverifikasi terhadap seluruh subjek pada `DelegationChain::subjects()`, sehingga bukti kepemilikan identitas terikat pada aktor yang tercatat dalam rantai delegasi.

IV.4 Evaluasi

Evaluasi dilakukan dengan membandingkan hasil implementasi dan pengujian terhadap kebutuhan sistem. Hasil evaluasi digunakan untuk menilai apakah pendekatan Macaroons, segmentasi data RME, dan penegakan akses pada *Server PRE* mampu menjawab keterbatasan kontrol akses pada DecMed awal.

Berdasarkan hasil pengujian kebutuhan fungsional dan nonfungsional, seluruh kebutuhan sistem yang dirumuskan pada Tugas Akhir ini dinyatakan terpenuhi.

IV.4.1 Evaluasi terhadap Kebutuhan Sistem

Berdasarkan kebutuhan sistem pada Subbab III.1.3, implementasi dievaluasi terhadap kebutuhan fungsional dan nonfungsional yang menjadi dasar pengembangan DecMed. Kebutuhan sistem pada Subbab III.1.3 dihubungkan dengan implementasi dan pengujian yang telah dijalankan. Setiap kebutuhan diperiksa berdasarkan komponen yang merealisasikannya dan skenario pengujian yang memverifikasi perilakunya. Pemetaan ini menunjukkan keterhubungan antara kebutuhan, implementasi, dan pengujian tanpa memisahkan ketiganya sebagai daftar yang berdiri sendiri.

Ringkasan pemetaan kebutuhan sistem terhadap implementasi dan pengujian disajikan pada Lampiran I, Tabel I.2. Hasil evaluasi menunjukkan bahwa seluruh kebutuhan fungsional dan nonfungsional telah terpenuhi berdasarkan skenario

pengujian manual serta pengujian unit atau integrasi yang telah dijalankan.

Dengan demikian, hasil evaluasi menunjukkan bahwa implementasi Macaroons, segmentasi data RME, atenuasi delegasi, revokasi, audit delegasi, dan verifikasi bukti kepemilikan identitas aktor pada rantai delegasi telah memenuhi kebutuhan yang ditetapkan. Kebutuhan fungsional terpenuhi melalui skenario P-KF-01 sampai P-KF-12, sedangkan kebutuhan nonfungsional terpenuhi melalui pengujian P-KNF-01 sampai P-KNF-13.

BAB V

PENUTUP

V.1 Kesimpulan

Berdasarkan hasil analisis, perancangan, implementasi, dan evaluasi yang telah dilakukan, dapat disimpulkan beberapa hal sebagai berikut:

1. Kontrol akses granular pada DecMed dirancang dan diimplementasikan dengan Macaroons sebagai token otorisasi. Batasan akses direpresentasikan melalui *caveats*, sedangkan penegakan otoritas dilakukan pada *Server PRE* sebelum data diakses.
2. Segmentasi data RME diterapkan dengan memecah data *off-chain* berdasarkan *dataset category* dan *function category*. Dengan struktur ini, data RME tidak lagi diperlakukan sebagai satu *encrypted blob* besar, tetapi sebagai kumpulan segmen klinis. Metadata setiap segmen digunakan untuk menentukan segmen yang dapat diakses oleh aktor sesuai cakupan token.
3. Atenuasi *offline* diterapkan untuk mendukung pendelegasian akses antar tenaga kesehatan tanpa penerbitan token baru oleh pasien pada setiap perpindahan akses. Pemegang token membentuk token turunan secara *offline* dengan menambahkan *caveats* yang mempersempit cakupan token induk. Pencatatan delegasi, pembatasan kedalaman delegasi, validasi agar token turunan tidak memperluas hak akses token induk, serta revokasi berantai juga dicakup dalam implementasi.

V.2 Saran

Berdasarkan batasan dan hasil evaluasi Tugas Akhir ini, beberapa saran untuk pengembangan berikutnya adalah sebagai berikut:

1. Cakupan skenario layanan klinis diperluas hingga pelayanan antar fasyankes agar skenario nyata seperti rujukan antar fasyankes dapat didukung.

2. Cakupan skenario layanan klinis diperluas hingga pelayanan gawat darurat. Data IGD dan mekanisme akses ketika pasien tidak sadar perlu diimplementasikan agar skenario nyata gawat darurat dapat didukung.
3. Integrasi dengan standar interoperabilitas data kesehatan dapat diteliti lebih lanjut. Segmentasi RME dapat dikembangkan untuk integrasi dengan SATUSEHAT atau pemetaan ke standar FHIR.
4. Integrasi dan pengujian dengan sistem rumah sakit dikembangkan untuk mendukung penggunaan sistem dalam konteks nyata, disesuaikan dengan tata laksana atau dokumen Pedoman Nasional Pelayanan Kesehatan.

DAFTAR REFERENSI

- Amaracitra, D. S., & Alamsyah, A. (2025). Decentralized Medical Record Model Using Composable NFT: Achieving Data Security, Interoperability, and Privacy through Granular Data Access. *2025 15th International Conference on Electrical Engineering (ICEENG)*. <https://doi.org/10.1109/ICEENG64546.2025.11031352>
- Anagnostopoulou, A., Kehrioti, E., Mavridis, I., & Gritzalis, D. (2025). Bolstering IIoT Resilience: The Synergy of Blockchain and CapBAC. *Proceedings of the 22nd International Conference on Security and Cryptography (SECRYPT 2025)*, 120–131. <https://doi.org/10.5220/0013513800003979>
- Arciszewski, S., & Haussmann, S. (2022, Mei). PASETO: Platform-Agnostic Security Tokens [Work in Progress, expired Internet-Draft]. <https://datatracker.ietf.org/doc/html/draft-paragon-paseto-rfc-01>
- Benet, J. (2014, Juli). *IPFS — Content Addressed, Versioned, P2P File System*. arXiv: 1407.3561 [cs.NI]. <https://doi.org/10.48550/arXiv.1407.3561>
- Birgisson, A., Politz, J. G., Erlingsson, Ú., Taly, A., Vrabie, M., & Lentzner, M. (2014). Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud. *Proceedings of the 2014 Network and Distributed System Security Symposium (NDSS)*. <https://doi.org/10.14722/ndss.2014.23251>
- Blaze, M., Bleumer, G., & Strauss, M. (1998). Divertible Protocols and Atomic Proxy Cryptography. *Advances in Cryptology — EUROCRYPT '98*, 1403, 127–144. <https://doi.org/10.1007/BFb0054122>
- dCache. (nodate). *Chapter 1. Understanding Macaroons: dCache UserGuide 8.2*. dCache. Diakses pada Juni 16, 2026, dari <https://dcache.org/manuals/UserGuide-8.2/macaroons.shtml>
- Eclipse Biscuit Project. (nodate). *Biscuit Tokens*. Diakses pada Juni 4, 2026, dari <https://www.biscuitsec.org/>
- Ferraiolo, D. F., Gavrila, S., & Kemp, R. P. (2015, Oktober). *Policy Machine: Features, Architecture, and Specification* (NIST IR 7987 Revision 1) (Available from

<https://nvlpubs.nist.gov/nistpubs/ir/2015/nist.ir.7987r1.pdf>).

National Institute of Standards dan Technology (NIST).
<https://doi.org/10.6028/NIST.IR.7987r1>

for Standardization, I. O. (2014, Oktober). *Health informatics — Privilege management and access control — Part 2: Formal models* (techreport Nomor ISO 22600-2:2014) (Accessed: 2026-07-02). ISO. Geneva, Switzerland. Diakses pada Juli 2, 2026, dari <https://www.iso.org/standard/62654.html>

Hu, V. C., Ferraiolo, D. F., Kuhn, R. D., Schnitzer, A., Sandlin, K., Miller, R., & Scarfone, K. (2014). *Guide to Attribute Based Access Control (ABAC) Definition and Considerations* (NIST Special Publication Nomor 800-162) (Accessed: 2026-06-03). National Institute of Standards dan Technology. Gaithersburg, MD. <https://doi.org/10.6028/NIST.SP.800-162>

Peraturan Menteri Kesehatan Republik Indonesia Nomor 73 Tahun 2016 tentang Standar Pelayanan Kefarmasian di Apotek, Jakarta (2016, Desember 23). Diakses pada Juni 16, 2026, dari <https://farmalkes.kemkes.go.id/unduh/permenkes-73-2016/>

Joint Task Force Transformation Initiative. (2020). *Security and Privacy Controls for Information Systems and Organizations* (NIST Special Publication Nomor 800-53, Revision 5). National Institute of Standards dan Technology. Gaithersburg, MD. <https://doi.org/10.6028/NIST.SP.800-53r5>

Jones, L. A., Nelder, J. R., Fryer, J. M., Alsop, P. H., Geary, M. R., Prince, M., & Cardinal, R. N. (2022). Public opinion on sharing data from health services for clinical and research purposes without explicit consent: an anonymous online survey in the UK. *BMJ Open*, 12, Artikel jurnal e057579. <https://doi.org/10.1136/bmjopen-2021-057579>

Jones, M. B., Bradley, J., & Sakimura, N. (2015, Mei). *JSON Web Token (JWT)* (RFC Nomor 7519). Internet Engineering Task Force. <https://doi.org/10.17487/RFC7519>

Kementerian Kesehatan Republik Indonesia. (2022a, April). Keputusan Menteri Kesehatan Republik Indonesia Nomor HK.01.07/MENKES/1128/2022 tentang Standar Akreditasi Rumah Sakit [Ditetapkan di Jakarta]. Diakses pada Juli 1, 2026, dari https://keslan.kemkes.go.id/unduh/fileunduhan_1654499045_682777.pdf

- Kementerian Kesehatan Republik Indonesia. (2022b, Agustus). Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 tentang Rekam Medis.
- Leffew, K. (2019, Desember 4). *Secure Access Control in the Decentralized Cloud*. Storj. Diakses pada Juni 16, 2026, dari <https://www.storj.io/blog/secure-access-control-in-the-decentralized-cloud>
- Li, A. S., Safavi-Naini, R., & Fong, P. W. L. (2022). A Capability-based Distributed Authorization System to Enforce Context-aware Permission Sequences. *Proceedings of the 27th ACM Symposium on Access Control Models and Technologies*, 195–206. <https://doi.org/10.1145/3532105.3535014>
- Liu, R., & Chen, P. (2025). Research on Access Control Model of Electronic Medical Records Based on Blockchain Technology. *2025 5th Asia-Pacific Conference on Communications Technology and Computer Science (ACCTCS)*, 662–665. <https://doi.org/10.1109/ACCTCS66275.2025.00066>
- Keputusan Menteri Kesehatan Republik Indonesia Nomor HK.01.07/Menkes/1423/2022 tentang Pedoman Variabel dan Metadata Rekam Medis, Jakarta (2022).
- Microsoft. (2006). *Uncover Security Design Flaws Using the STRIDE Approach*. Diakses pada April 1, 2026, dari <https://learn.microsoft.com/en-us/archive/msdn-magazine/2006/november/uncover-security-design-flaws-using-the-stride-approach>
- NHS England. (2025, Maret 14). *Consent to using and sharing patient information* (1.1). Diakses pada April 29, 2026, dari <https://www.england.nhs.uk/long-read/consent-to-using-and-sharing-patient-information/>
- Núñez, D. (2017). Umbral: A Threshold Proxy Re-Encryption Scheme [Available at <https://github.com/nucypher/umbral-doc/blob/master/umbral-doc.pdf>].
- Odugu, N. K., & Rajesh, A. (2021). A Fine-Grained Access Control Survey For The Secure Big Data Access [Accessed: 2026-06-03]. *Turkish Journal of Computer and Mathematics Education (TURCOMAT)*, 12(10), 4180–4186. <http://www.turcomat.org/index.php/turkbilmater/article/view/5141>
- of Health, U. D., & Services, H. (2009). *Minimum Necessary: guidance for covered entities* (techreport) (Accessed: 2026-07-02). Washington, D.C. Diakses pada Juli 2, 2026, dari <https://www.hhs.gov/sites/default/files/o%09cr/privacy/hipaa/understanding/coveredentities/minimumnecessary.pdf>

- Patil, S. P. (2024, Desember). *Blockchain Technology for Secure Healthcare Data Management with Patient Empowerment* [MSc Research Project]. National College of Ireland [MSc Cyber Security. Supervisor: Prof Liam McCabe. Word count: 6744]. <https://norma.ncirl.ie/8241/1/sidhantprakashpatil.pdf>
- Peng, G., Zhang, A., & Lin, X. (2023). Patient-Centric Fine-Grained Access Control for Electronic Medical Record Sharing With Security via Dual-Blockchain. *IEEE Transactions on Network Science and Engineering*, 10(6), 3908–3921. <https://doi.org/10.1109/TNSE.2023.3276166>
- Republik Indonesia. (2004, Oktober). Undang-Undang Nomor 29 Tahun 2004 tentang Praktik Kedokteran [LN. 2004/ No.116, TLN NO. 4431]. Diakses pada November 11, 2025, dari <https://peraturan.bpk.go.id/Details/40752/uu-no-29-tahun-2004>
- Sadewa, B. (2025). *Pengembangan Kontrol Akses dalam Kerangka Kerja Sistem Manajemen Rekam Medis Elektronik Berbasis IOTA* [Tugas Akhir]. Institut Teknologi Bandung. Diakses pada Maret 11, 2026, dari https://digilib.itb.ac.id/gdl/view_data/pengembangan-kontrol-akses-dalam-kerangka-kerja-sistem-manajemen-rekam-medis-elektronik-berbasis-iota/Bakta-Sadewa
- Sandhu, R., & Samarati, P. (1994). Access control: principle and practice. *IEEE Communications Magazine*, 32(9), 40–48. <https://doi.org/10.1109/35.312842>
- SATUSEHAT Platform. (nodate). *Rawat Inap*. Diakses pada Juni 30, 2026, dari <https://satusehat.kemkes.go.id/platform/docs/id/interoperability/rawat-inap-new/>
- SATUSEHAT Platform. (2023, Agustus 22). *Resume Medis - Rawat Jalan*. Diakses pada Juni 30, 2026, dari <https://satusehat.kemkes.go.id/platform/docs/id/interoperability/rme-rawat-jalan/>
- Savadatti, S. G., Krishnamoorthy, S., & Delhibabu, R. (2025). Survey of Distributed Ledger Technology (DLT) for Secure and Scalable Computing. *IEEE Access*, 13, 8393–8415. <https://doi.org/10.1109/ACCESS.2025.3528211>
- Sedi Nzakuna, P., Paciello, V., Lay-Ekuakille, A., Kuti Lusala, A., Dello Iacono, S., & Pietrosanto, A. (2025). From IOTA Tangle 2.0 to Rebased: A Comparative Analysis of Decentralization, Scalability, and Suitability for IoT Applications. *Sensors*, 25(11), 3408. <https://doi.org/10.3390/s25113408>
- Shostack, A. (2014). *Threat Modeling: Designing for Security*. Wiley.

- Singh, Y., Jaiswal, S., & Kumar, V. (2025). Granular Level Privacy Aware Access Control in Block Chain Based EHR Systems. *2025 12th International Conference on Reliability, Infocom Technologies and Optimization (Trends and Future Directions) (ICRITO)*. <https://doi.org/10.1109/ICRITO66076.2025.11241459>
- Srinivas, V., Choubey, U., Motwani, J., Anamika, F., Chennupati, C., Garg, N., Gupta, V., & Jain, R. (2023). Synergistic strategies: Optimizing outcomes through a multidisciplinary approach to clinical rounds. *Proceedings (Bayl Univ Med Cent)*, 37(1), 144–150. <https://doi.org/10.1080/08998280.2023.2274230>
- Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi, Jakarta (2022, Oktober 17). Diakses pada Desember 20, 2025, dari <https://peraturan.bpk.go.id/Details/229798/uu-no-27-tahun-2022>
- World Health Organization. (2010, September 1). *Framework for Action on Interprofessional Education and Collaborative Practice*. World Health Organization. Geneva. Diakses pada Juni 16, 2026, dari <https://www.who.int/publications/i/item/framework-for-action-on-interprofessional-education-collaborative-practice>

Lampiran A. Metadata Rekam Medis Elektronik

Tabel berikut menjabarkan metadata variabel RME yang diadopsi dari KMK No. HK.01.07/MENKES/1423/2022 untuk dataset Rawat Jalan, Rawat Inap, Laboratorium, dan Apotek (Menteri Kesehatan Republik Indonesia, 2022). Klasifikasi dokumentasi pada tabel berikut diperoleh melalui interpretasi terhadap definisi operasional metadata yang tercantum pada dokumen KMK tersebut. Dokumentasi administratif tidak dibagi ke dalam segmentasi yang lebih rinci karena tidak menjadi fokus utama pada rancangan segmentasi data dalam Tugas Akhir ini.

Tabel A.1: Metadata Variabel RME Rawat Jalan

Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
Lembar Identitas	Identitas pasien dan data dasar rekam medis	Administratif
Cara Pembayaran	Metode atau skema pembayaran pelayanan	Administratif
General Consent / Persetujuan Umum	Persetujuan umum pasien terhadap pelayanan	Administratif
Formulir Umum / Asesmen Awal Rawat Jalan	Anamnesis	Klinis
	Pemeriksaan Fisik	Klinis
	Pemeriksaan Psikologis, Sosial Ekonomi, Spiritual	Klinis
Pemeriksaan Spesialistik	Riwayat Penggunaan Obat	Klinis
	Rencana Rawat	Klinis
	Instruksi Medik dan Keperawatan	Klinis
	Pemeriksaan Penunjang	Klinis
	Diagnosis	Klinis
	Persetujuan Tindakan / Penolakan Tindakan (<i>Informed Consent</i>)	Klinis

Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
	Terapi: Tindakan dan Obat / Peresepan	Klinis

Tabel A.2: Metadata Variabel RME Rawat Inap

Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
Lembar Identitas	Identitas pasien dan data dasar rekam medis	Administratif
Cara Pembayaran	Metode atau skema pembayaran pelayanan	Administratif
General Consent / Persetujuan Umum	Persetujuan umum pasien terhadap pelayanan	Administratif
Formulir Rawat Inap	Anamnesis	Klinis
	Pemeriksaan Fisik	Klinis
	Pemeriksaan Psikologis, Sosial Ekonomi, Spiritual	Klinis
Pemeriksaan Spesialistik	Riwayat Penggunaan Obat	Klinis
	Perencanaan Pemulangan Pasien	Klinis
	Rencana Rawat	Klinis
	Instruksi Medik dan Keperawatan	Klinis
	Pemeriksaan Penunjang	Klinis
	Diagnosis	Klinis
	Persetujuan Tindakan / Penolakan Tindakan (<i>Informed Consent</i>)	Klinis
	Terapi	Klinis

Tabel A.3: Metadata Variabel RME Laboratorium

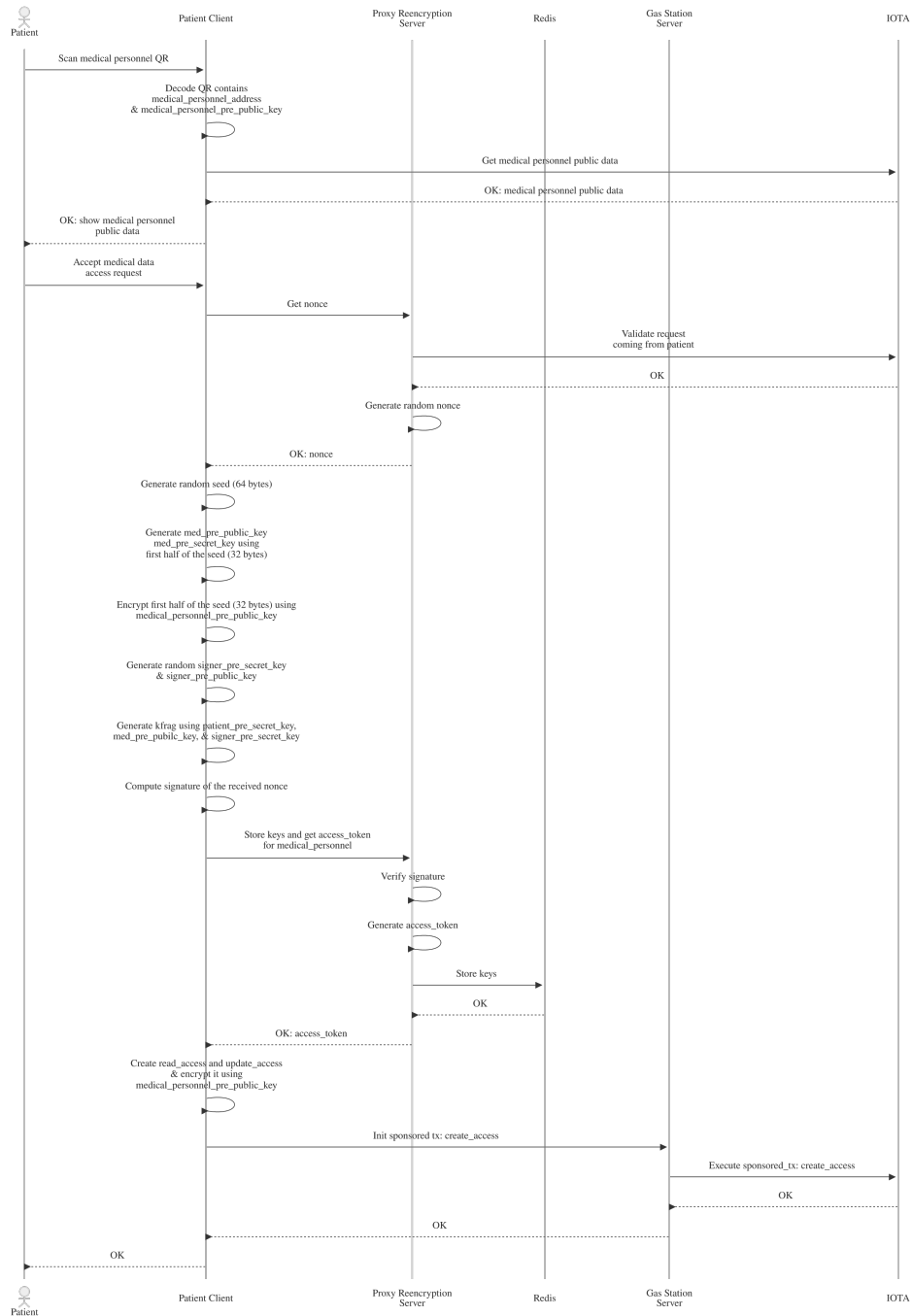
Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
Laboratorium	Identitas Laboratorium dan Pasien	Administratif
	Permintaan Pemeriksaan	Klinis
	Spesimen Klinis	Klinis
	Fiksasi dan Pengolahan Spesimen	Klinis
	Hasil Pemeriksaan	Klinis
	Interpretasi dan Validasi Hasil	Klinis

Tabel A.4: Metadata Variabel RME Apotek

Kelompok Data	Subkelompok Metadata	Klasifikasi Dokumentasi
Peresepan	Identitas Pasien	Administratif
	Data Resep dan Obat	Klinis
	Riwayat Penggunaan Obat	Klinis
	Riwayat Alergi	Klinis
	Asal Resep	Klinis
	Dokter Penulis Resep	Klinis
	Status dan Pengkajian Resep	Klinis
Dispensing	Status Resep	Klinis
	Waktu Penyiapan Obat	Klinis
	Waktu Penyerahan Obat	Klinis
	Nama Petugas yang Melakukan Dispensing	Klinis
	Etiket	Klinis

Lampiran B. Alur Pemberian Akses Medis pada DecMed

Alur pemberian akses medis dari pasien kepada tenaga medis pada implementasi DecMed saat ini dapat dilihat pada Gambar B.1.



Gambar B.1: *Sequence Diagram* Alur Pemberian Akses Medis dari Pasien kepada Tenaga Medis (Sadewa, 2025)

Lampiran C. Kebutuhan Fungsional DecMed

Tabel C.1: Kebutuhan Fungsional DecMed (Sadewa, 2025)

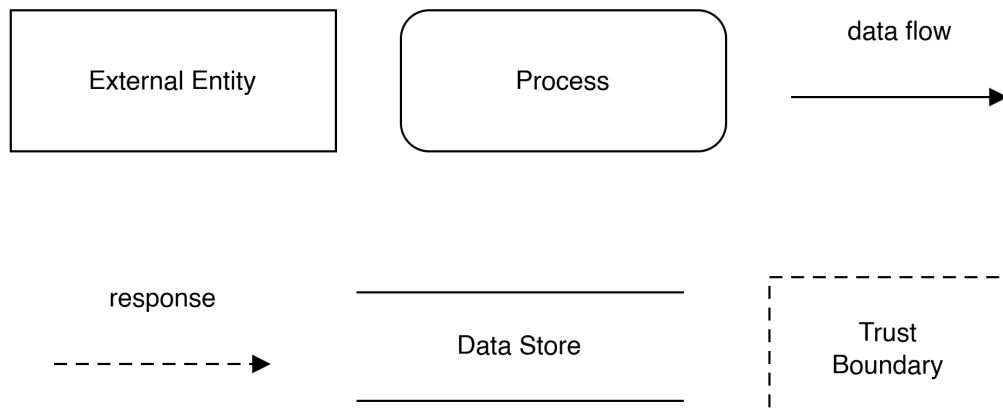
ID	Deskripsi
F01	Pasien dapat melakukan registrasi akun pada sistem
F02	Pasien dapat masuk ke akun menggunakan credentials yang dimiliki
F03	Pasien dapat keluar dari akun
F04	Pasien dapat melakukan scan kode QR yang dimiliki oleh masing-masing tenaga kesehatan dan petugas rekam medis
F05	Pasien dapat membaca seluruh RME yang ia miliki
F06	Pasien dapat memberikan akses baca bagian administratif dari data RME miliknya kepada petugas rekam medis untuk rentang waktu tertentu
F07	Pasien dapat memberikan akses baca bagian administratif dan klinis dari data RME miliknya kepada tenaga kesehatan untuk rentang waktu tertentu
F08	Pasien dapat melihat daftar log dari akses terhadap data RME yang dimiliki
F09	Pasien dapat mencabut akses yang telah diberikan. Akses tersebut berupa akses baca maupun tulis terhadap data RME.
F10	Tenaga kesehatan dapat melakukan aktivasi client
F11	Tenaga kesehatan dapat melakukan registrasi akun pada sistem
F12	Tenaga kesehatan dapat masuk ke akun menggunakan credentials yang dimiliki
F13	Tenaga kesehatan dapat keluar dari akun
F14	Tenaga kesehatan dapat membaca bagian administratif dan klinis dari data RME milik pasien setelah diberikan akses dalam waktu tertentu
F15	Tenaga kesehatan dapat menambahkan entri RME baru
F16	Tenaga kesehatan dapat mengedit bagian klinis dari entri RME baru yang dibuatnya pada rentang waktu yang telah ditentukan

Tabel C.1 – Lanjutan

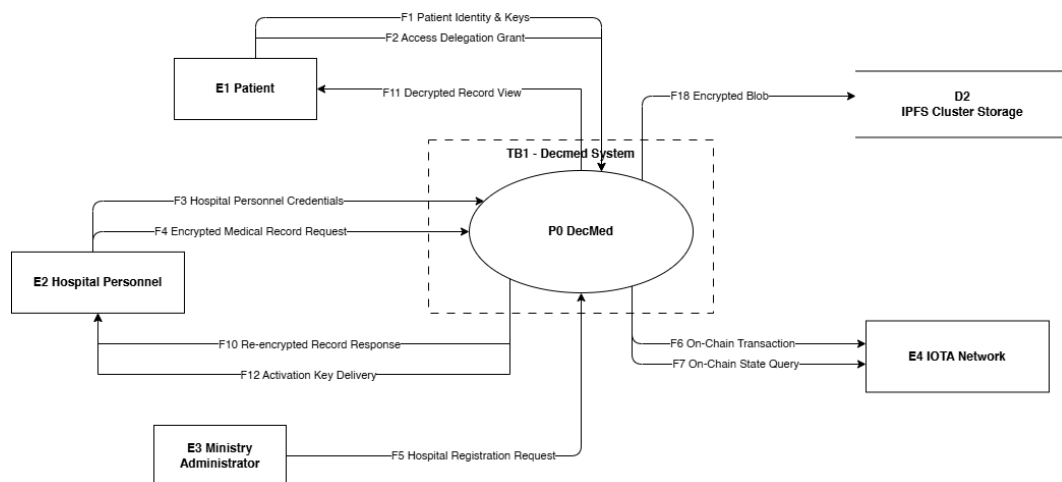
ID	Deskripsi
F17	Petugas rekam medis dapat melakukan aktivasi client
F18	Petugas rekam medis dapat melakukan registrasi akun pada sistem
F19	Petugas rekam medis dapat masuk ke akun menggunakan credentials yang dimiliki
F20	Petugas rekam medis dapat keluar dari akun
F21	Petugas rekam medis dapat membaca bagian administratif dari data RME milik pasien setelah diberikan akses dalam waktu tertentu
F22	Admin fasyankes dapat melakukan aktivasi client
F23	Admin fasyankes dapat melakukan registrasi akun pada sistem
F24	Admin fasyankes dapat masuk ke akun menggunakan credentials yang dimiliki
F25	Admin fasyankes dapat keluar dari akun
F26	Admin fasyankes dapat menambahkan personel fasyankes baru
F27	Admin fasyankes dapat membuat kunci aktivasi baru untuk personel fasyankes
F28	Kementerian kesehatan dapat mendaftarkan fasyankes dan admin untuk fasyankes tersebut
F29	Kementerian kesehatan dapat membuat kunci aktivasi baru untuk admin fasyankes

Lampiran D. DFD DecMed

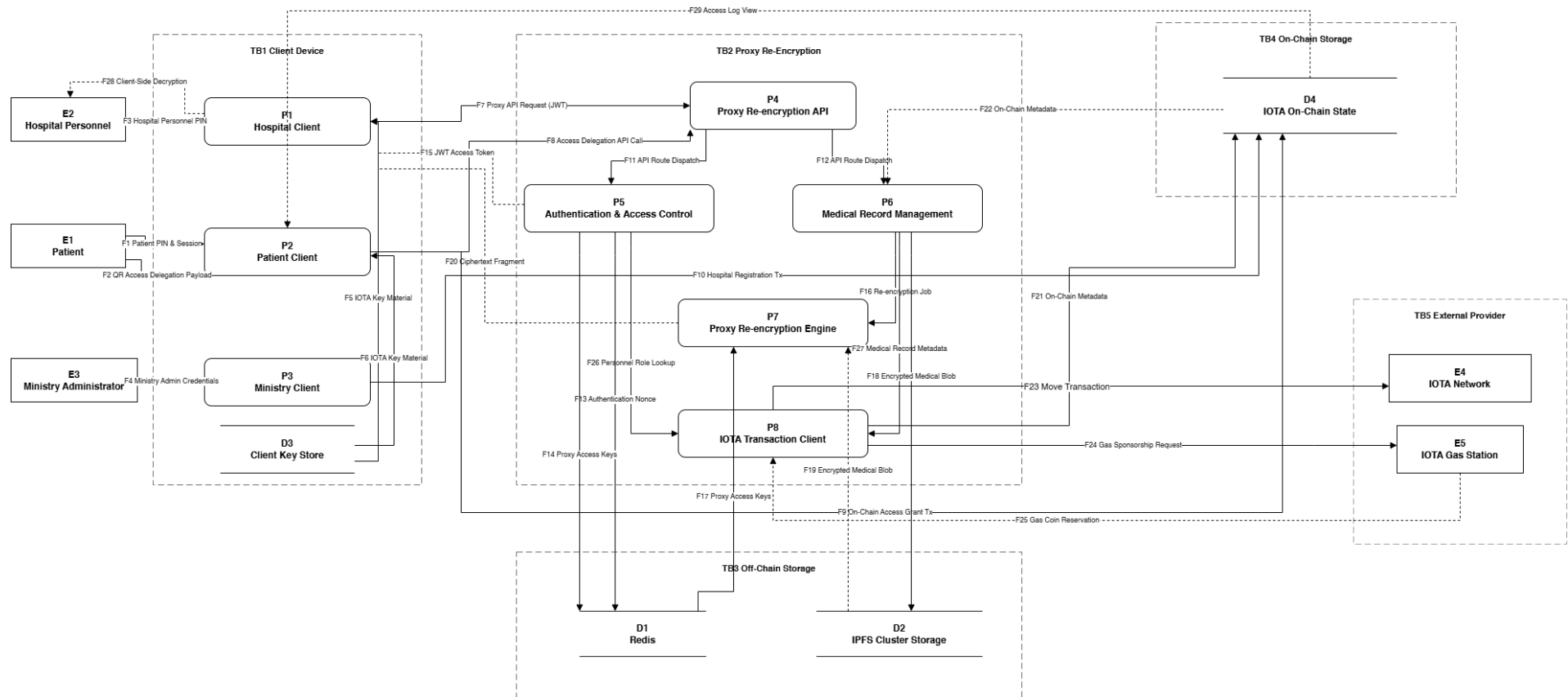
Hasil pemodelan DFD DecMed Level 0 dan Level 1 dapat dilihat pada Gambar D.2 dan D.3, sedangkan legenda pemodelan kedua DFD tersebut dapat dilihat pada Gambar D.1.



Gambar D.1: Legenda *Data Flow Diagram* (Dokumentasi Penulis)



Gambar D.2: DFD DecMed Level 0 (Dokumentasi Penulis)



Gambar D.3: DFD DecMed Level 1 (Dokumentasi Penulis)

Tabel D.1: Daftar *External Entities* pada DFD DecMed

ID	Nama	Interaksi utama
E1	Patient	PIN, QR delegasi akses, <i>revoke access</i> , lihat <i>access log</i>
E2	Hospital Personnel	PIN, baca/update rekam medis, data administratif
E3	Ministry Administrator	Registrasi rumah sakit, <i>activation key</i>
E4	IOTA Network	RPC, <i>publish/execute transaction</i> , <i>read state</i>
E5	IOTA Gas Station	<i>reserve_gas</i> , <i>execute_tx</i>

Tabel D.2: Daftar *Process* DFD DecMed

ID	Nama
P0	Decmed (seluruh sistem)
P1	Hospital Client
P2	Patient Client
P3	Ministry Client
P4	Proxy Re-encryption API
P5	Authentication & Access Control
P6	Medical Record Management
P7	Proxy Re-encryption Engine
P8	IOTA Transaction Client

Tabel D.3: Daftar *Data Store* pada DFD DecMed

ID	Nama	Data sensitif
D1	Redis Cache	<i>Nonce challenge</i> , <i>AccessKeys</i> (k-frag, PRE public keys, seed terenkripsi)
D2	IPFS Cluster Storage	Blob rekam medis terenkripsi (CID direferensikan <i>on-chain</i>)
D3	Client OS Keyring	IOTA keypair, PRE keys, PIN-derived secrets, <i>activation key</i>
D4	IOTA On-Chain State	Metadata, <i>access grants</i> , <i>access log</i> , <i>hospital registry</i>

Tabel D.4: Daftar Data Flow pada DFD DecMed (Level 0)

ID	Label	Arah
F1	Patient Identity & Keys	E1 → P0
F2	Access Delegation Grant	E1 → P0
F3	Hospital Personnel Credentials	E2 → P0
F4	Encrypted Medical Record Request	E2 → P0
F5	Hospital Registration Request	E3 → P0
F6	On-Chain Transaction	P0 → E4
F7	On-Chain State Query	P0 → E4
F10	Re-encrypted Record Response	P0 → E2
F11	Decrypted Record View	P0 → E1
F12	Activation Key Delivery	P0 → E2
F18	Encrypted Blob	P0 → D2

Tabel D.5: Daftar Data Flow pada DFD DecMed (Level 1)

ID	Label	Arah Ringkas
F1	Patient PIN & Session	E1 → P2
F2	QR Access Delegation Payload	E1 → P2
F3	Hospital Personnel PIN	E2 → P1
F4	Ministry Admin Credentials	E3 → P3
F5	IOTA Key Material	D3 → P1
F6	IOTA Key Material	D3 → P2
F7	Proxy API Request (JWT)	P1 → P4
F8	Access Delegation API Call	P2 → P4
F9	On-Chain Access Grant Tx	P2 → D4
F10	Hospital Registration Tx	P3 → D4
F11	API Route Dispatch	P4 → P5
F12	API Route Dispatch	P4 → P6
F13	Authentication Nonce	P5 → D1
F14	Proxy Access Keys	P5 → D1
F15	JWT Access Token	P5 → P1
F16	Re-encryption Job	P6 → P7
F17	Proxy Access Keys	D1 → P7
F18	Encrypted Medical Blob	P6 → D2
F19	Encrypted Medical Blob	D2 → P7
F20	Ciphertext Fragment	P7 → P1
F21	On-Chain Metadata	P8 → D4
F22	On-Chain Metadata	D4 → P6
F23	Move Transaction	P8 → E4
F24	Gas Sponsorship Request	P8 → E5
F25	Gas Coin Reservation	E5 → P8
F26	Personnel Role Lookup	P5 → P8
F27	Medical Record Metadata	P6 → P8
F28	Client-Side Decryption	P1 → E2
F29	Access Log View	D4 → P2

Lampiran E. Analisis STRIDE pada Sistem DecMed

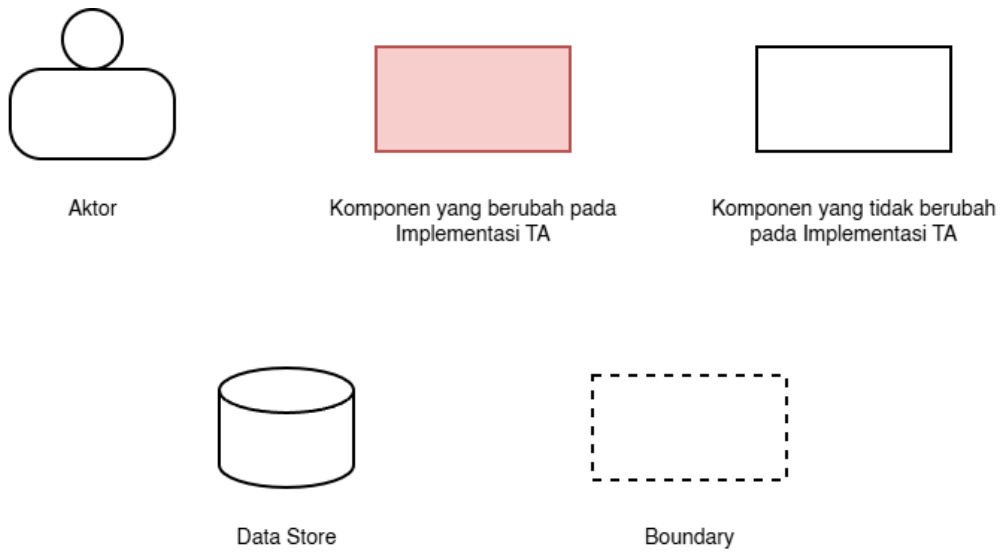
Tabel E.1: Analisis STRIDE pada Sistem DecMed

ID	Komponen / Flow	Kategori	Skenario Ancaman	Dampak
T01	P5, F7	<i>Spoofing</i>	Penyerang menggunakan token akses yang dicuri atau dipalsukan untuk data RME.	Akses tidak sah terhadap data rekam medis pasien.
T02	P8, D4, E4, dan F9	<i>Tampering</i>	Pengguna mengirim transaksi pemberian akses yang valid secara kriptografis, tetapi cakupan akses tidak dibatasi secara tepat oleh logika otorisasi <i>smart contract</i> .	Metadata akses atau metadata RME dapat menunjuk pada cakupan data yang tidak semestinya, sehingga integritas terganggu.
T03	P6, D2, dan F19	<i>Tampering</i>	Referensi CID yang mengarah ke objek <i>off-chain</i> dimanipulasi sehingga sistem mengambil <i>blob</i> terenkripsi yang tidak sesuai.	Data RME yang diambil tidak valid, tidak konsisten, atau gagal diverifikasi.
T04	P2, P5, P8, D4, F8, F9, F21, dan F29	<i>Repudiation</i>	Pihak tertentu menyangkal pernah memberikan atau menggunakan akses.	Kesulitan dalam audit dan investigasi penyalahgunaan akses.
T05	P5, P8, D4, F16, F19, F20, F21, dan F29	<i>Information Disclosure</i>	Delegasi akses membuka cakupan data pasien yang lebih luas dari kebutuhan.	Kebocoran data RME pasien.

Tabel E.1: Analisis STRIDE pada Sistem DecMed (lanjutan)

ID	Komponen / Flow	Kategori	Skenario Ancaman	Dampak
T06	P8, D4, dan F22	<i>Information Disclosure</i>	Metadata transaksi mengungkapkan relasi pasien, fasyankes, atau data pasien.	Privasi pasien dan informasi layanan klinis jadi terekspos.
T07	P4, P5, P6, P7, P8, D1, E4, dan F7	<i>Denial of Service</i>	Layanan PRE atau penyimpanan IPFS tidak dapat diakses akibat serangan atau gangguan layanan.	Proses akses rekam medis menjadi lambat atau tidak tersedia.
T08	P2, P5, P8, dan D4, F8, F9,	<i>Elevation of Privilege</i>	Pengguna memperoleh hak akses lebih tinggi melalui delegasi yang tidak dibatasi.	Terjadi eskalasi hak akses di luar kebutuhan klinis yang sah.

Lampiran F. Legenda Diagram Arsitektur Solusi



Gambar F.1: Legenda Diagram Arsitektur Solusi (Dokumentasi Penulis)

Lampiran G. Skema Penyimpanan Data RME

Lampiran ini memuat rincian skema penyimpanan data RME yang digunakan pada rancangan segmentasi data. Skema penyimpanan dibagi menjadi metadata segmen yang disimpan pada penyimpanan *on-chain* dan isi segmen terenkripsi yang disimpan pada penyimpanan *off-chain*.

Tabel G.1: Skema Metadata Segmen RME *On-Chain*

Komponen	Key JSON	Keterangan
Identitas Segmen	segment_id	UUID unik untuk satu segmen data RME.
	related_rme_id	ID RME atau episode pelayanan yang menjadi induk segmen, dengan format RME-{6_digit}.
	patient_address	Alamat <i>wallet</i> pasien pemilik RME.
	hospital_id	ID fasilitas pelayanan kesehatan ketika menerima pelayanan.
Kategori Data	dataset_category	Kategori dataset. Sesuai dengan tabel III.9.
	function_category	Kategori fungsi klinis atau administratif. Sesuai dengan tabel III.10.
Pointer dan Integritas	ipfs_cid	CID IPFS dari segmen data terenkripsi.
	integrity_hash	Hash SHA-256 dari segmen terenkripsi.
Kapsul Kunci	capsule	Kapsul PRE yang diperlukan untuk proses <i>re-encryption</i> .

Komponen	Key JSON	Keterangan
	enc_key_and_nonce	Kunci simetris dan <i>nonce</i> yang sudah terenkripsi untuk membuka segmen data.
Audit Metadata	created_at	Waktu pembuatan metadata segmen.
	author_address	Alamat <i>wallet</i> aktor yang membuat atau memperbarui segmen.

Tabel G.2: Skema Segmen Data RME *Off-Chain*

Komponen	Key JSON	Keterangan
Header Segmen	segment_id	UUID yang sama dengan segment_id pada metadata <i>on-chain</i> .
	related_rme_id	ID RME atau episode pelayanan yang menjadi induk segmen, dengan format RME-{6_digit}.
	dataset_category	Kategori dataset sesuai Tabel III.9.
	function_category	Kategori fungsi sesuai dengan Tabel III.10.
Konteks Medis	patient_address	Alamat IOTA pasien pemilik RME.
	service_date	Tanggal dan waktu ketika segmen tercatat dengan format YYYY-MM-DD HH:MM:SS beserta informasi <i>timezone</i> .
	author_address	Alamat IOTA aktor yang menulis isi segmen.

Komponen	Key JSON	Keterangan
Isi Segmen	payload	Objek segmen data RME dengan tipe data Value. Pada implementasi ini, isi segmen dalam bentuk text.
	payload_hash	<i>Hash</i> isi payload.

Lampiran H. Contoh *Caveat* Token Macaroon untuk Setiap Tahapan

Lampiran ini menyajikan contoh *caveat* token Macaroon pada setiap tahapan alur pemberian akses, mulai dari penerbitan token awal oleh pasien hingga rangkaian delegasi yang dilakukan oleh tenaga medis. Nilai alamat *wallet* (0xPASIEN, 0xPETUGAS_RM, 0xDOKTER, 0xPERAWAT, 0xLAB, 0xAPOTEKER), hospital-001, dan RME-001 hanya bersifat ilustratif. Pada implementasi, nilai-nilai tersebut akan berbeda tergantung pada alamat *wallet* pemegang token serta ID RME yang di-generate. Simbol titik tiga (...) adalah bentuk ilustrasi yang digunakan untuk menunjukkan bahwa token dapat memiliki lebih banyak nilai lainnya selain yang dituliskan.

Penerbitan Awal: Pasien → Petugas Rekam Medis

```
1  purpose = Read
2  patient_address = 0xPASIEN
3  root_subject = 0xPETUGAS_RM
4  hospital_cid = hospital-001
5
6  read_dataset_in = [RAWAT_JALAN, RAWAT_INAP, LABORATORIUM, APOTEK]
7
8  read_function_in = [
9      ADMINISTRATIVE_GENERAL,
10     ANAMNESIS,
11     PEMERIKSAAN_FISIK,
12     PEMERIKSAAN_PSIKOLOGIS,
13     ...
14 ] // seluruh 15 fungsi
15
16 expires_before = 2026-05-16T18:00:00
17 max_delegation_depth = 2
```

Kode H.1: Contoh *Caveat* Token Read Awal untuk Petugas Rekam Medis

```
1  purpose = Update
2  patient_address = 0xPASIEN
```

```

3 root_subject = 0xPETUGAS_RM
4 related_rme_id = RME-001
5 hospital_cid = hospital-001
6
7 write_dataset_in = [RAWAT_JALAN, LABORATORIUM, APOTEK]
8
9 write_function_in = [
10     ... // union fungsi dari ketiga dataset di atas
11 ]
12
13 expires_before = 2026-05-16T18:00:00
14 max_delegation_depth = 2

```

Kode H.2: Contoh *Caveat* Token Update Awal untuk Petugas Rekam Medis

Delegasi: Petugas Rekam Medis → Dokter

```

1 parent_token_hash = <sha256(parent)>
2 delegated_by = 0xPETUGAS_RM
3 delegated_to = 0xDOKTER
4
5 read_dataset_in = [RAWAT_JALAN, RAWAT_INAP, LABORATORIUM, APOTEK]
6 write_dataset_in = [RAWAT_JALAN, LABORATORIUM, APOTEK]
7
8 read_function_in = [
9     ... // semua 15 fungsi
10 ]
11 write_function_in = [
12     ... // 14 fungsi, ADMINISTRATIVE_GENERAL dihapus
13 ]
14
15 related_rme_id = RME-001
16 expires_before = 2026-05-16T18:00:00
17 max_delegation_depth = 1

```

Kode H.3: Contoh *Caveat* Delegasi Petugas Rekam Medis → Dokter

Delegasi: Petugas Rekam Medis → Perawat

```
1 parent_token_hash = <sha256(parent)>
2 delegated_by = 0xPETUGAS_RM
3 delegated_to = 0xPERAWAT
4
5 read_dataset_in = [RAWAT_JALAN]
6 write_dataset_in = [RAWAT_JALAN]
7
8 read_function_in = [
9     ADMINISTRATIVE_GENERAL,
10    ANAMNESIS,
11    PEMERIKSAAN_FISIK]
12 write_function_in = [ANAMNESIS, PEMERIKSAAN_FISIK]
13
14 expires_before = 2026-05-16T18:00:00
15 max_delegation_depth = 1
```

Kode H.4: Contoh *Caveat* Delegasi Petugas Rekam Medis → Perawat

Delegasi: Dokter → Petugas Laboratorium

```
1 parent_token_hash = <sha256(token_dokter)>
2 delegated_by = 0xDOKTER
3 delegated_to = 0xLAB
4
5 read_dataset_in = [LABORATORIUM]
6 write_dataset_in = [LABORATORIUM]
7
8 read_function_in = [
9     ADMINISTRATIVE_GENERAL,
10    PEMERIKSAAN_PENUNJANG,
11    LABORATORIUM]
12 write_function_in = [LABORATORIUM]
13
14 expires_before = 2026-05-16T18:00:00
15 max_delegation_depth = 0
```

Delegasi: Dokter → Apoteker

```
1 parent_token_hash = <sha256(token_dokter)>
2 delegated_by = 0xDOKTER
3 delegated_to = 0xAPOTEKER
4
5 read_dataset_in = [RAWAT_JALAN, APOTEK]
6 write_dataset_in = [APOTEK]
7
8 read_function_in = [
9     ADMINISTRATIVE_GENERAL,
10    RIWAYAT_PENGGUNAAN_OBAT,
11    TERAPI,
12    PERESEPAN,
13    DISPENSING
14 ]
15 write_function_in = [PERESEPAN, DISPENSING]
16
17 expires_before = 2026-05-16T18:00:00
18 max_delegation_depth = 0
```

Lampiran I. Pengujian dan Evaluasi Kebutuhan Sistem

I.1 Pengujian Kebutuhan Fungsional

Tabel berikut menyajikan rincian pengujian kebutuhan fungsional pada alur Rawat Jalan dan Rawat Inap.

Tabel I.1: Pengujian Kebutuhan Fungsional pada Alur Rawat Jalan dan Rawat Inap

ID	Skenario	Ekspektasi	KF
P-KF-01	Pasien memberikan akses awal kepada petugas RM sesuai konteks episode pelayanan.	Token awal episode pelayanan berhasil diterbitkan.	KF-TA-01
P-KF-02	Petugas RM mendelegasikan akses pemeriksaan awal kepada perawat.	Token turunan perawat berhasil dibuat.	KF-TA-04
P-KF-03	Petugas RM mendelegasikan akses klinis kepada dokter.	Token turunan dokter berhasil dibuat.	KF-TA-04
P-KF-04	Perawat mengisi hasil pemeriksaan awal.	Data pemeriksaan awal berhasil disimpan.	KF-TA-07
P-KF-05	Dokter membaca pemeriksaan awal dan mengisi data klinis.	Data klinis berhasil dibaca dan disimpan.	KF-TA-05
P-KF-06	Dokter mendelegasikan akses laboratorium.	Token turunan laboratorium berhasil dibuat.	KF-TA-06
P-KF-07	Petugas laboratorium membaca pemeriksaan penunjang dan mengisi hasil laboratorium.	Data pemeriksaan penunjang berhasil dibaca dan hasil laboratorium disimpan.	KF-TA-08

Tabel I.1: Pengujian Kebutuhan Fungsional pada Alur Rawat Jalan dan Rawat Inap (lanjutan)

ID	Skenario	Ekspektasi	KF
P-KF-08	Dokter membaca hasil laboratorium.	Hasil laboratorium berhasil dibaca oleh dokter.	KF-TA-05
P-KF-09	Dokter mendelegasikan akses apotek.	Token turunan apoteker berhasil dibuat.	KF-TA-06
P-KF-10	Apoteker membaca resep dan mengisi status pelayanan obat.	Data resep dan pelayanan obat berhasil diproses.	KF-TA-09
P-KF-11	Pasien membuka riwayat delegasi episode pelayanan.	Riwayat delegasi episode pelayanan ditampilkan.	KF-TA-03
P-KF-12	Pasien merevokasi salah satu akses delegasi episode pelayanan.	Aktor <i>delegatee</i> tidak bisa mengakses data RME pasien lagi.	KF-TA-02

I.2 Evaluasi Kebutuhan Sistem

Tabel berikut menyajikan pemetaan kebutuhan sistem terhadap implementasi dan pengujian.

Tabel I.2: Evaluasi Kebutuhan Sistem terhadap Implementasi dan Pengujian

Kebutuhan	Implementasi Terkait	Pengujian Terkait	Status
KF-TA-01	I-TA-02, I-TA-03, I-TA-05	P-KF-01	Terpenuhi.
KF-TA-02	I-TA-03, I-TA-04, I-TA-05	P-KF-12, P-KNF-11, P-KNF-12	Terpenuhi.
KF-TA-03	I-TA-04, I-TA-05	P-KF-11	Terpenuhi.
KF-TA-04	I-TA-02, I-TA-04, I-TA-06	P-KF-02, P-KF-03	Terpenuhi.
KF-TA-05	I-TA-01, I-TA-03, I-TA-06	P-KF-05, P-KF-08	Terpenuhi.

Tabel I.2: Evaluasi Kebutuhan Sistem terhadap Implementasi dan Pengujian (lanjutan)

Kebutuhan	Implementasi Terkait	Pengujian Terkait	Status
KF-TA-06	I-TA-02, I-TA-04, I-TA-06	P-KF-06, P-KF-09	Terpenuhi.
KF-TA-07	I-TA-01, I-TA-03, I-TA-06	P-KF-04	Terpenuhi.
KF-TA-08	I-TA-01, I-TA-03, I-TA-06	P-KF-07	Terpenuhi.
KF-TA-09	I-TA-01, I-TA-03, I-TA-06	P-KF-10	Terpenuhi.
KNF-TA-01	I-TA-01, I-TA-02, I-TA-03	P-KNF-01, P-KNF-02	Terpenuhi.
KNF-TA-02	I-TA-02, I-TA-03, I-TA-06	P-KNF-03, P-KNF-04, P-KNF-05, P-KNF-06	Terpenuhi.
KNF-TA-03	I-TA-02, I-TA-03, I-TA-06	P-KNF-07, P-KNF-08, P-KNF-09	Terpenuhi.
KNF-TA-04	I-TA-04, I-TA-05, I-TA-06	P-KF-11, P-KNF-10	Terpenuhi.
KNF-TA-05	I-TA-03, I-TA-05	P-KNF-11, P-KF-12, P-KNF-12	Terpenuhi.
KNF-TA-06	I-TA-03, I-TA-06	P-KNF-09, P-KNF-13	Terpenuhi.

Lampiran J. Daftar Dependensi DecMed

Daftar ini hanya mencakup dependensi langsung yang dideklarasikan pada masing-masing komponen, bukan seluruh dependensi transitif. Dependensi internal yang ditandai dengan path merupakan *crate* lokal yang dikembangkan sebagai bagian dari sistem.

Tabel J.1: Dependensi Umum yang Digunakan pada Beberapa Komponen

<i>Crate</i>	Versi/Sumber
serde	1
serde_json	1
sha2	0.10
uuid	1
bip39	2
iota-sdk	Git rev. 3d7c588
iota-keys	Git rev. 3d7c588
iota-config	Git rev. 3d7c588
iota-types	Git rev. 3d7c588
iota-json-rpc-types	Git rev. 3d7c588
shared_crypto	Git rev. 3d7c588
move-core-types	Git rev. 3d7c588
dotenv	0.15
bcs	0.1.4
schemars	0.8
rand	0.9
bincode	2
umbral-pre	0.11
aes-gcm	0.10
argon2	0.5.3
hex	0.4.3
regex	1.11.1
generic-array	1.2.0

<i>Crate</i>	Versi/Sumber
k256	0.13.4
elliptic-curve	0.13.8
chrono	0.4
base64	0.22
strum/strum_macros	0.27
anyhow	1.0
thiserror	2.0

Tabel J.2: Dependensi PRE

<i>Crate</i>	Versi/Sumber
axum	0.8.4
axum-extra	0.10.1
tower	0.5.2
tokio	1.44.2
reqwest	0.12
redis	0.32
r2d2	0.8
dotenvy	0.15.7
decmed-rme-segment	path
decmed-macaroon-auth	path

Tabel J.3: Dependensi *Client*

<i>Crate</i>	Versi/Sumber
tauri	2
tauri-plugin-opener	2
tauri-plugin-http	2
tauri-plugin-fs	2
keyring	3
rustls-platform-verifier	0.5
rqrr	0.9
image	0.25

<i>Crate</i>	Versi/Sumber
tokio-stream	0.1.17
decmed-rme-segment	path
decmed-macaroon-auth	path
tauri-build	2

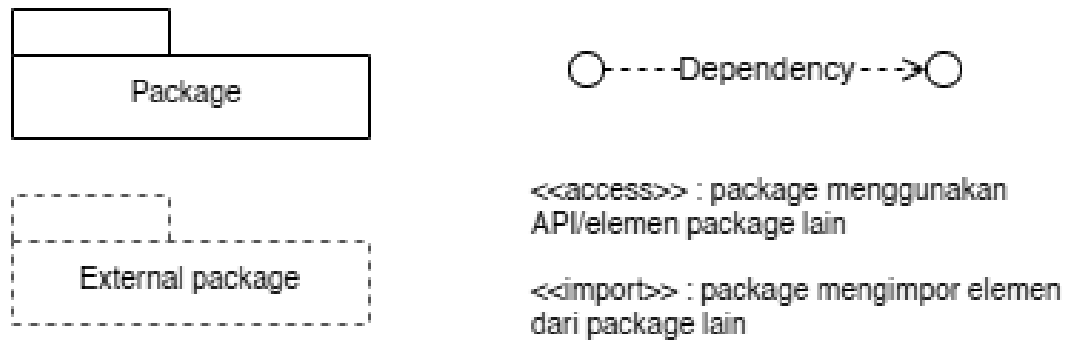
Tabel J.4: Dependensi decmed-rme-segment

<i>Crate</i>	Versi/Sumber
base64	0.22
serde	1
serde_json	1
sha2	0.10
uuid	1

Tabel J.5: Dependensi decmed-macaroon-auth

<i>Crate</i>	Versi/Sumber
chrono	0.4
serde	1
serde_json	1
thiserror	2.0
uuid	1
sha2	0.10
hex	0.4
macaroon	path
decmed-rme-segment	path

Lampiran K. Legenda Package Diagram



Gambar K.1: Legenda Package Diagram (Dokumentasi Penulis)

Lampiran L. Modul dan Implementasi *Crate* decmed-rme-segment

Tabel L.1: Daftar Modul dan Implementasi *Crate* decmed-rme-segment

Modul	Implementasi
types	CreateRmeSegmentRequest (<i>struct</i>), RmeSegmentData (<i>struct</i>) dengan new() dan validate(); ClientEncryptedRmeSegment (<i>struct</i>) dengan validate() dan into_metadata(); RmeSegmentMetadata (<i>struct</i>) dengan validate(); CreateRmeSegmentResponse (<i>struct</i>) dengan implementasi From<RmeSegmentMetadata>.
category	DatasetCategory (<i>enum</i>), FunctionCategory (<i>enum</i>), ALL_DATASET_CATEGORIES (<i>const</i>), ALL_FUNCTION_CATEGORIES (<i>const</i>).
crypto	canonical_json(), payload_hash(), sha256_hex(), ciphertext_integrity_hash_from_base64().
error	SegmentValidationError (<i>enum</i>).
administrative_payload	AdministrativeGeneralPayload (<i>struct</i>) dengan validate() dan to_payload_value(); administrative_general_payload_from_value(), administrative_general_payload_from_fields().
validation	assert_valid_correction_request(), assert_valid_correction_metadata(), get_allowed_function_categories(), is_valid_segment_category(), assert_valid_segment_category(), assert_segment_pair_consistent(), assert_no_plaintext_medical_fields().

Lampiran M. Modul dan Implementasi *Crate* decmed-macaroon-auth

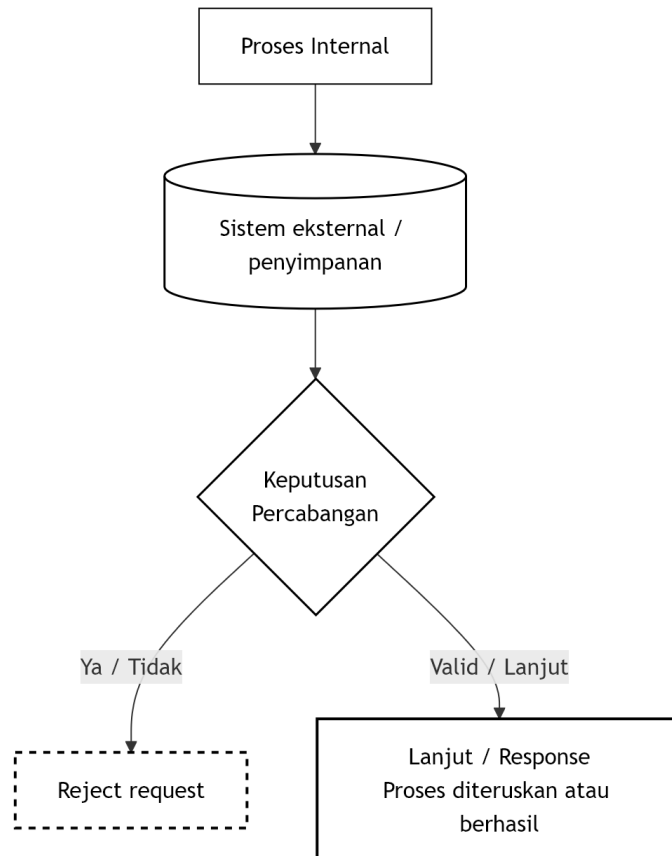
Tabel M.1: Daftar Modul dan Implementasi *Crate* decmed-macaroon-auth

Modul	Implementasi
attenuation	DelegationAttenuationParams (<i>struct</i>), attenuate_macaroon().
caveats	CaveatKey (<i>enum</i>), CaveatValue (<i>enum</i>), DecmedCaveat (<i>struct</i>), ParsedCaveats (<i>struct</i>), parse_caveat_line(), format_dataset_list(), format_function_list(), caveat_line(), add_caveat_to_macaroon().
delegation	DelegationStep (<i>struct</i>), DelegationChain (<i>struct</i>) dengan from_parsed(), delegation_depth(), subjects(), dan contains_subject().
delegation_ proof	DelegationProofContext (<i>struct</i>) dengan from_token(), from_last_delegation_step(), dan canonical_message(); hash_macaroon_token().
effective	AccessMode (<i>enum</i> : Read/Write), EffectiveCapability (<i>struct</i>) dengan from_parsed(), allows_dataset(), allows_function(), dan is_expired().
errors	CaveatVerificationError (<i>enum</i>).
issuance	AdminTokenKind (<i>enum</i> : Read/Update), InitialAdminPersonnelTokenParams (<i>struct</i>), admin_all_datasets(), admin_all_functions(), admin_write_datasets(), admin_write_functions(), issue_admin_personnel_token().
revocation	hash_token(), token_revocation_key(), compute_revocation_keys().
rme_id	format_related_rme_id().
verify	SegmentAccessContext (<i>struct</i>), TokenVerificationContext (<i>struct</i>), VerifiedDecmedToken (<i>struct</i>), verify_macaroon_signature(), verify_decmed_token(), verify_segment_access().

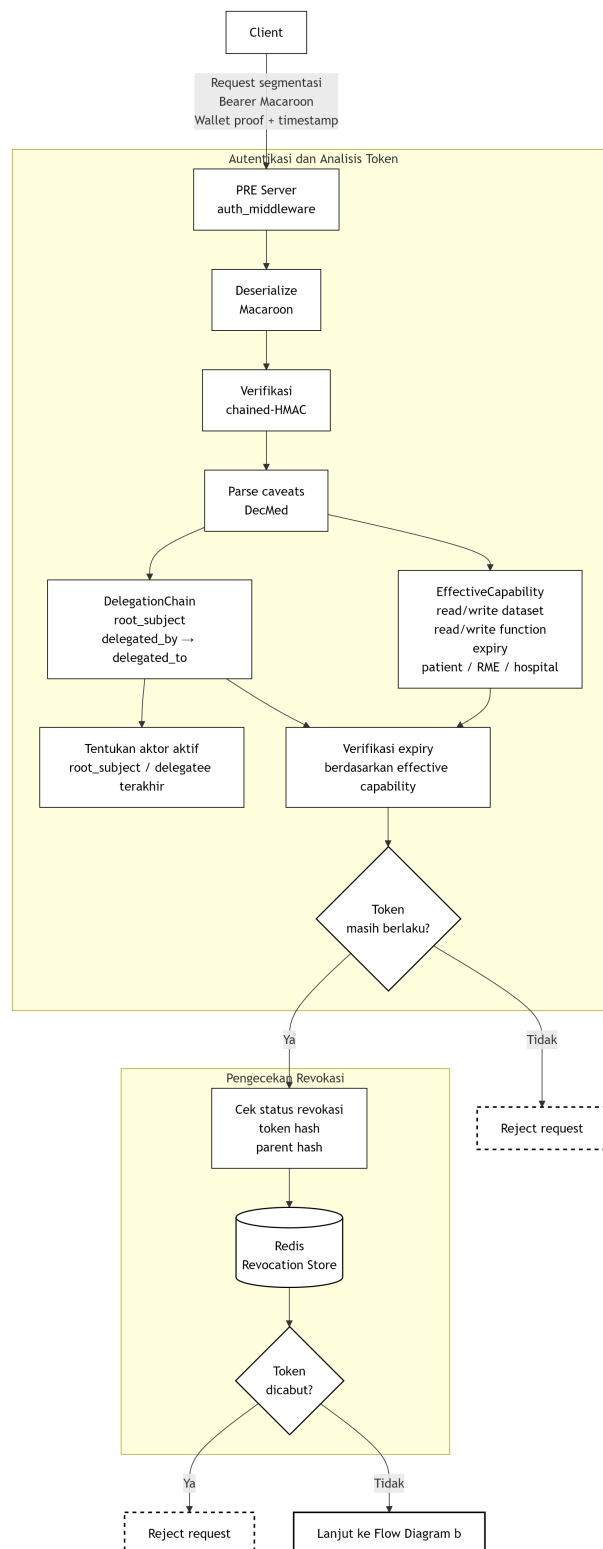
Modul	Implementasi
wallet_proof	WalletProofContext (<i>struct</i>) dengan canonical_message(), WalletSignatureVerifier (<i>trait</i>).

Lampiran N. Alur Implementasi Penegakan Otoritas pada Server PRE

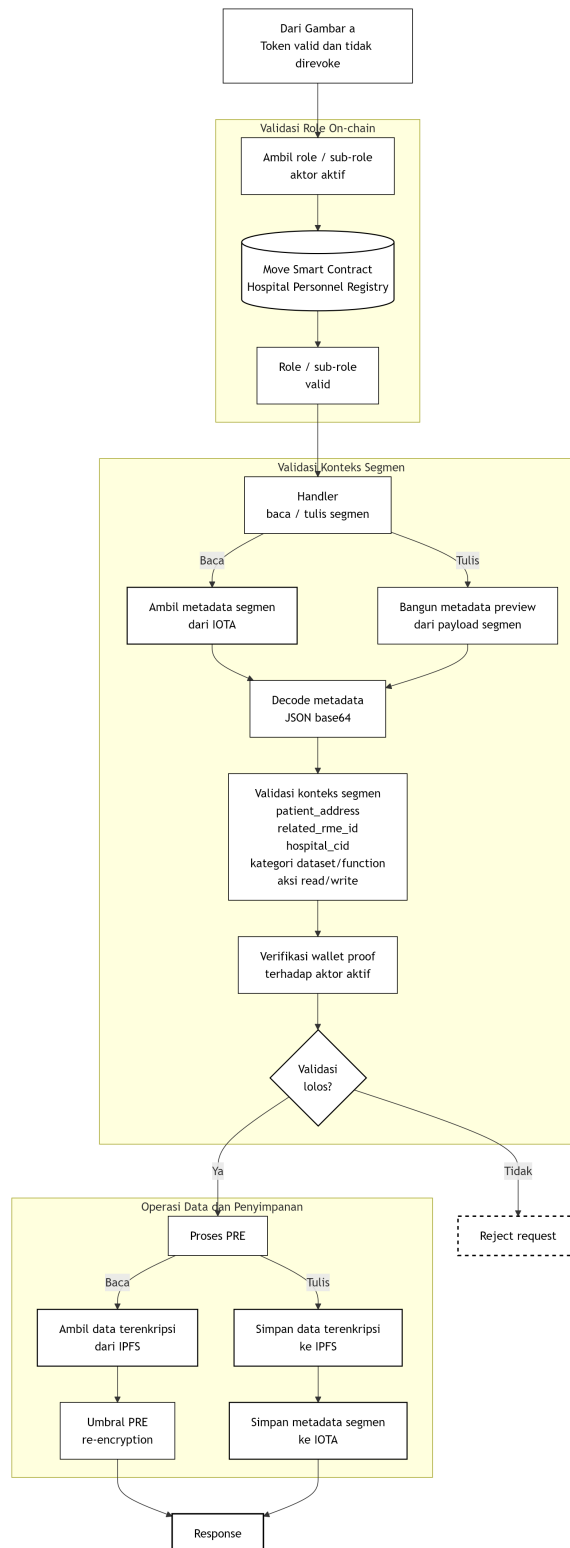
Alur penegakan otoritas pada *Server PRE* diilustrasikan dalam dua buah flow diagram yang saling berkelanjutan, sebagaimana ditunjukkan pada Gambar N.2 dan N.3. Gambar N.1 memuat legenda bentuk pada *Flow Diagram*.



Gambar N.1: Legenda bentuk pada *Flow Diagram*



Gambar N.2: Alur implementasi penegakan otoritas pada *Server PRE* bagian autentikasi token, *effective capability*, *delegation chain*, dan revokasi



Gambar N.3: Alur implementasi penegakan otoritas pada *Server PRE* bagian validasi *role* dan *subrole*, validasi segmen, *wallet proof*, serta eksekusi PRE, IPFS, dan IOTA

Lampiran O. Implementasi REST API Server PRE

Tabel O.1: Daftar Endpoint REST API pada Server PRE

Method	Endpoint	Fungsi	Status
GET	/	<i>Health check.</i>	Eksisting
GET	/medical-records	Mengambil daftar rekam medis.	Dimodifikasi
GET	/medical-record	Mengambil detail rekam medis.	Eksisting
POST	/medical-record	Membuat rekam medis.	Eksisting
PUT	/medical-record	Memperbarui rekam medis.	Eksisting
POST	/medical-record-segment	Membuat segmen rekam medis.	Baru
GET	/administrative	Mengambil data administratif pasien.	Eksisting
GET	/gen/macaroon-key	Menghasilkan RootKey Macaroon.	Baru
GET	/gen/sig	Menghasilkan <i>signature</i> .	Eksisting
GET	/gen/proxy-address	Menghasilkan dan mendaftarkan alamat proxy.	Eksisting
POST	/nonce	Mengambil nonce.	Eksisting
POST	/keys	Menyimpan kunci.	Eksisting
POST	/revocations/patient	Mencabut hak akses dan turunannya.	Baru
POST	/delegations/attenuate	Melakukan atenuasi token Macaroon sesuai <i>request</i> .	Baru

Lampiran P. Implementasi Smart Contract Sistem DecMed

Tabel P.1: Daftar Module Smart Contract Sistem DecMed

Nama Module	Deskripsi
<code>decmed::admin</code>	Modul global admin untuk registrasi rumah sakit, aktivasi admin fasyankes, dan daftar rumah sakit.
<code>decmed::hospital_personnel</code>	Modul akun tenaga fasyankes, aktivasi, akses baca/tulis, <i>delegation</i> , dan <i>audit delegation</i> .
<code>decmed::patient</code>	Modul akun pasien, <i>grant</i> akses ke <code>AdministrativePersonnel</code> , log akses, <i>audit delegation</i> , dan pembacaan metadata RME milik pasien.
<code>decmed::proxy</code>	Modul yang dipakai <i>server</i> PRE untuk baca/tulis metadata RME.
<code>decmed::shared</code>	Modul penyedia <code>GlobalAdminCap</code> dan <code>ProxyCap</code>

Tabel P.2: Daftar Method pada Module `decmed::admin`

Nama Method	Deskripsi
<code>create_activation_key</code>	Membuat data rumah sakit dan activation key pertama untuk admin rumah sakit.
<code>update_activation_key</code>	Memperbarui activation key dan metadata admin rumah sakit.
<code>get_hospitals</code>	Mengambil daftar rumah sakit untuk client kementerian/global admin.

Tabel P.3: Daftar Method pada Module `decmed::hospital_personnel`

Nama Method	Deskripsi
<code>create_activation_key</code>	Admin fasyankes membuat activation key untuk tenaga administratif atau medis.
<code>use_activation_key</code>	Menandai activation key tenaga fasyankes sebagai sudah digunakan.
<code>signup</code>	Registrasi akun tenaga fasyankes ke address IOTA dan menyimpan metadata administratif.
<code>is_account_registered</code>	Mengecek apakah akun tenaga fasyankes sudah aktif/terdaftar.
<code>get_account_state</code>	Menentukan status <i>onboarding</i> tenaga fasyankes.
<code>get_account_info</code>	Mengambil metadata akun, <i>role</i> , <i>subrole</i> , dan metadata rumah sakit.
<code>update_account_activation_key</code>	Admin fasyankes mengganti activation key personel.
<code>update_administrative_metadata</code>	Memperbarui profil administratif tenaga fasyankes.
<code>get_hospital_personnels</code>	Mengambil daftar personel di bawah admin fasyankes.
<code>get_delegatee_candidates</code>	Mengambil kandidat personel yang bisa menerima delegasi akses.
<code>cleanup_read_access</code>	Membersihkan akses baca yang sudah kedaluwarsa.
<code>cleanup_update_access</code>	Membersihkan akses <i>update</i> yang sudah kedaluwarsa.
<code>get_read_access</code>	Mengambil daftar <i>capability</i> baca milik tenaga fasyankes.
<code>get_update_access</code>	Mengambil daftar <i>capability</i> update milik tenaga fasyankes.

Nama Method	Deskripsi
<code>create_delegated_access</code>	Membuat <i>delegated access</i> untuk personel lain.
<code>create_medical_record</code>	Membuat entri RME blob besar. (<i>legacy</i>)

Tabel P.4: Daftar Method pada Module `decmed::patient`

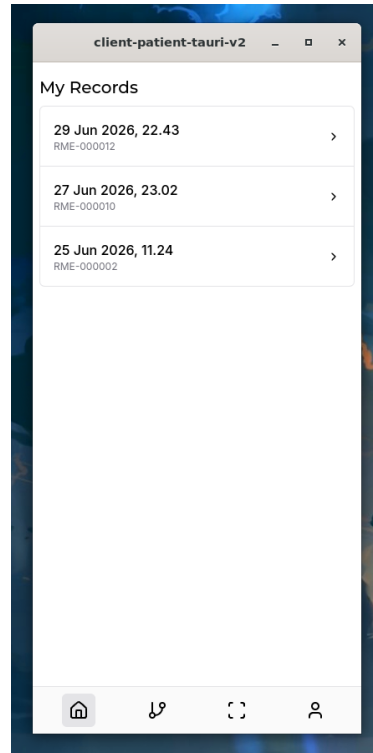
Nama Method	Deskripsi
<code>signup</code>	Registrasi akun pasien dan metadata administratif terenkripsi.
<code>is_account_registered</code>	Mengecek apakah <i>address</i> pasien terdaftar.
<code>get_account_state</code>	Menentukan status <i>onboarding</i> pasien.
<code>get_account_info</code>	Mengambil metadata administratif pasien.
<code>update_administrative_metadata</code>	Memperbarui metadata administratif pasien.
<code>get_hospital_personnel_info</code>	Mengambil info publik tenaga fasyankes saat pasien memproses QR.
<code>create_access</code>	Memberi akses baca/tulis kepada tenaga fasyankes.
<code>get_access_log</code>	Mengambil log <i>grant</i> akses pasien.
<code>get_delegation_audit_log</code>	Mengambil log <i>audit trail delegation</i> pasien.
<code>get_medical_records</code>	Mengambil daftar metadata RME pasien.
<code>get_medical_record</code>	Mengambil satu metadata RME berdasarkan indeks.
<code>revoke_access</code>	Mencabut akses tenaga fasyankes dan memicu <i>cascade revoke delegation</i> .

Tabel P.5: Daftar Method pada Module decmed : :proxy

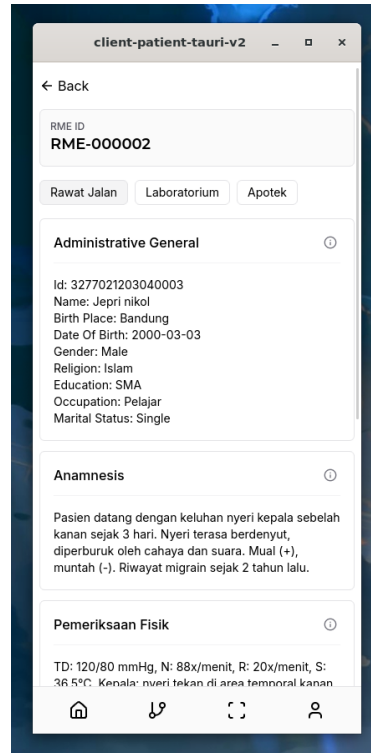
Nama Method	Deskripsi
create_capability	Membuat ProxyCap untuk address service proxy.
create_medical_record_segment	Menambahkan metadata RME tersegmentasi ke daftar medical metadata pasien.
get_administrative_data	Mengambil metadata administratif pasien untuk kebutuhan akses/dekripsi.
get_hospital_personnel_role	Mengecek role tenaga fasyankes saat setup token/key access.
get_hospital_personnel_auth_info	Mengecek <i>role</i> dan <i>subrole</i> .
get_medical_records	Mengambil daftar metadata RME pasien dan menyaringnya sebagai segmen berdasarkan cakupan akses.
get_medical_record	Mengambil satu metadata segmen dan data pendukung untuk pembacaan <i>payload</i> .
is_patient_registered	Memvalidasi bahwa pasien terdaftar
create_medical_record	Membuat entri RME blob besar. (<i>legacy</i>)
update_medical_record	Melakukan edit entri RME blob besar. (<i>legacy</i>)
get_medical_record_update	Mengambil data RME untuk proses edit entri blob besar. (<i>legacy</i>)
get_delegation_access_snapshot	Mengambil <i>snapshot</i> metadata akses delegasi.

Lampiran Q. Tangkapan Layar Implementasi *Patient Client*

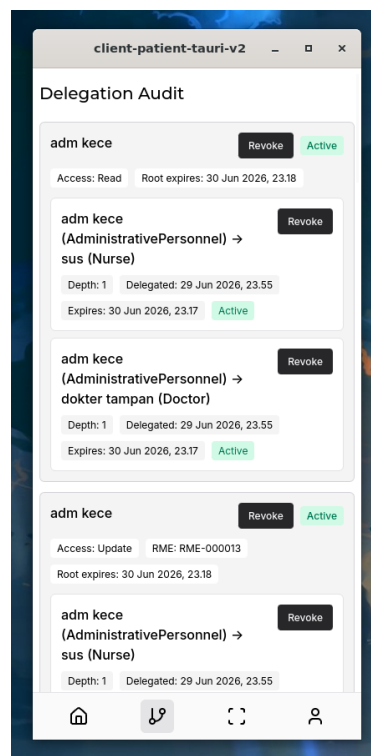
Semua tangkapan layar berikut merupakan dokumentasi penulis.



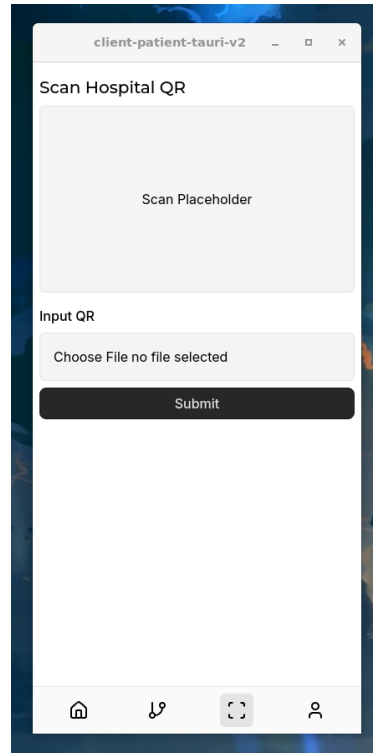
Gambar Q.1: Halaman *Home* daftar RME.



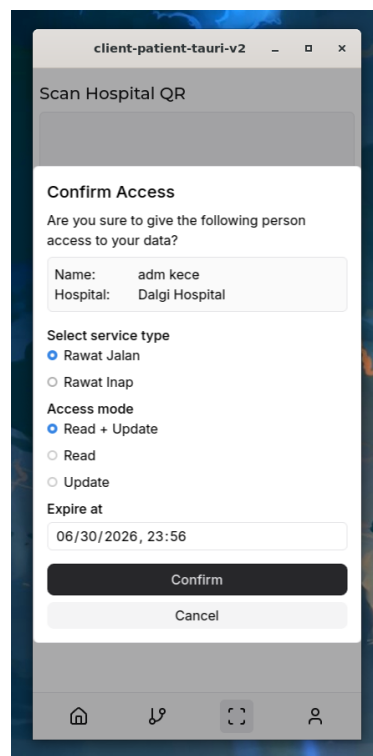
Gambar Q.2: Halaman detail RME.



Gambar Q.3: Halaman audit delegasi RME.



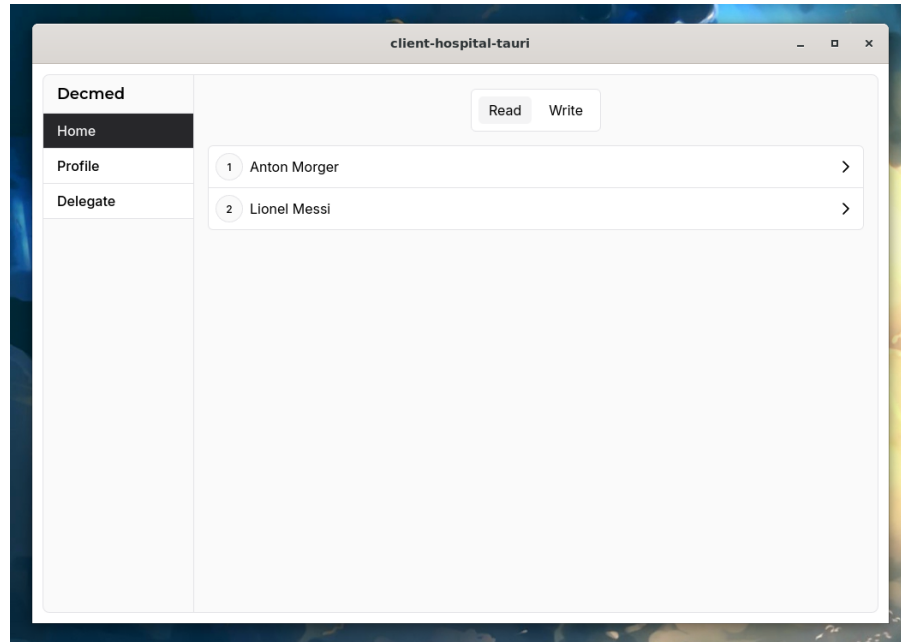
Gambar Q.4: Halaman *scan* QR.



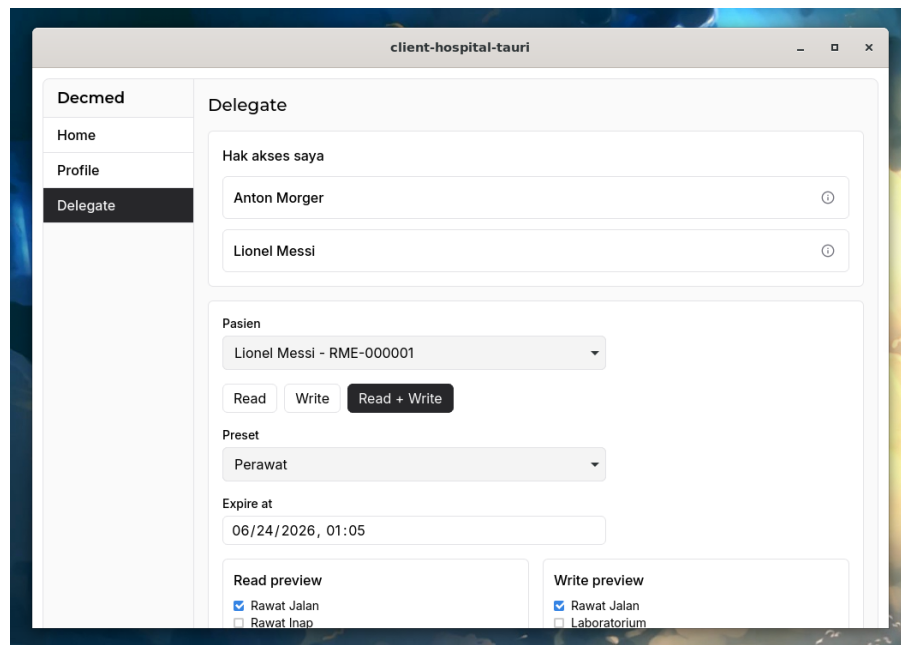
Gambar Q.5: Halaman konfirmasi pemberian akses awal.

Lampiran R. Tangkapan Layar Implementasi *Hospital Client*

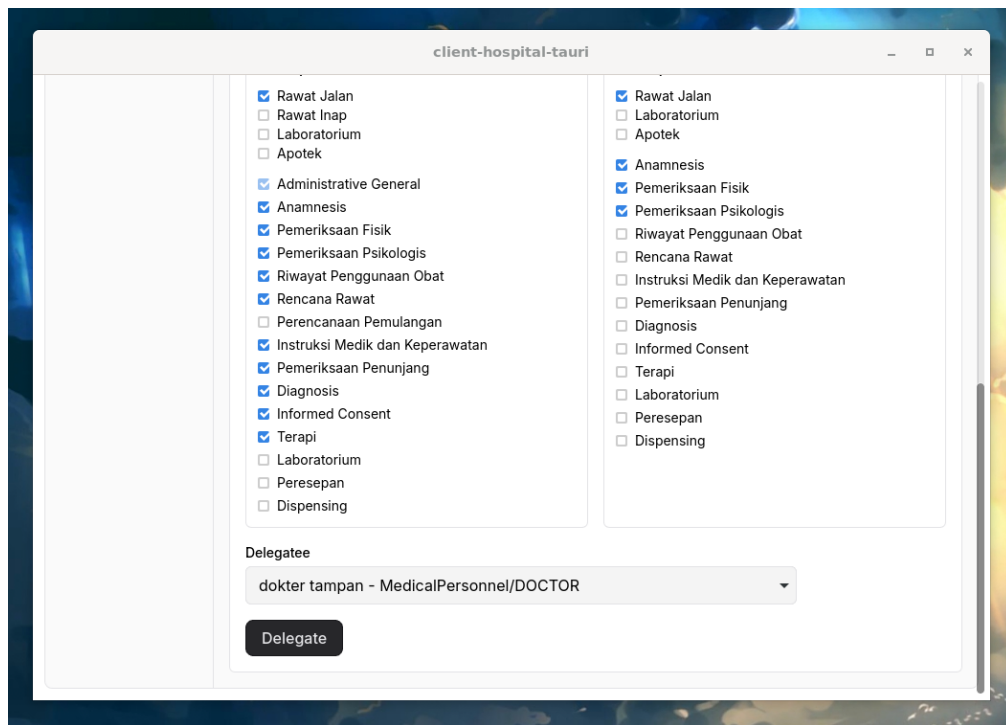
Semua tangkapan layar berikut merupakan dokumentasi penulis.



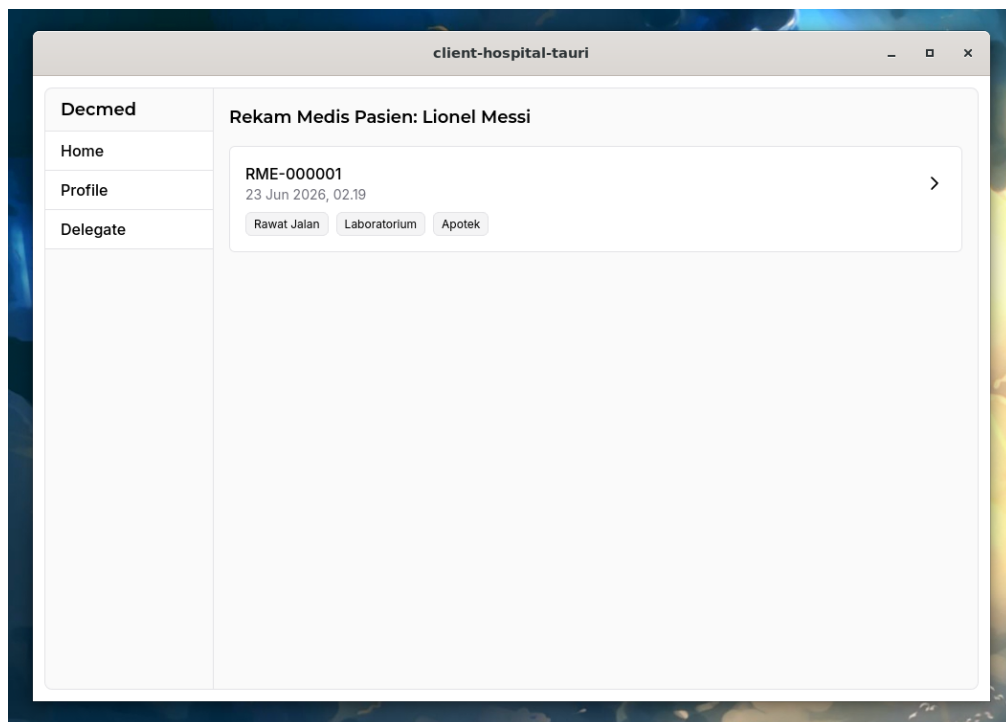
Gambar R.1: Halaman *dashboard MedicalPersonnel*.



Gambar R.2: Halaman delegasi akses bagian 1.



Gambar R.3: Halaman delegasi akses bagian 2.



Gambar R.4: Halaman daftar RME pasien pada *Hospital Client*.

client-hospital-tauri

Decmed

Home

Profile

Delegate

← Back

Detail RME

RME-000001

Rawat Jalan Laboratorium Apotek

Fungsi Administrative General

Administrative Data

NIK	3277021203040002
Name	Lionel Messi
Birth Place	Cimahi
Date of Birth	2000-03-03
Gender	Male
Religion	Katolik
Education	SMA
Occupation	Pemain
Marital Status	Married

Gambar R.5: Halaman detail RME pada *Hospital Client*.

client-hospital-tauri

Decmed

Home

Profile

Delegate

Write RME

Lionel Messi

0x4858a58fb137a1a84336f6cd2cc42079a8216d9aee1f852f830e4d18185ce95c

Dataset

Rawat Jalan

Anamnesis

Pasien mengeluh demam tinggi sejak 3 hari, disertai nyeri kepala dan lemas. Nafsu makan menurun. Tidak batuk, tidak pilek. Pernah tifoid 2 tahun lalu.

Pemeriksaan Fisik

Pemeriksaan Psikologis

Gambar R.6: Halaman alur akses tulis pada *Hospital Client*.